TAMGA NETWORK

TAMGA NETWORK WHITEPAPER

Türkiye ve Türk Dünyası için Dijital Güven Altyapısı

Genişletilmiş baskı: nasıl çalışır, neden böyle seçildi, nereye gidiyor

Tamga Network

KASIM 2026 · SÜRÜM 1.0

© 2026 Tamga Network. Bu eser Creative Commons Atıf 4.0 Uluslararası Lisansı (CC BY 4.0) ile yayımlanmıştır: kaynak gösterilerek paylaşılabilir ve uyarlanabilir. https://creativecommons.org/licenses/by/4.0/deed.tr

Özet

Tamga Network, Türkiye ve Türk dünyası için tasarlanmış, Avrupa Birliği'nin dijital kimlik düzeniyle aynı teknik dili konuşan bir güven ağıdır. Ağda kurum belgeyi verir, kişi belgeyi telefonundaki cüzdanda taşır ve kime göstereceğine kendisi karar verir, doğrulayıcı da belgeyi veren kuruma sormadan birkaç saniyede denetler. Belgeler AB'nin seçtiği açık standartlarla kodlanır (SD-JWT VC ve ISO/IEC 18013-5 mdoc); verme ve gösterme OpenID4VCI ve OpenID4VP profilleriyle yapılır; her belge cihazın güvenli donanımındaki bir anahtara bağlıdır ve kişi yalnızca istenen alanları gösterir. Güvenin kaynağı bugün herkesin indirip denetleyebildiği imzalı güven listeleri ve saat saat ilerleyen bir çapa günlüğüdür. Ortak bir defterin kodu yazılmış ve test edilmiştir; ama üretimde yoktur ve kapalıdır, en az iki bağımsız işletmeci olmadan da açılmaz. Ortak kayıtların hiçbirinde kişisel veri bulunmaz.

Belge, bu yapının nasıl çalıştığını, her önemli seçimin neden yapıldığını ve ağın nereye gittiğini yirmi dört bölümde anlatır. Güven listeleri, kurum sertifikaları, belge biçimleri, verme ve gösterme akışları, doğrulama hattı, iptal, cüzdan kuralları, geçici kimlik servisi, gizlilik mühendisliği ve tehdit modeli tek tek açılır; her seçim, onu bağlayan karar kaydıyla ve değerlendirilen alternatifleriyle birlikte verilir. Egemenlik tasarımın baştan koyduğu bir şarttır. Her devlet kendi kaydının tek yazarıdır ve bugün devlet adına geçici olarak yürütülen her rol, hiçbir belgeyi, kurum kimliğini ya da belge türünü değiştirmeden devredilebilecek biçimde kurulmuştur. Bugün listelerde yalnızca Türkiye yuvası etkindir; öteki devletler için yalnızca yer ayrılmıştır.

Metin her iddianın durumunu açıkça söyler: çalışan, kararı alınmış ama henüz canlı olmayan ve araştırma aşamasındaki işlevler ayrılır, yol haritası takvimle değil koşullarla verilir. Son bölümler kararların tamamını, beyan edilen artık riskleri ve açık soruları bir arada sunar. Belge hukuki görüş ya da sertifika iddiası değildir ve hiçbir devletle ya da kurumla yapılmış bir anlaşmanın bildirimi değildir.

Anahtar kelimeler: dijital güven altyapısı · güven listeleri · eIDAS 2.0 · EUDI ARF · SD-JWT VC · mdoc · OpenID4VCI · OpenID4VP · seçici açıklama · bağlanamazlık · egemenlik · Türk dünyası

ATIF

Tamga Network (2026). Türkiye ve Türk Dünyası için Dijital Güven Altyapısı. Whitepaper, sürüm 1.0. https://tamga.network/whitepaper-tr.pdf

İçindekiler

Okuma kılavuzu 6
1 Giriş: Kopyadan Kanıta 7
1.1 Bir başvuru sahnesi 7
1.2 Tamga'nın kısa cevabı 7
1.3 Bu belgenin katkısı ve planı 9
1.4 Ad: tamga 9
2 Sorun Alanı ve Gereksinimler 10
2.1 Kopya ekonomisinin bedeli 10
2.2 Sınırda duran güven 10
2.3 Mahremiyetin ikinci sorunu 11
2.4 Egemenlik sorusu 11
2.5 Gereksinimler 11
3 Arka Plan: eIDAS 2.0, EUDI ARF ve Açık Standartlar 13
3.1 eIDAS'tan eIDAS 2.0'a 13
3.2 Belge türleri: PID, EAA, QEAA, PuB-EAA 13
3.3 ARF'nin rolleri ve güven listeleri 14
3.4 Teknik standartlar haritası 15
3.5 AB dışından bakınca 16
4 Tasarım İlkeleri ve Konumlanma 17
4.1 Yedi ilke 17
4.2 Üç katman 18
4.3 Ağ ne değildir 19
4.4 Kâr amacı gütmeyen ağ, vakıf ve geçici işletmecilik 20
5 Roller ve Bileşenler 20
5.1 Rol seti 20
5.2 Rol ayrımı kuralları 22
5.3 Bileşenler ve hizmet adresleri 23
5.4 Ağ ve cüzdanlar 24
5.5 Yön kuralları 25
6 Güven Modeli: İmzalı Güven Listeleri ve Çapa Günlüğü 25
6.1 İmza neyi kanıtlar, liste neyi kanıtlar 25
6.2 Listelerin listesi ve ülke listeleri 26
6.3 Liste kuralları 27
6.4 Çapa günlüğü 28
6.5 Bant dışı güven çapası 29
6.6 Tek arayüz: TrustSource 29
6.7 Tanımlayıcılar 30
6.8 ETSI görünümleri 31
6.9 Federasyon: başkasının listesi 31
7 Kurum Kimliği ve Sertifikalar 32
7.1 Neden X.509, neden DID değil 32
7.2 Ulusal kök ve geçici işletmecilik 33
7.3 Belge veren sertifika profili 33
7.4 Doğrulayıcı erişim sertifikası 34
7.5 Kayıt sertifikası 34
7.6 Kurumun anahtarı kurumda: uzaktan imza 35
8 Belgeler: Biçimler, Türler ve Katalog 36

8.1 SD-JWT VC'nin anatomisi ... 36
8.2 Cihaz bağı neden istisnasız ... 39
8.3 mdoc: ikinci temsil ... 39
8.4 Belge türü kimliği ve katalog ... 40
8.5 Bugünkü türler ... 42
8.6 Kategori sinyali ve güvence ... 42
9 Belge Verme: OpenID4VCI Profili ... 43
9.1 İki başlangıç ... 43
9.2 Yetkili kaynak kurumda ... 44
9.3 Yalnız gerçek cüzdanlara ... 46
9.4 DPoP, nonce ve anahtar sahipliği ispatı ... 46
9.5 Toplu verme: on kopya, on anahtar ... 48
9.6 Sessiz yenileme ... 48
9.7 Bildirim ve "siz değilseniz" ... 49
10 Gösterme: OpenID4VP, DCQL ve Yakın Alan ... 49
10.1 İmzalı istek ve doğrulayıcının kimliği ... 50
10.2 DCQL ile ne isteniyor ... 50
10.3 Onay ekranı ve aşırı talep ... 51
10.4 Yanıt ve şifreleme ... 52
10.5 Sahte rete karşı çekim dalları ... 53
10.6 Tarayıcıdan gösterme ... 54
10.7 Web sitelerine giriş ... 55
10.8 Yakın alan: köprüler ve hedef ... 55
10.9 Kapı ve bilet ... 56
11 Doğrulama Hattı: Beş Katman, Üç Sonuç ... 57
11.1 Neden sabit bir hat ... 57
11.2 Katmanlar ... 57
11.3 Zamana bağlı yetki ... 58
11.4 Üç değerli sonuç ... 58
11.5 Barındırılan doğrulayıcı ... 60
12 İptal ve Yaşam Döngüsü ... 60
12.1 Geri almak, izlemeden ... 60
12.2 Neden zincirde değil ... 61
12.3 Bit sayısı ve askı ... 62
12.4 Gizlilik kuralları ... 62
12.5 Tazelik ve etkili olma süresi ... 63
12.6 İptal politikası ... 64
12.7 Cüzdan birimi iptali ... 65
13 Cüzdan: Kurallar, Anahtarlar ve Kanıtlar ... 65
13.1 Ağın cüzdana bakışı ... 65
13.2 Anahtar mimarisi ve seviyeler ... 65
13.3 WIA ve KA ... 66
13.4 Kopyalar ... 68
13.5 Kişinin denetimi ... 69
13.6 "Tamga Network'te listeli" ... 69
13.7 Yaş sınırı yok ... 70
14 Kimlik: Geçici Kimlik Belgesi Sağlayıcısı ... 70
14.1 PID yokken ne yapılır ... 70
14.2 Uzaktan kimlik doğrulama ... 71

14.3 Seviyeler ... 72
14.4 Sınıf: nitelikli değil ... 73
14.5 Alanlar ... 73
14.6 Kimlikten doğan belgeler ... 75
14.7 Saklama ve silme ... 75
14.8 Mağaza inceleme kodu ... 76
15 Gizlilik Mühendisliği ... 76
15.1 Tehdit olarak bağlanabilirlik ... 76
15.2 Doğrulayıcı başına kopya ve yuvarlanmış zaman ... 77
15.3 Site başına takma ad ... 77
15.4 Sıfır bilgi ispatı ... 78
15.5 Ortak kayıtlarda veri yok ... 80
15.6 Hukuki çerçeve ... 81
15.7 Kalan gizlilik riskleri ... 81
16 Güvenlik Modeli ve Tehditler ... 81
16.1 Varlıklar ve güven varsayımları ... 81
16.2 Saldırgan modelleri ... 82
16.3 Tehdit tablosu ... 82
16.4 Güvenli varsayılanlar ... 84
16.5 Uyum ve sınama ... 84
16.6 Olay müdahalesi ve sorumlu bildirim ... 84
17 Sandbox, Açık Paketler ve Referans Hizmetler ... 85
17.1 Sandbox ... 85
17.2 On paket ... 86
17.3 Referans hizmetler ... 87
17.4 Belgelerin üç kapısı ... 87
18 Yönetişim ve Egemenlik ... 88
18.1 Üç katmanlı egemenlik ... 88
18.2 Bugünkü organlar ... 89
18.3 Aşamalar ... 90
18.4 Devir planı ... 90
18.5 Ölçülebilir eşikler ve şeffaflık ... 91
18.6 Katılım kapıları ve uyum rejimi ... 92
18.7 Finansman ilkesi ... 93
18.8 Rulebook düzeni ... 93
19 Ortak Defter: Neden Şimdi Değil, Nasıl Gelir ... 93
19.1 Bir defter ne zaman bir şey katar ... 93
19.2 Neden Besu ve QBFT ... 94
19.3 Projeksiyon ilkesi ... 94
19.4 Eşikli çapa ve rakip adaylar ... 95
19.5 Ad alanı, devletler arası bağ, kotalar ... 97
19.6 Yükseltme bekleme süresi ... 97
19.7 İzinlendirme ve işletim ... 97
19.8 Geçiş ... 98
19.9 Değer katmanı: askıda ... 98
20 AB Uyumu ve Üçüncü Ülke Tanıma ... 98
20.1 Üç seviye birlikte çalışabilirlik ... 99
20.2 Standart uyum haritası ... 99
20.3 AB kayıt verisi ve sertifikalar ... 100

20.4 Hukuki tanıma ağın elinde değil 101
20.5 Uyumu nasıl gösteriyoruz 101
20.6 Ad ve işaret 102
21 Kararlar ve Gerekçeleri 103
21.1 Karar nasıl alınır 103
21.2 On büyük karar 103
21.3 Bütün kararlar 105
21.4 Değişen kararlar 109
22 Durum, Yol Haritası ve Açık Kararlar 109
22.1 Bugün ne çalışıyor 109
22.2 Yol haritası 111
22.3 Öneri durumundaki karar 111
22.4 Açık kararlar ve sonraki işler 112
23 Sınırlar ve Açık Sorular 112
23.1 Beyan edilen artık riskler 112
23.2 Henüz cevabı olmayan sorular 113
23.3 Araştırma yönleri 114
24 Sonuç 114
Ek A — Sözlük 115
Ek B — Karar kayıtları dizini 117
Ek C — Standart dizini 120
Ek D — Kısaltmalar 121
Ek E — Belge seti dizini 123
Kaynaklar 124

Okuma kılavuzu

Bu belge Tamga Network'ü baştan sona anlatır: nasıl çalıştığını, her önemli seçimin neden yapıldığını ve ağın nereye gittiğini. Herkesin her bölümü okuması gerekmez. Bir kamu yöneticisinin aradığı ile bir cüzdan geliştiricisinin aradığı farklıdır; Tablo 1 her okur grubu için kısa bir yol önerir. Yol önerisi bir sınır değildir. Bölümler birbirine bölüm numarasıyla atıf yapar, okur bir kavramı ilk kez gördüğü yerden geriye ya da ileriye gidebilir.

ÖNEMLİ

Bu belge ne değildir

Bu belge hukuki görüş değildir; KVKK [9], eIDAS ya da başka bir mevzuat hakkındaki cümleleri bir hukukçunun değerlendirmesinin yerini tutmaz. Bir sertifika iddiası da taşımaz; Tamga'nın uyum testleri öz-testtir ve hiçbir kurumun onayı anlamına gelmez. Hiçbir devletle ya da kurumla yapılmış bir anlaşmanın ya da sürmekte olan bir görüşmenin bildirimi değildir; metinde adı geçen devletler için listelerde yalnızca yer ayrılmıştır. Belge yaşayan bir metindir ve sürüm 1.0 içinde yerinde güncellenir. Kaynak belgelerle çelişirse kaynak geçerlidir: önce karar kayıtları, sonra şartnameler, sonra çerçeve belgeleri.

Tablo 1. Okur gruplarına göre önerilen okuma yolları.

Okur	Ne arar	Önerilen bölümler
Kamu yöneticisi, düzenleyici, devlet temsilcisi	egemenlik, devir, AB ile ilişki, hukuki sınır	1–4, 18, 20, 22–23
Kurum (üniversite, meslek kuruluşu, bilet satıcısı)	nasıl katılırım, katılmanın faydası ne, imza anahtarı kimde kalır	1–2, 5, 7–9, 12, 17
Doğrulayıcı, web sitesi	nasıl doğrularım, neyi görürüm, yükümlülüğüm ne	5, 10–11, 15
Cüzdan geliştiricisi	listeye nasıl girerim, hangi kanıtlar istenir, kurallar ne	5, 13, 17, 20
Akademisyen, araştırmacı, güvenlik uzmanı	modelin gerekçesi, tehditler, artık riskler	3, 6, 11, 15–16, 19, 21, 23
Gazeteci, genel okur	ne çözülüyor, neden önemli	Özet, 1–2, 4, 15, 24

Belgedeki her iddia üç durumdan birine aittir ve metin bunu her yerde açıkça söyler. Bir işlevin adının yanında kalın yazılmış bir durum etiketi görürseniz Tablo 2'deki anlamıyla okuyun. Bütün işlevlerin durumu Bölüm 22'de tek bir tabloda toplanır.

Tablo 2. Durum etiketleri.

Etiket	Anlamı	Örnek
Çalışıyor	Gerçek ağda ya da sandbox'ta canlıdır ve kaynakla gösterilebilir	imzalı güven listeleri, Tamga Verify, sandbox
Planlanan	Bir karara bağlıdır, kodu ya da tasarımı vardır, ama canlı değildir	Bluetooth ile yakın alan gösterme, gerçek ağda XML güven listesi
Araştırma	Karar yoktur ya da karar askıdadır	sıfır bilgi ispatıyla takma ad türetme, değer katmanı

Kararlar karar kayıtlarıyla (ADR, *Architecture Decision Record*), teknik kurallar şartnamelerle (SPEC) ve çerçeve kuralları Tamga Mimari ve Referans Çerçevesi'nin belgeleriyle (FW) anılır. Metinde "ADR-0042" gördüğünüz yerde kararın tam metni `docs.tamga.network/tr/adr/` altında, "SPEC-TRUST-0001 §5" gördüğünüz yerde şartnamenin ilgili bölümü `docs.tamga.network/tr/specifications/` altında, "FW-ARF-0001 §6.1" gördüğünüz yerde çerçeve belgesi `arf.tamga.network/tr/` altındadır. Kimliklerin adres eşlemesi Ek E'dedir [63, 64, 65]. Kimlikler kalıcıdır: bir belgenin başlığı ya da yeri değişse de kimliği aynı kalır.

Bu baskının hazırlandığı tarihte Tamga'nın açık paketleri npm'de 0.8.2 deneme sürümüyle yayımlanmıştır; çerçeve belgeleri sürüm 1.0'dadır. Sürüme bağlı her cümle bu tarihe göre yazılmıştır.

1 Giriş: Kopyadan Kanıta

1.1 Bir başvuru sahnesi

Bu dizinin ilk yazısında [67] Bakü'de lisansını bitirip İstanbul'da yüksek lisans yapmak isteyen Aynur'u tanımıştık. Aynur şimdi mezun oldu ve İstanbul'da bir şirketin ilanına başvuruyor. İlan açık: adaydan diploma, not dökümü ve kimlik isteniyor. Şirketin işe alım sorumlusu Timur, başvurular arasında Aynur'un özgeçmişini beğeniyor ve onu görüşmeye çağırıyor.

Görüşmeden önce belgeler geliyor. Aynur diplomasının taranmış bir kopyasını e-postayla gönderiyor; Timur Azerbaycanca metni okuyamadığı için noter onaylı bir tercüme istiyor. Aynur bir tercüme bürosu buluyor, bir noter randevusu alıyor, birkaç gün ve bir miktar para harcıyor. Sonunda Timur'un elinde iki kâğıt var: bir diplomanın kopyası ve o kopyanın tercümesi. Ama Timur'un asıl sorusu hâlâ cevapsız. Bu diploma gerçek mi?

Timur bunu öğrenmek için Bakü'deki üniversitenin öğrenci işlerine bir e-posta yazıyor. E-posta bir süre bekliyor; belki doğru kişiye ulaşıyor, belki ulaşmıyor. Cevap gelirse haftalar sonra geliyor, gelmezse Timur ya kopyaya güvenmek ya da adayı kaybetmek arasında bir seçim yapıyor. Bu arada Aynur'un diploması, kimlik kartının fotokopisi ve not dökümü şirketin işe alım klasöründe, e-posta sunucusunda ve belki bir aday takip sisteminde duruyor. Aynur bu kopyaların nerede, ne kadar süre ve kimin erişimiyle saklandığını hiç öğrenmeyecek.

Bu sahnede kimse kötü niyetli değil. Aynur dürüst, Timur dikkatli, üniversite yardımsever. Sorun, belgelerin taşındığı yoldadır. Kâğıt dünyasından devraldığımız düzen üç şeyi aynı anda kötü yapar. Kopya, aslının gerçek olduğunu kanıtlamaz; çünkü bir dosyayı düzenlemek, bir mührü taklit etmekten çok daha kolaydır. Doğrulama, kaynağın cevap vermesine bağlıdır; kaynak yavaşsa, başka dilde konuşuyorsa ya da hiç cevap vermiyorsa doğrulama da durur. Ve her başvuru, kişinin verisinden bir kopya daha üretir: Timur diplomadaki yalnızca birkaç bilgiye ihtiyaç duyduğu hâlde belgenin tamamını, üstelik kimlik kartıyla birlikte alır.

1.2 Tamga'nın kısa cevabı

Aynı başvuruyu bir de Tamga Network'ün tasarladığı yoldan izleyelim (Şekil 1).

Aynur'un üniversitesi diplomayı **dijital imzalı bir belge** olarak verir ve bu belge Aynur'un telefonundaki bir **cüzdana**, yani belgeleri tutan ve gösteren bir uygulamaya, yerleşir. Bu belge sıradan bir dosyadan farklıdır; içi üniversitenin anahtarıyla imzalıdır ve Aynur'un telefonunun güvenli donanımında üretilmiş bir anahtara bağlıdır. Bu bağ, belgenin başka bir telefona kopyalanıp orada kullanılmasını engeller (Bölüm 8).

Timur'un şirketi Aynur'dan belge istediğinde, şirketin sitesi bir **istek** üretir. İstek imzalıdır ve şirketin kim olduğunu, kayıtlı olduğu amacı ve hangi alanları istediğini taşır: diyelim ki "diplomanın unvanı, bölümü ve mezuniyet yılı". Aynur'un cüzdanı önce şirketin gerçekten kayıtlı bir doğrulayıcı olup olmadığını denetler, sonra isteği Aynur'a gösterir: kim istiyor, neden istiyor, hangi alanları istiyor. Aynur PIN'iyle ya da parmak iziyle onaylar. Telefonundan yalnızca bu üç alan çıkar; not ortalaması, doğum tarihi ya da kimlik numarası çıkmaz.

Timur'un doğrulama yazılımı birkaç saniye içinde dört soruya cevap arar. Belge gerçekten imzalanmış mı ve imzadan sonra hiçbir şey değişmemiş mi? İmzalayan gerçekten bir üniversite mi ve diploma vermeye yetkili mi; belge verildiği gün yetkili miydi? Üniversite bu belgeyi sonradan iptal etmiş mi? Belgeyi gösteren telefon, belgenin bağlı olduğu telefon mu? Bu soruların hiçbiri için üniversiteyi aramaya gerek yoktur. İkinci sorunun cevabı herkesin indirip denetleyebildiği **imzalı bir güven liste-**

sinde, üçüncüsünün cevabı üniversitenin önceden yayımladığı bir **iptal listesinde** durur (Bölüm 6 ve 12). Üniversite de Aynur'un diplomasını kime, ne zaman gösterdiğini öğrenmez.

TEKNİK AYRINTI

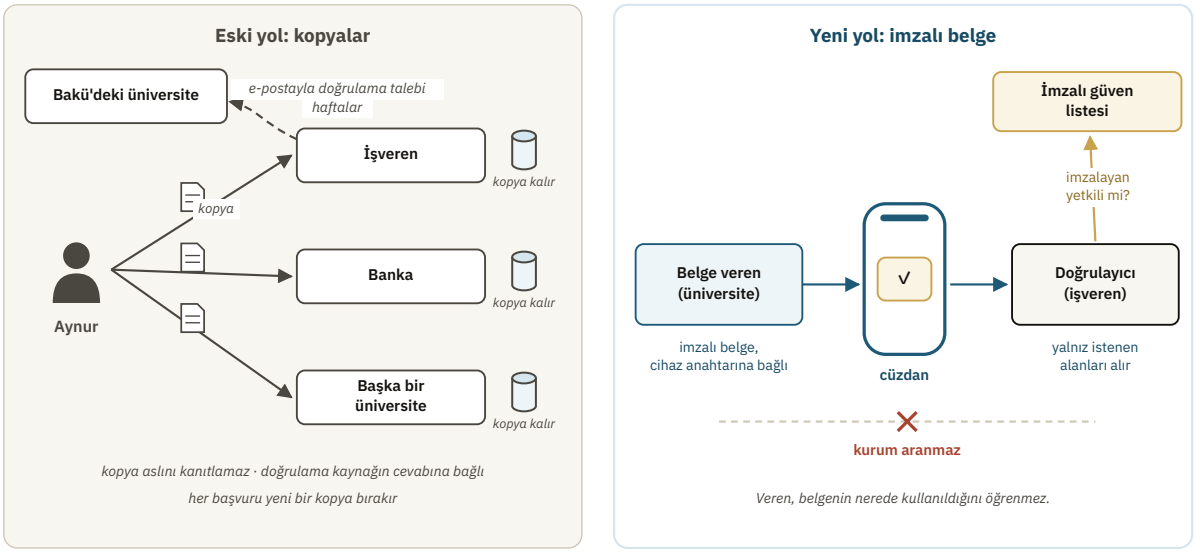
Aynı sahnenin protokol dilinde özeti

Aşağıdaki tablo sahnedeki mesajları sırasıyla gösterir. Ayrıntıları Bölüm 10 (gösterme) ve Bölüm 11 (doğrulama hattı) anlatır; burada yalnızca iskeleti veriyoruz.

1	`Timur → Aynur`	**İstek.** Şirketin doğrulayıcısı imzalı bir OpenID4VP isteği üretir; istek QR kodu ya da bağlantı olarak Aynur'a ulaşır.	$\text{istemci kimliği} = \text{x509_hash}$
2	`Aynur'un cüzdanı`	**Denetim ve onay.** Cüzdan, doğrulayıcının güven listesindeki kaydını ve kayıt sertifikasını denetler, istenen alanları gösterir, onay alır.	$\text{kayıt sertifikası yok} \Rightarrow \text{ret}$
3	`Aynur → Timur`	**Yanıt.** Cüzdan yalnızca onaylanan alanları ve bu isteğe bağlı bir cihaz imzasını şifreli olarak gönderir.	$\text{vp_token} = \text{SD-JWT VC} + \text{açıklanan alanlar} + \text{cihaz imzası}$
4	`Timur'un doğrulayıcısı`	**Doğrulama hattı.** İmza, belge türü, güven listesi, iptal durumu ve politika sırayla denetlenir.	$\text{sonuç} \in \{\text{kabul}, \text{ret}, \text{doğrulanamadı}\}$

Tablodaki terimlerin her biri ilk geçtikleri bölümlerde açılır: OpenID4VP [31] Bölüm 3.4 ve 10'da, kayıt sertifikası Bölüm 7.5'te, SD-JWT VC [16] Bölüm 8'de, üç değerli sonuç Bölüm 11'de.

Bu sahnenin bir tasarımı anlattığını açıkça söylemek gerekir. Tamga Network'ün yapısında her ülkenin kendi güven listesi için bir yer vardır, ama bugün yalnız Türkiye listesi etkindir. Azerbaycan için listelerde yer ayrılmıştır; bu bir anlaşma ya da görüşme bildirimi değildir, yalnızca bir devlet katıldığında kendi listesini yayınlayabileceği boş bir yuvadır. Aynur'un Bakü'deki üniversitesinin bu yoldan belge verebilmesi için o yuvanın dolması gerekir (Bölüm 6.2). Türkiye listesinde de bu baskının hazırlandığı tarihte etkin belge veren yalnızca ağın geçici kimlik servisidir (Bölüm 14); kurum belgeleri, ilk kurumlar katıldıkça aynı yoldan verilir. Akışın bütünü bugün sandbox'ta, yani gerçek ağdan tamamen ayrı test ağında, örnek kurumlarla denenebilir (Bölüm 17). Hangi işlevin bugün çalıştığı Bölüm 22'de tek tek gösterilir.



Şekil 1. Eski yol ve yeni yol: kopyalar zinciri ile kaynağa sormadan doğrulama

1.3 Bu belgenin katkısı ve planı

Tamga Network'ü daha önce kısa bir whitepaper'la anlatmıştık; bu genişletilmiş baskı onun yerini alır. Manifesto [62] ve geliştirici belgeleri yanında durur. Bu baskı üç soruya bir arada ve ayrıntıyla cevap vermek için yazıldı.

Birinci soru **nasıl çalıştığıdır**. Bir belgenin verilmesinden doğrulanmasına, iptalinden cüzdandaki yaşamına kadar her adımı hiçbir ön bilgi varsaymadan anlatıyoruz. Teknik ayrıntıyı atlamıyoruz, ama onu ayrı kutulara koyuyoruz; kutuları atlayan okur da metni izleyebilir. İkinci soru **neden böyle seçildiğidir**. Ağın her önemli kararı bir karar kaydına bağlıdır ve bu kayıtlar neyin seçildiğiyle birlikte hangi seçeneklerin neden bırakıldığını da yazar. Belge boyunca bir seçimi anlatırken onun karar kaydını ve alternatiflerini birlikte veriyoruz. Üçüncü soru **nereye gittiğidir**. Bugün neyin çalıştığını, neyin kararlaştırılıp henüz canlı olmadığını ve neyin hâlâ araştırma olduğunu ayırıyoruz; takvim yerine koşul veriyoruz.

Belge altı kısımdan oluşur. **Kısım I** (Bölüm 1–4) sorunu, Avrupa Birliği'nin bu soruna verdiği cevabı ve Tamga'nın tasarım ilkelerini anlatır. **Kısım II** (Bölüm 5–8) güvenin yapısını kurar: roller, güven listeleri, kurum sertifikaları ve belge biçimleri. **Kısım III** (Bölüm 9–12) akışları izler: belge verme, gösterme, doğrulama ve iptal. **Kısım IV** (Bölüm 13–16) kişinin tarafına geçer: cüzdan kuralları, geçici kimlik servisi, gizlilik mühendisliği ve güvenlik modeli. **Kısım V** (Bölüm 17–20) ekosistemi ve yönetişimi anlatır: sandbox ve açık paketler, egemenlik ve devir, ortak defterin neden bugün olmadığı ve AB ile ilişki. **Kısım VI** (Bölüm 21–24) kararları bir arada sunar, yol haritasını ve açık soruları verir. Ekler sözlüğü, karar dizinini, standart dizinini ve belge seti dizinini içerir.

Bu belgeyi yayımlayan ağın kendisi bir yazı dizisi de yayımlıyor. Seçici açıklama, bağlanamazlık, güven listeleri ya da iptal gibi bir kavramı bütün derinliğiyle merak eden okura metin içinde dizinin ilgili yazısını gösteriyoruz; burada kavramı yalnızca Tamga'yı anlamaya yetecek kadar açıyoruz.

1.4 Ad: tamga

Orta Asya'nın Türk boyları sürülerine, eşyalarına ve kayalara *tamga* adı verilen işaretler vururdu. Bir atın sağrısındaki tamga, sahibini tanımayan birine bile atın hangi boya ait olduğunu söylerdi. Dizinin ilk yazısı bu işaretin taşıdığı fikri ayrıntıyla anlatır: bir toplulukta herkesin tanıdığı bir işaret, tanımadığın biri hakkında sana güvenilir bir bilgi verir.

Doğrulanabilir dijital belge bu fikrin çağdaş karşılığıdır, ama iki noktada ondan ayrılır. Birincisi, kadim tamga taklit edilebilirdi; dijital imza ise imzalayanın gizli anahtarı olmadan üretilemez. İkincisi, bir

tamgayı tanımak için onu önceden bilmek gerekirdi; dijital dünyada hangi işaretin kime ait olduğunu söyleyen imzalı bir liste vardır ve bu liste herkese açıktır. Ağın adı bu iki fikri bir araya getirir: herkesin tanıyabildiği bir mühür ve o mührün kime ait olduğunu söyleyen, herkesin denetleyebildiği bir kayıt.

2 Sorun Alanı ve Gereksinimler

2.1 Kopya ekonomisinin bedeli

Aynur'un başvurusundaki sorun tek bir kişinin talihsizliği değildir; belgelerin kopya olarak dolaştığı bir düzenin olağan sonucudur. Bu düzenin bedelini kimse tek bir faturada görmez, ama herkes bir parçasını öder. Bu bölümde bedeli kimin neyi ödediği üzerinden anlatıyoruz ve rakam vermiyoruz; çünkü güvenilir ve karşılaştırılabilir bir sayı vermek bu belgenin kapsamını aşar ve kaynaksız istatistik yazmamayı ilke ediniyoruz.

İlk bedel **sahteciliktir**. Bir diplomanın taranmış kopyası, bir görüntü düzenleme programıyla birkaç dakikada değiştirilebilir. Kopyayı alan taraf, aslını görmediği sürece bunu fark edemez. Sahtecilik ne kadar kolaysa, dürüst başvuru sahibine duyulan güven de o kadar azalır: Timur, Aynur'un diplomasının gerçek olduğuna inansa bile bunu kanıtlayamaz.

İkinci bedel **tekrarlanan doğrulamadır**. Aynur'un diploması bir işverende, bir bankada, bir yüksek lisans programında ve bir burs başvurusunda ayrı ayrı doğrulanır. Her kurum aynı soruyu sıfırdan sorar ve aynı belirsizlikle yaşar. Doğrulamanın bir kez yapılıp herkesin ondan yararlanabileceği bir altyapı yoktur.

Üçüncü bedel, **verinin sahibinden kopmasıdır**. Her başvuru, kişinin verisinden bir kopyayı kişinin göremediği bir sunucuya bırakır. Kişi bu kopyanın ne zaman silineceğini, kimlerin göreceğini ya da bir veri sızıntısında nereye gideceğini bilmez. Belgeyi kanıtlamak için kişi belgenin tamamını verir, oysa karşı taraf çoğu zaman yalnızca bir iki bilgiye ihtiyaç duyar.

Dördüncü bedel **kaynağın üzerindeki yüktür**. Üniversitelerin öğrenci işleri, mezunlarının belgeleri hakkında gelen e-postalara, telefonlara ve resmî yazılara cevap verir. Bu iş ne kadar çoksa, kaynağın cevap vermesi o kadar gecikir; cevap ne kadar gecikirse kopyaya güvenme baskısı o kadar artar.

2.2 Sınırda duran güven

Bu bedeller sınır geçildiğinde katlanır. Türk dünyası ortak bir dil ailesini, kültürü ve uzun bir tarihi paylaşır; öğrenciler, çalışanlar ve aileler bu ülkeler arasında giderek daha çok hareket eder. Ama bir ülkenin kurumuna ötekinde güvenmenin bugün kısa bir yolu yoktur. Bakü'deki bir üniversitenin gerçekten bir üniversite olduğunu İstanbul'daki bir işveren nereden bilecektir? Kazakistan'da verilmiş bir meslek belgesinin hâlâ geçerli olup olmadığını Taşkent'teki bir hastane nasıl öğrenecektir?

Bugün bu soruların cevabı çoğunlukla kâğıt ve aracılarla verilir: tercümeler, noter onayları, tasdik zincirleri, kurumdan kuruma yazışmalar. Her aracı bir gecikme ve bir maliyet ekler, ama hiçbiri asıl soruyu, yani "bu belgeyi imzalayan gerçekten yetkili bir kurum mu?" sorusunu matematiksel olarak cevaplamaz. Tamga'nın Trust Framework'ü vizyonunu bu boşluğa göre yazar: Türk Devletleri Teşkilatı'nın üye ve gözlemci devletlerinin, kurumlarının ve vatandaşlarının birbirinin belgelerini kaynağa sormadan doğrulayabildiği ortak bir güven altyapısı (FW-TF-0001 §1.1). Bu cümle bir hedeftir; bugün hiçbir devlet ağa katılmış değildir ve bu belge hiçbir devletle bir anlaşma ya da görüşme bildirmez. Sorun alanını tarif ederken ülke adlarını, sorunun gündelik yüzünü somutlaştırmak için kullanıyoruz.

2.3 Mahremiyetin ikinci sorunu

Kopyayı imzalı bir dijital belgeyle değiştirmek ilk sorunu çözer, ama dikkatli tasarlanmazsa yeni bir sorun yaratır. Dijital bir doğrulama, kâğıdın hiçbir zaman yapamadığı biçimde **iz bırakabilir**. Bu izlerin dört türü vardır ve her biri ayrı bir tasarım önlemi ister.

Birincisi, doğrulayıcı her doğrulamada belgeyi verene sorarsa veren kurum, kişinin belgesini nerede ve ne zaman kullandığını öğrenir. Bu, dijital kimlik literatüründe "eve telefon etme" diye anılan sorundur. İkincisi, doğrulayıcı ihtiyacından fazlasını isteyebilir: yaşınızı doğrulamak isteyen bir site, doğum tarihinizi, adınızı ve adresinizi birlikte alabilir. Üçüncüsü, farklı doğrulayıcılar aldıkları bilgileri birleştirirse, kişi birbirinden habersiz sanılan ziyaretlerinde aynı kişi olarak eşleştirilebilir; aynı belge her seferinde aynı imzayla ve aynı tanımlayıcıyla gösteriliyorsa bu eşleştirme kolaylaşır. Dördüncüsü, ortak kayıtlar (listeler, günlükler, olası bir defter) kişisel veri ya da belge özeti taşırsa, bu kayıtlar herkesin okuyabildiği bir izleme aracına dönüşür.

Bu dört iz, dizinin seçici açıklama ve bağlanamazlık yazılarının [68, 70] konusudur. Tamga'nın ana çerçeve belgesi bunlara karşı yedi önlemi sayar (FW-ARF-0001 §7.2): ortak kayıtlarda kişisel veri olmaması, her doğrulayıcıya ayrı kopya ve site başına takma ad, sıfır bilgi ispatı, sabit aralıkla yayınlanan iptal listeleri, her gösterimde onay ve aşırı talep uyarısı, kimlik doğrulamada görüntülerin saklanmaması ve kullanım istatistiklerinin yalnızca en az ellişerlik gruplar hâlinde yayımlanması. Bunlar Bölüm 15'te tek tek anlatılır. Burada yalnızca şunu vurguluyoruz: gizlilik, sonradan eklenen bir özellik olamaz. Hangi bilginin hangi kayda gireceği, mimarinin ilk günden verdiği bir karardır.

2.4 Egemenlik sorusu

Dünya taşınabilir dijital belgelere geçerken bir ülkenin önünde kabaca iki yol vardır. Birincisi, bu dönüşümü dışarıdan almaktır: başka bir ülkenin ya da şirketin altyapısını, kurallarını ve anahtarlarını kullanmak. İkincisi, aynı açık standartlar üzerinde kendi altyapısını kurmak ve anahtarlarını kendi elinde tutmaktır. Tamga ikinci yolu seçer ve bunu manifestosunda "aynı standartlar, kendi ağımız" diye özetler.

Ama "kendi ağımız" demek tek bir otorite istemek demek değildir. Birden çok devletin katılacağı bir ağda asıl soru, kimin neye karar vereceğidir. Tamga'nın yönetişim kararı bu soruyu basit bir örnekle sorar: bir devlet kendi üniversitesini belge veren olarak kaydederken neden başka bir devletin oyunu beklesin? (ADR-0002). Beklememelidir. Avrupa Birliği'nde de her üye devlet kendi güven listesini bağımsız yayınlar ve hiçbir devlet başkasının hangi kurumu listeye alacağına oy vermez. Tamga bu emsali izler: her devlet kendi kaydının tek yazarıdır, sınır ötesi tanıma her devletin kendi kararıdır ve bir devletin ağdan çıkması vatandaşlarının belgelerini geçersiz kılmaz. Bu ilkelerin ayrıntısı Bölüm 18'dedir.

Egemenlik sorusunun bir de bugüne bakan yüzü vardır. Bugün hiçbir devlet ağa katılmadığı için devlete ait rolleri (güven listesini işletmek, kurumları kaydetmek, kök sertifikayı tutmak) ağın geçici işletmecisi devlet adına yürütür. Bu durum egemenlik ilkesine aykırı görünebilir; o yüzden her geçici rolün nasıl devredileceği baştan yazılır ve devirde hiçbir belgenin, kaydın ya da tanımlayıcının değişmemesi tasarımın bir şartı olur (Bölüm 4.1, ilke P4).

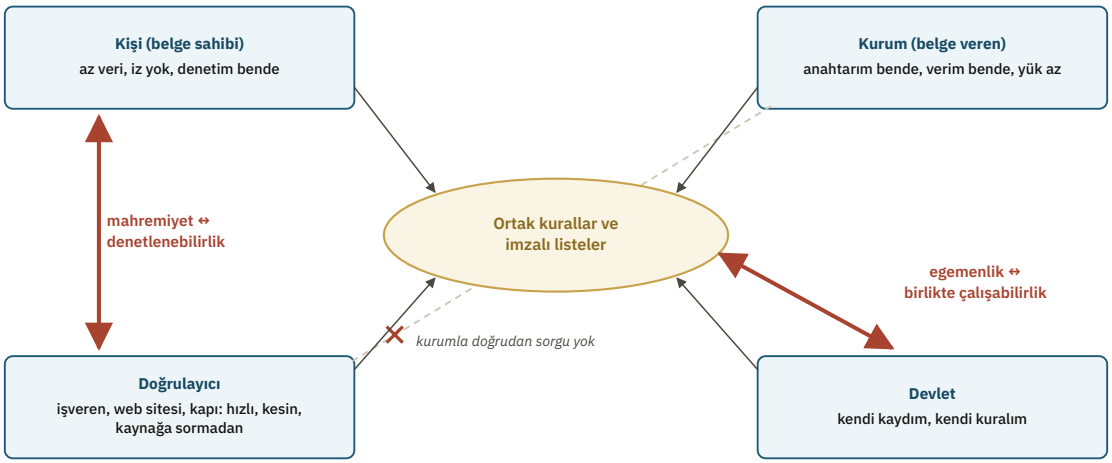
2.5 Gereksinimler

Buraya kadar anlatılanları, bir güven ağının karşılaması gereken on iki gereksinime çevirebiliriz. Tablo 3 bunları sıralar ve her birinin bu belgede nerede karşılandığını gösterir. Belgenin geri kalanı bu tabloya sık sık geri döner; bir tasarım seçimini anlatırken hangi gereksinimi karşıladığını söyleriz.

Tablo 3. Gereksinimler ve karşılandıkları bölümler.

#	Gereksinim	Neden	Nerede karşılanır
G1	Kaynağa sormadan doğrulama	Kaynağın yükü ve gecikmesi; “eve telefon etme”	6, 11, 12
G2	Seçici açıklama	Doğrulayıcı yalnızca ihtiyacını görmeli	8, 10
G3	Bağlanamazlık	Doğrulayıcılar kişiyi birbirine anlatamamalı	9.5, 13, 15
G4	Kişisel verisiz ortak kayıt	Listeler ve günlükler izleme aracına dönüşmemeli	6, 12, 15.5, 19
G5	Cihaza bağlı belge	Belge başkasının telefonunda kullanılamamalı	8.2, 13
G6	İptalin izlenmeden yayını	Geri alma, kişinin nerede doğrulandığını açığa vurmamalı	12
G7	Devlet egemenliği	Her devlet kendi kaydının tek yazarı olmalı	4.1, 18
G8	Tek işletmeci varsayımının olmaması ve devredilebilirlik	Geçici roller devredilebilmeli; devirde kimlikler değişmemeli	4.4, 6.7, 18.4
G9	AB standartlarıyla birlikte çalışma	Aynı dili konuşan cüzdan ve doğrulayıcılarla çalışabilmek	3, 20
G10	Açık kod ve kilitlenmeme	Hiçbir kurum tek bir üreticiye bağımlı kalmamalı	5.3, 17
G11	“Doğrulanamadı” ile “geçersiz”in ayrımı	Bir kesinti, dürüst bir belgeyi sahte göstermemeli	11.4
G12	Test ağı ve uyum kanıtı	Katılımcılar gerçek ağa girmeden deneyebilmeli; uyum gösterilebilmeli	16.5, 17, 20.5

Tablonun bir özelliğine dikkat çekmek isteriz. Gereksinimlerin bir kısmı birbiriyle gerilim içindedir. Seçici açıklama ve bağlanamazlık (G2, G3) kişinin olabildiğince az iz bırakmasını ister; ama bir doğrulayıcının belgeyi denetleyebilmesi için belgenin imzalı ve iptal edilebilir olması, yani bir yerde izlenebilir bir yapı taşıması gerekir (G1, G6). Egemenlik (G7) her devletin kendi kurallarını koymasını ister; birlikte çalışma (G9) ise herkesin aynı kurallarla konuşmasını. Tamga’nın tasarımının önemli bir bölümü bu gerilimlerin nasıl dengelendiğini anlatır. Şekil 2 paydaşları ve aralarındaki başlıca gerilimleri bir arada gösterir.



Şekil 2. Paydaşlar ve gerilimler

3 Arka Plan: eIDAS 2.0, EUDI ARF ve Açık Standartlar

Tamga Network bir boşlukta tasarlanmadı. Teknik katmanı, Avrupa Birliği'nin son on yılda kurduğu dijital kimlik düzeninin üzerine oturur. Bu bölüm o düzeni, Tamga'yı anlamaya yetecek kadar anlatır. AB hukukunu bütün ayrıntısıyla merak eden okur için dizinin eIDAS 2.0 yazısı [76] ayrı bir kaynaktır.

3.1 eIDAS'tan eIDAS 2.0'a

Avrupa Birliği'nin elektronik kimlik ve güven hizmetleri tüzüğü, kısa adıyla **eIDAS**, 910/2014 [1] sayısıyla 2014'te kabul edildi. Tüzük iki ayak üzerine kuruluydu. Birinci ayak elektronik kimlikti: bir üye devlet kendi elektronik kimlik sistemini bildirirse, diğer üye devletlerin kamu hizmetleri o sistemi tanımak zorundaydı. İkinci ayak güven hizmetleriydi: elektronik imza, elektronik mühür, zaman damgası ve bunları sağlayan kuruluşların denetimi. Tamga'nın güven modelinin dayandığı **güven listeleri**, bu ikinci ayağın ürünüdür: her üye devlet, denetlediği nitelikli güven hizmeti sağlayıcılarını imzalı bir listede yayımlar.

Elektronik kimlik ayağı beklenen yaygınlığa ulaşmadı. Kişiler bir belge taşımıyor, her girişte kendi ülkelerinin kimlik sistemine yönlendiriliyordu; bu, dizinin ilk yazısında [67] federasyon dönemi diye andığımız modeldir. Komisyon 2021'de tüzüğün değiştirilmesini önerdi ve aynı gün üye devletleri ortak bir teknik çerçeve üzerinde çalışmaya çağırdı [3]. Değişiklik, 11 Nisan 2024 tarihli **2024/1183 [2] sayılı Tüzük** olarak kabul edildi ve 20 Mayıs 2024'te yürürlüğe girdi. Bu metin bugün **eIDAS 2.0** diye anılır.

eIDAS 2.0'ın özü bir geçiştir: kişinin her seferinde bir kimlik sağlayıcısına yönlendirildiği modelden, belgeleri kendi cüzdanında taşıdığı modele. Tüzük her üye devletin vatandaşlarına en az bir **Avrupa Dijital Kimlik Cüzdanı** (*European Digital Identity Wallet*, EUDI Wallet) sunmasını zorunlu kılar. Zorunluluk devletin üzerindedir; kişiler için cüzdanı kullanmak gönüllüdür ve ücretsizdir. Tüzük ayrıca cüzdandan veri isteyen kurumların önce kayıt olmasını, cüzdanın bağımsız kuruluşlarca sertifikalandırılmasını ve kamu kurumlarıyla belirli özel sektör kuruluşlarının cüzdanı kabul etmesini öngörür.

Tüzüğün kendisi ilkeleri, rolleri ve yükümlülükleri koyar; ama bir Fransız cüzdanının bir Alman bankasıyla konuşabilmesi için gereken teknik kuralları yazmaz. Bu kurallar Komisyon'un çıkardığı **uygulama tüzüklerinde** (*Commission Implementing Regulation*, CIR) yer alır. Cüzdanla ilgili ilk beş uygulama tüzüğü (2024/2977–2982 [5]) 28 Kasım 2024'te kabul edildi ve 24 Aralık 2024'te yürürlüğe girdi; tüzüğün cüzdan için öngördüğü 24 aylık süre bu tarihten işlemeye başladı. Mayıs 2025'te güvenen tarafların kaydını da içeren ikinci bir paket (2025/846–849 [6]), Temmuz 2026'da da atıf yapılan standartları güncelleyen değiştirici tüzükler (2026/1730 [7], 2026/1731, 2026/1735) yayımlandı. Bir uygulama tüzüğü çoğu zaman bir standardı kopyalamaz, ona atıf yapar; bu yüzden AB'de bağlayıcı olan teknik kural, çoğu zaman tüzüğün atıf yaptığı standardın belirli bir sürümüdür.

3.2 Belge türleri: PID, EAA, QEAA, PuB-EAA

eIDAS 2.0, cüzdanda taşınan belgeleri iki büyük gruba ayırır. Birinci grup **kişi kimlik verisidir** (*Person Identification Data*, **PID**): ad, soyad, doğum tarihi, uyruk gibi kişinin kimliğini belirleyen veri. PID'i yalnızca devlet ya da devletin yetkilendirdiği bir kuruluş verebilir ve cüzdanın temelini oluşturur. İkinci grup **elektronik öznitelik belgeleridir** (*Electronic Attestation of Attributes*, **EAA**): diploma, öğrenci belgesi, meslek belgesi, üyelik kartı, bilet; kısacası PID dışındaki her belge.

Tüzük EAA'ları da kimin verdiğine ve hangi güvenceyi taşıdığına göre üçe ayırır. Nitelikli bir güven hizmeti sağlayıcısının verdiği **nitelikli öznitelik belgesi** (QEAA), kâğıt üzerindeki karşılığıyla aynı hukuki etkiye sahiptir. Bir yetkili kaynaktan sorumlu kamu kurumunun ya da onun adına görevlendirilen kurumun verdiği **kamu kurumu belgesi** (PuB-EAA) ayrı bir sınıftır ve o da kâğıt üzerindeki karşılığıyla aynı hukuki etkiyi taşır (Madde 45b(2)). Bunların dışında kalan herkes, örneğin bir üniversite, bir bilet

satıcısı ya da bir spor kulübü, **nitelikli olmayan öznitelik belgesi** verebilir. Ayrım hukuki etkiyi belirler; teknik biçim ise çoğu zaman aynıdır.

Tamga'nın bu kavramlarla ilişkisinde ilk kural, ağın **PID vermemesidir**. Ana çerçeve belgesi PID ihracını kapsam dışı sayar ve bu rolü devlete ayırır (FW-ARF-0001 §1.7). Güven listesinde PID sağlayıcıları için bir yer vardır, ama bu yer bugün boştur. Kişinin kimliğini doğrulayan bir belgeye yine de ihtiyaç duyulduğu için ağ, devletin PID sağlayıcısı atanana kadar **geçici bir kimlik belgesi sağlayıcısı** işletir; bu servisin verdiği belge PID değil, nitelikli olmayan bir EAA'dır ve devletin PID'i geldiğinde yerini ona bırakır (ADR-0011, ADR-0022; Bölüm 14). Tablo 4 dört kavramı ve Tamga'daki karşılıklarını yan yana koyar.

Tablo 4. AB belge kavramları ve Tamga'daki karşılıkları.

Kavram	Kim verir (AB)	Güvence ve hukuki etki	Tamga'da karşılığı
PID	Devlet ya da devletin yetkilendirdiği kuruluş	En yüksek güvence; cüzdanın temeli	Verilmez; listede yer ayrılmış ve boş. Geçici kimlik servisi PID yerine geçmez
EAA (nitelikli olmayan)	Herhangi bir kurum	Hukuki etkisi genel kurallara göre	Kurum belge türleri (öğrenci belgesi, diploma, bilet) ve geçici kimlik belgesi
QEAA	Nitelikli güven hizmeti sağlayıcısı	Kâğıt karşılığıyla aynı hukuki etki	Bugün yok; "nitelikli" bağımsız değerlendirme ve denetim ister (ADR-0022)
PuB-EAA	Yetkili kaynaktan sorumlu kamu kurumu	Kamu kaynağına dayanır	Kurum sınıflarında kamu sınıfı (PUB) için yer var; bugün kamu kurumu belge veren yok

3.3 ARF'nin rolleri ve güven listeleri

Komisyon'un 2021 çağrısıyla üye devletlerin uzmanları ve Komisyon, cüzdan ekosisteminin teknik çerçevesini birlikte yazmaya başladı. Bu çerçevenin adı **Mimari ve Referans Çerçevesi**'dir (*Architecture and Reference Framework*, **ARF** [11]). ARF bağlayıcı bir hukuk metni değildir; açık olarak geliştirilen ve düzenli güncellenen bir teknik belgedir. Ama uygulama tüzükleri ARF'deki çalışmaya dayanır; pratikte ARF, bir sonraki tüzükte neyin bağlayıcı olacağını önceden gösterir. Bu baskının hazırlandığı tarihte ARF'nin güncel sürümü 23 Temmuz 2026 tarihli 3.0.0'dır.

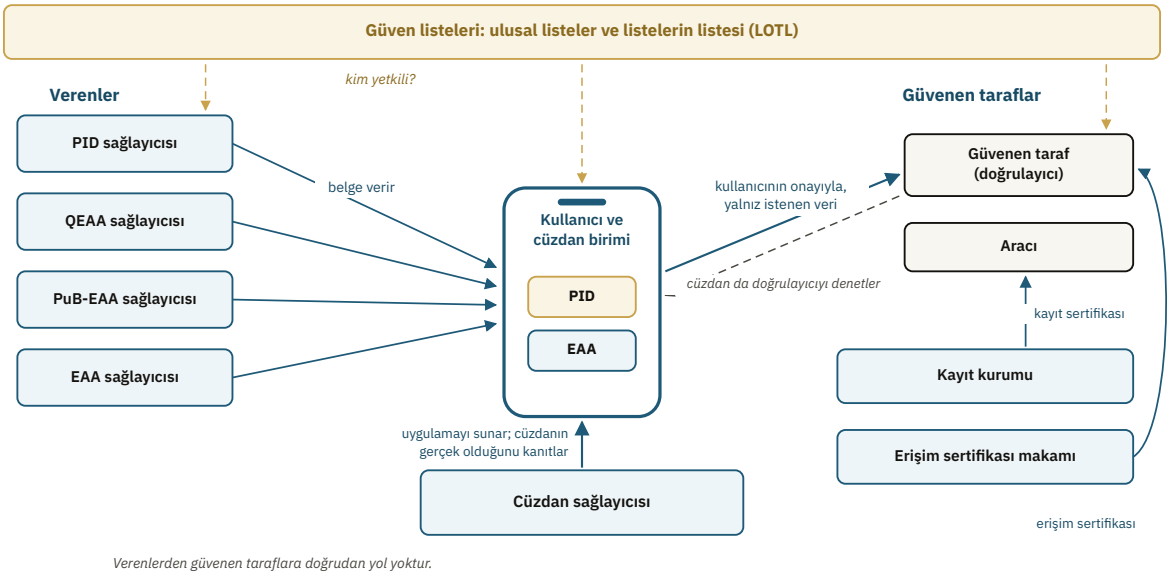
ARF'nin en kalıcı katkılarından biri bir **rol setidir**. Her rolün ne yaptığı ve kime karşı sorumlu olduğu bellidir:

- **Cüzdan sağlayıcısı** (*Wallet Provider*) cüzdan uygulamasını sunar ve cüzdanın gerçek, güvenli bir cüzdan olduğunu kanıtlayan imzalı beyanları üretir.
- **PID sağlayıcısı** kişi kimlik verisini verir; **öznitelik belgesi sağlayıcıları** diğer belgeleri.
- **Güvenen taraf** (*Relying Party*), yani doğrulayıcı, cüzdandan belge ister. Bir güvenen taraf adına çalışan **aracı** (*intermediary*) da bu rolün bir türüdür.
- **Kayıt kurumu** (*Registrar*) güvenen tarafları ve onların hangi amaçla hangi verileri isteyebileceğini kaydeder.
- **Erişim sertifikası makamı** (*Access Certificate Authority*) güvenen taraflara, cüzdana kendilerini tanıtacakları sertifikaları verir; **kayıt sertifikası sağlayıcısı** ise kayıttaki kapsamı taşıyan imzalı belgeyi üretir.
- **Güven listesi sağlayıcısı** bu rollerin kimler tarafından üstlenildiğini imzalı listelerde yayımlar.

Bu rollerin hepsinin üstünde, ilk eIDAS tüzüğünden beri işleyen güven listesi mimarisi durur. Her üye devlet kendi **ulusal güven listesini** imzalayıp yayımlar; Komisyon da bu listelerin adreslerini ve imzacılarını gösteren bir **listelerin listesi** (*List of Trusted Lists*, LOTL) yayımlar. eIDAS 2.0 ile bu mimari cüzdan ekosisteminin yeni rollerine genişler: hangi kuruluşların cüzdan sağlayıcısı, PID sağlayıcısı ya da erişim sertifikası makamı olduğu da benzer listelerle bildirilir.

Bu düzenin bir sonucu, doğrulamanın **iki yönlü** olmasıdır. Doğrulayıcı belgeyi denetlerken cüzdan da doğrulayıcıyı denetler: isteği imzalayan kuruluş gerçekten kayıtlı mı, istediği alanlar kaydının kapsa-

mında mı? Bölüm 1.2'deki sahnede Aynur'un cüzdanının Timur'un şirketini denetlemesi bu ilkenin uygulamasıdır. Şekil 3 rolleri AB'nin terimleriyle gösterir.



Şekil 3. EUDI ekosisteminde roller (AB terimleriyle, sadeleştirilmiş)

3.4 Teknik standartlar haritası

ARF tek bir teknolojiye bağlanmak yerine, farklı standart kuruluşlarının yazdığı olgun standartlardan bir set seçer. Bu standartları AB yazmaz; IETF, ISO, OpenID Foundation, ETSI ve W3C gibi kuruluşlar yazar. AB'nin yaptığı, bu standartlar arasından seçim yapmak ve seçeneklerini daraltan **profiller** tanımlamaktır. Tamga bu seçimi ve profilleri olduğu gibi kullanır. Tablo 5 standartları katmanlarına göre sıralar; her birinin Tamga'da nasıl kullanıldığı ilgili bölümde anlatılır. Şekil 4 aynı standartları katmanlar hâlinde gösterir.

Tablo 5. Tamga'nın dayandığı başlıca standartlar.

Katman	Standart	Yazan	Ne işe yarar	Belgede
Belge biçimi	SD-JWT (RFC 9901) ve SD-JWT VC (IETF taslağı)	IETF	Alanları tek tek gizlenebilen, imzalı JSON belge	Bölüm 8
Belge biçimi	ISO/IEC 18013-5 mdoc	ISO/IEC	Mobil ehliyet için geliştirilmiş, ikili (CBOR) biçim; yakın alan	Bölüm 8.3, 10.8
Belge verme	OpenID4VCI 1.0	OpenID Foundation	Bir kurumun cüzdana belge vermesi	Bölüm 9
Gösterme	OpenID4VP 1.0 ve sorgu dili DCQL	OpenID Foundation	Bir doğrulayıcının cüzdandan belge istemesi	Bölüm 10
Profil	HAIP 1.0	OpenID Foundation	Yüksek güvence için OpenID4VC seçeneklerini daraltan profil	Bölüm 9, 10
Tarayıcı	Digital Credentials API; ISO/IEC 18013-7	W3C; ISO/IEC	Bir web sitesinin belgeyi tarayıcı üzerinden istemesi	Bölüm 10.6
İptal	Token Status List (IETF taslağı)	IETF	Belgenin iptal edilip edilmediğini verene sormadan öğrenmek	Bölüm 12
Güven	ETSI TS 119 612 ve TS 119 602	ETSI	Güven listeleri ve güvenilir kuruluş listeleri	Bölüm 6
Kurum kimliği	X.509 (RFC 5280); ETSI TS 119	IETF; ETSI	Kurum, doğrulayıcı ve kayıt sertifikalarının profilleri	Bölüm 7

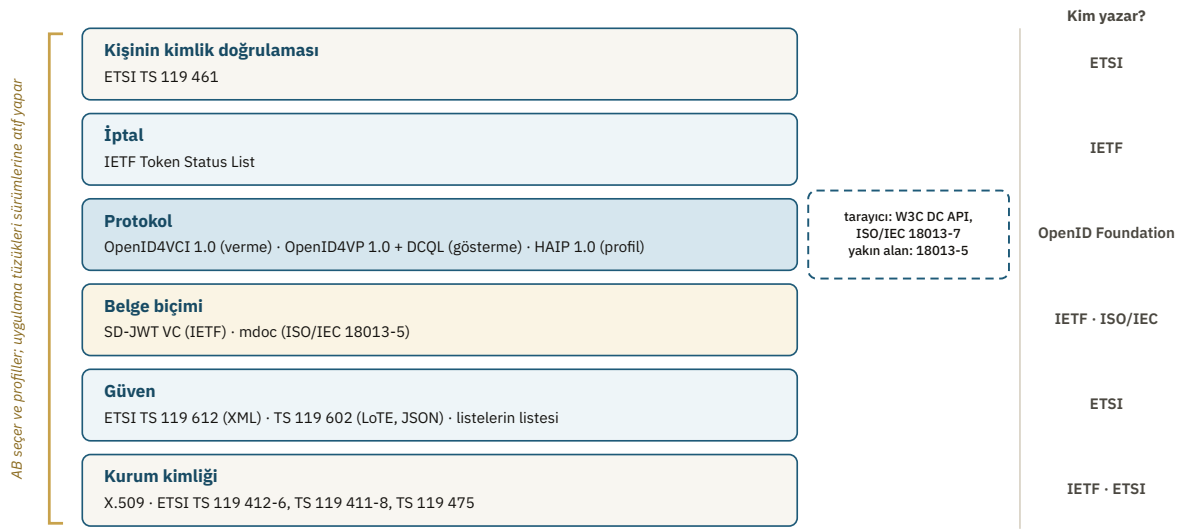
Katman	Standart	Yazan	Ne işe yarar	Belgede
	412-6, TS 119 411-8, TS 119 475			
Kimlik doğrulama	ETSI TS 119 461	ETSI	Uzaktan kimlik doğrulamanın politika ve güvenlik şartları	Bölüm 14

Tablodaki “taslak” ifadesi standardın olgunluk aşamasını gösterir. SD-JWT’nin kendisi 2025’te RFC 9901 [15] olarak yayımlandı; onun üzerine kurulan SD-JWT VC [16] ve Token Status List [17] ise IETF’te son aşamadadır. AB, uygulama tüzüklerinde ve bunların başvurduğu ETSI standartlarında bu taslakların belirli sürümlerine atıf yapar. Tamga, Token Status List’te AB’nin atıf yaptığı sürümü (draft-20) izler; SD-JWT VC’yi draft-19’a göre uygular. OpenID4VP 1.0 [31] Temmuz 2025’te, OpenID4VCI 1.0 [30] Eylül 2025’te, HAIP 1.0 [32] Aralık 2025’te son sürüm olarak yayımlandı.

TEKNİK AYRINTI

Bir standardın “profili” ne demektir?

Genel amaçlı bir standart, farklı kullanım durumlarına hizmet etmek için çoğu yerde seçenek bırakır: birden çok imza algoritması, birden çok istemci kimliği biçimi, birden çok anahtar bağlama yolu. Seçenek bolluğu esneklik sağlar ama birlikte çalışmayı zorlaştırır. A cüzdanı bir seçeneği, B doğrulayıcısı başka bir seçeneği uygularsa ikisi de standarda uyar, ama birbirini anlamaz. **Profil**, bu seçeneklerden bir alt küme seçip onu zorunlu kılan belgedir. HAIP 1.0, OpenID4VCI ve OpenID4VP’nin yüksek güvence gerektiren kullanımlar için profilidir. Tamga’nın bu profile uyumunu karara bağlayan kayıt (ADR-0034) iki örnek verir: doğrulayıcı imzalı istekte istemci kimliği olarak yalnızca kendi erişim sertifikasının özetini (`x509_hash`) kullanır ve cüzdan yalnız onu kabul eder; cüzdanın sağlayıcısından aldığı kanıttaki `sub` değeri de aynı cüzdan çözümünü kullanan bütün kurulumlarda ortaktır. İkinci kuralın gerekçesi HAIP’in açık hükmüdür, ama kural bir gizlilik sonucu da doğurur: kanıtın “kim” alanı tek bir telefona özgü bir değer taşımaz, yalnızca cüzdan çözümünün adını taşır.



Şekil 4. Standartların katmanları

3.5 AB dışından bakınca

AB dışında bir ülkede bu standartları kullanan biri için ilk soru, kendine ne ad verebileceğidir. “EUDI Wallet” ya da Avrupa Dijital Kimlik Cüzdanı, teknik bir tanım değil **hukuki bir unvandır**: bir AB üye devletinin sunduğu ya da tanıdığı ve AB kurallarına göre sertifikalanan cüzdanı anlatır. AB dışındaki bir kuruluşun cüzdanı bu unvanı alamaz, AB’nin cüzdan güven işaretini de kullanamaz (FW-ARF-0001

§1.4). Tamga'nın kamuya açık metinlerde kullandığı ifade bu yüzden "AB uyumlu"dur: aynı belge biçimlerini, aynı protokolleri ve aynı güven modelini kullanmak ve bunu testlerle göstermek.

İkinci soru, AB uyumlu bir belgenin AB'de geçerli olup olmayacağıdır. Bu sorunun cevabı tekniğin değil hukukun alanındadır ve ağın elinde değildir. Tamga'nın konumlanma kararına eklenen hukuki not bunu açıkça yazar (ADR-0035): tüzüğün kamu ve özel sektöre cüzdan kabul yükümlülüğü getiren 5f maddesi, AB dışındaki bir cüzdanı ya da listeyi tanıma yolu değildir. AB dışı için açık dayanak, güven hizmetleri bakımından Birlik ile o ülke arasında yapılacak bir anlaşmayı öngören 14. maddedir ve bu anlaşmanın tarafları devletlerdir. Ağın rolü teknik hazırlıktır: ETSI biçiminde listeler, ETSI profilli sertifikalar ve devredilebilir devlet rolleri. Kısa vadede bir AB doğrulayıcısı Tamga belgelerini ancak kendi isteğiyle, Tamga'nın güven listesini kendi güven kaynağına ekleyerek kabul edebilir; bu bir hukuki tanınma değildir ve öyle anlatılmaz. Tanıma meselesinin bütünü Bölüm 20'dedir.

4 Tasarım İlkeleri ve Konumlanma

Bir mimariyi anlamanın kısa yolu, onu kuranların neyi asla yapmayacaklarını söyledikleri yere bakmaktır. Tamga'nın ana çerçeve belgesi bu kuralları yedi ilkede toplar (FW-ARF-0001 §1.6). Bu bölüm önce bu ilkeleri, sonra ağın kendini nasıl konumladığını, neyi yapmadığını ve bugün kimin eliyle işletildiğini anlatır.

4.1 Yedi ilke

P1. Her devlet kendi ulusal kayıtlarının tek yazarıdır. Bir devletin hangi kurumu belge veren olarak kaydedeceğine başka hiçbir devlet oy vermez. Ağa üyelik, konsey kurulduğunda üye devletlerin üçte iki oyuyla olur; sınır ötesi tanıma ise her devletin tek taraflı kararıdır. Neden? Çünkü hiçbir devlet, kendi iç kurumsal kararlarının başkalarının oyuna bağlı olduğu ya da bir gün ağdan çıkarılırsa vatandaşlarının belgelerinin değersizleşeceği bir yapıya girmez (ADR-0002). Egemenlik güvencesi katılımın ön koşuludur.

P2. Hiçbir ortak kayıtta kişisel veri bulunmaz. Güven listesinde, çapa günlüğünde, olası bir ortak defterde ve kayıtlarda kişisel veri yoktur; belge içeriği de, belgenin özeti de yoktur. Neden özet bile? Çünkü bir özet, belgeyi bilen biri için belgenin kendisi kadar tanımlayıcıdır: elinde bir diploma olan kişi onun özetini hesaplayıp herkese açık kayıtta arayabilir. Ortak kayıtların izleme aracına dönüşmemesinin tek güvenilir yolu, onlara hiç kişisel bilgi koymamaktır.

P3. Teknik katman AB standartlarıyla aynıdır. Tamga'ya özgü her ek, standardın bir uzantı noktasıyla yapılır ve standart istemcileri bozmaz. Birlikte çalışmanın değeri, kimsenin özel bir uyarlama yazmak zorunda kalmamasından gelir. AB uyumlu bir cüzdan bir Tamga kurumundan belge alabilmeli, bir Tamga doğrulayıcısı da AB uyumlu bir cüzdandan gelen belgeyi işleyebilmelidir.

P4. Hiçbir tanımlayıcı, rol ya da yapı tek işletmeci varsayımı taşımaz. Ağın bugün geçici olarak üstlendiği her devlet rolü devredilebilir tasarlanır. Neden? Çünkü bir yapı tek işletmeciye göre kurulursa, devir günü her şeyin yeniden yazılması gerekir: kurum kimlikleri değişir, belgeler geçersizleşir, cüzdanlar güncellenir. Tamga'da devir yalnızca bir listenin işletmeci alanını ve imzacısını değiştirir; kurumların kimlikleri, belge türleri ve verilmiş belgeler aynı kalır (Bölüm 6.7, 18.4).

P5. Ortak defter bir depolama tercihi değil, imzacı tercihidir. Bugün güven imzalı listelerden gelir. En az iki bağımsız işletmeci olduğunda bir ortak defter kurulur. Neden? Çünkü tek bir işletmecinin çalıştırdığı dört düğümlü bir zincir, aynı işletmecinin imzaladığı bir listeden daha fazla güven üretmez (ADR-0009). Bir defteri değerli kılan, kayıtların birbirinden bağımsız tarafların ortak imzasıyla tutulmasıdır. Bu yüzden Tamga'da zincirin kodu yazılmış ve test edilmiştir, ama üretimde yoktur ve kapalıdır; ikinci bağımsız işletmeci olmadan açılmaz ve açıldığında da yalnızca imzalı listelerdeki kayıtların özetlerini ve parmak izlerini taşır (ADR-0051, ADR-0074; Bölüm 19).

P6. Her belge cihazın güvenli bölgesindeki bir anahtara bağlıdır. Belge kopyalanamaz ve devredilemez. Bağı olmayan bir belgeyi, onu ele geçiren herkes gösterebilir; bir diplomanın dosyasını alan biri, sahibiymiş gibi davranabilir. Cihaz bağı olmadan dijital belge, kâğıt kopyanın zaafını taşımaya devam eder (ADR-0006; Bölüm 8.2).

P7. Kodla sınırlanamayan her yetki politikayla, ölçülebilir devir eşiğiyle ve şeffaflık raporuyla sınırlanır. Barındırma, alan adı, kayıt tutma ve istatistik gibi yetkiler kodla engellenemez; ama kötüye kullanılabilir. Trust Framework bu ilkeyi "yumuşak güç de sınırlanır" diye adlandırır (FW-TF-0001 §1.2, G-B). Neden? Çünkü bir ağın tarafsızlığı, yazdığı kuralların yanında işletmecinin kural dışında kalan güçleriyle de sınanır. Örneğin barındırılan belge verenlerin oranı belirli bir eşiği aşarsa konu yönetişim gündemine gelir ve şeffaflık raporu üç ayda bir yayımlanır (Bölüm 18.5).

Trust Framework bu yedi ilkeye yönetişime özgü bir kural daha ekler ve onu "kayıt yetkilendirme değildir" diye adlandırır (FW-TF-0001 §1.2, G-A). Ağa kaydolmak bir kuruma belge verme yetkisi vermez; bir üniversitenin diploma verme yetkisi ağın dışından, kendi mevzuatından gelir. Ağ yalnızca ağın içindeki kapsamı, yani kurumun hangi belge türlerini hangi alanlarla verebileceğini tutar. Tablo 6 ilkeleri Bölüm 2.5'teki gereksinimlere ve onları ayrıntılandıran bölümlere bağlar.

Tablo 6. İlkeler, karşıladıkları gereksinimler ve ayrıntı bölümleri.

İlke	Özü	Gereksinim	Ayrıntı
P1	Her devlet kendi kaydının tek yazarı	G7	6.2, 18.1
P2	Ortak kayıtlarda kişisel veri yok	G4, G6	6, 12.4, 15.5, 19.3
P3	Teknik katman AB standartlarıyla aynı	G9, G10	3, 8–10, 20
P4	Tek işletmeci varsayımı yok, roller devredilebilir	G8	6.7, 7.2, 18.4
P5	Defter imzacı tercihi; en az iki bağımsız işletmeci	G8, G4	6.4, 19
P6	Her belge cihaz anahtarına bağlı	G5	8.2, 13
P7	Yumuşak güç politikayla ve eşikle sınırlı	G8	18.5

4.2 Üç katman

Tamga'nın konumlanma kararı (ADR-0035) yapıyı birbirinin üzerine oturan üç katmana ayırır ve her katmanın tek başına bir değer taşımasını şart koşar (Şekil 5).

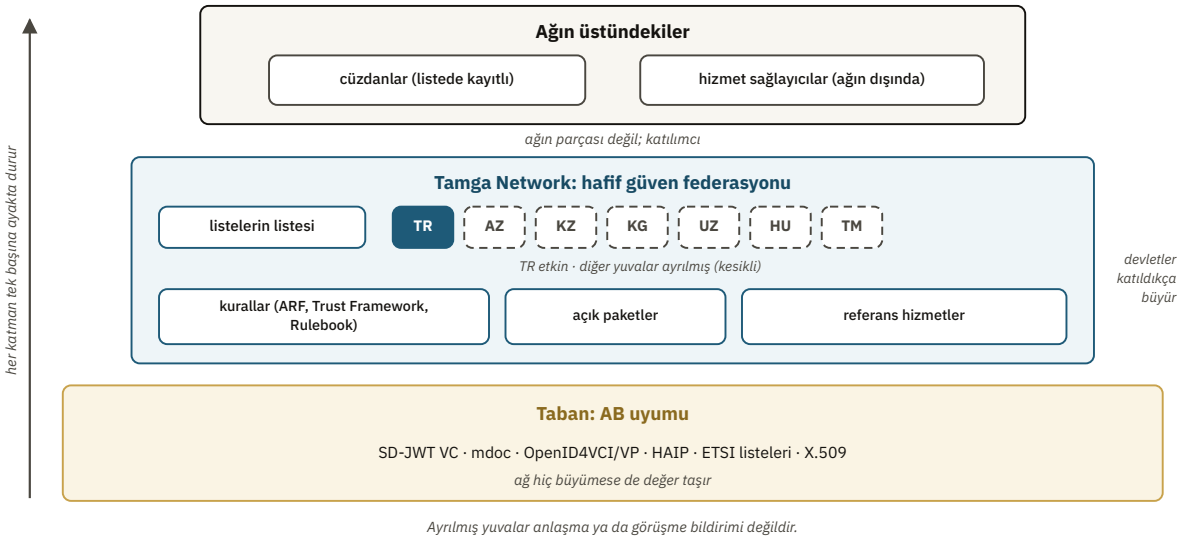
Taban: AB uyumu. Belgeler, protokoller ve güven listeleri AB standartlarındadır. Ağ hiç büyümese, tek bir devlet bile katılmasa, bu katman kurumlar ve cüzdanlar için yine bir değer taşır: bir kurum Tamga'nın açık paketleriyle AB uyumlu belge verebilir, bir doğrulayıcı AB uyumlu belgeleri doğrulayabilir.

Tamga Network: hafif bir güven federasyonu. Ağın asıl işi ülke güven listelerini bir araya getirmek ve birbirine tanıtmaktır. "Federasyon" burada, her listenin kendi sahibince işletildiği ve ortak bir listeler listesinde gösterildiği modeli anlatır. Ağ yayınlanmış kurallara uyan her cüzdan sağlayıcısını tanır; cüzdanları seçmez. Bugün Türkiye listesini ağ geçici olarak, devlet adına işletir. Bir devlet kendi listesini yayınladığında listelerin listesi o listenin adresini ve imzacısını gösterir. Ağır bir kurum ilk günden kurulmaz: bir ya da iki devlet katılmaya istekli olduğunda konsey ya da vakıf kurulur, listeler devredilir ve ortak defter gelir.

Ağın üstündekiler. Ağın kurallarına uyan cüzdanlar ve hizmet sağlayıcılar bu katmandadır. Bunlar ağın parçası sayılmaz; ağın katılımcıları ya da kullanıcılarıdır. Bu katman ilk kararda "ürün ve hizmetler" diye tanımlanmıştı; ağın kendisinin hizmet sunduğu bir yapı düşünülüyordu. Aynı karar kaydı bunun bir gerilim taşıdığını da not etmişti: AB modelinde listeyi yöneten tarafın hizmet satması çıkar çatışması sayılır. Bir sonraki karar bu gerilimi kaldırdı ve ağın yalnızca ağ olduğunu, ticari hizmetlerin

ağın dışındaki şirketlerce kendi adlarıyla sunulduğunu karara bağladı (ADR-0037). Ardından gelen karar cüzdanların da ağın dışında olduğunu netleştirdi (ADR-0042; Bölüm 5.4).

Neden üç katman? Karar kaydı üç yolu değerlendirir. Birincisi, yalnızca AB uyumlu bir cüzdan ve onun çevresindeki hizmetlerdi; bu yol hızlıdır, ama Türk dünyası için ortak bir güven zemini kurmaz ve devlet cüzdanları geldiğinde ayırt edici bir şey bırakmaz. İkincisi, önce AB benzeri ağır bir kurum kurmaktı; ama devletler katılmadan böyle bir kurumu kurmak hem erken hem dayanaksız olurdu. Üçüncü yol, katmanlı yapı, ilk ikisinin iyi yanlarını birleştirir: taban hemen değer üretir, federasyon katmanı devletler katıldıkça büyür ve devlet listeleri geldiğinde değer kaybolmaz, tersine federasyonun değeri artar.



Şekil 5. Tamga'nın üç katmanı

4.3 Ağ ne değildir

Bir yapıyı tarif etmenin bir yolu da onun ne olmadığını söylemektir. Tamga Network'ün kararları, ağın üstlenmeyeceği işleri açıkça sayar; bu sınırlar ağın tarafsızlığını ve devredilebilirliğini korur.

Ağ **ürün ya da hizmet satmaz**. Kuralları yazar, güven listelerini yayımlar, açık kodu ve ağın çalışması için gereken referans hizmetleri işletir; bunların hiçbiri satılmaz. Entegrasyon, destek ya da danışmanlık gibi ticari hizmetler ağın dışındaki şirketlerce kendi adlarıyla sunulur ve ağın referans hizmetleri ile kayıt süreci bütün katılımcılara aynı koşullarla açıktır (ADR-0037).

Ağ **cüzdan işletmez**. Hiçbir cüzdanın uygulamasını, cüzdan sağlayıcısını, sitesini ya da destek hizmetini işletmez; cüzdanları yalnızca güven listesindeki kayıtlarıyla tanır (ADR-0042).

Ağ **PID vermez**. Bu rol devlete ayrılmıştır. Ağın geçici kimlik servisi, PID olmayan, geçici bir kimlik belgesi verir (Bölüm 3.2, 14).

Ağ **ödeme işlemez ve token ihraç etmez**. Ağın erken tasarımında, olası bir defterin üzerine kurulabilecek bir değer katmanı için bazı yerler ayrılmıştı. Bu yerler bağlayıcı olmaktan çıkarıldı ve askıdaki bir araştırma yönü olarak kaldı; yeniden açılması yönetişim kurumunun kararını, bağımsız bir güvenlik incelemesini ve yeni bir karar kaydını gerektirir (ADR-0072). Ana çerçeve belgesi de ödeme ve değer aktarımını kapsam dışı sayar (FW-ARF-0001 §1.7).

Ağ **kişisel kayıt tutmaz**. Kişilerin belgeleri kurumların kendi sistemlerinden okunur, kişinin cüzdanında taşınır; ağın ortak kayıtlarında kişisel veri yoktur (P2). Bunun tek dar istisnası geçici kimlik servisidir: bu servis kimlik doğrulaması yaptığı kişiler için veri sorumlusudur ve sakladığı veriyi kısa ve tanımlı sürelerle sınırlar (Bölüm 14.7).

Ana çerçeve belgesinin kapsam dışı listesi ayrıca kurumların belge sahibi olduğu kurum cüzdanını, W3C VCDM [37] biçiminde ikinci bir belge temsilini ve nitelikli elektronik imzayı sayar. Bunlar kalıcı olarak dışlanmış değildir; her biri ancak ayrı bir kararla açılabilir.

4.4 Kâr amacı gütmeyen ağ, vakıf ve geçici işletmecilik

Tamga Network kâr amacı gütmeyen bir güven ağı olarak tasarlanmıştır ve kalıcı yeri bir vakıftır. Ama bir ağın, bir şirket gibi kendiliğinden bir tüzel kişiliği yoktur ve vakıf henüz kurulmamıştır. Öte yandan bazı işler bugünden bir tüzel kişi ister: bir sertifikanın konu alanına yazılacak kurum kimlik numarası, bir alan adının kaydı, kişisel veri mevzuatı karşısındaki veri sorumlusu kaydı, katılım sözleşmeleri.

Bu boşluk bir kararla doldurulmuştur (ADR-0070). Vakıf tüzel kişilik kazanana kadar ağın kendi hizmetlerini, yani liste yayınını, kayıt kurumu rolünün devlet adına yürütülmesini, kimlik servisini, Tamga Verify'ı, siteleri ve alan adlarını bir **geçici işletmeci** "Tamga Network adına" işletir. Tüzel kişilik gerektiren her işlem onun adıyla ve bu ibareyle yapılır; katılım sözleşmeleri vakfa geçişi öngören bir halefiyet maddesi taşır. Güven listelerinde ise liste işletmecisinin adı her zaman "Tamga Network"tür ve durumu "geçici" (`provisional`) olarak işaretlenir.

Kararın değerlendirdiği seçenekler, bu tasarımın neden seçildiğini gösterir. Listelerde işletmeci adı olarak doğrudan şirketin adını yazmak reddedildi; çünkü liste sahipliği ağa aittir ve devirde listenin kimliği değişirdi. Tüzel kişi gerektiren her işi vakfın kurulmasına kadar bekletmek de reddedildi; kimlik servisi, doğrulayıcı kaydı ve mağaza incelemesi bugünden tüzel kişi istiyordu. Bilgileri her kayıtta ayrı ayrı tutmak da dağınık ve denetlenemez olduğu için reddedildi. Seçilen yolda geçici işletmecinin bilgileri tek bir yapılandırma değerinden gelir ve liste yayıncısı her yayından önce bunu denetler; bilgiler tutarsızsa yayın durur. Vakfa devir yalnızca bu değeri ve ona bağlı kayıtlarla sertifikaları değiştirir; liste işletmecisinin adı, kök sertifikanın kimliği, belge türü kimlikleri ve kurumların kalıcı kimlikleri değişmez.

Geçici işletmecinin başka ürünleri olsa bile bunlar ağda ayrı birer katılımcıdır ve hiçbir ayrıcalık edinmez. Finansman konusunda ağın ilkesi de kısadır: ağ kâr amacı gütmez, geçici dönemde hiçbir katılımcıdan, yani belge veren kurumdan, doğrulayıcıdan, cüzdan sağlayıcısından ya da kişiden ücret almaz ve kişiler için her zaman ücretsizdir (ADR-0071; FW-TF-0001 §5.5). Finansmanın yönetişimle ilişkisi Bölüm 18.7'dedir.

5 Roller ve Bileşenler

Bölüm 3, AB'nin rol setini anlattı. Bu bölüm aynı seti Tamga'nın içinden gösterir: bugün her rolü kim üstleniyor, bir devlet katıldığında kim üstlenecek, hangi hizmet nerede çalışıyor ve bilgi hangi yönde akıyor.

5.1 Rol seti

Tamga'nın rol seti AB ARF'sinden [11] alınmıştır ve bir kuralla başlar: her ülke listesi bu rollerin her biri için bir yer ayırır; yer boş kalsa da vardır (FW-ARF-0001 §3). Bunun pratik anlamı şudur: bir devlet katıldığında yapıya yeni bir alan eklenmez, var olan bir yer dolar. Tablo 7 rolleri, bugünkü ve devlet katıldığındaki sahipleriyle birlikte verir.

Tablo 7. Roller: bugün ve devlet katıldığında.

Rol (AB adı)	Ne yapar	Bugün	Devlet katıldığında
Güven listesi işletmecisi (*Trusted List Scheme Operator*)	Ülke listesini derler, imzalar, yayımlar	Ağ, devlet adına geçici	Ulusal otorite ya da yetkilendirdiği kurum

Rol (AB adı)	Ne yapar	Bugün	Devlet katıldığında
Kayıt kurumu (*Registrar*)	Belge verenleri, doğrulayıcıları ve cüzdan sağlayıcılarını kaydeder; yasal yetki vermez	Ağ, devlet adına geçici	Devletin kayıt kurumu
Ulusal kök sertifika makamı	Kurum sertifikalarının kökü	Ağ, geçici; kök kimliği devirde değişmez	Devletin kökü ya da yetkili sertifika sağlayıcısı
Erişim ve kayıt sertifikası sağlayıcısı	Doğrulayıcılara erişim ve kayıt sertifikası verir	Ağ, geçici	Devlet
PID sağlayıcısı	Kişi kimlik verisini en yüksek güvencede verir	**Boş** ağ bu rolü üstlenmez	Devlet
Geçici kimlik belgesi sağlayıcısı	PID sağlayıcısı yokken uzaktan kimlik doğrulamasıyla kimlik belgesi verir	Ağın kimlik servisi	PID sağlayıcısı devralır
Belge veren (*Attestation Provider*)	Öznitelik belgesi verir ve gerektiğinde iptal eder	Kurumlar (üniversite, bilet satıcısı gibi)	Kurumlar ve kamu kurumları
Yetkili kaynak (*Authentic Source*)	Bilginin asıl kaydını tutar	Kurumun kendi kayıt sistemi	Aynı; ayrıca kamu kaynakları
Cüzdan sağlayıcısı (*Wallet Provider*)	Cüzdanı sunar; cüzdan ve anahtar kanıtlarını imzalar	Cüzdanı sunan kuruluşlar; ağ işletmez, listeler	Kurallara uyan her sağlayıcı
Doğrulayıcı (*Relying Party*)	Belge ister ve doğrular; kayıtlı ve kapsamı sınırlı	İşveren, web sitesi, kapı	Aynı
Aracı doğrulayıcı (*Intermediary*)	Bir doğrulayıcı adına belge ister ve doğrular	Tamga Verify	Aynı
Belge sahibi (*Holder*)	Belgeyi taşır, kime göstereceğine karar verir	Öğrenci, mezun, kullanıcı	Vatandaş
Defter işletmecisi	Ortak defterin bir düğümünü işletir	**Yok**	En az iki bağımsız kurum

Tablonun üç satırı ayrıca açıklanmayı hak eder. **PID sağlayıcısı** satırı boştur ve bu bilinçli bir boşluktur: ağ, devlete ait bu rolü doldurmaz, yalnızca yerini tutar. **Geçici kimlik belgesi sağlayıcısı** bu boşluğun yarattığı ihtiyacı geçici olarak karşılar; verdiği belge bir PID değildir ve devletin PID sağlayıcısı atandığında yerini ona bırakır (ADR-0011). **Aracı doğrulayıcı**, kendi doğrulama yazılımını çalıştırmak istemeyen bir doğrulayıcının adına işi yapan hizmettir; cüzdan kişiye asıl doğrulayıcının adını gösterir. Ağın barındırdığı Tamga Verify bu roldedir (Bölüm 11.5).

Bir kurum birden çok rol üstlenebilir. Örneğin bir bilet satıcısı hem bileti veren hem de kapıda doğrulayan taraftır; her rol için ayrı kaydolur ve o rolün kurallarına ayrı ayrı uyar (FW-ROLE-0001 §1). Tabloda görünmeyen bir rol de **denetçidir**. Bugün uyum öz beyan ve açık uyum testleriyle gösterilir; devletler katıldığında bağımsız uygunluk değerlendirme kuruluşları ve ulusal akreditasyon gelir (FW-ROLE-0001 §10; Bölüm 18.6).

TEKNİK AYRINTI

Listelerin listesinde bir ülke yuvası

Rollerin “boş da olsa yeri vardır” kuralı, listelerin listesindeki her ülke kaydında görülebilir. Aşağıdaki örnek, ağın liste yayıncısının kaynak dosyasından kısaltılmıştır; değerler örnek amaçlıdır ve yayımlanan listede biçim imzalı JWS olarak bulunur.

JSON Örnek: listelerin listesinde Türkiye yuvası ve ayrılmış bir yuva (kısaltılmış)

```
{
  "national_lists": [
    {
      "state_code": "TR",
      "status": "ACTIVE",
      "membership": "TDT_MEMBER",
      "list_url": "https://trust.tamga.network/tl-tr.jws",
      "operator": {
        "name": "Tamga Network",
        "status": "provisional",
        "on_behalf_of": "TR national authority (to be designated)"
      },
      "roles": {
        "registrar":        { "status": "PROVISIONAL", "operated_by": "Tamga Network" },
        "tlso":             { "status": "PROVISIONAL", "operated_by": "Tamga Network" },
        "access_ca":        { "status": "PROVISIONAL", "operated_by": "Tamga Network" },
        "national_root_ca": { "status": "ACTIVE", "operated_by": "Tamga Network (provisional)" },
        "pid_provider":     { "status": "RESERVED" }
      },
      "recognition": { "mode": "unilateral", "recognizes": ["TR"] }
    },
    { "state_code": "AZ", "status": "RESERVED", "membership": "TDT_MEMBER" },
    …
  ]
}
```

Üç ayrıntı dikkat çeker. İşletmeci bloğu (`operator`) ağın bu listeyi henüz atanmamış ulusal makam adına geçici olarak işlettiğini söyler; liste aşaması boyunca bu alan boş bırakılamaz (SPEC-TRUST-0001 §3, §8 TL1). PID sağlayıcısının yeri `RESERVED` olarak durur; ağ bu yeri doldurmaz (SPEC-TRUST-0001 §8, TL8). Tanıma kipi `unilateral`, yani tek taraflıdır: bir ülkenin hangi ülkelerin belgelerini tanıyacağı kendi kararıdır. Azerbaycan satırı ise yalnızca ayrılmış bir yuvadır; içinde liste adresi, imzacı ya da rol yoktur. Aynı biçimde ayrılmış yuvalar Kazakistan, Kırgızistan ve Özbekistan (Türk Devletleri Teşkilatı üyeleri) ile Macaristan ve Türkmenistan (gözlemciler) için de vardır. Bu yuvalar hiçbir devletle anlaşma ya da görüşme bildirimi değildir.

5.2 Rol ayrımı kuralları

Rollerin kimde olduğu kadar, hangi rolün neyi yapamayacağı da önemlidir. Tamga'nın çerçeve belgeleri üç ayrım kuralı koyar.

Birinci kural, **kurumun imza anahtarının kurumda kalmasıdır**. Ağ barındırdığı hiçbir hizmette bir kurumun imza anahtarını tutmaz; belge verme hizmeti ağın sunucusunda çalışsa bile belgenin imza anahtarı kuruma aittir (FW-ARF-0001 §3; FW-ROLE-0001 §1). Bu kural, barındırılan bir hizmetin kolaylığı ile kurumun egemenliği arasındaki gerilimi çözer. Karar kaydı bunun nasıl yapılacağını yazar (ADR-0057): kurumun anahtarı kendi donanım güvenlik modülünde ya da seçtiği güven hizmeti sağlayıcısında durur; barındırılan hizmet imzayı Cloud Signature Consortium'un [54] uzaktan imza arayüzüyle ister ve karşı tarafa yalnızca imzalanacak verinin SHA-256 özetini gönderir. Belge içeriği ve kişisel veri imza hizmetine gitmez. Dönen imza, kurumun güven listesindeki sertifikasıyla yerelde doğrulanır; doğrulanmazsa belge verilmez. Gerçek ağda kurum anahtarının hizmet sunucusunda bir dosyadan okunması yapılandırma düzeyinde reddedilir. Durum: uzaktan imzanın kodu ve testleri hazırdır, ama gerçek ağda bunu kullanan bir kurum henüz yoktur (**Planlanan** ayrıntı Bölüm 7.6).

İkinci kural, **kaydın yetkilendirme sayılmamasıdır**. Kayıt kurumu kaydeder, onaylamaz (FW-TF-0001 §1.2, G-A). Bir üniversitenin diploma verme yetkisini yükseköğretim mevzuatı, bir meslek kuruluşunun belge verme yetkisini kendi kanunu verir; ağ bu yetkiyi ne verir ne de denetler. Ağın tuttuğu, ağın içindeki kapsamdır: bu kurum hangi belge türlerini hangi alanlarla verebilir? Bu ayrım ağı hukuki bir otorite gibi davranmaktan korur ve her devletin kendi yetki düzenini olduğu gibi bırakır.

Üçüncü kurala göre **yetkili kaynak kurumdadır**. Bir belgedeki bilginin asıl kaydı, örneğin bir öğrencinin programı ya da mezuniyet tarihi, kurumun kendi kayıt sisteminde durur. Barındırılan belge verme hizmeti bu bilgiyi saklamaz; belge imzalanacağı anda kurumun sorgu ucundan okur, belge verilince

bellekten atar (ADR-0020). Karar iki yolu tanımlar. Birinci yolda kurum, kişinin kimliğine bağlı bir teklif oluşturur ve bağlantıyı kendisi gönderir; kişi cüzdanda kimliğini sunar, kimlik teklifle eşleşirse belge verilir. İkinci yolda kişi cüzdandan kurumu seçer ve kimliğini sunar; hizmet kurumun sorgu ucuna imzalı bir istekle sorar. İki yolda da ağ kişi kaydı tutmaz. Değerlendirilen alternatif, kişi kayıtlarını ağın kurum konsolunda tutmaktı; bu yol reddedildi ve konsoldaki kayıt defteri yalnızca sandbox'taki deneme kaynağı olarak kaldı. Akışın ayrıntısı Bölüm 9.2'dedir.

5.3 Bileşenler ve hizmet adresleri

Rollerin arkasında çalışan yazılım bileşenleri iki gruba ayrılır. Bir grup **açık kaynak kütüphanelerdir**: belge biçimlerini okuyan ve yazan, güven listelerini doğrulayan, belge veren ve doğrulayan paketler. Bunlar Apache-2.0 lisansıyla herkese açıktır ve bir kurum kendi belge verme ya da doğrulama yazılımını bu paketlerle kurabilir. Öteki grup **barındırılan referans hizmetlerdir**: ağın kendi işlettiği belge verme hizmeti, Kurum Konsolu, Tamga Verify, kimlik servisi, liste yayıncısı ve katalog. Kütüphaneler açıktır, barındırılan hizmetler işletmecidedir; ama kurallar ikisi için de aynıdır (FW-ARF-0001 §4.1). Bir kurum barındırılan hizmeti kullanmak zorunda değildir.

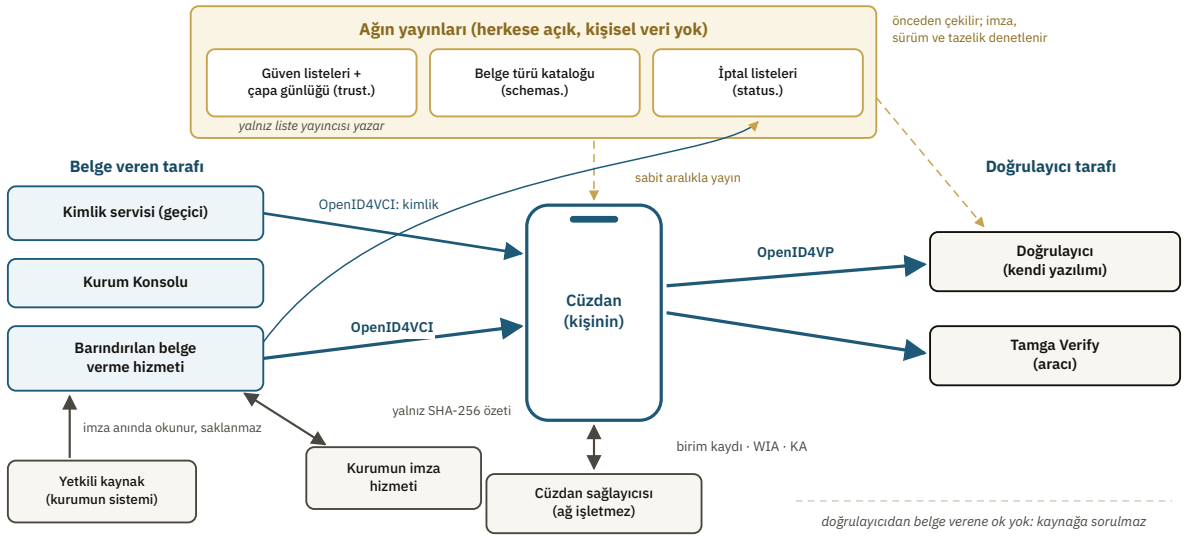
Tablo 8 hizmetleri adresleriyle birlikte verir. Bu baskının hazırlandığı tarihte tablodaki hizmetlerin hepsi canlıdır (**Çalışıyor**); `*.sandbox.tamga.network` altındaki test kopyaları da öyle.

Tablo 8. Bileşenler, görevleri ve hizmet adresleri.

Bileşen	Görev	Adres
Tanıtım sitesi	Ağın tanıtımı; kök anahtar parmak izleri	`tamga.network` (`/trust-anchor`)
Çerçeve belgeleri	Tamga ARF ve ekleri	`arf.tamga.network`
Geliştirici belgeleri	Rehberler, kavramlar, şartnameler, karar kayıtları	`docs.tamga.network`
Güven listesi yayıncısı	Listelerin listesi, ülke listeleri, çapa günlüğü, arşiv	`trust.tamga.network`
Belge türü kataloğu	Belge türlerinin tanımları ve şemaları, değişmez dosyalar	`schemas.tamga.network`
Barındırılan belge verme hizmeti	Kurumlar adına OpenID4VCI ile belge verme, iptal listesi yayını	`issuer.tamga.network/{kurum}`
İptal listeleri	Belge durum listeleri	`status.tamga.network`
Kurum Konsolu	Kurum personelinin belgeleri, kayıtları, anahtarları yönettiği ekran	`console.tamga.network`
Tamga Verify	Barındırılan aracı doğrulayıcı	`verify.tamga.network`
Kimlik servisi	Geçici kimlik belgesi; takma ad tohumu	`id.tamga.network`
Sandbox	Aynı hizmetlerin ayrı kökle çalışan test kopyaları	`*.sandbox.tamga.network`

Tablonun altına bir kural eklemek gerekir. **Alan adı bir hizmetin adresidir, kimlik değildir** (FW-ARF-0001 §4.2). Bir kurum barındırılan hizmetten kendi alan adındaki hizmete geçtiğinde, güven listesindeki kaydında yalnızca adres değişir; kurumun kimliği ve verdiği belgeler değişmez. Kurum kimliği kurumun sertifikasından türetilir (Bölüm 6.7). Bu kural iki şeyi birden korur. Kurumu barındırılan hizmete bağımlı olmaktan kurtarır (G10) ve ağın alan adlarının bir gün vakfa devrinin hiçbir belgeyi etkilememesini sağlar (G8).

Şekil 6 bileşenleri ve aralarındaki akışları gösterir. Okların üzerindeki protokol adları sonraki bölümlerde tek tek açılır.



Şekil 6. Bileşenler ve veri akışı

5.4 Ağ ve cüzdanlar

Bir güven ağının cüzdanlarla ilişkisi, dışarıdan bakan biri için çoğu zaman en kafa karıştırıcı konudur. Tamga'nın bu konudaki kararı tek cümleye sığar: ağ cüzdan işletmez, **cüzdanları listeler** (ADR-0042).

Ağın cüzdanlarla ilişkisi üç şeyden ibarettir. Birincisi, kurallardır: cüzdanın anahtarları nasıl tutacağı, onay ekranında neyi göstereceği, geçmişi nerede saklayacağı gibi kurallar şartnamede ve çerçeve belgelerinde yazılıdır (Bölüm 13). İkincisi, açık paketlerdir: bir cüzdan geliştiricisi belge almak, yerel denetim yapmak ve belge göstermek için ağın cüzdan çekirdeği paketini kullanabilir. Üçüncüsü, güven listesindeki **cüzdan sağlayıcısı kaydıdır**. Listelerin listesindeki `wallet_providers[]` alanı, tanınan her cüzdan sağlayıcısının kimliğini, imza sertifikalarını ve cüzdan çözümlerini taşır. Bir belge veren, belge vermeden önce cüzdanın sunduğu kanıtın bu listedeki bir sağlayıcıdan gelip gelmediğini denetler; listede olmayan bir sağlayıcının cüzdanına belge verilmez (Bölüm 9.3).

Neden ağ kendi cüzdanını işletmiyor? Karar kaydı bunu AB'nin rol ayrımıyla gerekçelendirir: AB yapısında her cüzdanı onu sunan kuruluş işletir ve güven çerçevesi cüzdan sağlayıcılarını yalnızca listeler. Ağ bir cüzdanın sağlayıcısını kendisi işletseydi tarafsızlığı bozulurdu; vakfa devir günü de bir cüzdanın hizmeti ağa bağlı kalırdı. Değerlendirilen öteki seçenek, cüzdanlar için ayrı bir test ortamı kurmaktı; bu da reddedildi, çünkü aynı kurumlar, doğrulayıcı ve kurallar iki kez kurulmuş olurdu. Sandbox tektir ve ağındır: cüzdan geliştiricisi kendi sağlayıcısını sandbox listesine kaydettirir ve cüzdanını oradaki örnek kurumlarla, kimlik servisiyle ve doğrulayıcıyla dener. Ağın alan adlarında da cüzdana ait hiçbir hizmet çalışmaz.

Ağın güven listesine giren ilk cüzdan Tamga Wallet'tır; ayrı bir ürün olarak kendi deposunda gelişir, sağlayıcı servisini kendi alan adında işletir ve listeye başka her cüzdanın gireceği yoldan, aynı kurallarla girmiştir. Sağlayıcı kaydı gerçek ağ ve sandbox listelerinde etkindir (**Çalışıyor** FW-ARF-0001 §2.8). Ağın arayüzleri ve belgeleri tek bir cüzdanı öne çıkarmaz; bu belge de bundan sonra cüzdanları genel adla anar.

Listelenmenin kişiye görünen bir karşılığı da vardır. AB'nin cüzdanlar için tanımladığı güven işareti AB dışında kullanılamadığı için ağ, listesindeki cüzdanlar için yazılı bir gösterge tanımlar: "Tamga Network'te listeli" (ADR-0049). Göstergenin logosu yoktur; AB yıldızları, AB renkleri ya da "güven işareti" sözü kullanılmaz. Kişi göstergeye dokunduğunda imzalı listedeki sağlayıcı kaydını görür; cüzdan birimi iptal edilirse ya da sağlayıcı listeden çıkarsa gösterge gizlenir (Bölüm 13.6).

5.5 Yön kuralları

Bileşenlerin birbirine nasıl bağlandığı kadar, bilginin hangi yönde aktığı da bir güvenlik ve gizlilik kararıdır. Ana çerçeve belgesi bunu dört kısa kuralla sabitler (FW-ARF-0001 §4.5).

1. **Güven listelerine yalnızca liste yayıncısı yazar.** Belge verme hizmetleri listeye yazamaz; yalnızca çapa günlüğüne bir kayıt eklenmesini isteyebilir. Bu kural, bir belge verme hizmeti ele geçirilse bile saldırganın kendini listeye yetkili bir kurum olarak ekleyememesini sağlar.
2. **Okuyanlar listeyi denetlemeden kullanmaz.** Doğrulayıcılar ve cüzdanlar hiçbir liste kaydını imzasını, sürüm zincirini ve tazeliğini denetlemeden kullanmaz. Açık paketler bu denetimleri hazır uygular; bütün istemciler güven sorularını tek bir arayüzden sorar (ADR-0015; Bölüm 6.6). Böylece bir listenin geri sarılmış eski bir sürümü ya da imzasız bir kopyası sessizce kabul edilemez.
3. **İptal listesi her doğrulamada indirilmez.** Doğrulayıcı iptal listelerini önceden ve toplu olarak çeker. Bu kural Bölüm 2.3'teki "eve telefon etme" sorununun mimaridaki cevabıdır: doğrulayıcı belgeyi denetlerken belge verene ya da onun sunucusuna o belge için bir istek göndermez, bu yüzden veren kurum hangi belgenin ne zaman doğrulandığını öğrenemez (Bölüm 12.4).
4. **Hiçbir Tamga hizmeti IP adresi kaydetmez.** Kayıtlarda belge alanlarının değerleri ve bir belgenin iptal listesindeki konumu da yer almaz. Bu kural P2'nin hizmet günlüklerine uygulanmasıdır: bir günlük, kişiyi tanımlamaya yetecek hiçbir iz taşımamalıdır.

Bu dört kural birlikte okunduğunda ağın bütün mimarisinin özetini verir. Güven tek bir yönden, imzalı yayınlardan gelir. Okuyan taraf her şeyi kendisi denetler. Doğrulama sırasında kaynağa sorulmaz. Ve ortak kayıtlar kişiyi tanımaz. Sonraki bölümler bu iskeletin her parçasını ayrıntılandırır: Bölüm 6 güven listelerini ve çapa günlüğünü, Bölüm 7 kurum sertifikalarını, Bölüm 8 belge biçimlerini anlatır.

6 Güven Modeli: İmzalı Güven Listeleri ve Çapa Günlüğü

Timur, İstanbul'da bir şirketin işe alım sorumlusu. Masasına bir başvuru geliyor; başvuran Aynur, diplomasını kâğıt olarak değil telefonundan göndermiş. Timur'un yazılımı belgeyi açıyor ve imzanın geçerli olduğunu söylüyor. Timur'un aklına ilk gelen soru ise imzayla ilgili değil: "Bu imzayı atan Örnek Üniversitesi gerçekten bir üniversite mi, diploma vermeye yetkili mi, bugün hâlâ faal mi?" Bu bölüm, Tamga Network'ün bu soruya nasıl cevap verdiğini anlatıyor. Cevabın merkezinde iki yapı var: herkesin indirip denetleyebildiği imzalı **güven listeleri** (*trust lists*) ve bu listelerin yanında tutulan, saat saat ilerleyen bir **çapa günlüğü** (*anchor log*). Bugün ağdaki bütün güven bu iki yapıya dayanır; ortak defter (zincir) kodu yazılmış ve test edilmiş olsa da üretimde yoktur ve kapalıdır, ikinci bağımsız bir işletmeci olmadan da açılmaz (Bölüm 19).

6.1 İmza neyi kanıtlar, liste neyi kanıtlar

Bir dijital imza tek bir şeyi kanıtlar: belge, belirli bir gizli anahtarın sahibi tarafından imzalanmış ve o andan beri değişmemiştir. İmzayı doğrulayan yazılımın elinde yalnız bir açık anahtar vardır; bu anahtarın "Örnek Üniversitesi"ne ait olduğunu imzanın kendisi söyleyemez. Saldırgan da imzayı kırmaya uğraşmaz; doğrulayıcıya kendi anahtarını doğru anahtarmış gibi kabul ettirmeye çalışır. Bu yüzden her güven altyapısının ikinci bir katmana ihtiyacı vardır: anahtarla kurum arasındaki bağı kuran ve o kurumun neye yetkili olduğunu söyleyen bir kayıt. Dizinin altıncı yazısı [71] bu sorunun tarihini ve AB'deki çözümünü ayrıntılı anlatıyor; burada Tamga'nın seçtiği yolu izliyoruz.

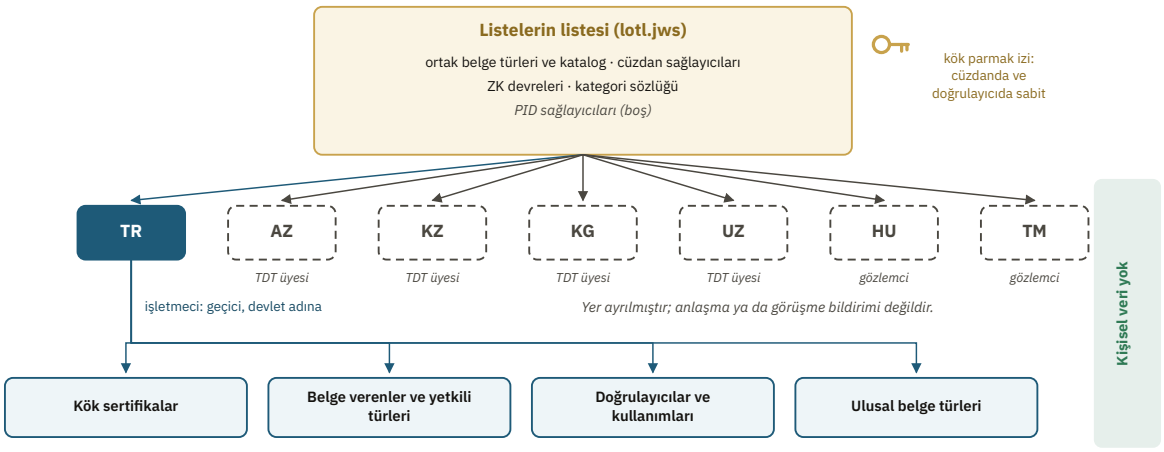
Tamga'da bu kayıt imzalı bir listedir. Liste "şu sertifikanın sahibi şu kurumdur, şu türleri şu tarihten beri vermeye yetkilidir, bugünkü durumu şudur" der. Doğrulayıcı kurumu aramaz; listeyi önceden indirmiştir. Düzen AB'nin güven listesi modeliyle aynıdır (FW-ARF-0001 §6.1); fark, Tamga'da bugün listeyi devlet adına geçici olarak ağın yayınlaması ve bunun listede açıkça yazmasıdır.

6.2 Listelerin listesi ve ülke listeleri

Güven iki katmanlı bir dosya düzeninde durur (Şekil 7). Yayınlanan dosyalar Tablo 9'de toplanmıştır. En üstte **listelerin listesi** (`lotl`, *List of Trusted Lists*) vardır. Bu dosya her ülke listesinin adresini, o listeyi imzalamaya yetkili anahtarları ve ülkenin tanınma ayarlarını gösterir. Ağ düzeyinde ortak olan kayıtlar da buradadır: ağın ortak belge türleri ve katalog adresi, tanınan cüzdan sağlayıcıları, kabul edilen sıfır bilgi ispatı devreleri ve kategori sözlüğü. Kişi kimlik verisi sağlayıcılarına (PID) ayrılan alan boştur; Tamga PID vermez (SPEC-TRUST-0001 §3, TL8).

Altta **ülke listeleri** (`tl-<cc>`) vardır. Bir ülke listesi o ülkenin kök sertifikalarını, belge verenlerini (sınıflarıyla, güvence seviyeleriyle ve hangi türleri vermeye yetkili olduklarıyla), kayıtlı doğrulayıcılarını ve ulusal belge türlerini taşır (SPEC-TRUST-0001 §4). Her ülke yuvası, AB mimarisindeki rollerin her biri için ayrı bir yer tutar: liste işletmecisi, kayıt kurumu, kişi kimlik verisi sağlayıcısı, erişim sertifikası sağlayıcısı ve ulusal kök sertifika makamı. Rol boş kalsa da yeri vardır.

Bugün yalnız Türkiye yuvası etkindir. Türk Devletleri Teşkilatı'nın üyeleri Azerbaycan, Kazakistan, Kırgızistan ve Özbekistan için ve gözlemciler Macaristan ile Türkmenistan için listelerin listesinde yer ayrılmıştır; bu, hiçbir devletle anlaşma ya da görüşme bildirimi değildir. Aynur'un Bakü'de aldığı lisans diploması bu yüzden bugün ağ üzerinden doğrulanamaz; Azerbaycan'ın yuvası, bir devlet katılıp kendi listesini yayınladığında dolar. Türkiye listesinin `operator` alanı, işletmecinin geçici olduğunu (`status: "provisional"`) ve kimin adına çalışıldığını (`on_behalf_of`) kayda geçirir; bu alan boş bırakılamaz (TL1). Her liste ayrıca `environment` alanında `production` ya da `sandbox` yazar; gerçek ağa bağlı bir cüzdan sandbox listesini yüklemez (ADR-0038).



Şekil 7. Listelerin listesi, ülke listeleri ve kayıtlar

Tablo 9. `trust.tamga.network` adresinde yayınlanan başlıca dosyalar (SPEC-TRUST-0001 §2).

Dosya	İçerik	Durum
`lotl.jws` (`lotl.json` okunabilir kopya)	listelerin listesi: ülke yuvaları ve imzacıları, ortak türler, cüzdan sağlayıcıları, ZK devreleri	çalışıyor
`tl-tr.jws` (`tl-tr.json`)	Türkiye: kök sertifika, belge verenler ve yetkileri, doğrulayıcılar ve kapı grupları	çalışıyor
`tl-<cc>.jws`	öteki ülke yuvaları; bugün boş, yalnız yer ayrılmış	ayrılmış
`anchors.jsonl`	çapa günlüğü: her satır ayrı imzalı, en az saatte bir satır	çalışıyor
`keys/root-fingerprints.json`	listelerin listesini imzalayan sertifikanın ve ulusal kökün parmak izleri	çalışıyor
`wrprc/`, `status/wrprc/`	kayıt sertifikaları ve onların 1 bitlik durum listesi (Bölüm 7.5)	çalışıyor

Dosya	İçerik	Durum
`zk/<devre>`	listede adı geçen ZK devre dosyaları	çalışıyor
`lote/<tür>.jws`	ETSI TS 119 602 görünümleri (Bölüm 6.8)	planlanan (üretici hazır, yayın ayarla açılır)
`tl-<cc>.xml`, `tl-<cc>.sha2`	ETSI TS 119 612 XML görünümü (Bölüm 6.8)	sandbox'ta çalışıyor, gerçek ağda planlanan
`archive/`	her eski liste sürümü ve günlük arşivi; hiçbir şey silinmez	çalışıyor
`CHANGELOG.md`	herkese açık değişiklik günlüğü	çalışıyor

TEKNİK AYRINTI

Bir belge veren kaydı nasıl görünür

Ülke listesindeki her belge veren kaydı bir dizi sabit alan taşır: kurumun kimliği ve sertifika parmak izi, sınıfı ve güvence seviyesi, hangi belge türlerine hangi tarih aralığında yetkili olduğu, iptal listelerinin adres kökü ve durum geçmişi. AB'nin ortak kayıt veri seti (resmî ad, kimlik numarası, adres, iletişim, veri koruma kurumu) de aynı kayıttadır (ADR-0024). Aşağıdaki örnek kurgusal Örnek Üniversitesi içindir ve kısaltılmıştır. `issuer_id` ile parmak izi, bu belge için üretilmiş örnek bir P-256 sertifikasından gerçekten hesaplandı; `schema_id` değerleri yazım günündeki katalogdan alındı ve yeniden hesaplanarak doğrulandı. Değerler örnektir.

JSON Örnek: tl-tr içinden kısaltılmış bir belge veren kaydı

```
{
  "issuer_id": "0xe41abbb087864814f3de55b27c9ce923537485bcc08e349c7c0b2209e8db1b60",
  "slug": "example-university",
  "legal_name": "Örnek Üniversitesi",
  "category": "EDUCATION",
  "assurance": "I2",
  "class": "EAA",
  "cert_fingerprint_sha256": "fb58ea8de393d34d2b73ce7672a08c3e2908028edbd5fce9a4c10fb4ad2577ce",
  "issuer_url": "https://issuer.sandbox.tamga.network/example-university",
  "status": "ACTIVE",
  "valid_from": "2026-09-01T00:00:00Z",
  "status_history": [
    { "status": "ACTIVE", "since": "2026-09-01T00:00:00Z", "reason": "initial-registration" }
  ],
  "schema_authorizations": [
    { "vct": "urn:tamga:edu:DiplomaCredential:1",
      "schema_id": "0x9d6d0e873ee0466cf1cdc8a8bd73f9435022635f0b6e46cd478e70f6e6aed26b",
      "allowed": true, "valid_from": "2026-09-01T00:00:00Z", "valid_until": null }
  ],
  "identifiers": [ { "scheme": "TR-VKN", "value": "…" } ],
  "delegate_keys": [ { "fingerprint_sha256": "…", "purpose": "status_list", "status": "ACTIVE" } ]
}
```

Yetki **zaman pencerelidir**: `schema_authorizations` her tür için bir başlangıç ve isteğe bağlı bir bitiş taşır. Doğrulayıcı, kurumun belgeyi verdiği anda (`iat`) bu türe yetkili olup olmadığına bakar. Kapanan bir üniversitenin daha önce verdiği diploma bu yüzden geçerli kalır; yeni belge verme ise kurumun durumu değiştiği anda durur (SPEC-TRUST-0001 §4; Bölüm 11.3).

6.3 Liste kuralları

İmzalı olmak yetmez; okur elindeki sürümün en güncel ve gerçek sürüm olduğundan emin olabilmelidir. Listeler bunun için birkaç sade kurala uyar (FW-ARF-0001 §6.3; SPEC-TRUST-0001 §1, §8). Her listenin bir **sürüm numarası** vardır ve bu numara yalnız artar. Her yeni sürüm, bir öncekinin imzalı dosyasının SHA-256 özetini `previous_version_hash` alanında taşır; sürümler böylece bir zincir gibi birbirine bağlanır. Liste kayıt **silmez**: bir kurum askıya alındığında ya da listeden çekildiğinde kaydı

yerinde kalır, yalnız durum değişikliği `status_history` geçmişine eklenir. Eski belgeler ancak böyle kendi verildikleri tarihe göre değerlendirilebilir.

Listelerin bir **tazelik takvimi** vardır. Her liste bir sonraki güncelleme tarihini (`next_update`) taşır ve bu tarih en fazla 90 gün sonrasıdır; değişiklik olmasa da liste bu süre içinde yeniden imzalanır. Bir değişiklik ise en geç 24 saat içinde yayınlanır. Tarihi geçmiş ya da erişilemeyen bir listeyle yapılan doğrulama "kabul" de "ret" de üretmez; sonuç "doğrulanamadı"dır (TL5); Timur için "bu diploma sahte" ile "şu an denetleyemiyorum" aynı şey değildir (Bölüm 11.4). Yükleyici tanımadığı bir biçim sürümünde de durur, sessizce yanlış yorumlamaz (TL6).

Liste ve çapa günlüğü imzası için kural **en az iki kaydırmalı sertifika** ister: anahtar değişimi en az 30 gün önceden duyurulur ve yeni anahtar eskisiyle imzalanarak tanıtılır (TL3). Yazım gününde yayındaki listelerde tek bir imza sertifikası etkindir; ikinci sertifikanın devreye alınması ve imza anahtarının donanım anahtar deposuna taşınması şartnamede açık iş olarak kayıtlıdır (SPEC-TRUST-0001, Açık Konular 3). *Durum: planlanan.* Her değişiklik ayrıca herkese açık bir değişiklik günlüğüne yazılır.

TEKNİK AYRINTI

Sürüm zinciri ve geri sarmanın yakalanması

Bir doğrulayıcı her listenin en son kabul ettiği sürümü ve o sürümün özetini hatırlar. Yeni gelen sürüm üç kurala göre değerlendirilir (paketlerdeki `TrustSource` yükleyicisi, TL2):

$$h_n = \mathrm{SHA\text{-}256}(\mathrm{liste}_n\ \text{.jws})$$

$$\mathrm{prev}(\mathrm{liste}_{n+1}) = h_n$$

$$v_{\text{gelen}} < v_{\text{bilinen}} \Rightarrow \text{ret (geri sarma)}$$

$$v_{\text{gelen}} = v_{\text{bilinen}} \ \text{ ve } \ h_{\text{gelen}} \neq h_{\text{bilinen}} \Rightarrow \text{ret (aynı sürüm, farklı içerik)}$$

Özet, listede `sha256:` önekli onaltılık bir dize olarak yazılır. Bir saldırgan doğrulayıcıya eski bir listeyi, örneğin bir kurumun henüz askıya alınmadığı sürümü sunarsa, sürüm numarası geride kaldığı için liste reddedilir. Sürüm numarasını değiştirmek imzayı bozar; imzayı yeniden atmak için de listelerin listesinin imza anahtarı gerekir.

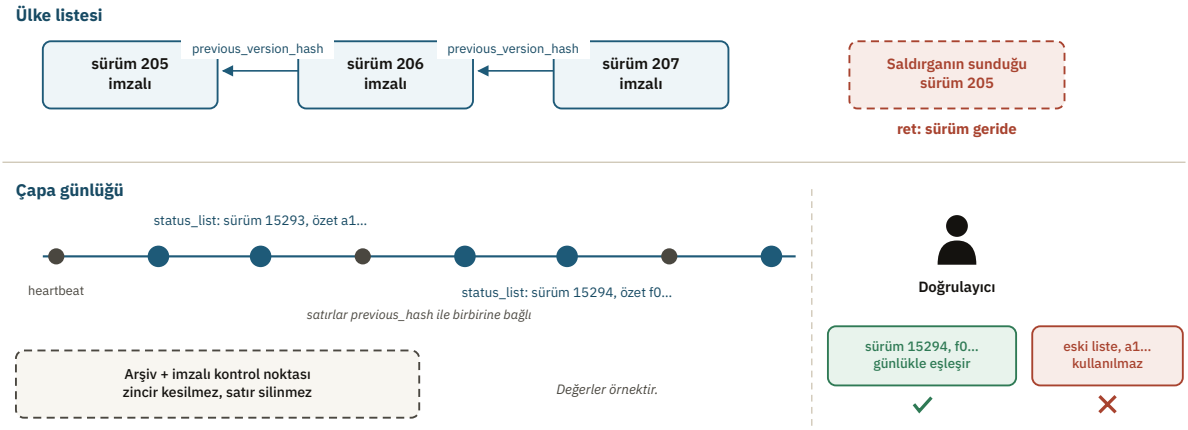
6.4 Çapa günlüğü

Ağda listelerden çok daha sık değişen iki şey vardır: kurumların iptal listeleri, birkaç dakikada bir yeniden yayınlanır (Bölüm 12.5), ve belge türü tanımları. Bunları ülke listesine yazmak listeyi şişirirdi; Tamga bu yüzden ikinci bir yapı tutar: **çapa günlüğü** (`anchors.jsonl`).

Günlüğün her satırı kendi başına imzalı bir JWS'tir. Satır bir sıra numarası (`seq`), bir önceki satırın SHA-256 özeti (`previous_hash`), bir zaman damgası ve bir tür taşır. Dört tür vardır (SPEC-TRUST-0001 §5): bir iptal listesi yayını (`status_list`: hangi kurumun hangi listesi, kaçıncı sürüm, içeriğin özeti), bir belge türü tanımının özeti (`schema`), saatlik yaşam işareti (`heartbeat`) ve arşivleme sırasında yazılan kontrol noktası (`checkpoint`). Günlüğe saatte en az bir satır düşer; değişiklik olmasa bile yaşam işareti yazılır. Satırlar silinmez, günlük herkese açıktır ve satırlarda kişisel veri ya da belge özeti bulunmaz (TL11). Günlüğün imza anahtarları da listelerin listesinde yayınlanır.

Günlüğün işe yaradığı yer, iptal listelerinin geri sarılmasıdır. Diyelim ki biri iptal edilmiş bir belgeyi kullanmak için doğrulayıcıya o iptalden önceki iptal listesini sunuyor. Liste kurumun imzasını taşıdığı için imza geçerlidir. Ama çapa günlüğü o listenin son sürümünün numarasını ve içerik özetini kaydetmiştir; doğrulayıcı aldığı listenin özetini günlükteki özetle karşılaştırır ve tutmayan listeyi kullanmaz (SPEC-TRUST-0001 §5; doğrulama hattında D adımı). Günlüğün kendisi de saatlik kadansla bayatlığa karşı korunur: son satırı fazla eski olan günlük, listeyi bayat sayar (Şekil 8).

Günlük büyüdükçe yükleme süresi uzar. Bu yüzden belirli bir eşikte satırlar bir arşive taşınır ve yeni günlük, arşivin son satırına ve arşiv dosyasının özetine bağlı, arşivin ürettiği son durumu taşıyan imzalı bir kontrol noktasıyla başlar. Zincir kesilmez, satır silinmez, tam geçmiş arşivlerden yeniden kurulabilir (TL12). *Durum: çalışıyor.*



Şekil 8. Hash zincirli liste sürümleri ve çapa günlüğü: geri sarılmış bir yayın nasıl yakalanır

TEKNİK AYRINTI

Çapa günlüğünden bir satır

Aşağıdaki satır, bir kurumun iptal listesi yayınının günlüğe nasıl yazıldığını gösterir. Biçim gerçek günlüktekiyle aynıdır; değerler örnektir ve kısaltılmıştır. Liste adresi (`list_uri`) opaktır: kurumu, yılı ya da öğrenci grubunu ele vermez (S8).

JSON Örnek: çapa günlüğünde bir iptal listesi yayını (JWS yükü, çözülmüş)

```json
{
  "seq": 51588,
  "previous_hash": "sha256:73f6842108c0…a694c408",
  "ts": "2026-11-03T23:10:06Z",
  "kind": "status_list",
  "list_id": "0x…4101234c731b7165",
  "issuer_id": "0xe41abbb0…e8db1b60",
  "list_uri": "https://status.sandbox.tamga.network/4101234c731b7165",
  "content_hash": "sha256:f037c5749daa…e9f4851d50",
  "list_version": 15294
}
```

6.5 Bant dışı güven çapası

Bütün bu zincirin bir başlangıç noktası olmalıdır. Cüzdan ve doğrulayıcı baştan yalnız **bir şeye** güvenir: listelerin listesini imzalayan sertifikanın parmak izine. Bu değer **güven çapası** (*trust anchor*) olarak adlandırılır. Geri kalan her şeyi, yani ülke listelerinin imzacılarını, kurumları, doğrulayıcıları ve cüzdan sağlayıcılarını, imzası bu çapaya bağlanan listeler söyler.

Çapa, listelerin kendisinden ayrı bir kanaldan, yani "bant dışında" yayınlanır. Aynı değer üç yerde aynı biçimde görünür: tanıtım sitesinin güven çapası sayfası (`tamga.network/trust-anchor`), güven listesi sitesindeki anahtar dosyası (`keys/root-fingerprints.json`) ve katılım sözleşmeleri (FW-ARF-0001 §6.1); üç yeri birden değiştirmek tek bir yeri değiştirmekten çok daha zordur. Listeli cüzdanlar bu parmak izini uygulamanın içine sabitler. Sandbox'ın ayrı bir kökü vardır ve gerçek ağdaki hiçbir cüzdan ya da doğrulayıcı ona güvenmez (ADR-0038).

6.6 Tek arayüz: TrustSource

Listeleri okumak imza, sürüm zinciri, tazelik, biçim sürümü ve çapa günlüğü kurallarının birlikte uygulanmasını gerektirir; bunları her istemcide ayrı yazmak birbirinden ayrışan gerçeklemeler üretir.

Tamga bu yüzden bütün güven sorularının tek bir arayüzden sorulmasını karara bağladı (ADR-0015): `TrustSource`. Belge verme hizmeti, doğrulayıcı, kimlik servisi ve cüzdan aynı soruları aynı arayüze sorar: "Bu kurum bu belgeyi verdiği tarihte kabul edilebilir miydi?", "Bu türe yetkili miydi?", "Bu doğrulayıcının kaydı ne?", "Bu anahtar listedeki bir cüzdan sağlayıcısına mı ait?", "Listeler ne kadar taze?" (SPEC-TRUST-0001 §6). Arayüzün dışında hiçbir bileşen liste dosyalarını yorumlamaz (TL4).

Arayüzün cevabı üç değerlidir: `YES`, `NO` ya da `UNKNOWN`. Bilinmeyen cevap doğrulamada "doğrulanamadı" sonucuna dönüşür; hiçbir zaman ret gibi gösterilmez. Arayüzün ikinci kazancı geleceğe dönüktür: bugün arkasında imzalı listeler vardır, ortak defter kurulursa aynı arayüzün arkasına defter girer ve cüzdan, doğrulayıcı ya da belge verme kodu değişmez (Bölüm 19.8).

Karar alınırken üç alternatif tartıldı: cüzdanın listeyi kendi kodunda ayrıca doğrulaması (iki gerçekleme zamanla ayrışırdı), cüzdana sunucu kütüphanelerini taşıyan uyarlamalar eklemek (kırılgandı) ve cüzdanın her güven sorusunu ağın bir sunucusuna sorması. Sonuncusu en kolayıydı ve reddedildi: o sunucu hangi cüzdanın hangi kurumu ne zaman sorduğunu öğrenirdi. Seçilen yolda doğrulama çekirdeği platformdan bağımsız bir alt pakettir ve listeler toplu çekilir; istemci ağa kişiye bağlanabilecek bir çağrı yapmaz (ADR-0015, TS3 [12]).

6.7 Tanımlayıcılar

Bir güven ağında adlar değişebilir, alan adları el değiştirebilir, işletmeciler devredilebilir. Kimliklerin bunlardan etkilenmemesi gerekir. Tamga'daki kalıcı tanımlayıcılar bu yüzden sertifikaların ve tür adlarının kendisinden türetilir; kurumun adı ya da ağın alan adı bu hesaba girmez (FW-ARF-0001 §5.3; SPEC-ID-0002 §2).

TEKNİK AYRINTI

Tanımlayıcıların türetilmesi

Kök sertifika ve kurum kimlikleri, ülke kodunun UTF-8 baytları ile sertifikanın DER kodlamasının SHA-256 özeti uç uca eklenip Keccak-256 ile özetlenerek elde edilir. Belge türü kimliği, tür adının (`vct`) kendisinin Keccak-256 özetidir:

$$\begin{aligned} \text{ca_id} &= \text{keccak256}(\text{utf8}(\text{cc}) \parallel \text{SHA-256}(\text{DER}(\text{kök sertifika}))) \\ \text{issuer_id} &= \text{keccak256}(\text{utf8}(\text{cc}) \parallel \text{SHA-256}(\text{DER}(\text{kurum sertifikası}))) \\ \text{schema_id} &= \text{keccak256}(\text{utf8}(\text{vct})) \end{aligned}$$

Burada $\parallel$ uç uca eklemek demektir. Örnek değerlerle: Bölüm 6.2'deki kayıtta kurum sertifikasının parmak izi `fb58ea8d…2577ce`, ülke kodu `TR` olduğunda `issuer_id = 0xe41abbb0…e8db1b60` çıkar. Diploma türünün adı `urn:tamga:edu:DiplomaCredential:1` için `schema_id = 0x9d6d0e87…e6aed26b` çıkar; bu değer katalogdaki kayıtla aynıdır.

Neden SHA-256 değil de Keccak-256? Kimlikler, ortak defter kurulduğunda kontratlardaki kayıtların anahtarı olacaktır ve EVM ortamında yerleşik özet işlevi Keccak-256'dır. Liste aşamasında türetilen kimlik, defter aşamasında hiç değişmeden aynı kaydın anahtarı olur (SPEC-TRUST-0001 §7; Bölüm 19).

Tablo 10. Tanımlayıcılar: nasıl oluşur, ne zaman değişir (FW-ARF-0001 §5.3).

Tanımlayıcı	Nasıl oluşur	Ne zaman değişir
Kök sertifika kimliği (`ca_id`)	ülke kodu + kök sertifikanın parmak izi	kök değişirse
Kurum kimliği (`issuer_id`)	ülke kodu + kurum sertifikasının parmak izi	sertifika yenilenince; yeni kayıt eskisine halef (`successor_id`) olarak bağlanır
Belge türü kimliği (`vct`, `schema_id`)	`urn:tamga:<alan>:<Tür>:<ana sürüm>` ve onun özeti	yalnız ana sürüm değişince

Tanımlayıcı	Nasıl oluşur	Ne zaman değişir
Doğrulayıcı istemci kimliği (`client_id`)	erişim sertifikasının özeti (`x509_hash`)	sertifika yenilenince
Doğrulayıcı kalıcı kaydı (`dns_name`)	kayıttaki alan adı	değişmez; kopyalar ve takma adlar buna bağlıdır
Kişi	küresel kimlik yok	belge başına cihaz anahtarı, doğrulayıcı başına kopya, site başına takma ad

Sertifika yenilenince kurum kimliğinin değişmesi, kimliğin taklit edilemez olmasının bedelidir; süreklilik halef bağıyla sağlanır ve eski sertifikayla verilmiş belgeler eski kayda göre doğrulanmaya devam eder (SPEC-ID-0002, XC2). Devirde yalnız listenin `operator` alanı değişir; kök, kurum ve tür kimlikleri sabit kalır (SPEC-TRUST-0001 §1). Alan adı bir hizmetin adresidir, kimlik değildir (FW-ARF-0001 §4.2).

6.8 ETSI görünümleri

AB'nin güven listesi ekosistemi yıllardır ETSI standartlarıyla çalışır. Tamga'nın yetkili kaynağı kendi JSON listeleridir; ama aynı içeriği AB araçlarının okuyabileceği biçimlerde de sunmak, ağın AB ile birlikte çalışabilmesinin teknik koşuludur. İki görünüm tanımlıdır.

ETSI TS 119 602 [42] (LoTE). AB, cüzdan rolleri için (cüzdan sağlayıcıları, belge verenler, erişim sertifikası sağlayıcıları) JSON tabanlı "Lists of Trusted Entities" biçimini kullanır. Liste yayıncısı Tamga listelerinden bu biçimde üç görünüm üretebilir; "üye devletçe bildirilmiş" anlamı taşıyan ETSI adresleri yerine Tamga'nın kendi adres kökünü kullanır ve nitelikli olmayan belge veren için ETSI'de karşılık olmadığından kendi tür adresini yazar (SPEC-ID-0002 §8.1.1). Yayın kaynakta bir ayarla açılır. *Durum: üretici hazır; yayın planlanan.*

ETSI TS 119 612 [41] (XML). AB'nin imza doğrulama araçları ve AB dışındaki ülkeler için açılan ara yol ulusal listeyi bu XML biçiminde, XAdES [53] imzasıyla ister. Tamga bu görünümü aynı imzalı ülke listesinden ve **aynı sürüm numarasıyla** üretir; XML'de JSON'da olmayan hiçbir kayıt bulunamaz ve ikisi çelişirse JSON geçerlidir (ADR-0066, TX1). XML'de AB anlamında "nitelikli" ya da "bildirilmiş" iddiası taşıyan hiçbir ETSI adresi kullanılmaz; liste türü, durum ve kural adresleri Tamga kökündendir ve her XML dosyası "910/2014 [1] kapsamında bildirilmiş liste değildir; listede nitelikli güven hizmeti yoktur" uyarısını taşır (TX2). XML'i ayrı bir imza sertifikası imzalar; bu sertifika ETSI'nin liste imzası profiline uyar ve JSON listelerini imzalayamaz. Doğrulayıcılar XML'e girmez, çünkü güven hizmeti sağlayıcısı değildir; kayıtları JSON listesinde ve kayıt sertifikalarındadır.

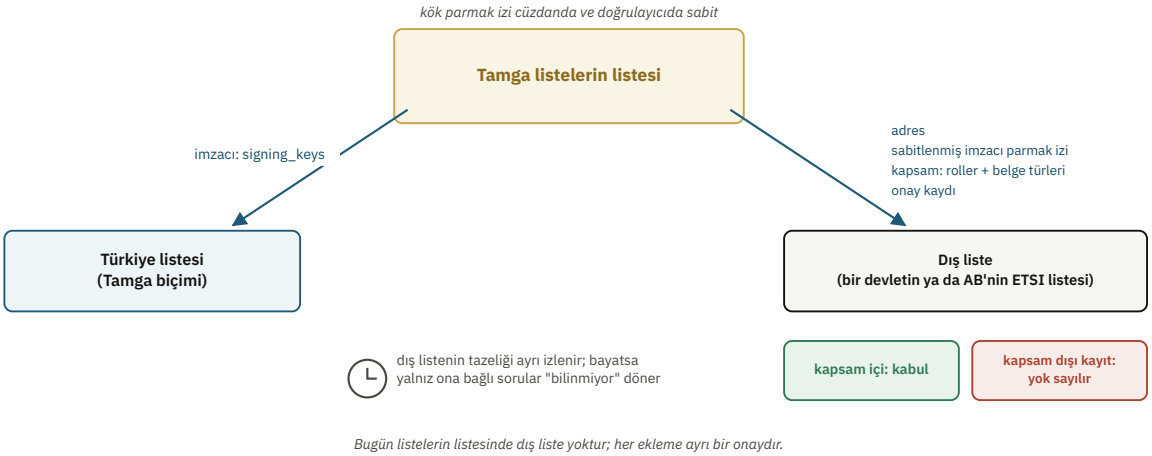
Reddedilen seçenekler şunlardı: yayını ertelemeyi sürdürmek (bir devlete araç sunma sözü boş kalırdı), XML'i ayrı bir kayıt defterinden üretmek (iki kaynak birbirinden kayardı) ve ETSI'nin "nitelikli" durum adreslerini kullanmak (Tamga'nın beyan edemeyeceği bir iddia). Tamga'nın XML listesi AB'nin üçüncü ülke listelerine girmez; o listeler devletlerin denetlediği imza ve mühür hizmetleri içindir. Kazanç, bir Türk devleti kendi listesini yayımlamak istediğinde denenmiş bir aracın ve şablonun hazır olmasıdır (ADR-0066). *Durum: sandbox'ta yayında (`trust.sandbox.tamga.network/tl-tr.xml`, "TEST" işaretli yer tutucu adreslerle); gerçek ağda listeyi işletecek vakıf, posta adresleri ve imzacısıyla birlikte planlanan.* Hukuki tanıma sorusu Bölüm 20'dedir.

6.9 Federasyon: başkasının listesi

Tamga'nın bir ülke listesinin sahibi olması gerekmez. Bir devlet, devletin yetkilendirdiği bir kurum ya da AB kendi listesini yayınladığında listelerin listesi o listeyi bir **işaretçi** olarak gösterebilir (ADR-0036; FW-TF-0001 §6.1). İşaretçi dört bilgi taşır: listenin özgün adresi, listeyi imzalayan sertifikaların Tamga'nın imzaladığı listelerin listesinde **sabitlenmiş** parmak izleri, listenin hangi rollere ve hangi belge türlerine kefil olabileceğini söyleyen **kapsam** ve listenin hangi kararla eklendiğini gösteren **onay** kaydı (Şekil 9).

Kurallar kısa ve katıdır. İmzacısı sabitlenen parmak iziyle eşleşmeyen dış liste yüklenmez (FD1). Dış liste kapsamının dışına çıkamaz: yalnız kimlik sağlayıcılarına kefil olan bir liste diploma veren bir kurum ekleyemez, ekleyse bile o kayıt yok sayılır (FD2). Her dış listenin tazeliği ayrı izlenir: biri eksik ya da bayat olsa bile Tamga listeleri etkilenmez, yalnız o listeye bağlı sorular "bilinmiyor" döner (FD3). Bir dış listenin eklenmesi, değişmesi ya da çıkarılması proje yönetiminin onayıyla olur ve kayıtta yazar (FD4). Ağın kendi türlerinde tür tanımının bütünlük özeti zorunludur; dış türlerde (AB kişi kimlik verisi ya da mobil sürücü belgesi gibi) türün güveni dış listenin imzalı kaydından gelir (FD5).

Seçilen yol AB'nin kendi modelidir. Dış kayıtları Tamga listesine kopyalamak onları Tamga'nın imzasıyla gösterir, sahipliği ve devri bulandırırdı; her doğrulayıcının dış listeleri kendisinin seçmesi ise tek güven çapasını ortadan kaldırırdı (ADR-0036). Paketler ETSI TS 119 602 ve 119 612 biçimindeki dış listeleri okur ve AB kişi kimlik verisi ile mobil sürücü belgesi türlerini tanır. Mekanizmanın hazır olması ile belirli bir listeye güvenilmesi ayrı kararlardır. *Durum: mekanizma çalışıyor; bugün listelerin listesinde dış liste yok.*



Şekil 9. Federasyon: başkasının listesi listelerin listesinde bir işaretçidir

7 Kurum Kimliği ve Sertifikalar

Elif, Örnek Üniversitesi'nin öğrenci işlerinde çalışıyor. Üniversite ağa katılırken Elif'in ekibine bir anahtar çifti üretmesi ve yalnız bir sertifika isteği göndermesi söyleniyor; gizli anahtar üniversitenin donanım güvenlik modülünden hiç çıkmayacak. Birkaç gün sonra üniversitenin Türkiye kök sertifikasına bağlı bir sertifikası oluyor ve sertifikanın parmak izi ülke listesine giriyor. Bu bölüm, bu sertifikanın neden X.509 [28] olduğunu, içinde ne yazdığını, doğrulayıcıların ve kayıt kurumunun hangi sertifikaları kullandığını ve barındırılan hizmetin kurumun anahtarına dokunmadan nasıl imza aldığını anlatıyor.

7.1 Neden X.509, neden DID değil

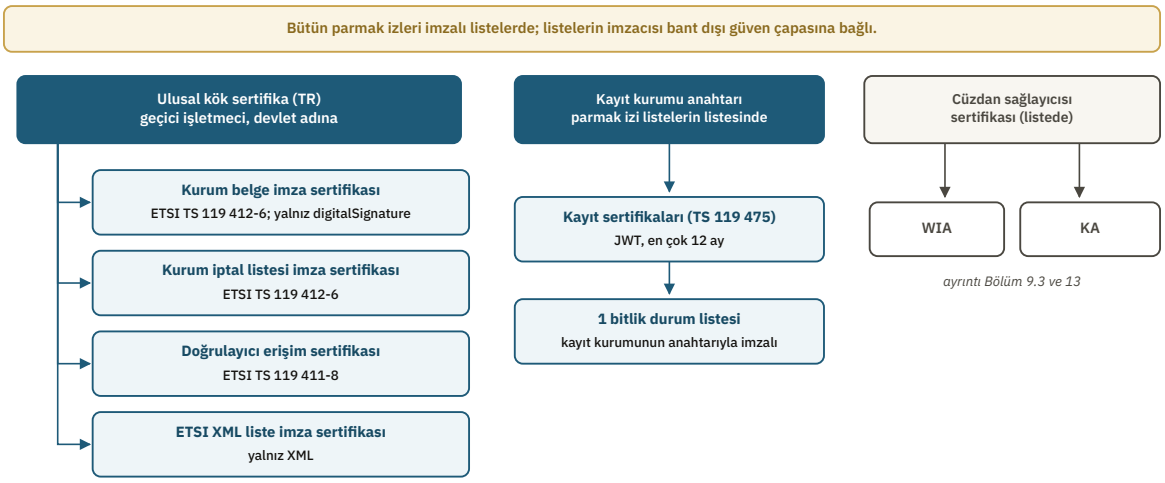
Kurum kimliği için iki aday vardı: ağa özgü bir merkeziyetsiz tanımlayıcı (`did:tamga`) profili ve kurumların zaten kullandığı X.509 sertifikaları. Proje yönetimi X.509'u seçti ve DID kurum profilini geçersiz kıldı (ADR-0004). Kurumlar elektronik mühür ve imza için zaten X.509 kullanır ve düzenleyici kayıtları vardır. "Kimlik nitelikli sertifikayla doğrulandı" cümlesinin mevzuatta bir karşılığı vardır; "DID ile doğrulandı" cümlesinin henüz yoktur. AB'nin nitelikli sertifika ve nitelikli imza oluşturma cihazı düzeni de X.509 üzerine kuruludur; aynı zemini kullanmak AB uyumunu kolaylaştırır.

Aynı karar kişiler için ters yönde bir ilke koyar: **kişiye küresel bir tanımlayıcı verilmez.** Sabit bir kimlik numarası kişinin eğitim, sağlık ve iş ilişkilerini tek bir ipe dizerdi. Kişi her ilişkide başka bir anahtarla, başka bir kopyayla ve gerekiyorsa başka bir takma adla görünür (Tablo 10 son satır; Bölüm 15). Kurumların kimliği ise tersine, herkesin denetleyebileceği kadar açık ve sabittir.

7.2 Ulusal kök ve geçici işletmecilik

Her devletin kendi ulusal kök sertifikası vardır ve kurum sertifikaları bu köke bağlanır. Bir doğrulayıcı belgedeki imzadan kurum sertifikasına, oradan köke ulaşır; kökün parmak izini ülke listesinde arar (SPEC-ID-0002 §1). Bugün Türkiye kökünü ağın geçici işletmecisi işletir ve bu durum listede rolün yanında açıkça yazar. Kökün adı devirde sabit kalır: devlet ya aynı kökün işletmesini devralır ya da kendi kökünü kaydırmalı olarak ekler ve eski kök emekliye ayrılır (FW-TF-0001 §7, adım 3).

Kök sertifika da sonsuz değildir. Süresi dolarken ya da anahtar güçlendirilecekken **kaydırma** (*rollover*) uygulanır: yeni kök kaydedilir, eski kökün durumu `ROLLING_OVER` olur ve bir örtüşme döneminde iki kök de kabul edilir; kurumlar sertifikalarını yeni köke taşır, dönem sonunda eski kök `RETIRED` olur. Emekli kök, kendi döneminde verilmiş belgelerin doğrulanmasında kabul edilmeye devam eder. Kök ele geçirilirse durum farklıdır: kök `REVOKED` olur ve ona bağlı bütün sertifikalar geçersizleşir (SPEC-ID-0002 §4). Örtüşme süresinin uzunluğu (öneri 12 ay) ve devletlerin ara sertifika makamı kullanıp kullanmayacağı şartnamede açık soru olarak kayıtlıdır (Şekil 10).



Şekil 10. Sertifika ağacı: kim kimi imzalar

7.3 Belge veren sertifika profili

Bir sertifikanın içinde ne yazdığı, onu okuyan araçların kurumu tanıyıp tanıyamayacağını belirler. AB'nin kimlik belgesi, cüzdan ve öznitelik belgesi sağlayıcıları için yazdığı sertifika profili ETSI TS 119 412-6'dır [43]; konu tüzel kişi olduğunda EN 319 412-3 [44] uygulanır. Tamga'da belge veren kurumların, kimlik servisi dahil, belge imza ve iptal listesi imza sertifikaları bu profile göre yazılır (ADR-0050).

Profilin en önemli alanı konu bölümündeki **kurum kimlik numarası**dır (`organizationIdentifier`). Bu alan, kurumun vergi ya da sicil numarasından türetilen ve kayıt sertifikasındaki numarayla aynı olan bir semantik tanımlayıcı taşır; Türkiye'de vergi kimlik numarası için `VATTR-…`, ticaret sicili için `NTRTR-…` biçimi kullanılır. Bu eşleşme sayesinde AB tarafındaki bir doğrulayıcı, belgeyi imzalayan kurumu kayıt verisiyle bağlayabilir. Anahtar kullanımı zorunlu (*critical*) işaretli bir uzantıdır ve **tek türlüdür**: yalnız `digitalSignature`. Aynı sertifika mdoc belge imzasında da kullanıldığı için ISO 18013-5'in [34] istediği tür budur. Konu ve makam anahtar tanımlayıcıları (SKI, AKI) zorunludur; doğrulayıcı isteklerindeki güven otoritesi eşleşmesi bu tanımlayıcıya dayanır. Algoritma P-256 ile ECDSA SHA-256'dır ve sertifika en çok 3 yıl geçerlidir.

Değerlendirilen seçeneklerden biri kurum numarasını yalnız güven listesinde tutmaktı; reddedildi, çünkü liste dışındaki AB araçları sertifikanın kendisine bakar. Anahtar kullanımına içerik bağlılığı (`nonRepudiation`) eklemek de mdoc profiliyle çatıştığı için reddedildi. Nitelikli ya da kamu sınıfı belge verenler için gereken ek alanlar (yetki erişim bilgisi, nitelikli sertifika beyanları) o sınıf açıldığında

ayrı kararla gelecektir; bugün ağdaki bütün belge verenler nitelikli olmayan öznitelik belgesi verir (ADR-0022, ADR-0050).

7.4 Doğrulayıcı erişim sertifikası

Bir doğrulayıcı cüzdandan belge isterken isteğini kendi **erişim sertifikasıyla** imzalar. Bu sertifikanın profili ETSI TS 119 411-8'dir ve AB'nin güvenen taraf kaydına ilişkin uygulama tüzüğü buna atıf yapar (ADR-0058). Sertifikanın konu alanında kurum kimlik numarası, resmî ad ve ülke bulunur. Ortak ad (`CN`) alanı kişinin tanıyacağı ticari ad ya da hizmet adıdır; Aynur'un onay ekranında Timur'un şirketi tanıdık adıyla görünür. Sertifikanın alternatif ad bölümü iki şey taşır: kayıttaki alan adı ve en az bir **iletişim bilgisi**, Tamga'da kayıttaki destek adresi. Destek adresi olmayan bir doğrulayıcıya gerçek ağda erişim sertifikası verilmez (AC1). Aynı kurum farklı hizmetler için ayrı sertifika isterse her sertifika hizmet kimliğini ayrı bir alanda taşır (AC2).

İki ayrıntı ağın dürüstlük çizgisini gösterir. ETSI'nin AB güven hizmeti sağlayıcılarına ait politika tanımlayıcısı erişim sertifikasına yazılmaz; çünkü o tanımlayıcı, sertifikanın denetlenmiş bir AB güven hizmeti sağlayıcısınca verildiği beyanıdır ve Tamga bunu beyan edemez (AC3). Ağın kendi politika tanımlayıcısı ve sertifika uygulama beyanı vakıf kuruluşuyla eklenecektir. *Durum: planlanan.* İkinci ayrıntı tanımlayıcılarla ilgilidir: sertifika yenilenince doğrulayıcının istemci kimliği (`x509_hash`) değişir, kalıcı kaydı olan alan adı değişmez. Ekim 2026'da gerçek ve sandbox doğrulayıcılarının sertifikaları aynı anahtarla yeniden verildiğinde sitelerdeki takma adlar bu yüzden etkilenmedi; takma ad alan adından türetilir (ADR-0058; Bölüm 15.3).

7.5 Kayıt sertifikası

Erişim sertifikası "bu istek şu kurumdan geliyor" der; cüzdanın asıl sorusu ise bu kurumun **ne isteyebileceğidir**. AB bunun için ikinci bir belge öngörür: kayıt sertifikası (*registration certificate*), ETSI TS 119 475 [46]. Tamga, Türkiye adına geçici kayıt kurumu olarak her doğrulayıcı kullanımı ve her belge veren için bir kayıt sertifikası üretir (ADR-0026). Sertifikanın içeriği yalnız imzalı güven listesindeki kayıttan gelir: doğrulayıcının amacı, hangi belge türünden hangi alanları isteyebileceği, gizlilik politikası, kurum kimlik numarası. Sertifika JWT biçimindedir (`rc-wrp+jwt`), liste imza anahtarından ayrı bir **kayıt kurumu anahtarıyla** imzalanır ve en çok 12 ay geçerlidir. Anahtarın parmak izi listelerin listesinde yayınlanır.

Doğrulayıcı kayıt sertifikasını isteğine ekler; cüzdan imzayı, süreyi, sertifikadaki kurum numarasının isteği imzalayan erişim sertifikasındaki numarayla aynı olduğunu ve istenen alanların sertifikanın izin verdiği alanların içinde kaldığını denetler. Kayıt sertifikası taşımayan istek bugün reddedilir (ADR-0056; FW-ARF-0001 §2.2); fazla alan isteyen istekte cüzdan kişiyi uyarır (Bölüm 10.3). Kayıt sertifikaları ayrıca Tamga'nın kendi politika tanımlayıcısını, politika belgesinin adresini ve bir durum girdisi taşır; kayıt kurumu 1 bitlik bir durum listesi tutar ve kayıt ya da içerik değişince eski sertifika kendiliğinden iptal olur. Cüzdan iptal edilmiş sertifikalı isteği reddeder, durumu denetleyemezse uyarır (ADR-0068; FW-POL-0003). Tablo 11 bu bölümde anlatılan sertifika türlerini bir arada verir. *Durum: kayıt sertifikaları, politika alanları ve durum listesi gerçek ağda ve sandbox'ta çalışıyor.*

Tablo 11. Sertifika türleri: kim verir, ne taşır, nerede denetlenir.

Tür	Kim verir	Ne taşır	Profil	Nerede denetlenir
Kurum belge imza ve iptal listesi imza sertifikası	ulusal kök (bugün geçici işletmeci)	kurum kimlik numarası, resmî ad, ülke; yalnız `digitalSignature`	ETSI TS 119 412-6, EN 319 412-3	doğrulayıcıda (yapı ve güven adımları), cüzdanda
Doğrulayıcı erişim sertifikası	ulusal kök	kurum kimlik numarası, ticari ad, alan adı, destek adresi	ETSI TS 119 411-8	cüzdanda, imzalı istek alınınca

Tür	Kim verir	Ne taşır	Profil	Nerede denetlenir
Kayıt sertifikası	kayıt kurumu (bugün geçici)	kullanım amacı, istenebilecek alanlar, politika, durum girdisi	ETSI TS 119 475	cüzdanda, istenen alanlarla karşılaştırma
Liste imza sertifikaları (JSON ve ayrı XML imzacısı)	geçici işletmeci	listelerin imzası	Tamga JWS; XML için ETSI TS 119 612 §5.7.1	listeyi yükleyen her istemcide
Cüzdan sağlayıcısı sertifikası	cüzdan sağlayıcısı, listede kayıtlı	WIA ve anahtar kanıtı imzası	ETSI TS 119 412-6 (cüzdan türü)	belge verende (Bölüm 9.3)

7.6 Kurumun anahtarı kurumda: uzaktan imza

Ağın barındırdığı hiçbir hizmet kurumların imza anahtarını tutmaz (FW-ARF-0001 §3); ama barındırılan hizmetle verilen belgeler de kurumun anahtarıyla imzalanmalıdır. İkisini bir arada tutan yol uzaktan imzadır (ADR-0057). Kurumun belge ve iptal listesi imza anahtarları kurumun kendi donanım güvenlik modülünde ya da kurumun sözleşme yaptığı bir güven hizmeti sağlayıcısında üretilir ve orada kalır. Barındırılan hizmet imzayı, AB'de uzaktan imza ve mühür için yerleşik arayüz olan Cloud Signature Consortium [54] API'nin 2. sürümüyle ister.

Hizmete giden tek şey, imzalanacak verinin SHA-256 özetidir. Belge içeriği, kişisel veri ya da kişinin anahtarı imza hizmetine gitmez; imza hizmeti hangi kişiye belge verildiğini öğrenmez (RS2). Dönen imza, kurumun güven listesindeki sertifikasıyla yerelde doğrulanır; doğrulanmayan imzayla belge verilmez (RS3). Gerçek ağda kurum anahtarının hizmet sunucusunda dosyadan okunması yapılandırma düzeyinde reddedilir; dosya anahtarı yalnız yerel geliştirme, testler ve sandbox içindir (RS4). Kurum imza yetkisini istediği an geri alabilir; imza hizmetindeki istemci kimliğini kapatması, barındırılan hizmetin o kurum adına belge vermesini hemen durdurur.

TEKNİK AYRINTI

Uzaktan imzanın adımları

Barındırılan hizmet bir belgeyi imzalayacağı her seferinde üç çağrı ve iki yerel adım uygular (CSC API v2; ADR-0057 K1–K3). Algoritma tanımlayıcıları SHA-256 için `2.16.840.1.101.3.4.2.1`, imza için `ecdsa-with-SHA256` (`1.2.840.10045.4.3.2`) olur.

1	**Belge verme hizmeti → İmza hizmeti**	**Erişim.** Kurumun tanımladığı istemci kimliğiyle kısa ömürlü bir erişim belirteci alır (`client_credentials`).	$\text{belirteç} \leftarrow$ imza hizmeti
2	**Belge verme hizmeti**	**Özet.** İmzalanacak verinin (JWS imza girdisi ya da COSE yapısı) yalnız özetini hesaplar.	$h = \text{SHA-256}(\text{imza girdisi})$
3	**Belge verme hizmeti → İmza hizmeti**	**Yetki.** Tek bir imza için, bu özete bağlı bir imza yetkisi ister (`credentials/authorize`).	$\text{SAD} \leftarrow \text{yetki}(h)$
4	**Belge verme hizmeti → İmza hizmeti**	**İmza.** Özeti imzalatır (`signatures/signHash`).	$\sigma \leftarrow \text{imzala}_{\text{kurum}}(h)$
5	**Belge verme hizmeti**	**Denetim.** İmzayı listedeki kurum sertifikasının açık anahtarıyla yerelde doğrular; tutmazsa belgeyi vermez.	$\text{doğrula}(\sigma, h, \text{pk}_{\text{liste}}) \stackrel{?}{=} \text{evet}$

> İmza hizmetine ulaşılamazsa belge verilmez ve kişi sonra yeniden dener; tıpkı kurumun yetkili kaynağına ulaşılamadığı durumda olduğu gibi (Bölüm 9.2).

Reddedilen seçenekler: anahtarı sunucuda dosya olarak tutmak (ağın kuralına aykırı), tek bir bulut sağlayıcısının anahtar hizmetine bağlanmak (kurumu bir sağlayıcıya bağlar) ve ağa özgü yeni bir imza arayüzü (standart zaten var). Kurumun belge verme yazılımını açık paketlerle kendi sunucusunda çalıştırması ikinci yol olarak açık kalır (ADR-0016, ADR-0057). *Durum: barındırılan hizmette kod ve testler hazır; gerçek ağda bu yolu kullanan kurum henüz yok, planlanan.*

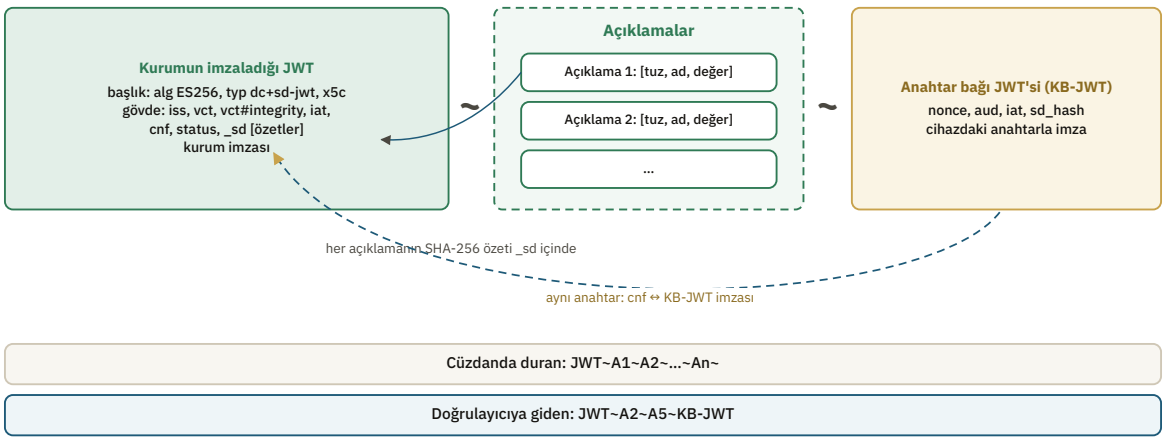
8 Belgeler: Biçimler, Türler ve Katalog

Aynur, Örnek Üniversitesi'nde yüksek lisansını bitirdi ve diplomasını cüzdanına aldı. Telefonunda gördüğü şey bir kart: üniversitenin adı, derece, mezuniyet tarihi. Kartın arkasında ise birbirine sıkı sıkıya bağlı birkaç yapı var: kurumun imzaladığı bir çekirdek, her biri ayrı açılabilen alanlar, telefondaki bir anahtara bağ ve belgenin türünü tanımlayan bir katalog kaydı. Bu bölüm bu yapıları tek tek açıyor. Seçici açıklamanın kendisi dizinin üçüncü yazısının [68] konusu; burada Tamga profilinin onu nasıl daralttığına ve neden öyle daralttığına odaklanıyoruz.

8.1 SD-JWT VC'nin anatomisi

Tamga belgelerinin ana biçimi SD-JWT VC'dir [16] (IETF RFC 9901 [15] üzerine kurulu SD-JWT tabanlı belge biçimi; ADR-0006). Biçim, AB mimarisinin ana biçimidir, JSON tabanlıdır ve seçici açıklamayı yapısının içinde taşır. Bir SD-JWT VC, tilde (`~`) ile ayrılmış üç parçadan oluşur (Şekil 11): kurumun imzaladığı bir JWT, her biri tek bir alanı taşıyan **açıklamalar** (*disclosures*) ve gösterim anında cüzdanın eklediği **anahtar bağı JWT'si** (*KB-JWT*). Kurum belgeyi verirken dize son tilde ile biter, çünkü anahtar bağı henüz yoktur. Aynur belgeyi gösterirken göstermek istemediği açıklamaları dizeden **çıkarır** ve sona anahtar bağını ekler. JWT değişmez, kurumun imzası geçerli kalır. Gizlemek bir şey eklemek değil, çıkarmaktır (SPEC-CRED-0002 §2).

Kurumun imzaladığı JWT, açıklanabilir alanların kendisini değil, yalnız **tuzlanmış özetlerini** (`_sd` dizisi) taşır. Her alan için rastgele bir tuz (*salt*) üretilir; tuz, alan adı ve değer bir JSON dizisi olarak yazılır, Base64URL ile kodlanır ve bu dizenin SHA-256 özeti JWT'ye girer. Doğrulayıcı gelen açıklamanın özetini yeniden hesaplar ve JWT'deki dizide arar. Tuz yoksa, doğum tarihi gibi tahmin edilebilir bir alanın özeti sözlük saldırısıyla çözülebilirdi; tuz bunu engeller.



Şekil 11. SD-JWT VC katmanları: hangi parça kimden gelir

TEKNİK AYRINTI

Bir açıklamanın ve özetinin hesabı

Tamga profili standardın bıraktığı seçenekleri daraltır (SPEC-CRED-0002 §1): imza algoritması yalnız ES256, `typ` yalnız `dc+sd-jwt`, özet algoritması (`_sd_alg`) yalnız `sha-256`, tuz 128 bit, kurum sertifika zinciri (`x5c`) zorunlu ve kök sertifika zincire konmaz, anahtar bağı istisnasız zorunlu, sahte özet (*decoy digest*) yasak, iç içe seçici açıklama en çok iki seviye ve `_sd` dizisi her zaman baytsal artan sırada. Bir açıklamanın hesabı şöyledir:

$$A = \text{BASE64URL}(\text{UTF-8}(\text{JSON}([\text{tuz}, \text{ad}, \text{değer}])))$$

$$d = \text{BASE64URL}(\text{SHA-256}(\text{ASCII}(A)))$$

$$\text{kabul} \Leftrightarrow d \in \text{_sd}$$

Kurumlar diziyi sabit bir sözleşmeyle yazar: elemanlar arasında virgül ve bir boşluk, ASCII dışı karakterler `\uXXXX` kaçışıyla. Aşağıdaki değerler bu sözleşmeyle gerçekten hesaplandı; tuzlar bu örnek için seçildi, değerler örnektir.

TEXT Örnek: Aynur'un diplomasından iki açıklama

```
Tuz (16 bayt, onaltılık)  : 9c41e07b2fd35a8816c4be72031d9fa5
Tuz (Base64URL)           : nEHgey_TWogWxL5yAx2fpQ
JSON dizisi               : ["nEHgey_TWogWxL5yAx2fpQ", "given_name", "Aynur"]
Açıklama (Base64URL)      : WyJuRUhnZXlfVFdvZ1d4TDV5QXgyZnBRIiwgImdpdmVuX25hbWUiLCAiQXludXIiXQ
Özet (_sd içine giren)    : Ib6OYL63r2BOsXDxfg3agTb5ZL4vjI3nD2Ya5WBqyxs

Tuz (Base64URL)           : Wy6P0QR6yT5mELfUL-hcGQ
JSON dizisi               : ["Wy6P0QR6yT5mELfUL-hcGQ", "family_name", "Məmmədova"]
Açıklama (Base64URL)      :
WyJXeTZQMFFSNnlUNW1FTGZVTC1oY0dRIiwgImZhbWlseV9uYW1lIiwgIk1cdTAyNTltbVx1MDI1OWRvdmEiXQ
Özet (_sd içine giren)    : 31B1ZwTB5I8Vvg3TjV3_YVjNlgO-dZ39Ftfl_nQhTiA
```

Yeniden serileştirme tuzağı. Özet, açıklama *dizesinin* özetidir; dizinin yeniden yazılmış hâlinin değil. Aynı soyadı dizisini boşluksuz ve `ə` harfi kaçışsız yazarsak (`["Wy6P0QR6yT5mELfUL-hcGQ","family_name","Məmmədova"]`) veri aynı kalır ama özet `wCd6pAztppTpS9k8d-IPbCifKlRIJFHE_t_eCV_ySa8` olur ve JWT'dekiyle eşleşmez. Doğrulayıcı bu yüzden açıklamayı **önce özetler, sonra çözer** çözüp yeniden yazan bir uygulama kendi ürettiği belgeyi bile doğrulayamaz (SPEC-CRED-0002 §3.3, §3.5). Sözleşme yalnız üretim içindir; doğrulayıcı başka sözleşmeyle yazılmış dış belgeleri de doğrular.

Sahte özet neden yasak? Standart, gizli alan sayısını belirsizleştirmek için karşılığı olmayan özetlere izin verir. Tamga'da tür tanımı açıktır ve alan sayısını zaten söyler; kurumdan kuruma değişen sahte özet sayısı ise kendi başına bir parmak izi olurdu. Yan kanala karşı çözüm, cüzdanın aynı doğrulayıcıya tutarlı bir açıklama kümesi sunmasıdır (SPEC-CRED-0002 §4.4).

Gösterim anında cüzdan sona bir anahtar bağı JWT'si ekler. Bu küçük JWT, belgenin bağlı olduğu cihaz anahtarıyla imzalanır ve dört alan taşır: doğrulayıcının verdiği tek kullanımlık değer (`nonce`), hedef doğrulayıcı (`aud`), gösterim anı (`iat`) ve sunulan dizenin özeti (`sd_hash`). İlk üçü tekrar oynatmayı önler: kaydedilmiş bir gösterim başka bir doğrulayıcıya ya da başka bir isteğe yeniden sunulamaz. Dördüncüsü, araya giren birinin sunulan açıklamalardan bazılarını sessizce çıkarmasını engeller (SPEC-CRED-0002 §6).

TEKNİK AYRINTI

Anahtar bağının hesabı

sd_hash , anahtar bağı hariç, sunulan dizenin tamamının özetidir; son açıklamadan sonraki tilde dahildir ve yalnız sunulan açıklamalar girer:

$$\text{sd_hash} = \text{BASE64URL}(\text{SHA-256}(\text{JWT} \parallel \sim \parallel A_1 \parallel \sim \parallel \cdots \parallel A_k \parallel \sim))$$

$$\text{KB-JWT} = \text{imza}_{\text{cnf}}(\text{nonce}, \text{aud}, \text{iat}, \text{sd_hash})$$

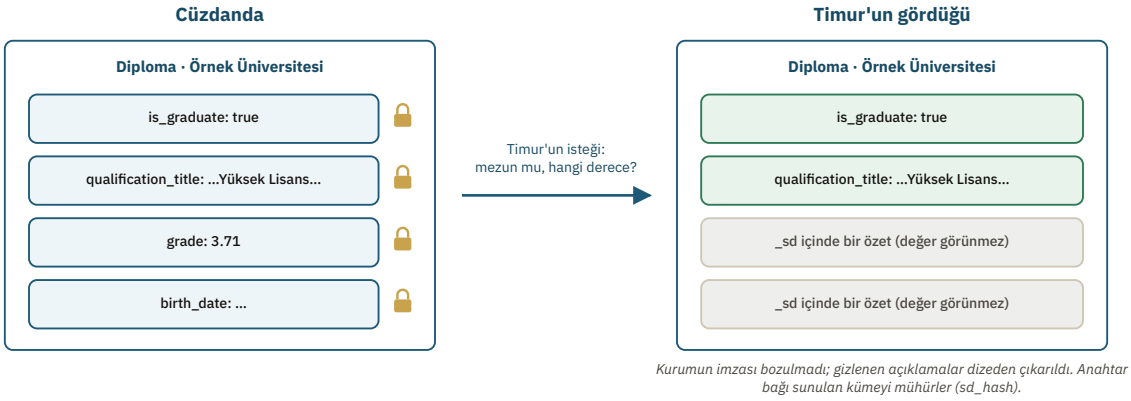
Doğrulayıcı anahtar bağının imzasını belgedeki `cnf` anahtarıyla doğrular, `aud` değerinin kendisi, `nonce` değerinin kendi verdiği değer olduğunu denetler, `iat` için ±300 saniyelik bir pencere uygular ve sd_hash 'i kendisi hesaplayıp karşılaştırır (SPEC-CRED-0002 §8, Ş8; C17). Tamga türlerinde anahtar bağı olmayan gösterim reddedilir (C8).

Aşağıdaki örnek, Aynur'un diplomasının kurumun imzaladığı gövdesini, açıklamalar çözülmüş hâlde gösteriyor. Gösterimde bu alanların yalnız bir kısmı açılır (Şekil 12).

JSON Örnek: çözülmüş bir diploma gövdesi (açıklamalar yerine konmuş, kısaltılmış; değerler örnektir)

```
{
  "iss": "https://issuer.sandbox.tamga.network/example-university",
  "vct": "urn:tamga:edu:DiplomaCredential:1",
  "vct#integrity": "sha256-7Dcy7bWeg5CURNEE+veGmjOE3HWb95ZGJBWX/ZrZgtI=",
  "iat": 1782896400,
  "cnf": { "jwk": { "kty": "EC", "crv": "P-256", "x": "…", "y": "…" } },
  "status": { "status_list": { "idx": 48213, "uri": "https://status.sandbox.tamga.network/…" } },
  "given_name": "Aynur",
  "family_name": "Məmmədova",
  "qualification_title": { "tr-TR": "Bilgisayar Mühendisliği Yüksek Lisans Diploması",
                           "en-US": "Master of Science in Computer Engineering" },
  "eqf_level": 7,
  "isced_f_code": "0613",
  "awarding_body_name": { "tr-TR": "Örnek Üniversitesi", "en-US": "Example University" },
  "awarding_date": "2026-06-30",
  "grade": "3.71",
  "thesis_title": { "tr-TR": "…" },
  "is_graduate": true
}
```

Örnekte üç ayrıntı var. `iat` saat başına yuvarlanmıştır; kopyalar veriliş anından eşleştirilemesin diye (paketlerin sürüm notları; Bölüm 15.2). Diplomanın `exp` alanı yoktur; yenileme zorunluluğu mezunu ömür boyu üniversiteye bağlardı. Not ve tez başlığı tür tanımında "her zaman gizlenebilir" işaretlidir: Aynur diplomasını notunu göstermeden sunabilir, kâğıt diplomada ise üstündeki her şey görünür (SPEC-SCHEMA-0002 §3.3).



Şekil 12. Seçici açıklama: dört alanlı bir belgeden iki alanın gösterilmesi

8.2 Cihaz bağı neden istisnasız

Şartnamelerde "üniversite fikrindeki gizli hata" diye anılan bir yanlış varsayım vardır: "Bir öğrenci üniversitenin onayıyla belge alırsa, belgeyi taşıyan o öğrencidir." Üniversite öğrencinin var olduğunu doğrular; ama belgenin girdiği cüzdanın o öğrenciye ait olduğunu doğrulamaz. Bağ yoksa belge arkadaşın cüzdanına aldırılabilir ya da birden çok cüzdana alınıp satılabilir; sistem hata vermez, sessizce yanlış söyler (SPEC-CRED-0001 §3).

Tamga'da her belge, verildiği anda kişinin cihazında üretilmiş bir anahtara bağlanır: anahtarın açık kısmı belgenin `cnf` alanına yazılır, gizli kısmı cihazın güvenli bölgesinden çıkmaz. Gösterimde cüzdan bu anahtarla anahtar bağını imzalar. Bağ istisnasız zorunludur (ADR-0006). Kanıtladığı şey, belgeyi sunanın belge verilirken bağlanan gizli anahtarı şu anda elinde tuttuğudur; karşıdaki insanın belgede adı geçen kişi olduğunu kanıtlamaz. Belge sahibi telefonunu ve kilit kodunu başkasına verirse hiçbir adım hata vermez. Bağ yanlış cüzdana yazılmayı ve devri önler, gönüllü cihaz paylaşımını önlemez (SPEC-CRED-0001 §3). Kişinin kendisini bağlamak için kimlik belgesine ihtiyaç vardır: kurumlar belge verirken kişinin kimlik belgesi sunumunu kendi kayıtlarıyla eşler (Bölüm 9.2; Bölüm 14).

8.3 mdoc: ikinci temsil

Tamga'nın kimlik belgesi SD-JWT VC'nin yanında ISO/IEC 18013-5 [34] **mdoc** biçiminde de verilir (ADR-0013). mdoc, mobil sürücü belgesi için geliştirilmiş, CBOR [29] kodlaması ve COSE imzası kullanan bir biçimdir. Üç gerekçe var: tarayıcıdan belge isteyen Digital Credentials API'nin [36] Safari ve iOS tarafı yalnız mdoc kabul eder; ADR-0013'ün kaydettiği gibi AB mimarisi kişi kimlik verisi için mdoc'u zorunlu tutar; yakın alanda ISO 18013-5 mdoc taşır (Bölüm 10.8). Yalnız SD-JWT VC ile kalmak tarayıcı girişini ve AB hizasını kaybettirirdi; tamamen mdoc'a geçmek mevcut hattı kırar ve web için daha yalın biçimi bırakırdı.

Kurallar iki temsili sıkı tutar. mdoc yalnız SD-JWT VC'nin ikinci temsilidir; aynı alanları, aynı veriliş ve bitiş zamanlarını taşır ve **aynı cihaz anahtarına** bağlıdır: SD-JWT'deki `cnf` ile mdoc'taki `deviceKey` aynı anahtardır (MD1, MD2). İki temsil tek verme akışında üretilir ve aynı iptal bitini paylaşır. mdoc'un `docType` değeri tür adıyla (`urn:tamga:id:IdentityAttestation:1`) aynıdır, ad alanı `tamga.id.1`'dir. Alan adları ve kodlaması AB kişi kimlik verisinin uygulama tüzüğüyle (AB 2026/1731 [7]) sabitlenmiş kodlamaya göredir: SD-JWT'de `birthdate` ve `nationalities` dizisi, mdoc'ta `birth_date` ve dizi değerli `nationality` (ADR-0045). Kimlik belgesi dışındaki türler bugün yalnız SD-JWT VC'dir. Sıfır bilgi ispatı için kullanılan kısa ömürlü kopya da bir mdoc'tur (Bölüm 15.4).

TEKNİK AYRINTI

mdoc'ta seçici açıklama

mdoc'ta her alan ayrı bir `IssuerSignedItem` yapısıdır: rastgele bir tanımlayıcı (`digestID`), 16 baytlık rastgele değer (`random`), alan adı ve değer. Yapı CBOR ile kodlanır, 24 numaralı CBOR etiketiyle sarılır ve bu baytların SHA-256 özeti, kurumun imzaladığı **Mobile Security Object** (MSO) içine yazılır. Cüzdan gösterimde yalnız seçtiği yapıları gönderir; doğrulayıcı özetleri MSO'yla, MSO'nun imzasını kurum sertifikasıyla ve cihaz imzasını oturuma bağlı bir döküm üzerinde doğrular.

$$\text{öğe} = \text{CBOR}(\text{tag } 24(\text{CBOR}(\{\text{digestID}, \text{random}, \text{elementIdentifier}, \text{elementValue}\})))$$

$$\text{MSO.valueDigests}[\text{tamga.id.1}][\text{digestID}] = \text{SHA-256}(\text{öğe})$$

`age_over_18 = true` öğesi, tanımlayıcı `1438205713` ve rastgele değer `8d1f6a20c43b97e5512a0ff6b8c3d471` ile kodlandığında 87 baytlık bir dizi çıkar ve özeti `b42af3a67628a8e5…a0536d4d` olur. Hesap ağın mdoc paketinin kodlayıcısıyla yapıldı; değerler örnektir. Tanımlayıcılar sıralı değil rastgeledir; sıralı olsaydı açıklanan alanların numaraları gizlenen alanların sayısını ve sırasını ele verirdi.

TEXT Örnek: bir kimlik belgesinin MSO'su (CBOR tanı gösterimine yakın, kısaltılmış; değerler örnektir)

```
{
  "version": "1.0",
  "digestAlgorithm": "SHA-256",
  "docType": "urn:tamga:id:IdentityAttestation:1",
  "valueDigests": { "tamga.id.1": { 1438205713: h'b42af3a6…a0536d4d', 902114467: h'…', … } },
  "deviceKeyInfo": { "deviceKey": { 1: 2, -1: 1, -2: h'…', -3: h'…' } },
  "validityInfo": { "signed": 0("2026-07-01T09:00:00Z"),
                    "validFrom": 0("2026-07-01T09:00:00Z"),
                    "validUntil": 0("2028-07-01T09:00:00Z") },
  "status": { "status_list": { "idx": 7310, "uri": "https://…" } }
}
```

mdoc'un iptal girdisi, aynı mantıksal listenin CWT gösterimine işaret eder; JWT ve CWT gösterimleri aynı bitleri taşır (ADR-0048). MSO, kurumun sertifikasıyla COSE_Sign1 imzası taşır ve sertifika zinciri imzanın içindedir; SD-JWT ile aynı güven çapasına bağlanır (MD3). Tablo 12 iki biçimi yan yana koyar.

Tablo 12. SD-JWT VC ile mdoc'un karşılaştırması (FW-ARF-0001 §5.1; ADR-0013).

	SD-JWT VC	ISO/IEC 18013-5 mdoc
Kodlama ve imza	JSON, JOSE (ES256)	CBOR, COSE_Sign1 (ES256)
Tür kimliği	`vct` (URN)	`docType` (aynı URN)
Seçici açıklama	tuzlanmış özetler (`_sd`) ve açıklamalar	`IssuerSignedItem` özetleri (MSO)
Cihaz bağı	`cnf` + anahtar bağı JWT'si	`deviceKey` + oturum dökümü üzerinde cihaz imzası
İptal	Token Status List (JWT gösterimi)	aynı liste, CWT gösterimi
Tamga'da kullanım	bütün türler; uzaktan gösterim	kimlik belgesi; tarayıcı, yakın alan, ZK

8.4 Belge türü kimliği ve katalog

Bir belgenin "diploma" olduğunu söyleyen şey, belgenin `vct` alanındaki tür adıdır. Tamga'da bu ad bir URN'dir: `urn:tamga:<alan>:<Tür>:<ana sürüm>`, örneğin `urn:tamga:edu:DiplomaCredential:1` (ADR-0010). Türün anlamı, yani hangi alanları taşıdığı, ekranda hangi dillerde nasıl gösterileceği ve hangi alanların gizlenebileceği, **tür tanımında** (*Type Metadata*) yazar; veri kuralları ayrı bir JSON Schema [39] dosyasındadır. Tanımlar `schemas.tamga.network` adresindeki katalogda değişmez dosyalar olarak yayınlanır (SPEC-SCHEMA-0001).

Bu ilk karar değildi. İlk şema kararı tür adını kararlı bir HTTPS adresi yapmıştı (ADR-0007, Karar 1); iki hafta sonra değiştirildi. Gerekçe yönetişimseldi: birden çok devletin katılacağı bir ağda tür kimliği bir vakfın alan adına bağlı olamaz. HTTPS seçeneği standarda uygundu, ama alan adını sonsuza kadar kimliğin parçası yapıyordu. AB'nin `urn:eudi:pid:1` ve katalog düzeni de aynı desendir. Standart dışı bir `.well-known` yolu ve DID tabanlı tür kimliği de reddedildi (ADR-0010). Bedeli kayda geçti: ağın kataloğunu bilmeyen bir doğrulayıcı URN'den tanıma ulaşamaz; katalog adresi bu yüzden listelerin listesinde ve paketlerde taşınır.

Tanımın nerede durduğunu katalogdaki `metadata_url` söyler; alan adı değişirse yalnız bu adresler değişir. Her belge, kastettiği tanımın özetini `vct#integrity` alanında taşır ve bu alan Tamga'da zorunludur (ETSI TS 119 472-1 [49]; IETF taslağında isteğe bağlı). Katalog sunucusu ele geçirilse bile bir alanın anlamı sessizce kaydırılamaz; özet içeriği tek başına tanımladığı için cüzdan tanımı bir kez indirip çevrim dışıyken de kullanabilir.

TEKNİK AYRINTI

Katalog kaydı, bütünlük özeti ve çözümleme

Bütünlük özeti W3C Subresource Integrity [38] biçimindedir: `sha256-` öneki ve dosyanın ham baytlarının SHA-256 özetinin Base64 kodlaması. Özet, sunucunun döndürdüğü bayt dizisi üzerinden alınır; dosya yeniden biçimlendirilmez, satır sonları LF, kodlama BOM'suz UTF-8'dir (SPEC-SCHEMA-0001 §3). Aşağıdaki kayıt yazım günündeki katalogdan alındı ve yeniden hesaplanarak doğrulandı: diploma tanımının 4.536 baytlık dosyasının özeti katalogdaki `content_hash` ile, tür adının Keccak-256 özeti `schema_id` ile aynıdır. Geliştirme evresinde tanımlar yerinde düzeltilebildiği için (aşağıda) değerler değişebilir; örnek olarak okunmalıdır.

JSON Örnek: katalogdaki diploma kaydı

```
{
  "vct": "urn:tamga:edu:DiplomaCredential:1",
  "schema_id": "0x9d6d0e873ee0466cf1cdc8a8bd73f9435022635f0b6e46cd478e70f6e6aed26b",
  "metadata_url": "https://schemas.tamga.network/v1/edu/DiplomaCredential/1.0.0/metadata.json",
  "content_hash": "sha256-7Dcy7bWeg5CURNEE+veGmjOE3HWb95ZGJBWX/ZrZgtI=",
  "version": "1.0.0",
  "layer": "NETWORK",
  "status": "ACTIVE"
}
```

JSON Örnek: diploma tür tanımından bir parça (kısaltılmış)

```
{
  "vct": "urn:tamga:edu:DiplomaCredential:1",
  "extends": "urn:tamga:core:TamgaBaseCredential:1",
  "extends#integrity": "sha256-8ZCjtH26C7Bh0u+Lox3zJA+JLfP4JYtcQPW+8fxoyPU=",
  "schema_uri": "https://schemas.tamga.network/v1/edu/DiplomaCredential/1.0.0/schema.json",
  "schema_uri#integrity": "sha256-AJXIk9o4DlyVFC3PyCeH/4XEeZnh+dYTWVFlvjQjonc=",
  "display": [ { "lang": "tr-TR", "name": "Diploma", "description": "Yükseköğretim mezuniyet belgesi" },
               { "lang": "en-US", "name": "Diploma", "description": "Higher education degree" } ],
  "claims": [ { "path": ["grade"], "sd": "always",
                "display": [ { "lang": "tr-TR", "label": "Not ortalaması" } ] },
              { "path": ["is_graduate"], "sd": "allowed" } ],
  "tamga": { "tier": "NETWORK", "issuer_categories": ["EDUCATION"], "uses_status_list": true,
             "suspension_allowed": true, "min_issuer_assurance": "I2", "min_binding_level": "T2" }
}
```

`schema_uri` ve onun özeti IETF taslağının güncel sürümünde yoktur; Tamga bunları kendi eki olarak tutar ve standart bir okuyucu tanımadığı alanı yok sayar. Doğrulayıcının tür adımı sırayla şunları yapar (ADR-0010 K2; SPEC-SCHEMA-0001 §7): `vct` ile `vct#integrity` yoksa ret; türün katalog kaydı yoksa ya da geri çekilmişse ret; tanımı önbellekten, yoksa `metadata_url` adresinden al; alınan baytların özeti hem belgedeki değerle hem katalog kaydıyla eşleşmiyorsa ret; tanımdaki `vct` belgeyle aynı değilse ret; üst tür zincirini (`extends`) en çok beş seviye ve döngüsüz çöz; belgeyi JSON Schema'ya karşı denetle; son olarak kurumun bu türe belgenin verildiği tarihte yetkili olduğunu listeden sor. Tanım hiçbir yerden alınamazsa sonuç ret değil "doğrulanamadı"dır.

Ana sürüm URN'nin parçasıdır; kırıcı bir değişiklik yeni bir URN demektir. Ara ve yama sürümler aynı URN altında yeni bir `metadata_url` ve yeni bir özetle yayınlanır; belgedeki `vct#integrity` hangisinin kastedildiğini kesinleştirir. Kullanımdan kaldırılan (`DEPRECATED`) bir tür artık **verilemez** ama onunla verilmiş belgeler **doğrulanmaya devam eder** 2027'de verilmiş bir diploma, türün yeni ana sürümü çıktığında da doğrulanabilir kalmalıdır (ADR-0007 Karar 7; ADR-0010 K4). Ulusal belge türleri kendi ad alanını kullanır: `urn:tamga:<cc>:<alan>:<Tür>:<ana sürüm>` ağ türü bu biçimde olamaz, böylece bir ulusal ad ağ geneli bir adla hiçbir zaman çakışmaz (ADR-0054).

Bugün ağ bir **geliştirme evresindedir**: beta yayınına kadar tür tanımları yerinde düzeltilir, deneme belgeleri yeniden alınır; yayınlanmış tanımın değişmezliği beta ile başlar (ADR-0029). Diplomanın tanımına askı izni eklendiğinde özet değişti ve önceki deneme diplomaları yeniden verildi (SPEC-SCHEMA-0002 §3.1); gerçek kullanıcı yokken geriye uyum kodu yazılmadı.

8.5 Bugünkü türler

Tablo 13. Katalogdaki belge türleri (yazım günü; `packages/schemas` kataloğu, SPEC-SCHEMA-0002/0003, FW-RB-0002...0005).

Tür (`vct`, `urn:tamga:` öneki atlanmış)	Görünen adı	Biçim · iptal · askı · asgari seviye · kural kitabı
`edu:StudentCredential:1`	öğrenci belgesi	SD-JWT VC · iptal listesi yok, en çok 90 gün · askı yok · T1 · FW-RB-0002
`edu:DiplomaCredential:1`	diploma	SD-JWT VC · Status List, 2 bit · askı var · T2 · FW-RB-0002
`id:IdentityAttestation:1`	kimlik belgesi	PID değildir · SD-JWT VC + mdoc · Status List, 1 bit · askı yok · T2 · FW-RB-0003
`contact:EmailAddress:1`, `contact:PhoneNumber:1`	e-posta, telefon	doğrulanmış iletişim · SD-JWT VC · Status List, 1 bit · askı yok · T0 · FW-RB-0005
`tkt:EventTicket:1`	etkinlik bileti	SD-JWT VC · Status List · askı yok · T0 · FW-RB-0004
`id:DrivingLicenceAttestation:1`	sürücü belgesi bilgisi	resmî belge değildir · SD-JWT VC · Status List, 1 bit · askı yok · T2 · FW-RB-0003
`id:PseudonymSeed:1`	takma ad tohumu	hiçbir doğrulayıcıya gösterilmez · SD-JWT VC · iptal listesi yok · T2 · ADR-0031, ADR-0061
`id:ShortLivedIdentityAttestation:1`	ZK kopyası	mdoc · iptal listesi yok, en çok 24 saat · askı yok · T2 · ADR-0044

Öğrenci belgesi iptal listesi kullanmaz; kısa ömür iptalin yerini tutar. Diploma süresizdir ve iptal listesi kullanır; intihal ya da sahte kayıt gibi nadir ama gerçek iptal nedenleri vardır. Diploma, kodlu alanlarıyla Avrupa Öğrenme Modeli'ne (ELM [61]) eşlenir: Avrupa Yeterlilikler Çerçevesi seviyesi (EQF) ve ISCED-F alan kodu. Almanya'daki bir işverenin "Bilgisayar Mühendisliği" ibaresini okuması gerekmez; `0613` alan kodunu ve 7. seviyeyi anlar (SPEC-SCHEMA-0001 §8.3). Sürücü belgesi bilgisi resmî bir sürücü belgesi de mobil sürücü belgesi de değildir; trafik denetiminde geçmez ve bunu kartın üzerinde açıkça söyler (ADR-0039). Ulusal kimlik numarası yalnız kimlik belgesinde ve yalnız seçici açılabilen bir alan olarak bulunur; hiçbir diploma, kart ya da bilet onu taşımaz (FW-ARF-0001 §5.1). Kimlik belgesinden doğan türlerin ayrıntısı Bölüm 14'tedir.

8.6 Kategori sinyali ve güvence

AB hukukunda nitelikli öznitelik belgeleri ve kamu kaynağı adına verilen öznitelik belgeleri, belgenin içinde otomatik işlenebilir bir kategori göstergesi taşır; nitelikli olmayanlar taşımaz. Tamga bu yapıyı kendi bağlamında aynalar (ADR-0010 K5). Belge veren kaydının sınıfı `PUB` ise belge `category` alanında `urn:tamga:eaa:pub`, `QUALIFIED` ise `urn:tamga:eaa:qualified` taşır; sınıfı `EAA` olan, yani kayıtlı ya da sözleşmeli seviyedeki belge verenler kategori taşımaz. Kurum yalnız kayıttaki sınıfının sinyalini koyabilir; doğrulayıcı güven adımında belgedeki kategoriyi listeyle karşılaştırır ve uyuşmazlıkta belgeyi reddeder (C4). Sahte bir sinyal böylece işe yaramaz. AB'nin kendi kategori adları (`urn:etsi:esi:eaa:eu:*`) kullanılmaz; ağ AB bağlamının dışındadır.

İkinci kural kişiyle ilgilidir: **kişinin kimlik doğrulama seviyesi belgeye hiçbir zaman yazılmaz** (C18). Seviye türün ön koşuludur; diploma ancak en az T2 bağlamayla verilir (Tablo 13) ve bağlama yöntemi yalnız belge verenin denetim kaydına yazılır (PR7). AB de seviyeyi belgeye yazmaz (ADR-0010, alternatif E).

Bugünkü tablo sadedir: ağdaki bütün belge verenler nitelikli olmayan öznitelik belgesi verir ve hiçbir belge kategori alanı taşımaz. Kimlik servisi de nitelikli değildir; AB'de bu unvan bağımsız uygunluk değerlendirmesi ve gözetim gerektirir (ADR-0022). Belgeye ayrıca bir "nitelikli değildir" göstergesi

de yazılmaz (ADR-0047). Diplomada en yüksek kurum seviyesinin (I3) ne zaman açılacağı pilottan sonraya bırakıldı.

9 Belge Verme: OpenID4VCI Profili

Aynur'un yüksek lisans diploması hazır. Elif üniversitenin öğrenci bilgi sisteminde mezuniyet kaydını onayladıktan sonra Aynur'a aynı sistemden bir bağlantı gidiyor. Aynur bağlantıyı telefonunda açıyor, cüzdan kimliğini sormak için onay istiyor, ardından birkaç saniye içinde diploma kartı beliriyor. O birkaç saniyede cüzdanla üniversitenin belge verme hizmeti arasında bir dizi mesaj gidip geliyor. Bu bölüm o mesajları anlatıyor. Protokol, OpenID Foundation'ın OpenID for Verifiable Credential Issuance 1.0 (OpenID4VCI [30]) belgesidir; Tamga onun üzerine sıkı bir profil kurar (SPEC-PROTO-0001). Dizinin sekizinci yazısı [73] protokolün kendisini sıfırdan anlatıyor; burada profilin seçimlerine ve gerekçelerine bakıyoruz.

9.1 İki başlangıç

Bir belge iki yoldan istenebilir (FW-ARF-0001 §2.1). **Kurumun başlattığı** yolda kurum bir **teklif** (*credential offer*) üretir ve kişiye karekod ya da bağlantı olarak iletir. **Cüzdanın başlattığı** yolda kişi cüzdanda kurumu seçer ve belgesini ister; kurum dizinini cüzdan güven listesinden okur, ayrı bir sunucuya sormaz (PR15). İki yolda da kurum önce kendini tanıtır: her belge verme hizmeti standart bir tanıtım belgesi (*issuer metadata*) yayınlar. Cüzdan bu belgeyi imzalı ister; imzacı kurumun listedeki sertifikası değilse kullanmaz. Belge kurumun kayıt sertifikasını da taşır; cüzdan istenen türün kayıtlı olduğunu önceden denetler (SPEC-PROTO-0001 §2.1).

Teklif karekodun içine gömülmez; karekod yalnız teklifin adresini (`credential_offer_uri`) taşır ve adres **tek kullanımlıktır** (PR3). Kullanılmış bir teklif ikinci kez okutulduğunda cüzdan "bu davet kullanılmış" der; Aynur "karekodum çalışmıyor" dediği anda bir sızıntı fark edilir. Kurumun başlattığı yolda teklifler üç sınıfa ayrılır (Tablo 14).

Tablo 14. Teklif sınıfları ve koruma (SPEC-PROTO-0001 §3.3).

Sınıf	Nerede görünür	Ömür	İkinci faktör	Ek kural
`on-screen`	kişinin oturum açtığı kurum ekranında	5 dakika, tek kullanımlık	6 haneli işlem kodu, aynı oturumda	3 yanlış denemede teklif yanar
`out-of-band`	e-posta ya da kısa mesajla giden karekod	en çok 72 saat, tek kullanımlık	6 haneli işlem kodu, **farklı kanaldan**	kanal adresi yalnız kurumun kayıtlı verisinden; verildikten sonra iki kanala da "cüzdana eklendi" bildirimi
`identity-bound`	kurumun kendi kanalıyla ilettiği bağlantı	7 gün, tek kullanımlık	işlem kodu yok; kişi kimlik belgesini sunar	teklif kişinin kimliğine bağlıdır (Bölüm 9.2)

İşlem kodu (`tx_code`), ekranı omuz üstünden gören ya da karekodu fotoğraflayan birine karşı ikinci faktördür ve ön yetkili akışta atlanamaz (PR1). Kod teklifin içinde gitmez. Kimliğe bağlı teklif ise işlem koduna hiç ihtiyaç duymaz; çünkü belge yalnız teklifte adı geçen kişiye verilebilir.

> TEKNİK AYRINTI
>
> **Kimliğe bağlı bir teklif nesnesi**
>
> Kimliğe bağlı teklif standardın yetki kodu akışını kullanır; teklifte ön yetkili kod yoktur, yalnız teklifin kimliğini taşıyan bir `issuer_state` değeri vardır. Cüzdan bu değeri yetki isteğine koyar ve belge veren teklifin geçerli, kullanılmamış ve aynı belge türü için olduğunu denetler (SPEC-PROTO-0001 §3.4). Değerler örnektir.

JSON Örnek: Aynur'un diploması için kimliğe bağlı teklif

```
{
  "credential_issuer": "https://issuer.sandbox.tamga.network/example-university",
  "credential_configuration_ids": ["urn:tamga:edu:DiplomaCredential:1"],
  "grants": { "authorization_code": { "issuer_state": "b3f1c2…" } }
}
```

TEXT Örnek: karekodun taşıdığı adres

```
openid-credential-offer://?credential_offer_uri=
  https%3A%2F%2Fissuer.sandbox.tamga.network%2Fexample-university%2Foffers%2F8a3f9c21
```

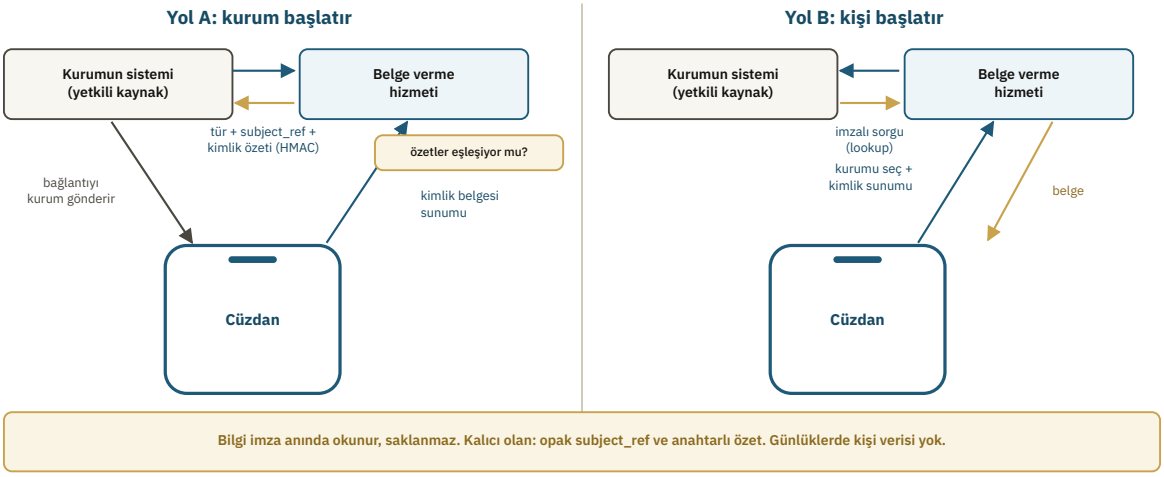
Tanıtım belgesinde her belge yapılandırmasının kimliği ve kapsamı (`scope`) türün URN'sidir; biçim her zaman `dc+sd-jwt` , imza ve kanıt algoritması yalnız ES256, toplu verme büyüklüğü 10'dur. Ertelenmiş verme ucu ve bildirim ucu bugün ilan edilmez (§2.1, §9, §10).

9.2 Yetkili kaynak kurumda

Bir diplomanın içindeki bilgi kimin? Tamga'nın cevabı kesindir: bilgi kurumun kendi sistemindedir ve orada kalır. Barındırılan belge verme hizmetinde bile ağ kişi kaydı tutmaz; belge bilgileri imza anında kurumun **yetkili kaynağından** (*authentic source*) okunur ve belge verilince bellekten atılır (ADR-0020). Proje yönetiminin bu karardaki yönü açıktı: toplu öğrenci yüklemesi yok, teklif e-postasını kurum kendisi gönderir, ağın kişi verisiyle işi yoktur. AB'de de belge sağlayıcısı özniteliği yetkili kaynaktan alır ve aracının kaynak veriyi kalıcı tutması beklenmez.

İki yol tanımlıdır (Şekil 13). **Yol A**'da kurum başlatır: kurumun sistemi ağın API'sine belge türünü, kurumun kişi için kullandığı opak bir referansı (`subject_ref`) ve iki eşleştirme anahtarını, kişinin kimlik numarasını ve doğum tarihini gönderir. Hizmet bu anahtarları düz saklamaz; kurum başına anahtarlı bir özet (HMAC-SHA-256 [26]) tutar. Bağlantıyı kişiye kurum kendisi iletir; ağ kişinin iletişim adresini görmez (AS3). Aynur bağlantıyı açtığında cüzdan kimlik belgesini sunar; sunulan belgedeki kimlik numarası ve doğum tarihinin özeti teklifteki özetle eşleşmezse belge verilmez. Bağlantıyı başka biri ele geçirse bile belgeyi alamaz (AS2). **Yol B**'de kişi başlatır: Aynur cüzdanda üniversiteyi seçer ve kimliğini sunar; belge verme hizmeti kurumun sorgu ucuna imzalı, kısa ömürlü bir istekle sorar. Kayıt varsa belge verilir, yoksa "kurum kaydında bulunamadı" döner ve yanıt saklanmaz. Kalıcı olan yalnız kurumun opak kişi referansı (iptal ve yenileme için) ve kimliğe bağlı teklifteki anahtarlı özettir (AS1).

Ağın kendi kayıt defterini tutması (kişi verisini ağa taşır) yalnız deneme ortamına bırakıldı; teklif e-postasını ağın göndermesi (ağa iletişim adresi gösterir) reddedildi; kimlik bağı olmadan yalnız işlem koduna dayanmak, kimlik belgesi olmayanlar için yedek kaldı (ADR-0020). *Durum: iki yol da barındırılan hizmette çalışıyor.*



Şekil 13. Yetkili kaynak kurumda: Yol A ve Yol B

TEKNİK AYRINTI

Cüzdanın başlattığı verme

Cüzdanın başlattığı yolda yetki kodu akışı, OAuth'un güvenlik eklentileriyle birlikte çalışır: yetki isteği önce arka kanaldan itilir (PAR [21], RFC 9126), kod değişimi PKCE [22] (S256) ile korunur ve istemci kimliği bir parola değil cüzdan örneği kanıtıdır (PR13). Kişinin kimliği, kurumun belge verme hizmetine yapılan standart bir gösterimle eşlenir (SPEC-PROTO-0001 §11.2).

1	`Cüzdan → Belge veren`	**PAR.** İstenen türü (`scope` = tür URN'si), dönüş adresini, PKCE değerini ve varsa `issuer_state` 'i arka kanaldan iter; isteğe cüzdan örneği kanıtı ve onun sahiplik kanıtı eklenir.	$\text{request_uri} \leftarrow \text{PAR}(s, \text{code_challenge}, \text{WIA})$
2	`Cüzdan → Belge veren`	**Yetki.** Yetki ucunu çağırır; belge veren kimlik belgesini isteyen imzalı bir gösterim isteği döner (kimlik numarası, doğum tarihi, ad, soyad).	$\text{istek} \leftarrow \text{authorize}(\text{request_uri})$
3	`Cüzdan → Belge veren`	**Gösterim.** Standart gösterim akışını çalıştırır; belge veren sunumu tam doğrulama hattından geçirir.	$\text{vp_token} \rightarrow \text{T0} + \text{A...E}$
4	`Belge veren`	**Eşleme.** Kimlik numarası ve doğum tarihini teklifteki özetle ya da kurumun kaynağındaki kayıtla eşler; eşleşmezse `access_denied` .	$\text{HMAC}_k(\text{kimlik no}, \text{doğum t.}) \stackrel{?}{=} \text{teklif özeti}$
5	`Cüzdan → Belge veren`	**Belirteç.** Yetki kodunu PKCE sırrıyla belirtece çevirir; kod tek kullanımlık ve en çok 60 saniyelik.	$\text{access_token} \leftarrow (\text{code}, v)$
6	`Cüzdan → Belge veren`	**Belge.** Nonce, anahtar sahipliği ispatları (`proof`) ve belge isteği; adımlar kurumun başlattığı akışla aynıdır (Bölüm 9.4).	$\text{proofs} \rightarrow \text{credential}$

Kullanılmış bir yetki kodu ikinci kez gelirse belge veren o koddan verilmiş belirteçleri önce geri alır. Bu, kodun sızdığı şüphesinde kişinin oturumunu kapatmayı saldırganın kodu kullanmasını engellemekten önce getiren bilinçli bir tercihtir (RFC 9700 [23] §4.5; SPEC-PROTO-0001 §11.2).

9.3 Yalnız gerçek cüzdanlara

Belge veren karşısındakinin listede tanınan bir cüzdan mı, sahte bir istemci mi olduğunu bilmek ister. AB modelinde cevap, cüzdan sağlayıcısının imzaladığı iki kanıttır (ADR-0025; FW-POL-0002). **Cüzdan örneği kanıtı** (*Wallet Instance Attestation*, WIA) cüzdanın listede kayıtlı bir sağlayıcının çözümü olduğunu söyler. Ömrü 24 saatten kısadır ve her işlemde yeni anahtar ve yeni iptal girdisiyle alınır; iki kurum aynı WIA'yı görmez, sağlayıcı da cüzdanın kaç kurumla görüştüğünü öğrenmez. **Anahtar kanıtı** (*key attestation*, KA) ise belgenin bağlanacağı anahtarların hangi depoda durduğunu, yazılımda mı, telefonun güvenli bölgesinde mi olduğunu söyler; seviyesi gerçeği söylemek zorundadır, doğrulanmamış bir beyan kanıta yazılmaz (WIA3).

Belge veren WIA'nın imzasını, imzacının listedeki bir cüzdan sağlayıcısına ait olduğunu, süresini, sahiplik kanıtını ve iptal durumunu denetler; KA'nın imzasını, iptal durumunu ve depo seviyesinin kurumun alt sınırını karşıladığını denetler. Listede olmayan bir sağlayıcının cüzdanına belge verilmez; iptal edilmiş bir kanıtla da verilmez (PR11, PR19). Kurumlar alt sınırı kendi politikalarıyla yükseltebilir. Gerçek ağda kimlik servisi yalnız anahtar kanıtlı isteği kabul eder ve güvenli bölge seviyesini alt sınır olarak uygular; sandbox ve yerel geliştirme yazılım seviyesini kabul etmeyi sürdürür (SPEC-PROTO-0001 §11.1.1). Eski model, 30 gün geçerli ve her kuruma aynı gösterilen tek bir cüzdan kanıtıydı; bağlanabilir ve iptal edilemez olduğu için bırakıldı (ADR-0025). Ayrıntı Bölüm 13'tedir.

9.4 DPoP, nonce ve anahtar sahipliği ispatı

Belge verme akışında üç ayrı mekanizma, üç ayrı soruyu cevaplar. Birincisi belirteçle ilgilidir: erişim belirteci çalınırsa ne olur? Tamga'da erişim belirteci **DPoP** [20] ile göndericisine bağlıdır (RFC 9449). Cüzdan geçici bir P-256 anahtarıyla imzalı bir kanıt gönderir ve belge veren belirteci bu anahtarın parmak izine bağlar; belirteci çalan, anahtar onda olmadığı için onu kullanamaz. Kanıt tek kullanımlıktır ve ±5 dakikalık bir pencereye sahiptir; belirtecin ömrü 5 dakikadır (PR9, PR17).

İkincisi tazelikle ilgilidir: cüzdanın kanıtı az önce mi üretildi, yoksa başka bir yerden mi kopyalandı? Belge verenin **nonce ucu** 5 dakika geçerli, tek kullanımlık bir değer (`c_nonce`) verir ve değer **atomik** olarak tüketilir; "önce kontrol et, sonra sil" diye iki adımda yapılan tüketim aynı ispatın iki kez kullanılmasına yol açan bir yarış bırakırdı (PR4). OpenID4VCI 1.0'da bu değer yalnız nonce ucundan gelir.

Üçüncüsü anahtarla ilgilidir: belgenin bağlanacağı anahtar gerçekten cüzdanda mı? Cüzdan bu anahtarla küçük bir JWT imzalar: **anahtar sahipliği ispatı** (`proof`, türü `openid4vci-proof+jwt`); içinde ispatın hangi belge veren için olduğu (`aud`), üretim anı (`iat`) ve az önce alınan `nonce` bulunur. İspatın başlığındaki açık anahtar, belgenin `cnf` alanına girecek anahtardır; KA da bu başlıkta taşınır. İspatta yalnız ES256 kabul edilir (PR5).

TEKNİK AYRINTI

DPoP bağı ve kurumun başlattığı vermenin adımları

DPoP bağında belirteç, kanıttaki açık anahtarın RFC 7638 [24] parmak izine bağlanır. Parmak izi, anahtarın zorunlu alanlarının sözlük sırasıyla ve boşluksuz yazılmış JSON'unun SHA-256 özetidir. Belge ucunda her istek ayrıca belirtecin özetini (`ath`) taşır:

$$\mathrm{jkt} = \mathrm{BASE64URL}(\text{SHA-256}(\mathrm{JSON}(\{\mathrm{crv}, \mathrm{kty}, \mathrm{x}, \mathrm{y}\})))$$

$$\text{token.cnf.jkt} \stackrel{?}{=} \mathrm{jkt}(\text{DPoP kanıtındaki jwk})$$

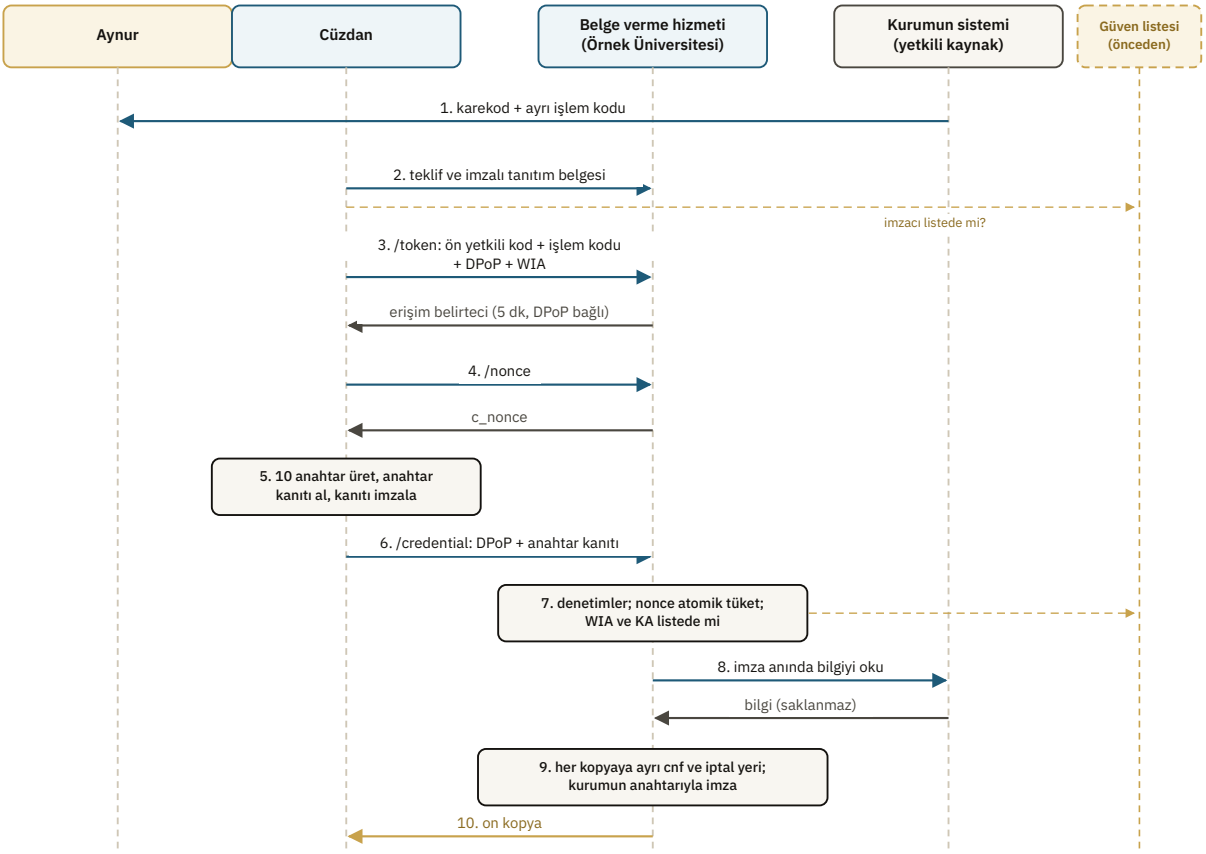
$$\mathrm{ath} = \mathrm{BASE64URL}(\text{SHA-256}(\text{erişim belirteci}))$$

Şartnamedeki örnek P-256 anahtarı (`x = f83OJ3D2…VEU`, `y = x_FEzRu9…I5a0`) için parmak izi `oKIywvGUpTVTyxMQ3bwIIeQUudfr_CkLMjCE19ECD-U` çıkar; değerler örnektir. Kurumun başlattığı, ön yetkili kodlu akış şu adımlarla ilerler (SPEC-PROTO-0001 §1–§8; Şekil 14):

1	`Kurum → Aynur`	**Teklif.** Ekranda karekod ve ayrı olarak 6 haneli işlem kodu gösterir; teklif adresi tek kullanımlık.	$\text{offer_uri}, \text{tx_code}$
2	`Cüzdan → Belge veren`	**Teklif ve tanıtım.** Teklifi ve imzalı tanıtım belgesini çeker; imzacıyı listedeki kurum sertifikasıyla eşler.	$\text{metadata} \rightarrow \text{liste}$
3	`Cüzdan → Belge veren`	**Belirteç.** Ön yetkili kodu ve işlem kodunu, DPoP kanıtı ve cüzdan örneği kanıtıyla gönderir.	$\text{access_token} \leftarrow (\text{code}, \text{tx_code}, \text{DPoP}, \text{WIA})$
4	`Cüzdan → Belge veren`	**Nonce.** Nonce ucundan taze değer alır.	$\text{c_nonce} \leftarrow \text{nonce ucu}$
5	`Cüzdan`	**Anahtarlar.** On kopya için on ayrı anahtar üretir; sağlayıcıdan anahtar kanıtı (KA) alır ve anahtar sahipliği ispatını imzalar.	$k_1 \cdots k_{10} \quad \pi = \text{imza}(\text{aud}, \text{iat}, \text{c_nonce})$
6	`Cüzdan → Belge veren`	**Belge isteği.** `Authorization: DPoP` başlığı, aynı anahtarla yeni DPoP kanıtı (`ath` dahil) ve başlığında KA taşıyan anahtar sahipliği ispatı.	$\text{POST } /\text{credential}$
7	`Belge veren`	**Denetimler.** Belirteç ve kapsam; ispatın imzası, `aud`, `iat` nonce'u atomik tüket; anahtarların farklılığı; tür yetkisi hâlâ geçerli mi.	$\text{nonce} \in \text{taze küme} \Rightarrow \text{sil}$
8	`Belge veren`	**İmza.** Bilgiyi yetkili kaynaktan okur, her kopyayı ayrı anahtara bağlar, her kopyaya iptal listesinde rastgele yer ayırır ve kurumun anahtarıyla imzalar.	$\text{cnf}_i = k_i \quad \text{idx}_i \leftarrow \text{rastgele}$
9	`Belge veren → Cüzdan`	**Yanıt.** Kopyaları döner; her biri SD-JWT VC dizesidir ve son tilde ile biter.	$\text{credentials}[1 \cdots 10]$

Tür yetkisinin belge ucunda yeniden sorulması gereksiz görünebilir; tanıtım belgesi üretilirken zaten denetlenmişti (PR2). Ama yetki, tanıtım belgesi önbelleğe alındıktan sonra geri çekilmiş olabilir; ucuz bir denetimdir ve yanlış belge üretmenin bedeli yüksektir (SPEC-PROTO-0001 §7.3).

Hata kodları standardın kendi kodlarıdır ve kişisel veri içermez: "Aynur Məmmədova için kayıt bulunamadı" denmez, `credential_request_denied` denir (PR8). Akışın bazı ayrıntıları, Ekim 2026'da OpenID Foundation'ın uyum test aracıyla sandbox üzerinde yapılan öz-testten çıktı (ADR-0059, ADR-0060); bu bir öz-testtir, sertifika ayrı bir süreçtir (Bölüm 16.5).



Ortak deftere hiçbir şey yazılmaz; iptal yeri ayırma belge verenin kendi veritabanındadır.

Şekil 14. Kurumun başlattığı belge verme: sıra diyagramı

9.5 Toplu verme: on kopya, on anahtar

Aynur diplomasını Timur'a, sonra başka bir işverene, sonra bir burs kurumuna gösterebilir. Hep aynı kopyayı gösterseydi bu kurumlar aynı `cnf` anahtarından ve aynı iptal yerinden üçünün aynı kişiyle görüştüğünü anlayabilirdi. Çözüm her gösterimde farklı bir kopya kullanmaktır (SPEC-PROTO-0001 §8.1). Tamga'da bir verme işleminde **on kopya** verilir ve her kopya **farklı bir cihaz anahtarına** bağlanır (PR6). Belge veren, bir istekte aynı anahtarla iki kanıt gelirse isteği reddeder. Cüzdan her doğrulayıcıya ayrı bir kopya gösterir ve aynı doğrulayıcıya aynı kopyayı göstermeyi sürdürür (Bölüm 13.4).

On sayısı bir dengedir: tek kopya bağlanabilirliği açık bırakır, elli kopya israf üretir; değer pilot verisiyle yeniden ayarlanacaktır (SPEC-PROTO-0001 §8.3, Açık Konular 4). Her diploma kopyası iptal listesinde **ayrı bir yer** tüketir. Bir diploma iptal edildiğinde on yerin hepsi işaretlenir; hangi yerlerin aynı diplomaya ait olduğunu yalnız kurum kendi veritabanında bilir ve bu eşleme hiçbir zaman dışarı çıkmaz (PR10). On bitin aynı anda değişmesi dışarıdan bir sinyal olabilirdi; ama iptal listeleri değişiklik olsa da olmasa da sabit aralıkla yayınlandığı için hangi bitlerin birlikte değiştiği görünmez (Bölüm 12.4).

Bir erişim belirteci, 5 dakikalık ömrü içinde birden çok belge isteğinde kullanılabilir; ama yalnız kapsadığı yapılandırma için, toplam on kopyaya kadar ve her zaman bağlı olduğu DPoP anahtarıyla. Ömür yeniden kullanımla uzamaz (ADR-0059, AT1–AT3). Tek kullanımlık belirteç AB'nin referans belge vereninden ayrışıyor ve ağ kopmasında yeni yetki istiyordu; sınırsız yeniden kullanım iptal yerlerini tüketebilirdi. Bilet ve ZK kopyası tek paket kalır.

9.6 Sessiz yenileme

Kopyalar tasarım gereği tükenir. Kurum belgelerinde (öğrenci belgesi ve diploma; biletler hariç) cüzdan, kopyalar azaldığında ya da süresi bitmek üzereyken kişiye sormadan yeni kopya alabilir

(ADR-0023). Eşikleri belge veren ilan eder: iki kullanılmamış kopya kalınca ya da yedi günlük ömür kalınca (SPEC-PROTO-0001 §2.1). Cüzdan yenilemeyi uygulama öndeyken ve rastgele bir gecikmeyle yapar.

Yenileme, ilk verme işleminde verilen bir **yenileme belirteciyle** yapılır. Belirteç tek kullanımlıktır, her kullanımda yenisiyle değiştirilir ve belge veren yalnız onun özetini saklar. Yenilemede belge veren kaydı yetkili kaynaktan yeniden okur; kişi kaynakta yoksa belirteç düşer ve belge verilmez (PR18). Belirtecin neye bağlı olduğu bir kez değişti. İlk kararda belirteç ilk işlemdeki DPoP anahtarına bağlıydı. OAuth'un cüzdan kanıtıyla istemci doğrulama profili ise bağın **istemci örneği anahtarına**, yani ilk işlemdeki cüzdan örneği kanıtının `cnf` anahtarına kurulmasını ve DPoP anahtarının değişebilmesini ister. Tamga bağı buna göre değiştirdi (ADR-0060). Cüzdan her işlemde yeni WIA anahtarı kullandığı için bağın anahtarı yalnız o belgeyle saklanır ve yenilemede sağlayıcıdan bu anahtara taze WIA istenir; anahtarı yalnız o kurum görür. Tek bir kalıcı örnek anahtarı daha basit olurdu ve bütün kurumlar aynı anahtarı göreceği için reddedildi.

Kişi bilgisini saklamayan türlerde sessiz yenileme yoktur: kimlik belgesi ve iletişim belgeleri yenileme belirteci vermez ve yenileme kişinin eylemiyle olur. Kimlik servisinin tek istisnası, sıfır bilgi ispatı için kullanılan kısa ömürlü kopyalardır; onların belirteci kimlik belgesini yenilemez, yalnız kısa ömürlü kopya alır ve yalnız cüzdan bu kapsamı ayrıca isterse verilir (ADR-0044, ADR-0062; Bölüm 15.4). *Durum: sessiz yenileme ve istemci örneği bağı çalışıyor (paketlerde 0.7.2'den beri).*

9.7 Bildirim ve "siz değilseniz"

Belge verme akışının son adımı kişiyle ilgilidir. Ağın mimari belgesi, bir belge cüzdana eklendiğinde kişiye "belgeniz bir cüzdana eklendi; siz değilseniz bildirin" iletisinin gitmesini öngörür (FW-ARF-0001 §4.3). E-posta ya da kısa mesajla giden tekliflerde bu ileti belge verildikten sonra iki kanala da gider (SPEC-PROTO-0001 §3.3). Kişinin haberi olmadan cüzdana alınan bir belge böylece fark edilir; kullanılmış teklif uyarısıyla birlikte, ele geçirilmiş bir bağlantının izini süren ikinci bir işarettir.

Bundan ayrı olarak OpenID4VCI, cüzdanın belgeyi kabul ettiğini belge verene bildirdiği bir **bildirim ucu** tanımlar. Tamga belge verenleri bu ucu bugün ilan etmez (SPEC-PROTO-0001 §10). Uç eklenirse bildirimler yalnız sayaç olarak kullanılacak, kişi bazında saklanmayacaktır; cüzdan bir belgenin sonradan silindiğini hiçbir belge verene bildirmez. Ertelenmiş verme ucu da sunulmaz: kayıt hazır değilse istek reddedilir ve kurum sonra yeni teklif üretir (SPEC-PROTO-0001 §9). *Durum: kişiye bildirim kuralı tanımlı; standart bildirim ucu ve ertelenmiş verme sunulmuyor.*

Aynur'un diploması artık cüzdanında, on kopya hâlinde, her biri ayrı bir anahtara bağlı. Timur'un ona nasıl soracağı, cüzdanın neyi göstereceği ve doğrulayıcının hangi sırayla neyi denetleyeceği sonraki bölümlerin konusu.

10 Gösterme: OpenID4VP, DCQL ve Yakın Alan

Aynur kurgusal Örnek Holding'in bir ilanına başvuruyor. Bakü'deki diploması için bugün bu yol açık değil: ağda yalnız Türkiye listesi etkin, Azerbaycan için yer ayrılmıştır (hiçbir devletle anlaşma ya da görüşme bildirimi değildir). Bu yüzden örneği, Aynur'un Türkiye listesindeki kurgusal Örnek Üniversitesi'nden aldığı diploma üzerinden kuruyoruz. İşe alım sorumlusu Timur'un ekranında bir QR kod beliriyor; Aynur okutuyor, cüzdanı ona kimin ne istediğini söylüyor, Aynur onaylıyor ve birkaç saniye sonra ekranda "kabul" yazıyor. Bir diploma bir kez verilir ama onlarca kez gösterilir ve her gösterimde üç soru vardır: Kim istiyor? Ne istiyor ve neden? Cevap yalnız ona mı ulaşıyor? Tamga bu soruları AB'nin seçtiği protokolle, **OpenID4VP 1.0** [31] (*OpenID for Verifiable Presentations*, doğrulanabilir sunum protokolü) ve onun AB'deki yüksek güvence profili **HAIP 1.0** [32] ile cevaplar (SPEC-PROTO-0002). Protokolün temeli dizinin sekizinci yazısında anlatıldı; burada Tamga'nın neyi neden seçtiğine odaklanıyoruz.

10.1 İmzalı istek ve doğrulayıcının kimliği

QR kodun içinde belge yoktur, kişisel veri de yoktur; yalnızca isteğin indirileceği bir adres (`request_uri`) vardır. Cüzdan bu adresten **imzalı bir istek nesnesi** indirir. İstek, doğrulayıcının (*verifier*) erişim sertifikasıyla imzalanmış bir JWT'dir; başlığında sertifika zinciri (`x5c`) bulunur. İmzasız istek reddedilir (PV6); imza olmadan cüzdan karşısındakinin kim olduğunu bilemez, kişiyi fazla talebe karşı da uyaramaz.

Doğrulayıcı kendini bir **istemci kimliğiyle** (*client identifier*) tanıtır. HAIP 1.0 §5, imzalı isteklerde doğrulayıcının `x509_hash` önekini kullanmasını ve cüzdanın onu kabul etmesini zorunlu tutar. Değer, isteği imzalayan yaprak sertifikanın özetinden hesaplanır. Tamga yalnız bu öneki kabul eder; daha önce kullanılan alan adı tabanlı önek (`x509_san_dns`) ve imzasız `redirect_uri` öneki reddedilir (ADR-0034). Alan adı kuralının güvenlik yanı korunur: yanıt adresinin alan adı, isteği imzalayan sertifikanın SAN alanında yazılı olmalıdır.

> TEKNİK AYRINTI
>
> **İstemci kimliği nasıl hesaplanır, neden ikinci bir kimlik gerekir**
>
> `x509_hash` değeri, yaprak sertifikanın DER kodlamasının SHA-256 özetinin base64url gösterimidir (OpenID4VP 1.0 §5.9.3):
>
> $$\text{client_id} = \text{x509_hash:} \parallel \text{base64url}(\text{SHA-256}(\text{DER}(\text{yaprak sertifika})))$$
>
> Liste yayıncısı aynı değeri doğrulayıcının erişim sertifikasından hesaplayıp güven listesindeki kayda yazar. Cüzdan istekteki değeri listedeki kayıtla eşleştirir ve doğrulayıcının kayıtlı adını, kapsamını ve durumunu bulur. Değer elle verilmez; paketler onu sertifikadan hesaplar (ADR-0034 CI1).
>
> Bu kimliğin bir zayıf yanı var: sertifika yenilenince özet de değişir. Takma adlar, belge kopyalarının eşlemesi ve geçiş kartları bu değere bağlansaydı her yenilemede kişinin hesapları ve kartları kaybolurdu. Bu yüzden her doğrulayıcı kaydı ayrıca **kalıcı bir kimlik** taşır: sertifikanın SAN alanındaki alan adı (`dns_name`). Sertifikadan bağımsız kalması gereken her şey bu alana bağlanır (ADR-0034 CI3, CI4). Kalıcı kimlik için `rp_id` de düşünüldü ama o da sertifikadan türediği için seçilmedi.

İstek bir şey daha taşır: doğrulayıcının o kullanım için aldığı **kayıt sertifikası** (*registration certificate*, ETSI TS 119 475 [46]). Erişim sertifikası "kim olduğumu", kayıt sertifikası "neyi, hangi amaçla istemeye kayıtlı olduğumu" söyler. Sertifika, isteğin `verifier_info` alanında gelir; yalnız güven listesindeki kayıttan üretilir ve kayıt kurumunun ayrı anahtarıyla imzalanır (ADR-0026). Cüzdan dört şeyi sırayla denetler: imzanın listelerin listesindeki kayıt kurumu anahtarına ait olduğunu, süreyi (en çok 12 ay), sertifikadaki kurum kimlik numarasının (`sub`) erişim sertifikasındaki `organizationIdentifier` ile aynı olduğunu ve istenen alanların sertifikanın kapsamında kaldığını. İlk üçünden biri tutmazsa cüzdan veri göndermez (ADR-0026 WRC4).

AB'nin 2026/1731 [7] sayılı uygulama tüzüğü bu doğrulamayı cüzdanda 2028-08-11'den itibaren zorunlu kılıyor. Tamga o tarihe kadar uyarıyla bir geçiş düşünmüştü; 2026-10-19'da geçiş kaldırıldı ve kayıt sertifikası taşımayan istek bugünden, kişiye sorulmadan reddedilir (ADR-0056 K10). Uyarı kayıtsız kullanıma kapı bırakıyordu ve kırıcı bir değişikliğin en ucuz anı, cüzdanlar yaygınlaşmadan önceydi. Kayıt sertifikaları 2026-10-29'dan beri bir politika kimliği ve kayıt kurumunun 1 bitlik iptal listesindeki bir girişi de taşır; cüzdan iptal edilmiş sertifikalı isteğe veri göndermez (ADR-0068, FW-POL-0003). **Durum:** çalışıyor (gerçek ağ ve sandbox).

10.2 DCQL ile ne isteniyor

Doğrulayıcı ne istediğini **DCQL** (*Digital Credentials Query Language*, dijital belge sorgu dili) ile söyler. OpenID4VP'nin eski taslaklarındaki Presentation Exchange Tamga'da hiç desteklenmez;

`presentation_definition` taşıyan istek reddedilir (PV1). İki sorgu motorunu birlikte bakımda tutmak, eski yükü olmayan bir ağ için yalnızca saldırı yüzeyi demekti.

DCQL'in en somut faydası, en küçük soruyu sorabilmektir. Öğrenci indirimi soran bir sinema yalnızca "öğrenci mi" diye sorar.

JSON Örnek: öğrenci indirimi için en küçük DCQL sorgusu (değerler örnektir)

```
{
  "credentials": [
    {
      "id": "student",
      "format": "dc+sd-jwt",
      "meta": { "vct_values": ["urn:tamga:edu:StudentCredential:1"] },
      "claims": [ { "path": ["is_enrolled"], "values": [true] } ]
    }
  ]
}
```

Sinema bu sorguyla adı, üniversiteyi, bölümü ve kayıt yılını görmez. Timur'un işe alım politikası ise diploma için sekiz alan ister (mezuniyet, unvan, seviye, alan kodu, veren kurum, tarih, ad, soyad); not ortalaması ve tez başlığı sorguda yer almadığı için cüzdandan çıkmaz. `vct_values` bir dizidir ve doğrulayıcıya en az iki şema sürümünü birlikte kabul etmesi önerilir; aksi hâlde bir şema yükseltmesi eski mezunları dışarıda bırakır (SPEC-PROTO-0002 §4.2).

Sorgu seçenek de sunabilir (`credential_sets`: "diploma ya da öğrenci belgesi"; `claim_sets`: "önce tezli, olmazsa tezsiz"). Her seçenek kişinin onay ekranında anlaması gereken bir karmaşıklıktır; bu yüzden bir istekte en çok üç belge ve iki `credential_sets` girişi olabilir (PV9). Sınırın tahmini olduğu ve kullanıcı testiyle ayarlanacağı şartnamede yazılıdır. İsteğe bağlı küme varsayılan olarak paylaşılmaz; istenen alanlardan birini taşımayan belge hiç gönderilmez (PV12). mdoc [34] biçimindeki kimlik belgesinde yaş soran doğrulayıcı yalnız `["tamga.id.1", "age_over_18"]` yolunu ister ve yalnız `true` görür.

10.3 Onay ekranı ve aşırı talep

Onay ekranı kişinin gördüğü tek yüzdür ve sırası kuralla belirlidir: kim istiyor (listedeki kayıtlı ad ve kayıt işareti), ne için (kayıt sertifikasındaki amaç metni), ne paylaşılacak (alan alan, değerleriyle), ne paylaşılmayacak (gizli kalan alanların yalnız adları), sonra onay ya da ret (SPEC-WALLET-0001 §5.1). Dördüncü madde alışılmadıktır. "Not ortalamanız paylaşılmayacak" satırı, seçici açıklamanın çalıştığını kişiye gösterir; görülmeyen bir koruma, kişi için yok gibidir.

İstek kayıtlı kapsamı aşarsa ne olur? Burada iki yol vardı: cüzdan isteği engelleyebilir ya da kişiyi uyarıp kararı ona bırakabilir. Tamga uyarmayı seçti. Cüzdan kişinin aracıdır; kişi bilerek kayıtsız bir araştırmacıya ya da bir teste belge göstermek isteyebilir. Ama uyarının gerçekten görülmesi gerekir. Onay düğmesinin yanındaki küçük gri bir yazı bunu sağlamaz; kural ayrı bir görsel blok ve geç etkinleşen bir düğme ister (WL8). Uyarı yorgunluğunu önlemek için olağan akışta hiçbir uyarı yoktur (Tablo 15).

Tablo 15. İsteğin durumuna göre cüzdanın davranışı.

Durum	Cüzdan ne yapar	Kaynak
Doğrulayıcı kayıtlı, bütün alanlar kapsamda	Olağan onay ekranı, uyarı yok	SPEC-WALLET-0001 §5.2
Kayıtlı ama bazı alanlar kapsam dışında	Kapsam dışı alanlar ayrı blokta ve farklı renkte; onay düğmesi 3 saniye gecikmeli	WL8
Doğrulayıcı listede kayıtlı değil	Akışı kesen ayrı ekran: "Kim olduğunu doğrulayamıyoruz" → Devam / İptal	SPEC-PROTO-0002 §6.1

Durum	Cüzdan ne yapar	Kaynak
İstekte kayıt sertifikası yok, sertifika geçersiz ya da iptal edilmiş	Kişiye sorulmadan ret; veri gitmez	ADR-0026, ADR-0056 K10, ADR-0068
Belge verenin paylaşım kuralı tutmuyor ya da değerlendirilemiyor	Ayrı uyarı bloğu, varsa “Kuralı oku”; varsayılan düğme “Paylaşma”, “Yine de paylaş” gecikmeli	ADR-0046
Aynı doğrulayıcıdan 24 saatte 3’ten fazla farklı sorgu	Kişiye bilgi: “Bu doğrulayıcı bugün 4 farklı belge sordu”	SPEC-WALLET-0001 §5.3

Beşinci satır belge verenin sesidir: kurum bir türün yalnız belirli doğrulayıcılara gösterilmesini isteyebilir (AB ARF [11] Konu 43). Kural belgenin içine konmadı; belge biçimi değişmesin, kural doğrulayıcıya açılmasın ve gösterimde ağ isteği gerekmesin diye kurumun imzalı belge verme bilgisinde (*Credential Issuer metadata*) değer olarak yayımlanır, cüzdan onu belgeyle birlikte saklar (ADR-0046). Kural tutmazsa son kararı yine kişi verir; kesin engel, aynı belgenin AB cüzdanında farklı davranmasına yol açacağı için reddedildi. Son satır ise doğrulayıcının farklı sorgularla kişinin hangi belgelere sahip olduğunu haritalamasını görünür kılar.

10.4 Yanıt ve şifreleme

Aynur onayladığında cüzdan yalnız istenen alanların açıklamalarını (*disclosure*) seçer ve bunlara bir **KB-JWT** (*Key Binding JWT*, cihaz bağı imzası) ekler. KB-JWT, belgenin bağlı olduğu cihaz anahtarıyla imzalanır ve üç şeyi birbirine bağlar: doğrulayıcının istemci kimliğinin tamamını (`aud`, önekiyle birlikte; PV7), isteğin tek kullanımlık değerini (`nonce`) ve gönderilen dizinin özetini (`sd_hash` hesabı Bölüm 8’de). Böylece kaydedilmiş bir sunum ne başka bir doğrulayıcıya ne de aynı doğrulayıcının başka bir isteğine yeniden oynatılabilir.

TEKNİK AYRINTI

Tek kullanımlık değer neden 128 bit, mdoc’ta bağ nasıl kurulur

İstekteki `nonce` ve `state` en az 128 bit rastgeledir (SPEC-PROTO-0002 §3). Bir saldırganın tek denemede doğru değeri tutturma olasılığı şudur:

$$P = 2^{-128} \approx 2.9 \cdot 10^{-39}$$

mdoc biçiminde aynı bağ, cihaz imzasının üzerine kurulduğu oturum dökümüyle (*SessionTranscript*) sağlanır. OpenID4VP 1.0 Ek B.2.6.1’e göre döküm, istemci kimliğini, `nonce`’u, yanıtın şifrelendiği anahtarın RFC 7638 [24] parmak izini ve yanıt adresini birlikte özetler:

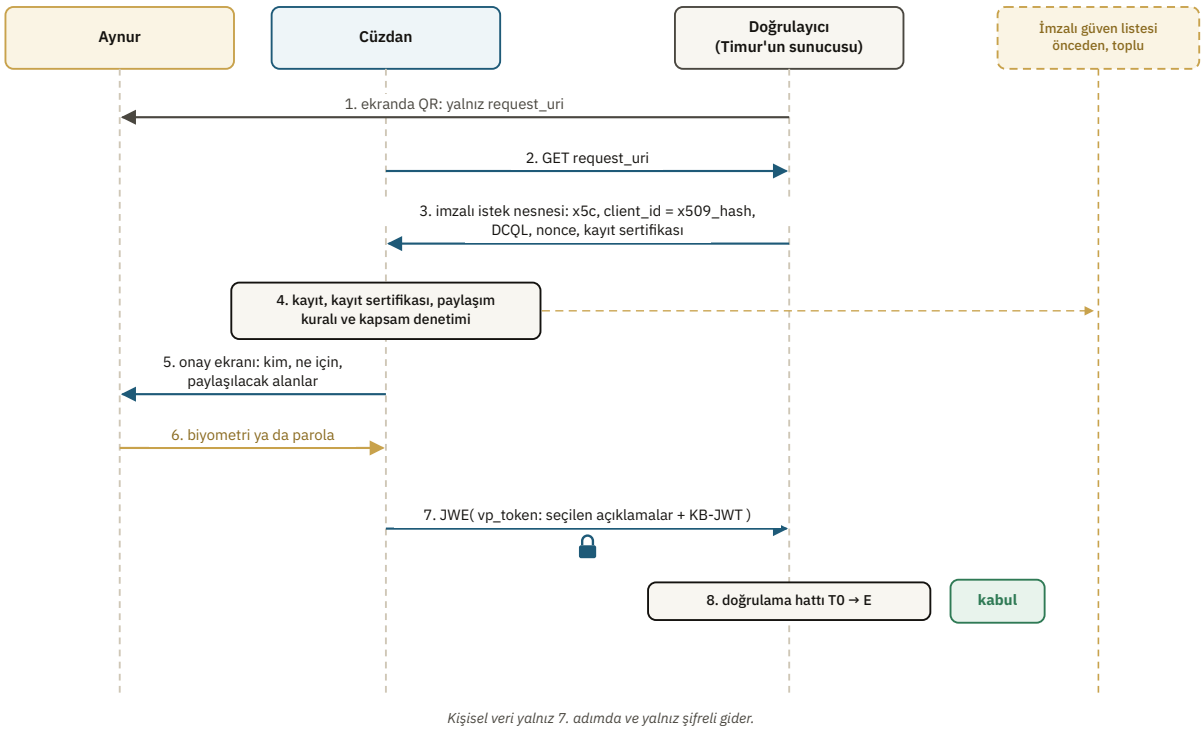
$$\text{SessionTranscript} = [\text{null}, \text{null}, [\text{OpenID4VPHandover}, \text{SHA-256}(\text{CBOR}([\text{client_id}, \text{nonce}, \text{jwkThumbprint}, \text{response_uri}]))]]$$

Başka bir isteğe taşınan cihaz yanıtı, doğrulamanın A6 adımında reddedilir (PV11).

Sunum kişisel veri taşır. Bu yüzden yanıt her zaman şifrelidir: istek nesnesindeki doğrulayıcı anahtarıyla JWE olarak (`ECDH-ES`, `A128GCM` ya da `A256GCM` HAIP §5) yanıt adresine gönderilir (`direct_post.jwt`). Şifresiz yanıt kipleri hiç kullanılmaz (PV3). Taşıma katmanının şifrelemesi yetmez; yanıt adresinin önündeki ters vekil, güvenlik duvarı ya da günlük sistemi içeriği görebilir. Yanıt ucu geçerli yanıta yalnızca bir dönüş adresi verir; başka bir şey dönmez (OpenID4VP 1.0 §8.2).

Aynur vermemeyi seçerse cüzdan yalnız “vermedi” der (`access_denied`) ve nedenini söylemez (PV5). “Kişinin bu belgesi yok” ile “kişi vermek istemedi” arasındaki fark doğrulayıcıya sızarsa, doğrulayıcı sorgu yaparak kişinin hangi belgelere sahip olduğunu çıkarabilir. Aşağıdaki adımlar ve Şekil 15 akışın bütününü gösterir.

1	`Timur'un sunucusu`	**Sunum aç.** Politikadan DCQL üretir, tek kullanımlık değerlerle istek nesnesini hazırlar; QR'a yalnız adres girer.	$\text{nonce}, \text{state} \leftarrow \text{rastgele}_{\geq 128\ \text{bit}}$
2	`Cüzdan → Doğrulayıcı`	**İsteği çek.** Adresten imzalı istek nesnesini indirir; her çekim ayrı bir daldır (§10.5).	GET request_uri
3	`Cüzdan`	**Denetle.** İmza ve zincir, istemci kimliğinin listedeki kaydı, kayıt sertifikası ve durumu, paylaşım kuralı, kapsam.	$\text{client_id} \stackrel{?}{=} \text{kayıt.client_id}$
4	`Aynur`	**Onayla.** Ekranda kimin, ne için, hangi alanları istediğini görür; cihaz biyometrisi ya da parolasıyla onaylar.	$\text{kullanıcı doğrulaması}$
5	`Cüzdan`	**Yanıtı kur.** Yalnız istenen açıklamaları seçer, KB-JWT'yi imzalar.	$\text{aud} = \text{client_id}, \quad \text{sd_hash}$
6	`Cüzdan → Doğrulayıcı`	**Gönder.** Yanıtı doğrulayıcının anahtarıyla şifreleyip yanıt adresine gönderir.	$\text{JWE}(\text{vp_token})$
7	`Doğrulayıcı`	**Doğrula.** Yanıtı çözer ve doğrulama hattını (Bölüm 11) çalıştırır; sonucu üç değerden biri olarak verir.	$\text{T0} \rightarrow \text{A} \rightarrow \text{B} \rightarrow \text{C} \rightarrow \text{D} \rightarrow \text{E}$



Şekil 15. Uzaktan gösterme: imzalı istek, onay ve şifreli yanıt

10.5 Sahte rete karşı çekim dalları

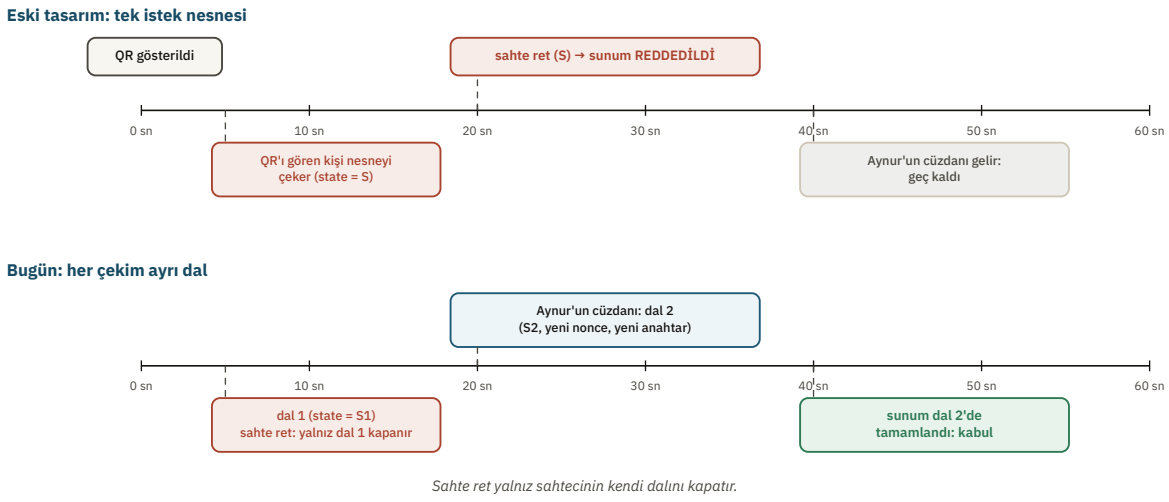
2026-10-29'da kapatılan bir açık, standardın bir boşluğunu iyi gösterir. OpenID4VP 1.0'da cüzdanın ret yanıtı imzasızdır ve şifresiz gönderilebilir; reddi sunuma bağlayan tek şey `state` değeridir. Tamga'da `state` imzalı istek nesnesindeydi ve istek nesnesi QR'daki adresten herkes tarafından, kimlik doğrulaması olmadan çekilebiliyordu. Timur'un ekranındaki QR'ı yandaki masadan gören biri nesneyi çekip "kişi reddetti" diye sahte bir yanıt gönderebilir ve Aynur'un başvurusunu bozabilirdi. Kişisel veri sızmazdı ama işlem engellenirdi.

Çözüm, istek adresinin her çekiminde yeni bir **çekim dalı** açmaktır (ADR-0067). Her çekim aynı içerikle yeniden imzalanmış bir istek nesnesi alır; ama `state`, `nonce` ve yanıt şifreleme anahtarı her dalda tazedir. QR'ı gören kişi yalnız kendi dalının `state`'ini öğrenir. Onun sahte reddi yalnız kendi dalını kapatır; Aynur'un cüzdanı kendi dalında sunumu tamamlar. Sunum bütünüyle ancak tek çekimi varsa ve o dal kapandıysa reddedilmiş sayılır; birden çok çekim varsa süresi bitene kadar açık kalır ve ilk geçerli sunum kazanır (Tablo 16).

Tablo 16. Sahte ret sorunu için değerlendirilen seçenekler (ADR-0067).

Seçenek	Sonuç	Neden
İlk ret sunumu kapatır (yaygın uygulama)	ret	QR'ı gören herkes gerçek kişinin işlemini bozabilir
Cüzdan reddi cihaz anahtarıyla imzalar	ret	Standart dışı; reddin kimin cihazından geldiğini doğrulayıcıya bağlar ve "ret nedeni sızmaz" ilkesiyle çelişir
Ret sunumu hiç kapatmaz	ret	Olağan akışta kişi "vermedim" dediğinde doğrulayıcı süre bitene dek bekler
Her çekim ayrı dal, ret yalnız kendi dalını kapatır	**seçildi**	Standardın içinde kalır; HAIP'in "her istekte efemer anahtar" kuralının daha sıkı karşılığıdır

Dalların bir bellek bedeli vardır. İlk tasarımdaki sabit sınır (sunum başına 10 dal) kendisi bir engelleme yoluydu; bugün 10'u aşan çekim, hiç yanıt almamış ve en az 120 saniyelik en eski dalın yerini alır, 32'de yaş koşulu düşer, yanıtı işlenen dal hiç atılmaz. Sahiplik kanıtına ulaşmayan yanıtlar dal başına sayılır ve beşincide yalnız o dal kapanır. Kalan risk kayıtlıdır: QR'ı gerçek cüzdandan önce çekip hemen reddeden biri tek dallı sunumu kapatabilir; bu, cihazlar arası akışın bilinen sınırıdır (OpenID4VP 1.0 §14) ve doğrulayıcı yeni sunum açar. **Durum:** çalışıyor (paketler 0.7.4'ten beri) (Şekil 16).



Şekil 16. Sahte ret saldırısı ve çekim dalları

10.6 Tarayıcıdan gösterme

Aynur başvuruyu telefonundan, şirketin sitesinde yapsaydı QR'a gerek kalmazdı. W3C'nin **Digital Credentials API** [36]'si (dijital belge arayüzü) tarayıcının cüzdanı doğrudan çağırmasını sağlar; yanıt kipi `dc_api.jwt` olur (OpenID4VP 1.0 Ek A). Bu yolun güçlü bir yanı vardır: sunumun hedefi, tarayıcının kendisinin verdiği köken (*origin*) değeridir. Sahte bir site kendi kökeninden başkasını iddia edemez; oltalamaya karşı kuvvetli bir bağdır. Ama köken tek başına doğrulayıcının neyi istemeye yetkili olduğunu söylemez. Tamga bu yüzden bu yolda da imzalı istek nesnesini kullanır: köken oltalamayı, `x509_hash` yetki denetimini çözer (SPEC-PROTO-0002 §7.2).

Bazı tarayıcılar OpenID4VP'yi bu arayüz üzerinden taşımaz ve mdoc'u ISO/IEC 18013-7 [35] Ek C ile ister. Doğrulayıcı bu durumda aynı sunum için ikinci bir istek üretir; yanıt HPKE [25] (RFC 9180) ile şifrelenir ve oturum dökümü sayfanın kökenini içerir. Masaüstünde tarayıcı arayüzü varsa varsayılan yol odur; QR yedek olarak yanında kalır. **Durum:** doğrulayıcı tarafı çalışıyor; cüzdan tarafı planlanan (ağdaki ilk cüzdanda Android kodu yazıldı, henüz derlenmedi ve cihazda denenmedi; iOS yok; FW-ARF-0001 §2.8).

10.7 Web sitelerine giriş

Dilnoza bir sitenin geliştiricisi ve sitesine "Tamga ile giriş yap" düğmesi koymak istiyor (ürün adı ADR-0030). Bu akış da aynı OpenID4VP isteğidir; fark, sitenin hesap anahtarı olarak **site başına bir takma ad** almasıdır, belge değerlerinden hiçbiri hesap anahtarı olmaz (ADR-0031). Kayıtta site yalnız politikasında izin verilen alanları (örneğin ad ve soyad) ve o siteye özgü bir takma ad anahtarını görür. İki farklı site aynı kişiyi eşleştiremez; kişi telefonunu değiştirip kimliğini yeniden doğruladığında aynı takma adlar geri gelir. Günlük giriş sitenin kendi passkey'iyle yapılır ve hiçbir belge alanı paylaşılmaz. Takma adın nasıl türetildiği, kalan riski (kimlik servisinin takma adı teorik olarak türetebilmesi) ve sıfır bilgi ispatıyla kaldırılma hedefi Bölüm 15'te anlatılıyor. **Durum:** çalışıyor.

10.8 Yakın alan: köprüler ve hedef

Uzaktan göstermede QR'ı doğrulayıcı gösterir, cüzdan okur. Kapıda, gişede ya da bir görevlinin karşısında ise tersi gerekir: QR'ı cüzdan gösterir. ARF bu alanı ISO/IEC 18013-5 ile çözer. Cüzdanın gösterdiği QR yalnızca bir tanışmadır (*device engagement*); asıl istek ve cevap Bluetooth ya da NFC üzerinden, oturum şifrelemesiyle yürür ve belge mdoc biçimindedir (dizinin dokuzuncu yazısı [74]).

Tamga bu hedefi kodladı ama henüz cihazlarda sınamadı. O güne kadar iki köprü yol kullanılır (ADR-0012). İkisinin dayandığı ilke şudur: **doğrulama için tek kullanımlık değeri, ikna olmak isteyen taraf üretir.** Cüzdan QR gösteriyorsa ya ikinci bir kanal açılır (ISO 18013-5) ya da kısa bir zaman penceresi ve tekrar listesiyle yetinilir. Tek bir QR'ın taşıyabileceği yaklaşık 2,9 KB, bir SD-JWT [15] VC'yi ve sertifika zincirini taşımaya yetmez; QR ya bir başvuru adresi ya da küçük, imzalı, kişisel verisiz bir jeton taşır.

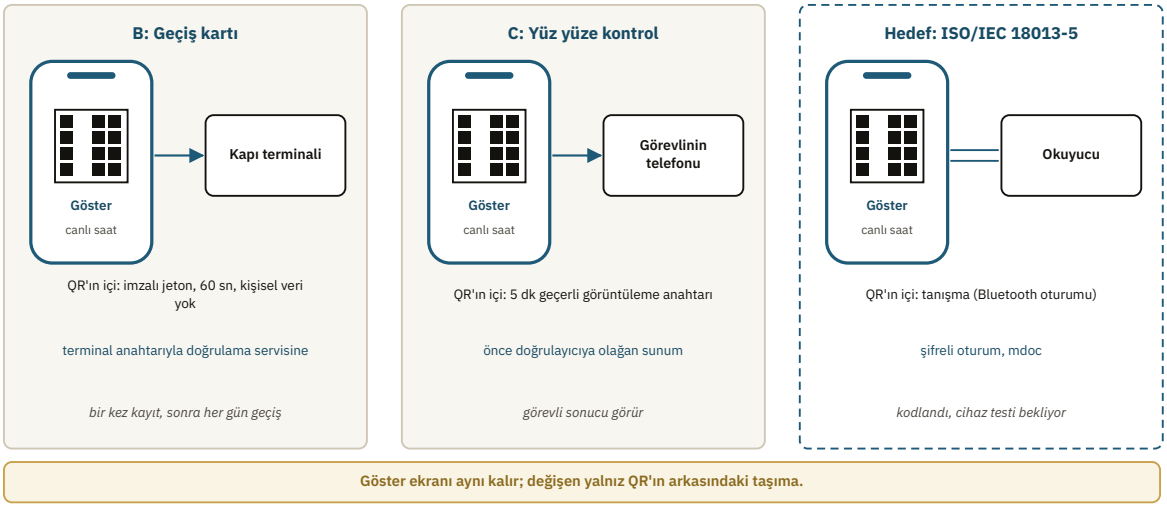
- **B, geçiş kartı.** Kişi belgesini bir kez, olağan uzaktan akışla, kayıtlı bir doğrulayıcıya gösterir ve karşılığında bir geçiş hakkı alır. Sonra her geçişte cüzdan 60 saniyelik, kişisel veri içermeyen imzalı bir jeton gösterir (§10.9).
- **C, yüz yüze kontrol.** Kişi kontrolü cüzdandan kendisi başlatır; sunum olağan uzaktan yoldan Tamga Verify'a gider. Kabulde cüzdana dönen adres beş dakika geçerli bir görüntüleme anahtarı taşır; cüzdan bunu QR olarak gösterir, görevli okutunca sonucu görür (SPEC-PROTO-0002 §5.4). Kişi alanları gösterimden önce onaylamıştır.
- **Hedef, ISO/IEC 18013-5.** Bluetooth üzerinden mdoc. Okuyucu kayıt sertifikasını isteğin içinde CBOR [29] biçiminde gönderir ve isteği kendi sertifikasıyla imzalar; cüzdan uzaktan akıştaki denetimleri burada da yapar ve okuyucu sertifikasının listeye bağlandığını ayrıca doğrular (SPEC-PROTO-0002 §7.5). NFC bu aşamada yoktur.

Köprüler standardı taklit etmez: C standart OpenID4VP'dir, B ise standart dışı olduğu açıkça yazılı, sürümlü bir jetondur. "Göster" ekranı üç yolda aynıdır; Bluetooth gelince yalnız QR'ın arkasındaki taşıma değişir (Şekil 17) (Tablo 17).

Tablo 17. Gösterme kanalları ve bugünkü durumları.

Kanal	Kim QR gösterir	Mekanizma	Durum
Aynı cihaz (bağlantı)	yok	OpenID4VP, `direct_post.jwt`	Çalışıyor

Kanal	Kim QR gösterir	Mekanizma	Durum
Farklı cihaz (QR)	doğrulayıcı	OpenID4VP, `direct_post.jwt`, çekim dalları	Çalışıyor
Tarayıcı (Digital Credentials API, 18013-7 Ek C)	yok	OpenID4VP `dc_api.jwt` mdoc için Ek C	Doğrulayıcı çalışıyor; cüzdan planlanan
Geçiş kartı (B)	cüzdan	60 sn imzalı jeton + terminal anahtarı	Çalışıyor (sandbox; gerçek ağda bugün kapı politikası yok)
Yüz yüze kontrol (C)	cüzdan	Olağan sunum + 5 dk görüntüleme anahtarı	Çalışıyor (Tamga Verify)
Bluetooth (ISO/IEC 18013-5)	cüzdan	Tanışma QR'ı + BLE oturumu, mdoc	Planlanan (kodlandı, cihaz testi bekliyor)
NFC	—	—	Bu aşamada yok



Şekil 17. Yakın alanda üç yol: geçiş kartı, yüz yüze kontrol ve ISO/IEC 18013-5 hedefi

10.9 Kapı ve bilet

Nurlan bir konsere gidiyor. Bileti, bilet satıcısının verdiği bir belgedir ve kişisel veri taşımaz: etkinlik, mekân, bilet sınıfı, koltuk ve satıcının bilet numarasının özeti vardır, ad yoktur (FW-RB-0004). Bilet cihaz anahtarına bağlıdır; Nurlan onu arkadaşının telefonuna kopyalayamaz.

Nurlan bileti konserden önce bir kez kapının doğrulayıcısına gösterir ve bir geçiş hakkı alır. Kapıda cüzdan bir jeton imzalar ve QR olarak gösterir. Jetonun içinde yalnızca opak bir geçiş kimliği, hedef doğrulayıcı, zaman alanları ve tekrar kimliği vardır; QR 400 baytı geçmez. Ekranda canlı saat ve 60 saniyelik geri sayım bulunur; ekran görüntüsü süre dolunca işe yaramaz.

1	`Nurlan → Doğrulayıcı`	**Kayıt.** Bileti olağan uzaktan akışla bir kez gösterir; doğrulayıcı yalnız kabul sonucundan bir geçiş hakkı verir.	$\text{pass_grant} \leftarrow \text{ACCEPTED}$
2	`Cüzdan`	**Jeton.** Kapıda kopya anahtarıyla kısa ömürlü jetonu imzalar; QR'a yalnız jeton girer.	$\text{exp} - \text{iat} \leq 60$ sn
3	`Kapı → Tamga Verify`	**Doğrulama isteği.** Jetonu, terminal grubuna bağlı terminal anahtarıyla gönderir.	$\text{Authorization: Bearer tk_...}$

4	`Tamga Verify`	**Denetim.** Anahtarı, grubun listede etkin olduğunu, imzayı, süreyi, tekrar kimliğini ve biletin kullanılmamış olduğunu denetler.	$\text{jti} \notin \text{tekrar listesi}$
5	`Tamga Verify → Kapı`	**Geçiş.** Kabulde bileti tüketir; aynı biletin ikinci geçişi reddedilir.	$\text{kullanıldı} = 1$

Aynı jetonun iki kez okutulmasına karşı terminal grubunun kapıları jeton kimliklerini (`jti`) ortak bir listede tutar. Aynı biletin iki kez kullanılmasına karşı bilet iptal listesindeki bir bitle "kullanıldı" yapılır; liste sabit aralıkla yayımlandığı için (Bölüm 12) aralığın içindeki ikinci geçişi kapıların ortak "kullanıldı" listesi keser. Çevrim dışı bir kapı yalnız süreyi denetler ve 60 saniye içinde kopyalanan bir QR'ın başka kapıda geçmesi riskini kabul eder (ADR-0012 K3).

2026-10-26'daki güvenlik incelemesi, kapıların istek gönderdiği ucun kimlik istemediğini buldu: QR'ı gören biri jetonu kendisi gönderip bileti tüketebilir, gerçek kapıda Nurlan'ı durdurabilirdi. Karar, her terminal grubunun işletmeciden aldığı 192 bitlik bir **terminal anahtarıyla** kimlik göstermesidir; anahtarsız istek jetona hiç dokunmaz, sunucu yalnız anahtarın özetini saklar (ADR-0065). Karşılıklı TLS ve kapı sertifikası hedef olarak kaldı; erişim sertifikasının özel anahtarını her kapı cihazına dağıtmak reddedildi. 2026-10-29'dan beri kapı grupları imzalı listede, doğrulayıcı kaydının altında, kapıları işleten kurum ve kabul edilen politikalarla durur; kurum yalnız kendi kapılarının anahtarlarını yönetir, listeden çekilen grubun kapıları hemen durur (ADR-0069).

Organizatör hem veren hem doğrulayan taraf olduğu için bilette bağlanamazlık anlamsızdır ve bu kabul edilmiştir. Geçiş kartı her gösterimde biyometri sormaz; bu, kayıtta verilen süreli (en çok yaklaşık 6 ay) ve kapsamı belli bir rızaya dayanır, her gösterim cüzdanın geçmişine yazılır ve rıza her an geri alınır (WL13, WL14). **Durum:** sandbox'ta çalışıyor; gerçek ağda bugün tanımlı bir kapı politikası yok; sertifikalı ve çevrim dışı kapı kimliği için alan ve okuyucu hazır, kullanılmıyor (planlanan).

11 Doğrulama Hattı: Beş Katman, Üç Sonuç

Timur'un ekranında "kabul" yazmadan önce, sunucusunda otuzdan fazla küçük denetim sırayla çalıştı. Bir belgeyi doğrulamak "imza tutuyor mu" sorusundan ibaret değildir. İmza geçerli olabilir ama belgeyi imzalayan kurum o türü vermeye yetkili olmayabilir; yetkili olabilir ama belge iptal edilmiş olabilir; her şey yerinde olabilir ama doğrulayıcı istediğinden fazlasını almış olabilir.

11.1 Neden sabit bir hat

Tamga doğrulamayı tek bir normatif sıraya bağlar ve her adıma kalıcı bir kod verir (SPEC-API-0001 §1). Bunun üç nedeni var. Birincisi tutarlılıktır: aynı belge hangi doğrulayıcıda, hangi paketle doğrulanırsa doğrulansın aynı sonucu almalıdır. İkincisi açıklanabilirliktir: "doğrulama başarısız" yerine "C2'de düştü, kurum bu türü vermeye yetkili değil" denebilir. Üçüncüsü denetimdir: sonuçlar denetim kayıtlarında yıllarca saklanır. Bu yüzden bir adım kodunun anlamı asla değişmez; yeni adım yeni kod alır, kaldırılan kod yeniden kullanılmaz (AP1). C2'nin anlamı 2029'da değişseydi 2027 kayıtları yanlış okunurdu.

Adımlar sırayla çalışır ve ilk başarısızlıkta durulur; yalnız denetim kaydı (E4) her durumda yazılır. HTTP durum kodu sonucu taşımaz: reddedilen bir belge başarılı bir API çağrısıdır ve 200 döner, 4xx yalnız istek hatasıdır (AP5). Karıştırılırsa istemciler ağ hatasını geçersiz belgeden ayıramaz, izleme sistemleri de reddedilen belgeleri arıza sanar.

11.2 Katmanlar

Tablo 18 katmanları ve her birinin seçilmiş adımlarını verir.

Tablo 18. Doğrulama hattının katmanları ve seçilmiş adım kodları (tam liste SPEC-API-0001 §1).

Katman	Sorduğu soru	Seçilmiş adımlar
T0 Ön koşul	Elimdeki güven listesi taze mi?	Liste bayat ya da erişilemezse, politikanın tazelik sınırları eksikse: doğrulanamadı
A Biçim	Belge bozulmamış mı, imzalı mı, bu isteğe mi ait?	A2 başlık (`ES256` , `dc+sd-jwt` , `x5c`) · A3 zincir köke ulaşıyor · **A3b** kurum kimliği sertifikadan · A3d cihaz bağı (`cnf`) var · A5 her açıklamanın özeti belgede · A6 KB-JWT (`aud` , `nonce` , `sd_hash`) · A7 süre
Z1 Sıfır bilgi yolu	İspat geçerli mi?	Devre listede ve dosya özeti eşleşiyor; yalnız istenen öğeler açıklanmış (Bölüm 15)
B Tür	Belge türü tanınıyor mu?	B2 tür kayıtlı ve geri çekilmemiş · B4 tür tanımının özeti `vct#integrity` ile aynı · B6 JSON Schema uyumu
C Güven	Kurum listede mi, bu türe yetkili mi?	C1 kurum belgenin verildiği anda kabul edilebilir miydi · **C2** kurum bu türe yetkili miydi (atlanamaz) · C3 tanıma · C4 kategori göstergesi kayıtla uyumlu
D Durum	Belge iptal ya da askıda mı?	D2 iptal listesi ön çekim önbelleğinden · D3 liste imzacısı kurumun kayıtlı iptal anahtarı · D4 tazelik · D5 çapa günlüğüyle eşleşme, sürüm geri gitmemiş · D6 bit değeri
E Politika	Doğrulayıcının istedikleri karşılanıyor mu?	E1 kurum sınıfı eşiği · E2 istenen alanlar açıklanmış · E3 kayıtlı kapsam aşılmamış · E4 denetim kaydı yazıldı

İki adım, tablonun içinde kaybolmamalı. **A3b**, kurumun kimliğini belgenin `iss` alanından değil, imzalayan yaprak sertifikanın parmak izinden türetir. Neden önemli olduğu bir saldırıyla görülür: doğrulayıcı kimliği `iss`'ten okusaydı, aynı kök altında geçerli sertifikası olan herhangi bir kurum `iss` alanına başka bir üniversitenin adresini yazıp onun adına belge üretebilirdi. İmza kendi sertifikasıyla geçerli, zincir geçerli, `iss` sahte olurdu. `iss` bu yüzden yalnız tutarlılık denetiminde kullanılır (AP12). Kimliğin nasıl türetildiği Bölüm 6'da.

C2 ise hiçbir yapılandırmayla atlanamaz (AP8). Bir doğrulayıcı politikayı istediği kadar gevşetebilir ama "bu kurum bu belge türünü vermeye yetkili miydi" sorusunu kapatamaz. Kapatabilseydi, listedeki her kurum her türlü belgeyi geçerli gösterebilirdi.

Paketler bu sırayı tek bir işlevde uygular ve güvenlik girdilerinin unutulmasına izin vermez. Güven çapası, doğrulayıcı kaydı ya da iptal listesi imzacısı verilmezse işlev reddeder; bir denetimi bilerek atlamak isteyen bunu açık bir `"none"` değeriyle yazmak zorundadır ve atlanan adım sonuçta görünür (ADR-0056 MR1). Unutmak artık ret demektir; bilerek atlamak koda yazılı, incelemede görünür bir karardır.

11.3 Zamana bağlı yetki

C1 ve C2 belgenin verildiği anı sorar: kurum, belgenin `iat` anında listede etkin ve bu türe yetkili miydi (AP11)? Bunun yerine "kurum bugün belge verebilir mi" diye sorulsaydı iki sessiz hata çıkardı. Kapanan bir kurumun daha önce verdiği bütün diplomalar bir gecede geçersiz görünürdü. Bir tür yeni sürüme geçip eskisi geri planlanınca eski sürümle verilmiş her belge reddedilirdi. Planlı bir sertifika yenilemesi bile belgeleri düşürürdü. Doğrulama geçmişe dönük bir işlemdir: belge geçmişte verilmiştir ve belirleyici olan o günkü durumdur (FW-ARF-0001 §4.4).

Bu kuralın bir sınırı vardır ve o sınır iptaldir. Kurum belgenin verildiği gün yetkiliyse belge C katmanından geçer; ama belge sonradan iptal edildiyse D katmanında düşer. Zaman ekseni güven için geriye, durum için bugüne bakar.

11.4 Üç değerli sonuç

Hattın sonucu üç değerden biridir: **kabul** (`ACCEPTED`), **ret** (`REJECTED`) ve **doğrulanamadı** (`INDETERMINATE`). Üçüncüsü bir hüküm değildir; altyapıya ulaşılamadığını ya da bilginin bayat olduğunu söyler. "Bu diploma sahte" ile "şu an kontrol edemiyorum" arasındaki fark, bir insanın işe alınıp

alınmamasıdır. Bu yüzden doğrulanamadı sonucu ret ile aynı kovaya konmaz ve kullanıcı arayüzünde ayrı gösterilir (AP2). Doğrulanamadı sonucunun nedeni zorunlu bir alanda gelir: tür tanımına ulaşılamadı, iptal listesine ulaşılamadı, iptal listesi bayat, iptal listesindeki değerin tanımlı bir anlamı yok, güven listesi bayat gibi.

TEKNİK AYRINTI

Sonuç nasıl birleşir

Hattın adımlarını sabit sırayla $s_1, s_2, \ldots, s_n$ diye yazalım (T0, A1 … E3). Her adımın çıktısı "geçti", "ret" ya da "doğrulanamadı"dır. Hat ilk başarısızlıkta durduğu için sonuç, geçmeyen ilk adımın çıktısıdır; hiçbiri yoksa kabuldür:

$$k^* = \min(k : s_k \neq \text{geçti})$$

$$\text{sonuç} = s_{k^*} \quad (\text{böyle bir adım yoksa } \mathrm{ACCEPTED})$$

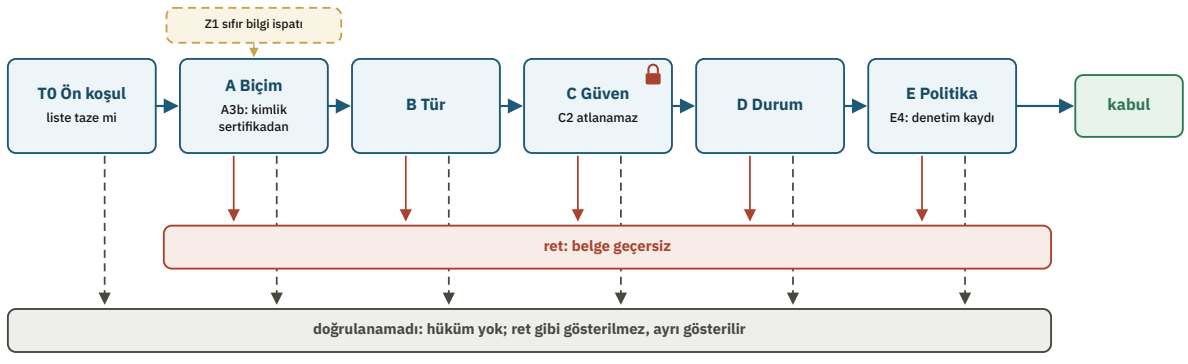
Bu kuralın bir sonucu vardır: güven listesi bayatsa (T0) sonuç doğrulanamadı olur ve sonraki adımlar hiç çalışmaz; belge sahte olsa bile "ret" denmez. Bayat bir listeyle verilecek bir ret, listeye yeni eklenmiş bir kurumun doğru belgesini de reddedebilirdi. Beklenmeyen bir yazılım hatası da aynı kuralla doğrulanamadı verir, ret vermez.

Sonuç nesnesinde iki şey hiç bulunmaz. Açıklanan alanların **değerleri** sonuç nesnesine girmez, yalnız adları girer (AP3); değerler ayrı bir uçtan, ayrıca yetkilendirilerek alınır. İptal listesindeki konum (`idx`) ise hiçbir yanıtta ve kayıtta yer almaz (AP4). Sonuç nesnesi denetim kaydına yazılır ve uzun süre saklanır; bu iki kural, o kaydın bir izleme aracına dönüşmesini engeller.

JSON Örnek: kısaltılmış bir sonuç nesnesi; değer yok, idx yok (değerler örnektir)

```
{
  "verification_id": "vrf_01J8XKQ2M4",
  "outcome": "ACCEPTED",
  "failed_step": null,
  "indeterminate_reason": null,
  "spec_version": "SPEC-API-0001@1.0.0",
  "sdk_version": "@tamga-network/verifier@0.8.2",
  "checks_performed": ["T0", "A1", "A2", "A3", "A3b", "…", "D6", "E1", "E2", "E3", "E4"],
  "checks_skipped": [],
  "issuer": { "issuer_id": "0x7f3a…", "state_code": "TR", "category": "EDUCATION", "assurance": "I2" },
  "schema": { "vct": "urn:tamga:edu:DiplomaCredential:1", "status": "ACTIVE" },
  "disclosed_claims": ["is_graduate", "qualification_title", "eqf_level", "isced_f_code",
                       "awarding_body_name", "awarding_date", "family_name", "given_name"],
  "status": { "value": "VALID", "token_age_sec": 1830 },
  "evaluated_at": "2026-11-04T09:12:44Z"
}
```

`checks_skipped` boş değilse doğrulayıcı bunu görünür kılmalıdır; bir denetimin atlandığını sessizce kabul etmek, atlanmasının amacını boşa çıkarır (Şekil 18).



Şekil 18. Doğrulama hattı: altı kapı, üç çıkış

11.5 Barındırılan doğrulayıcı

Her doğrulayıcı bu hattı kendi sunucusunda çalıştırabilir; paketler açıktır ve değerler hiçbir aracıya uğramaz. Kendi altyapısını kurmak istemeyenler için ağın barındırdığı doğrulayıcı **Tamga Verify**'dır (ADR-0030). Bir aracı yeni bir risk getirir ve bu risk ADR-0017 ile daraltıldı. İlk tasarımda değer uçları sunum kimliğini bilen herkese cevap veriyordu; kimlik tarayıcı geçmişinde ya da ekran paylaşımında görünebilirdi. Bugün değer döndüren her uç yalnız sunumu açan doğrulayıcıya açıktır. Doğrulayıcı kimliğini, listede kayıtlı erişim sertifikasının anahtarıyla imzaladığı en çok 60 saniyelik, tekrar edilemeyen bir beyanla kanıtlar; yeni bir sır gerekmez. Değerler bir kez okunur ve en geç beş dakika sonra bellekten silinir; tarayıcıya giden hiçbir jeton değer okuma yetkisi taşımaz (ADR-0017 HV1–HV5). Site başına statik API anahtarı, ayrı bir OAuth sunucusu ve karşılıklı TLS aynı güvenceyi daha fazla sır ya da işletim yüküyle verdiği için seçilmedi. Tamga Verify bir doğrulayıcı adına istek açtığında cüzdan **asıl doğrulayıcının** kayıtlı adını gösterir, aracıyı ayrıca belirtir ve kapsamı asıl doğrulayıcının kaydına göre denetler; aracı ilişkisi iki kayıtta da yazılı değilse istek reddedilir (PV14). **Durum:** çalışıyor.

12 İptal ve Yaşam Döngüsü

Elif, Örnek Üniversitesi'nin öğrenci işlerinde çalışıyor. Bir sabah, bir mezunun tezinde intihal şüphesi olduğuna dair bir yazı geliyor. İnceleme haftalar sürecek. Elif'in elinde iki kötü seçenek olsaydı, diplomayı ya haksız yere kalıcı olarak iptal edecek ya da inceleme bitene kadar hiçbir şey yapmayacaktı. Bu bölüm, bir belgenin sonradan nasıl geri alındığını ya da askıya alındığını ve bunun neden kimseyi izlemeden yapılması gerektiğini anlatıyor. Konunun temeli dizinin yedinci yazısında [72] anlatıldı.

12.1 Geri almak, izlemeden

Kurumun "bu belge artık geçerli değil" diyebilmesi için doğrulayıcının bir yere bakması gerekir. En kolay yol her doğrulamada kuruma sormaktır; ama o zaman kurum mezunlarının hangi işverenlere ne zaman başvurduğunu öğrenir ve kâğıt diplomada olmayan bir takip kanalı doğar.

Tamga'nın cevabı, IETF'nin **Token Status List** [17] taslağıdır (iptal listesi, durum listesi; AB'nin 2026/1731 [7] ile sabitlediği draft-20 sürümü izlenir; SPEC-CRED-0003). Kurum her belgeye büyük bir bit dizisinde rastgele bir konum verir. Belge iptal edilince o konumdaki değer değişir. Dizi sıkıştırılır, imzalanır ve sabit aralıklarla yayımlanır. Doğrulayıcı diziyi önceden indirir ve belgeyi gördüğünde kimseye sormadan kendi kopyasına bakar. Kurum, belgenin nerede ve ne zaman gösterildiğini öğrenemez.

TEKNİK AYRINTI

Bir belgenin durumunu okumak

Belge `status.status_list` içinde konumunu (`idx`) ve listenin adresini (`uri`) taşır; bu alan seçici açıklamayla gizlenemez. Liste her belge için b bit kullanır (Tamga'da 1 ya da 2). Sıra numarası küçük olan belge baytın en düşük değerli bitine yerleşir. Açılmış dizinin n'inci baytına $D[n]$ dersek:

$$n = \left\lfloor \frac{i \cdot b}{8} \right\rfloor$$

$$k = (i \cdot b) \bmod 8$$

$$\text{durum} = \left\lfloor \frac{D[n]}{2^k} \right\rfloor \bmod 2^b$$

Örnek değerlerle, iki bitlik bir kurum listesinde konumu 48213 olan bir diploma:

$$i \cdot b = 48213 \cdot 2 = 96426$$

$$n = \left\lfloor \frac{96426}{8} \right\rfloor = 12053, \quad k = 96426 \bmod 8 = 2$$

$$\text{durum} = \left\lfloor \frac{D[12053]}{4} \right\rfloor \bmod 4$$

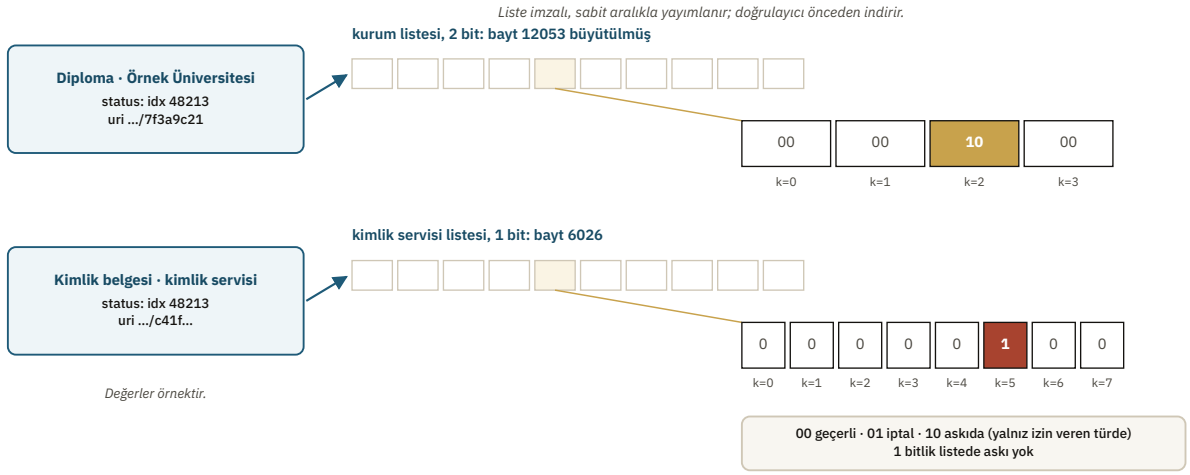
Aynı konum bir bitlik bir kimlik servisi listesinde olsaydı $n = \lfloor \frac{48213}{8} \rfloor = 6026$, $k = 48213 \bmod 8 = 5$ olurdu ve tek bit okunurdu. Listenin boyu da kolay hesaplanır. Asgari kapasite olan 100.000 konumla:

$$2 \text{ bit:} \quad 100.000 \cdot 2 = 200.000 \text{ bit} = 25.000 \text{ bayt}$$

$$1 \text{ bit:} \quad 100.000 \cdot 1 = 100.000 \text{ bit} = 12.500 \text{ bayt}$$

Liste büyük ölçüde sıfırdan oluştuğu için sıkıştırılmış boyutu tipik olarak birkaç yüz bayttır (SPEC-CRED-0003 §3.3).

Şekil 19 aynı örneği belgeden bite kadar izler.



Şekil 19. İptal listesi: belgeden konuma, konumdan bite

12.2 Neden zincirde değil

Bu kararın ilk hâli bir çelişkiden doğdu. 2026-09-09'daki depo denetiminde şartname "liste zincir dışında, işaretçi zincirde" diyordu; kontrat kodu ise bit dizisini zincirde tutuyordu ve her iptal bir zincir işlemiydi. ADR-0008 çelişkiyi zincir dışı listenin lehine kapattı. Asıl gerekçe mahremiyettir. İzinli bir defterde her işlem her doğrulayıcı düğüme, bir zaman damgasıyla birlikte görünür. "Şu üniversite, şu gün şu saatte, şu konumdaki belgeyi iptal etti" bilgisi tek başına kişiyi söylemez. Ama bir disiplin kararının tarihi, bir işten ayrılma günü ya da bir bölümün kapanması bu damgayla birleşince kişiyi daraltır (Tablo 19).

Tablo 19. İptal listesinin yeri için değerlendirilen seçenekler (ADR-0008).

Seçenek	Sonuç	Neden
Bit dizisi tamamen zincirde	ret	İptal anı bütün düğümlere sızar; kalıcı zincir durumu büyür; standardın taşıma modelinden sapar
Kriptografik akümülatör ya da sıfır bilgi ile iptal	ertelendi (araştırma)	En güçlü mahremiyet; ama olgun kütüphane ve cüzdan desteği yok
Kısa ömürlü belge, iptal yok	kısmen benimsendi	Öğrenci belgesinde (en çok 90 gün) doğru; süresiz diplomada yanlış

Seçenek	Sonuç	Neden
Acil iptal zincirde, olağan iptal dışarıda	ret	Zincire yazılan iptal tam da en hassas olandır; sızıntıyı yoğunlaştırır
İmzalı liste zincir dışında, yalnız özeti çapalanır	**seçildi**	İptal anı görünmez; standardın kendi modeli; doğrulayıcı agresif önbellekler

Maliyet de aynı yönü gösteriyordu. 100.000 konumluk tek bitlik bir liste 12,5 KB'tır; yaklaşık 200 yükseköğretim kurumu için bu kalıcı zincir durumunda 2,5 MB eder ve her iptal bir işlemdir (ADR-0008). Bugün çapa, liste yayıncısının çapa günlüğüdür; bir ortak defter gelirse ona yalnız yayımların özeti yazılır (Bölüm 19).

12.3 Bit sayısı ve askı

Standart her belge için 1, 2, 4 ya da 8 bite izin verir. Tamga iki değer kullanır ve hangisinin kullanılacağını türün anlamı belirler (ADR-0048) (Tablo 20).

Tablo 20. Durum değerleri ve hangi türde kullanıldıkları.

Değer	Standart adı	Tamga anlamı	Nerede
`0x00`	VALID	Geçerli	Bütün listeler
`0x01`	INVALID	Kalıcı iptal; geri dönüşü yok	Bütün listeler
`0x02`	SUSPENDED	Geçici askı; geri alınabilir	Yalnız 2 bitlik kurum listelerinde ve yalnız şeması askıya izin veren türde (bugün diploma)
`0x03`	ayrılmış	Kullanılmaz; okunursa ret	—

Kimlik servisinin türleri (kimlik belgesi, sürücü belgesi bilgisi, e-posta ve telefon belgeleri) 1 bitlik listelerle yayımlanır ve askı yoktur. Bu, AB'nin kişi kimlik verisi (PID) kuralına hizalanmadır: 2024/2979 [5] sayılı tüzüğün Ek II'si, 2026/1731 ile değişik hâliyle, PID'de durumu yalnız "iptal / iptal değil" diye tanımlar. Tamga'nın kimlik belgesi PID değildir, ama AB PID'inin adlarını kullanır ve bir devletin PID'i gelince onun yerini almaya en yakın türdür. Kimlik hakkında "inceleme süresince geçici olarak geçersiz" denecek bir durum da yaşanmaz; şüphede belge iptal edilir ve kişi yeniden doğrulanır.

Kurum listeleri 2 bitliktir; askı ise yalnız şemasında `suspension_allowed: true` yazan türlerde kullanılır. Elif'in sorunu burada çözülür: diplomayı inceleme süresince askıya alır, inceleme bitince ya askıyı kaldırır ya da iptale çevirir. Kurum Konsolu "Askıya al" düğmesini yalnız bu türlerde gösterir. Askı izninin kurum başına değil tür başına verilmesi bilinçlidir; askı türün anlamına bağlıdır ve şema herkes için aynı kuralı söyler.

Belge mdoc [34] olarak da verildiyse aynı mantıksal liste iki gösterimle, ayrı ve opak adreslerde yayımlanır: SD-JWT [15] kopyası JWT gösterimine, mdoc kopyası CWT gösterimine işaret eder. İki gösterim aynı bitleri taşır ve aynı döngüde aynı anahtarla imzalanır; böylece bir mdoc okuyucusu bir JWT ayrıştırıcısı taşımak zorunda kalmaz.

12.4 Gizlilik kuralları

İptal listesinin mahremiyet faydası, birkaç yerde kolayca bozulabilir. Şartname bu yerleri tek tek kapatır (SPEC-CRED-0003 §5–§6, §9).

- **Konum rastgeledir.** Konum her sunumda görünür; sıralı dağıtılsaydı mezuniyet sırası ve iki mezun arasındaki zaman farkı konumdan okunur, seçici açıklamayla gizlenen tarih sızardı.
- **Kapasite büyüktür.** Her liste en az 100.000 konumludur, en çok %80 doldurulur.
- **Adres opaktır ve bölme yalnız türe göredir.** `…/edu-2026-a` gibi bir adres ya da "2026 mezunları A listesinde" gibi bir düzen, gizlenmiş mezuniyet yılını kendisi söylerdi; adres `…/7f3a9c21` gibi anlamsız bir dizedir.

- **Doğrulama başına çekim yasaktır.** Doğrulayıcı listeleri zamanlanmış toplu ön çekimle alır; paketler bunu varsayılan yapar.
- **Liste imzacısı sabitlenir.** İptal listesi belge anahtarından ayrı bir anahtarla imzalanır; doğrulayıcı imzacıyı, imzayı denetlemeden önce kurumun listedeki kayıtlı iptal anahtarına sabitler (ADR-0056 K6). Bu anahtar ele geçirilse bile sahte diploma üretilemez.

TEKNİK AYRINTI

Rastgele konum neyi gizler, neyi gizlemez

Sıralı dağıtımda iki belgenin konum sırası, veriliş sıralarıyla her zaman aynıdır. Rastgele dağıtımda bu bağ kopar. A belgesi B'den önce verilmiş olsun; konumlar kapasite içinden bağımsız ve tekdüze seçildiğinde:

$$\text{sıralı:} \quad P(\text{idx}_A < \text{idx}_B) = 1$$

$$\text{rastgele:} \quad P(\text{idx}_A < \text{idx}_B) = \frac{1}{2}$$

Yani konumların sırasına bakan biri, yazı tura atmaktan iyi bir tahmin yapamaz. Kullanılmamış bir konumun biti ile geçerli bir belgenin biti aynıdır (`0x00`); dışarıdan bakan biri listede kaç belge olduğunu bile göremez. Bu yüzden boş konumları "dolu" göstermeye çalışan bir başlangıç gürültüsü kuralı gözlenebilir bir koruma sağlamadığı için 2026-10-09'da kaldırıldı.

Rastgele konumun gizleyemediği iki şey vardır. Birincisi kurumun kendisidir: 300 mezunu olan bir yüksekokul 100.000 konumluk bir listede 300 dolu konum demektir; liste büyüktür ama "sürü" kurumla sınırlıdır ve `iss` alanı kurumu zaten söyler. Bu, şartnamede kabul edilmiş bir sınırdır. İkincisi aynı belgenin tekrar gösterimidir: konum ve adres bir kopyada sabittir, iki doğrulayıcı aynı kopyayı görüp anlaşırsa eşleştirebilir. Çözüm, her doğrulayıcıya farklı konumlu ayrı bir kopya göstermektir (§13.4, Bölüm 9).

12.5 Tazelik ve etkili olma süresi

Liste değişiklik olsa da olmasa da sabit aralıkla yayımlanır; bugün bu aralık **2 dakikadır**. Yalnız iptal olduğunda yayımlansaydı, yeni bir sürümün ortaya çıkması "şu dakikada bir iptal oldu" demek olurdu. Aralık dışı, "acil" bir yayın da yapılmaz; acil bir durumda doğru araç kurumun askıya alınması ya da sertifikasının iptalidir (SPEC-CRED-0003 §5.3). ADR-0008 aralığı bir saat önermişti; şartname, iptallerin birkaç dakikada görünmesi için kısa aralığı ve kesintiye dayanmak için uzun geçerliliği birlikte seçti (proje yönetiminin onayıyla, 2026-10-09).

Liste belirtecinde iki zaman alanı vardır. `ttl`, doğrulayıcının yenisini çekmeden önce bekleyebileceği süredir ve yayın aralığına eşittir (120 saniye). `exp`, belirtecin kesin son anıdır: yayından **6 saat** sonra. Durum sunucusu kesintiye uğrarsa doğrulayıcı elindeki son listeyle 6 saate kadar doğrulamaya devam eder; sonuç hemen doğrulanamadı'ya düşmez.

TEKNİK AYRINTI

Bir iptal ne zaman etkili olur

İptal önce bir sonraki yayını bekler, sonra doğrulayıcının bir sonraki ön çekimini. Yayın aralığı $\Delta_{\text{yayın}}$, ön çekim aralığı $\Delta_{\text{öncekim}}$ ise en kötü gecikme:

$$t_{\text{etkili}} \le \Delta_{\text{yayın}} + \Delta_{\text{öncekim}}$$

Yayın aralığı 120 saniye ve doğrulayıcı önerildiği gibi `ttl` aralığında çekiyorsa:

$$t_{\text{etkili}} \le 120 + 120 = 240 \text{ sn} = 4 \text{ dakika}$$

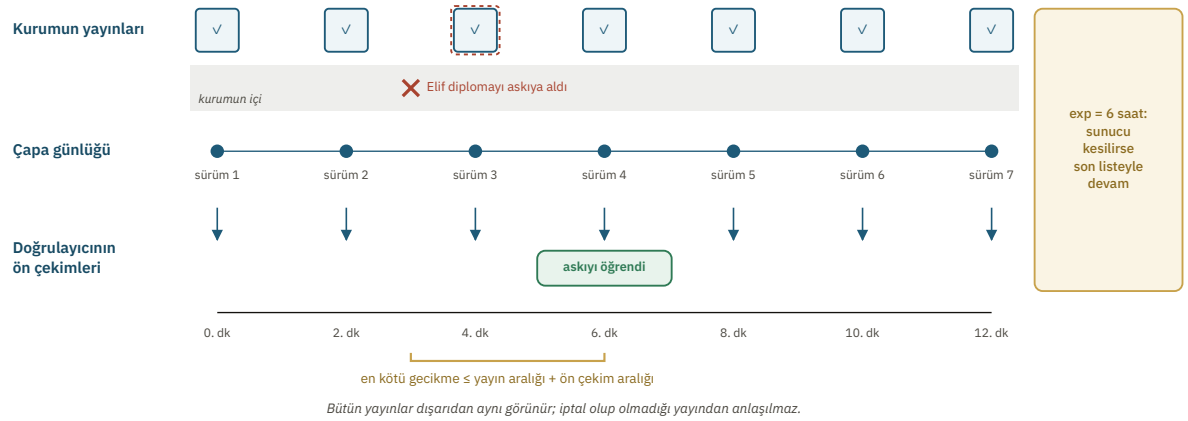
Doğrulayıcı listeyi beş dakikada bir çekiyorsa sınır $120 + 300 = 420$ saniye, yani yedi dakika olur. Kesinti tarafında pencere $\exp - \text{iat} = 6 \text{ sa} = 21.600 \text{ sn}$'dir; bu, referans politikalardaki azami belirteç yaşıyla (`max_status_token_age_sec = 21600`) aynıdır.

Doğrulayıcı riskine göre daha sıkı davranabilir. Bir belirteç 09:00'da yayımlanmış ve doğrulama 10:30'da yapılıyor olsun:

$$\text{yaş} = 1{,}5 \text{ sa} = 5.400 \text{ sn}$$

Düşük riskli bir doğrulayıcı (sınır 21.600 sn) bu listeyle doğrular. Resmî işlem gibi yüksek riskli bir doğrulayıcı (sınır 600 sn) ise aynı durumda "doğrulanamadı, liste bayat" der ve yeni listeyi bekler (SPEC-CRED-0003 §8.2).

Uzun `exp`'in bir bedeli vardır ve o bedel de hesaplanmıştır. Ağ yolunu ele geçiren biri eski ama imzalı bir belirteci sunarak bir iptali en çok 6 saat gizleyebilir. Çapa denetimi bu pencereyi daraltır: her yayının özeti çapa günlüğüne yazılır ve doğrulayıcı elindeki belirtecin sürümünün geri gitmediğini denetler (D5). Ön çekim çapadan önce yapıldıysa sonuç doğrulanamadı, sonra yapıldıysa ret olur; böylece bir kurumun iptal ettiği bir belgeyi kendi sunucusunda sessizce yeniden "geçerli" göstermesi de yakalanır (Şekil 20).



Şekil 20. Yayın döngüsü: sabit aralık, değişiklik olsa da olmasa da

12.6 İptal politikası

Kimin, hangi koşulda iptal edebileceği tek bir politika belgesinde toplanır (FW-POL-0001; AB ARF [11] VCR_05). Politika yeni kural koymaz, türlerin kural kitaplarını ve kararları derler. Ortak koşullar her iptal edilebilir türde geçerlidir: kişi rızasını geri alırsa, kişi "belgeniz bir cüzdana eklendi" bildirimine itiraz ederse, belge hatalı verilmişse, aynı kişiye aynı türün yeni bir kopya seti verilirse (eski set iptal edilir) ve kurumun imza anahtarı sızmışsa. Türe özgü koşullar da yazılıdır: diplomada sahtecilik ya da mahkeme kararı, bilette iade, etkinliğin iptali ve kapıda geçiş, kimlik belgesinde kişinin silme talebi ya da belgenin kaybolduğu bildirimi.

Politika iptal sebebi **olmayanları** da sayar ve bu liste en az ilki kadar önemlidir. Bir kurumun askıya alınması ya da listeden çıkarılması eski belgelerini geçersiz kılmaz; yalnız yeni belge verilmesini durdurur. Kurumun sertifika yenilemesi ve bir belge türünün yeni sürüme geçmesi de belgeleri iptal etmez (§11.3). Belgeyi yalnız belge veren iptal eder; ağın işletmecisi belge iptal etmez, gerekirse kurumu askıya alır.

Kurum isterse kendi ek koşullarını kendi sayfasında yayımlayabilir; bağlantı güven listesindeki kaydında `revocation_policy_uri` alanında durur ve cüzdan kurum sayfasında gösterir. Ek koşullar ortak politikayı daraltamaz, yalnız ekler (ADR-0047 K2).

İptal sebebi listede ve belgede yer almaz; liste kişisel veri taşımaz ve hiçbir kayıt konum bilgisini tutmaz. Kurumun API'si iptal isteğine "kuyruğa alındı, şu andan sonra etkili" diye cevap verir; anında

iptal yoktur ve API bunu açıkça söyler, böylece çağıranın beklentisi baştan doğru kurulur (SPEC-API-0001 §5.3).

12.7 Cüzdan birimi iptali

Bir telefon kaybolduğunda ne iptal edilmelidir? AB'nin ARF'si, cüzdan birimi iptal edilince belge verenlerin kendi belgelerini de iptal etmesini PID sağlayıcısı için zorunlu, ötekiler için isteğe bağlı bırakır. Tamga'nın kuralı şudur (ADR-0047 K1): kimlik servisi birimi en geç 24 saat içinde denetler ve o birimdeki kendi belgelerini iptal eder; kurum belgeleri ise iptal edilmez.

Kurum belgeleri yine de kullanılamaz hâle gelir: her kopya dışa aktarılamayan bir cihaz anahtarına bağlıdır ve her gösterim kullanıcı doğrulaması ister; iptal edilmiş birime hiçbir kurum yeni belge ya da yenileme vermez; iptali gören cüzdan belgelerini siler; kısa ömürlü türler süresi dolunca biter. Zincirleme iptal ise her belge kaydına bir cüzdan tanımlayıcısı yazmayı gerektirirdi. Kalan risk kayıtlıdır: telefonu ve kilit açma bilgisini birlikte ele geçiren biri, telefon ağa bağlanmadıkça süresi dolmamış bir kurum belgesini gösterebilir; kişi bunun için kurumdan iptal ister. Zincirleme iptal bu riski kapatmazdı, çünkü ağa bağlanmayan telefon iptali de öğrenmez. Birimin telefonsuz iptali Bölüm 13.5'te.

13 Cüzdan: Kurallar, Anahtarlar ve Kanıtlar

Aynur'un diplomasının değeri, telefonundaki bir anahtara bağlıdır. Anahtar başka bir yere kopyalanabilseydi diploma da kopyalanabilirdi; anahtar kaybolsaydı diploma da gösterilemezdi. Bu bölüm, bir cüzdanın ağın gözünde nasıl tanındığını, anahtarlarını nerede ve nasıl tuttuğunu, bunu belge verene nasıl kanıtladığını ve kişinin kendi verisi üzerindeki denetimini anlatıyor. Cüzdan güvenliğinin genel çerçevesi dizinin onuncu yazısında [75].

13.1 Ağın cüzdana bakışı

Tamga Network hiçbir cüzdanın uygulamasını, cüzdan sağlayıcısını ya da sitesini işletmez (ADR-0042). Ağın cüzdanlarla ilişkisi üç şeydir: kurallar (SPEC-WALLET-0001, Tamga ARF), açık paketler (`@tamga-network/wallet-core` ve ötekiler) ve güven listesindeki **cüzdan sağlayıcısı** kaydı (`wallet_providers[]`: adres, kanıt imza sertifikası, çözüm adı). AB'de de her cüzdanı onu sunan kuruluş işletir; güven çerçevesi sağlayıcıları yalnız listeler. Ağın kendi sağlayıcı barındırması değerlendirildi ve reddedildi, çünkü ağın tarafsızlığını bozar ve vakfa devirde bir cüzdanın hizmetini ağa bağlı bırakırdı.

Bir cüzdanın listeye girişi dört adımdır (FW-ONB-0001 §4): cüzdan çözümü beyanı (platformlar, güvenli donanım seviyesi, PIN ve biyometri, yedekleme modeli), sağlayıcı sözleşmesi (kanıtlar, güncelleme ve iptal süreleri, kurtarma anahtarı tutmama), uyum testleri ve listeye giriş. Cüzdan geliştiricisi önce kendi sağlayıcısını sandbox listesine kaydettirip cüzdanını oradaki örnek kurumlarla dener. Listeye giren ilk cüzdan, Tamga Wallet, ayrı bir üründür ve bu yoldan, her cüzdanla aynı koşullarla girmiştir. Ağın arayüzleri cüzdanı genel adla anar; bir cüzdanın adı gerektiğinde listedeki kayıt verisinden gelir (ADR-0042 NW4).

13.2 Anahtar mimarisi ve seviyeler

Cüzdan şartnamesi bir çelişkinin çözümüyle başlar (SPEC-WALLET-0001 §1). Belge anahtarı güvenli bölgeden hiç çıkmamalıydı; ilk proje notlarında ise "24 kelimelik tohumla yedekleme" fikri vardı. Tohum cüzdanı kullanılabilir hâlde geri getiriyorsa anahtarları da getiriyor demektir. Anahtarları tohumdan türetmek cazipti ama cihaz bağını çürütürdü: tohum paylaşılabilirse belge devredilebilir ve belge verilirken kapatılan "öğrenci belgesini arkadaşının cüzdanına aldırma" açığı kurtarma anında yeniden açılır. Platformların cihazlar arası eşitlenen anahtarları da reddedildi; güven Apple ve Google

hesabına kayar, aynı hesaptaki başka bir cihaz anahtarı alabilir ve AB bu sınıfı en yüksek cüzdan seviyesi saymaz.

Karar: belge sahibi anahtarları tohumdan türetilmez ve güvenli bölgeden asla çıkmaz (WL1); yedek belgeleri ve listesini taşır, anahtarları taşımaz (WL2). Yeni telefonda geri yüklenen belge okunabilir ama gösterilemez, kurumdan yeniden alınır; tohumun işi kişiye "şu dört belgeyi yeniden iste" diye tek dokunuşluk bir liste sunmaktır. Ağ ya da sağlayıcı kişi adına hiçbir koşulda kurtarma anahtarı tutmaz (WL10); tutsaydı bütün cüzdanları açabilecek bir merkez doğardı (Tablo 21).

Tablo 21. Cüzdan güvence seviyeleri (SPEC-WALLET-0001 §2.2, FW-ARF-0001 §6.5).

Seviye	Anahtar deposu	Ağdaki yeri	Cihaz kanıtı
W1	Yazılım	Desteklenmez; belge verilmez (yalnız sandbox'ta ağın kendi deneme anahtarı)	—
W2	Cihazın güvenli bölgesi (Secure Enclave, StrongBox, en az TEE)	Bugünkü asgari seviye	İsteğe bağlı; sağlayıcının kararı
W3	Sertifikalı güvenli donanım	Devlet aşamasında	Zorunlu (ADR-0047 K5)

Her sunum bir kullanıcı doğrulaması ister (WL11). Güvenli donanım anahtarı olan cihazda belge anahtarı telefonun kilidine bağlıdır ve sunum onayı işletim sisteminin biyometri ya da cihaz parolası istemidir; uygulamanın ayarları bunu kapatamaz. Kişi istemden vazgeçerse geri düşüş yoktur, sunum yapılmaz. Açık bir cüzdanın arka planda sessizce sunum yapması böylece engellenir.

TEKNİK AYRINTI

PIN sınırlarının hesabı

Uygulama PIN'i en az 6 hanedir; 5 hatalı denemede 30 saniye beklenir, 10'da cüzdan kilitlenir ve tohum gerekir (SPEC-WALLET-0001 §2.3). Telefonu ele geçiren birinin kilitlenmeden önce PIN'i rastgele tahminle bulma olasılığı:

$$P_{\text{tahmin}} \le \frac{10}{10^6} = 10^{-5} = \%0{,}001$$

Bu sınırın bir bedeli de vardır: aynı kişi 10 kez yanlış girerek cüzdanı kilitleyebilir. Şartname bunu kabul edilmiş bir risk olarak yazar; alternatifi PIN'i kaba kuvvete açık bırakmaktır.

13.3 WIA ve KA

Kurum belge vermeden önce karşısındaki uygulamanın listede tanınan bir cüzdan olduğunu ve anahtarların güvenli donanımda durduğunu bilmek ister. İlk tasarımda cüzdan 30 gün geçerli tek bir kanıtı her kuruma gösteriyordu; kurumlar aynı cüzdanı birbirine bağlayabilirdi ve kanıtın iptal yolu yoktu. Tamga bunu AB'nin TS3 [12] modeliyle değiştirdi (ADR-0025).

- **WIA** (*Wallet Instance Attestation*, cüzdan örneği kanıtı) cüzdanın kendisini tanıtır. Ömrü 24 saatten kısadır ve **her belge işleminde yenisi** alınır: yeni bir sahiplik anahtarı ve iptal listesinde yeni, birbirine bağlanamaz bir girişle. Kurum başına yeniden kullanım seçeneği bilerek kullanılmadı; kullanılsaydı sağlayıcı cüzdanın kaç kurumla görüştüğünü öğrenirdi.
- **KA** (*key attestation*, anahtar kanıtı) belge anahtarlarının hangi depoda ve hangi kullanıcı doğrulamasıyla korunduğunu söyler. Bir paketteki bütün belge anahtarlarını taşır ve bir kez kullanılır. İptali anahtar deposu **türü** başına ortak bir girişle yapılır; böylece birimin kimliği KA'dan çıkarılamaz.

HAIP 1.0 [32] §4.4.1 bir kural daha getirir: WIA'nın "kim" alanı (`sub`), aynı cüzdan çözümünü kullanan bütün örneklerde ortak bir değer olmalıdır. Tamga'da bu, çözümün adıdır; telefona özgü bir değer taşımaz (ADR-0034 CI6). Kurumun gördüğü, kişiye değil çözüme işaret eder.

JSON Örnek: bir WIA'nın kısaltılmış içeriği; alan yapısı sadeleştirilmiştir (değerler örnektir)

```
{
  "iss": "https://saglayici.example",
  "sub": "ornek-cuzdan-cozumu",
  "iat": 1795000000,
  "exp": 1795082800,
  "wallet_name": "Örnek Cüzdan",
  "wallet_version": "1.4.0",
  "cnf": { "jwk": { "kty": "EC", "crv": "P-256", "x": "…", "y": "…" } },
  "client_status": {
    "status": { "status_list": { "idx": 5127, "uri": "https://saglayici.example/status/wia/3" } },
    "exp": 1800184000
  }
}
```

TEKNİK AYRINTI

WIA'nın ömrü ve bağlanamazlık

Örnekteki değerlerle WIA'nın ömrü ve iptal bakım süresi şöyle hesaplanır:

$$\text{exp} - \text{iat} = 1.795.082.800 - 1.795.000.000 = 82.800 \text{ sn} = 23 \text{ sa} < 24 \text{ sa}$$

$$\text{client_status.exp} - \text{iat} = 5.184.000 \text{ sn} = 60 \text{ gün} \geq 31 \text{ gün}$$

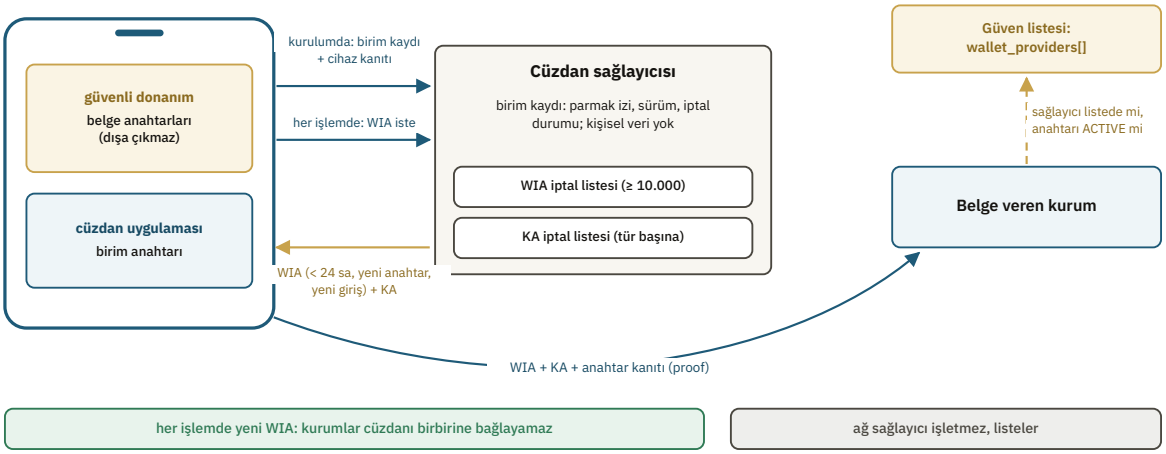
23 saat Tamga'nın seçtiği ömürdür, 60 gün olağan bakım süresidir; kurum daha uzun bir süre ilan ederse sağlayıcı kendi üst sınırına kadar verir. Bağlanamazlık kuralı ise tek satırdır: i ve j iki ayrı belge işlemiyse

$$\text{cnf}_i \neq \text{cnf}_j \quad \text{ve} \quad \text{idx}_i \neq \text{idx}_j$$

Yani iki kurum, aynı cüzdandan gelen kanıtlarda ortak bir anahtar ya da ortak bir iptal girişi görmez. WIA ve KA iptal listelerinin her biri en az 10.000 girişlidir (2024/2979 [5] sayılı tüzüğün Ek Ib'si); kurum bu sınırın altındaki bir listeye dayanan kanıtı kabul etmez.

Kurum, belge vermeden önce WIA'nın imzasını, sağlayıcının listede olduğunu, süreyi, sahiplik kanıtını ve iptal durumunu denetler; belge ucunda KA'yı ve anahtar deposu seviyesinin kendi alt sınırını karşıladığını denetler. İptal edilmiş bir WIA ya da KA ile belge verilmez (ADR-0025 WIA4). Listede olmayan bir sağlayıcının cüzdanına da belge verilmez.

KA'nın en önemli kuralı "seviye gerçeği söyler" kuralıdır (ADR-0025 WIA3): doğrulanmamış bir beyan KA'ya yazılmaz. Cihaz kanıtı (Apple App Attest, Android anahtar kanıtı, Play Integrity) bu gerçeğin kaynağıdır. Ağın kuralı, cihaz kanıtını yalnız en yüksek seviyede zorunlu tutar: W3 beyan eden her KA'dan önce sağlayıcı cihaz kanıtını doğrular, W2'de bu sağlayıcının kararıdır (ADR-0047 K5). Her seviyede zorunlu kılmak değerlendirildi; cihaz kanıtı her platformda ve her cihazda bulunmadığı için W2 cüzdanlarını dışarıda bırakacağından reddedildi. **Durum:** WIA ve KA biçimi ve doğrulaması çalışıyor; donanım anahtarları ve cihaz kanıtı kodlandı, cihaz testi bekliyor (planlanan; FW-ARF-0001 §2.8); doğrulanamayan bir donanım beyanı KA'ya girmez (Şekil 21).



Şekil 21. Cüzdan birimi, cüzdan sağlayıcısı ve kanıtlar

13.4 Kopyalar

Kurum belgeleri on kopya hâlinde verilir; her kopya ayrı bir cihaz anahtarına ve iptal listesinde ayrı bir konuma bağlıdır (Bölüm 9). Kopyaların nasıl kullanılacağı iki yönlü bir kurala bağlanmıştır: bir doğrulayıcıya **her zaman aynı** kopya, farklı doğrulayıcılara **farklı** kopyalar gösterilir (WL5). Aynı doğrulayıcıya farklı kopya göstermek bir şey kazandırmaz; Timur Aynur'u başvurusundan zaten tanır, farklı kopya yalnız kopya harcar. Farklı doğrulayıcılara farklı kopya ise, iki doğrulayıcının cihaz anahtarı ya da iptal konumu üzerinden anlaşıp Aynur'u eşleştirmesini engeller. Eşlemenin anahtarı doğrulayıcının kalıcı kimliğidir (`dns_name`); sertifika yenilense de bozulmaz.

Aynı doğrulayıcıya aynı tür için yapılan tekrar sunumlarda açıklanan alan seti de tutarlı kalır (WL6). İlk sunumda sekiz, ikincisinde altı alan açıklansaydı doğrulayıcı aradaki farktan gizlenen alanlar hakkında bir şey çıkarabilirdi. Doğrulayıcı daha az isterse cüzdan fazlasını göndermez, ama kişiye "bu doğrulayıcıya daha önce şu alanları vermiştiniz" bilgisini gösterir.

Kopyalar tükenir. Bilinen bir doğrulayıcıda bu sorun değildir; yeni bir doğrulayıcıda kişi ya yeniler ya da bir kopyayı bağlanabilirlik uyarısıyla yeniden kullanır. Cüzdan, kurumun ilan ettiği eşiklerde kopyaları kişiye sormadan da yeniler (ADR-0023): yenileme belirteci olan kurum belgelerinde, uygulama öndeyken ve kilit açıkken, rastgele bir gecikmeyle. Eski "otomatik yenileme yok" kuralı, AB ARF'nin [11] yeniden vermenin mümkün olduğunca kullanıcı eylemi gerektirmemesi şartı yüzünden değişti. Kimlik ve iletişim belgeleri kapsam dışıdır; kimlik servisi kişi alanlarını belge verdikten sonra tutmaz.

TEKNİK AYRINTI

Sessiz yenilemenin kalan izi

Kurum bugün on kopyalık paket verir ve iki kullanılmamış kopya kalınca yenilemeyi tetikler. Aynı doğrulayıcıya tekrar sunum kopya harcamadığı için bir paket şu kadar **yeni** doğrulayıcıya yeter:

$$10 - 2 = 8 \text{ yeni doğrulayıcı}$$

Kurum yenileme isteklerinin sıklığından belgenin kabaca kaç yeni doğrulayıcıya gösterildiğini çıkarabilir: her sekiz yeni doğrulayıcıda bir istek. Bu iz kabul edilmiş bir dengedir ve dört önlemle daraltılır: aynı doğrulayıcıya aynı kopya, 0 ile 6 saat arası rastgele gecikme, yenileme isteğinin hangi doğrulayıcı için yapıldığını hiç içermemesi ve kişinin ayarı kapatabilmesi (ADR-0023 K6). Belgenin bitişine 7 gün kala da yenileme tetiklenir.

13.5 Kişinin denetimi

Cüzdan her sunumu yerel olarak kaydeder: ne zaman, hangi doğrulayıcı, hangi alanlar, aşırı talep var mıydı. Bu kayıt cihazda kalır ve hiçbir sunucuya gönderilmez; gönderilseydi tam da korunmak istenen davranış profili bir merkezde toplanırdı (SPEC-PROTO-0002 PV8, SPEC-WALLET-0001 WL4). Hangi doğrulayıcıya hangi kopyanın gösterildiğini tutan eşleme de aynı kurala tabidir ve yedeğe girmez.

AB ise kişinin işlem günlüğünü ve belgelerinin listesini dışa aktarabilmesini zorunlu tutar (2024/2979 sayılı tüzük, TS10). Günlüğün sunucuda şifreli yedeklenmesi (üst veri yine birikir) ve düz JSON dışa aktarımı (paylaşım uygulamalarında açık kalır) reddedildi. Karar: günlük yalnız kişinin kendisinin başlattığı ve kendi parolasıyla şifrelediği bir dosyada cihazdan çıkar; dosyaya belge değerleri, kopyalar ve anahtarlar girmez (ADR-0027) (Tablo 22).

Tablo 22. Kişinin hakları ve cüzdandaki karşılıkları.

Hak ya da ihtiyaç	Cüzdandaki karşılığı	Kaynak
Kime ne gösterdiğimi bilmek	Cihazdaki geçmiş: zaman, doğrulayıcı, alan adları, aşırı talep	WL4, FW-ARF-0001 §2.7
Verimi almak ve taşımak	Kişinin başlattığı, parolalı TS10 dosyası (taşıma listesi ve günlük)	ADR-0027
Geçmişin ne kadar tutulacağını seçmek	30 / 90 / 180 / 365 gün ya da süresiz; silmeden önce uyarı	SPEC-WALLET-0001 §5.7
Her şeyi silmek	“Cüzdanı sıfırla ve verilerimi sil”: kimlik servisindeki kayıt, sağlayıcıdaki birim kaydı, cihazdaki her şey	SPEC-WALLET-0001 §7.6
Bir kurumdan verimi silmesini istemek	Geçmişten “Verilerimi silmesini iste”	FW-ARF-0001 §2.7
Şikâyet etmek	Doğrulayıcının bağlı olduğu veri koruma kurumuna giden yol	FW-ARF-0001 §2.7
Telefonum kaybolunca cüzdanı kapatmak	Telefonsuz, hesapsız iptal yolu (kurulumda verilen iptal sırrı)	ADR-0047 K3
Cüzdanımın iptal edildiğini öğrenmek	Cüzdan dışından en az bir yol	ADR-0047 K4

Silmenin sırası önemlidir: önce kimlik servisi (cüzdan alan açmadan bir sahiplik sunumuyla silme ister; servis kaydı siler, kopyaları iptal eder, uzaktan kimlik doğrulama sağlayıcısındaki oturumu sildirir), sonra cüzdan sağlayıcısı (birim iptal edilir, kaydı silinir), en son cihaz. Ağ yoksa cihazdaki silme yine yapılır ve kişiye kalan adımlar gösterilir.

Kaybolan telefon için AB’nin ARF’si sağlayıcıda bir kullanıcı hesabı öngörür; Tamga’da hesap yoktur. Bu yüzden her sağlayıcı, telefon olmadan ve hesap açmadan çalışan bir iptal yolu sunmak zorundadır: birim etkinleştirilirken üretilip kişiye bir kez gösterilen bir iptal sırrı, sağlayıcıda yalnız yavaş özetiyle (ADR-0047 K3). Bu, ARF’den açıkça yazılmış bir sapmadır; SMS ile bildirim ise kayıp telefona gideceği ve kişisel veri isteyeceği için ağ kuralı olarak reddedildi.

13.6 “Tamga Network’te listeli”

AB’nin sertifikalı cüzdanlar için bir güven işareti vardır; biçimi ve renkleri tüzükle belirlidir ve yalnız bir üye devletin sağladığı ya da tanıdığı sertifikalı cüzdan içindir. Ağdaki hiçbir cüzdan bir AB cüzdanı değildir ve bu işareti kullanamaz. Ama işaretin çözdüğü ihtiyaç burada da vardır: kişi, telefonundaki uygulamanın kurallara uyan ve listede kayıtlı bir cüzdan olup olmadığını bilmek ister.

Tamga’nın cevabı yazılı bir göstergedir: **“Tamga Network’te listeli”** (ADR-0049). Logo, rozet ya da mühür yoktur; AB yıldızları ve renkleri, “güven işareti” ya da “sertifikalı” sözü kullanılmaz. Göstergeye dokunulunca cüzdan, imzası doğrulanmış listedeki kendi sağlayıcı kaydını gösterir: resmî adı, kaydın durumu, seviyesi ve listenin yayın zamanı. Gösterge doğrulanabilir bir beyandır, süs değildir. Birim iptal edilmişse, sağlayıcı ya da çözüm kaydı etkin değilse, liste doğrulanamıyor ya da bayatsa veya

cüzdan yalnız sandbox listesine bağlıysa gösterge gizlenir. Kendi logolu bir "Tamga güven işareti" de değerlendirildi; adı AB işaretini çağrıştırdığı ve logo doğrulanabilir bir şey söylemediği için reddedildi. **Durum:** çalışıyor (paketler 0.6.0'dan beri).

13.7 Yaş sınırı yok

eIDAS 2.0 [2], Avrupa Dijital Kimlik Cüzdanı için asgari bir yaş öngörmez ve Tamga da yaş sınırı koymaz: ne cüzdanların listeye kaydı için ne de kimlik servisinin kimlik belgesi vermesi için (ADR-0043). Tek şart, geçerli bir kimlik belgesiyle kimlik doğrulamasıdır. Bir belgeyi kimin alabileceğini o belgeyi veren belirler; öğrenci belgesini yalnız kayıtlı öğrenciye üniversite verir. Yaşa bağlı bir hizmet de doğrulayıcı olarak yalnız gereken bilgiyi ister (`age_over_18` gibi; Bölüm 14). Ağ genelinde 18 ya da 13–16 yaş sınırı değerlendirildi; ilki öğrenci, sporcu ve etkinlik gibi küçük yaştakilerin de kullandığı belgeleri dışarıda bırakacağı, ikincisi bir yaş sınırı değil rızaya dayalı hizmetlerde veli onayı kuralı olduğu için reddedildi.

Açık kalan iş veli onayıdır. GDPR'ın [8] 8. maddesi rızaya dayalı bilgi toplumu hizmetlerinde 16 yaş altı için veli onayı ister (üye devletler bu yaşı 13'e indirebilir); KVKK [9] özel bir yaş koymaz. Kimlik servisinin rıza akışı için gereken düzen hukuki incelemeden sonra ayrı bir kararla ele alınacak; uzaktan kimlik doğrulama sağlayıcısının küçükler için koşulu da teyit bekliyor. **Durum:** yaş sınırı olmaması çalışıyor; veli onayı akışı açık iş.

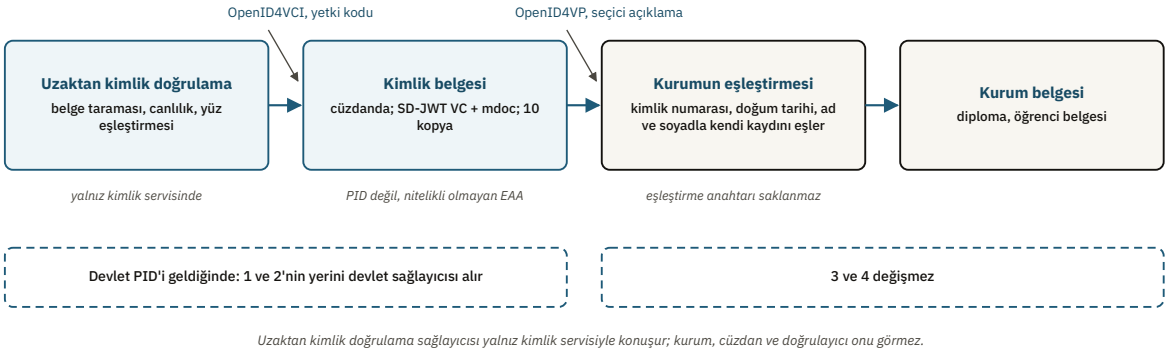
14 Kimlik: Geçici Kimlik Belgesi Sağlayıcısı

Aynur İstanbul'da bir işe başvurmadan önce mezun olduğu kurumdan belgesini cüzdanına almak istiyor. Kurum ona tek bir soru sorar: "Gerçekten sen misin?" Bu soruyu her kurumun ayrı ayrı sorması, her seferinde kimlik kartının fotoğrafını, bir özçekimi ve bir bekleme süresini istemesi demektir. Avrupa Birliği'nde bu soruya devletin verdiği kişi kimlik verisi (PID) cevap verir: kişi PID'ini cüzdanında gösterir, kurum onu kendi kaydıyla eşler ve belgeyi verir. Türkiye'de ve Türk dünyasının hiçbir ülkesinde bugün böyle bir devlet sağlayıcısı yoktur. Bu bölüm, ağın bu boşluğu nasıl ve hangi sınırlarla doldurduğunu anlatır.

14.1 PID yokken ne yapılır

Üç yol vardı. Devletin PID sağlayıcısını beklemek, ama bunun bir tarihi yoktu. Kimlik doğrulamayı her kurumun kendi belge verme servisine bırakmak; bu durumda kişi her kurumda yeniden doğrulanır ve her kurum ayrı bir sağlayıcı entegrasyonu kurar. Ya da kimlik doğrulamayı tek bir yerde yapıp sonucu kişinin cüzdanına taşınabilir bir belge olarak vermek. Proje yönetimi üçüncü yolu seçti (ADR-0011): ağın kimlik servisi (`id.tamga.network`) kişiyi bir kez uzaktan doğrular ve ona kendi imzaladığı bir **kimlik belgesi** verir. Kişi bu belgeyle istediği kuruma gider; kurum belgeyi gösterme yoluyla alır, kendi kaydıyla eşler ve kendi belgesini verir.

Bu belge PID değildir; AB'nin dilinde nitelikli olmayan bir elektronik öznitelik belgesidir (EAA). Güven listesinde PID sağlayıcılarının yeri (`pid_providers[]`) bilerek boş tutulur ve kimlik servisi sıradan bir belge veren kaydıdır (kategori `IDENTITY`). Ayrımın pratik sonucu devirde görünür: bir devlet PID sağlayıcısı atadığında kimlik servisinin kaydı bir halef göstergesiyle (`successor_id`) devredilir, yeni belge verilmez, verilmiş belgeler süreleri dolana kadar doğrulanabilir kalır (FW-RB-0003 §4.7). Alan adları AB PID'iyle aynı olduğu için kurumların eşleştirme kodu değişmez; yalnız imzacı değişir. Bu, ARF'nin [11] "PID sunumuyla EAA verme" deseninin aynısıdır (FW-TF-0001 §3.5). *Durum: çalışıyor.* Gerçek ağın Türkiye listesinde bugün etkin tek belge veren kimlik servisidir (Şekil 22).



Şekil 22. Kimlik zinciri: bir kez doğrula, her kuruma aynı belgeyle git

14.2 Uzaktan kimlik doğrulama

Uzaktan kimlik doğrulama üç denetimin birleşimidir: kimlik belgesinin taranıp gerçekliğinin incelenmesi, kameranın önündeki kişinin canlı olduğunun anlaşılması (canlılık) ve yüzün belgedeki fotoğrafla eşleştirilmesi. Bu işi lisanslı bir uzaktan kimlik doğrulama sağlayıcısı yapar. Tasarım belirli bir sağlayıcıya bağlı değildir: kimlik servisi sağlayıcıyla dar bir adaptör arayüzü üzerinden konuşur (oturum aç, kararı al, bildirimi doğrula) ve ikinci bir sağlayıcı aynı arayüzün arkasına eklenebilir (SPEC-ID-0003 §6). İkinci, yerli bir sağlayıcının eklenmesi açık bir konudur (SPEC-ID-0003, Açık Konular 3).

Sağlayıcı ağın en çok görme yetkisi olan dış parçasıdır; kişinin belgesini ve yüzünü görür. Bu yüzden onun çevresine sıkı kurallar çizilmiştir (SPEC-ID-0003 §3, §8). Sağlayıcıyla yalnız kimlik servisi konuşur; kurumlar, cüzdanlar ve doğrulayıcılar konuşmaz. Sağlayıcı oturumu kişiye kimlik servisinin verdiği opak bir referansla bağlanır; bu alana ad, kimlik numarası ya da e-posta yazılmaz. İş akışında yalnız belge, canlılık ve yüz eşleştirmesi açıktır; kara para taraması ve iletişim doğrulaması kapalıdır, çünkü amaç yalnız belge vermenin ön koşulunu sağlamaktır. Sağlayıcının bildirimi (webhook) imza ve zaman damgasıyla denetlenir ama yalnız bir tetikleyicidir; karar her zaman sağlayıcının karar ucundan yeniden çekilir. Belge görüntüsü, portre, video ve karakter tanıma çıktısı kimlik servisinde saklanmaz; servisin tuttuğu şey sonucun kısa özetidir. Günlüklere olay türü, oturum referansı ve seviye yazılır; ad, belge numarası ve eşleşme skoru yazılmaz.

Hata durumları da güvenli yöne kurulmuştur. “İncelemede” ya da “reddedildi” kararında belge verilmez ve kişiye sağlayıcının gerekçesi aktarılmaz; sağlayıcı kesintisi seviyeyi düşürmez, yalnız belge vermeyi durdurur. Kişi sağlayıcıya geçmeden önce aydınlatma metnini görür ve açık rızasını verir; rıza yoksa doğrulama başlamaz.

Bu adımın bir zayıf noktası açıkça söylenmelidir: canlılık ve yüz eşleştirmesi, yapay olarak üretilmiş yüzlere ve video akışına araya girilerek yapılan saldırılara (deepfake ve enjeksiyon saldırıları [55]) karşı sağlayıcının tespit gücü kadar güçlüdür. Ağ bu riski iki kuralla daraltır: en yüksek seviye (T3) hiçbir uzaktan yüz doğrulamasıyla verilmez ve sağlayıcıyla yapılan sözleşme ETSI TS 119 461’e [47] atıf yapar (FW-TF-0001 §3.5). Konu dizinin “Deepfake Çağında Kimlik Doğrulama” [78] yazısında ayrıntılı ele alınır.

> TEKNİK AYRINTI
>
> **Kimlik belgesi alma akışı**
>
> Kimlik belgesini kurum değil cüzdan başlatır; akış OpenID4VCI’nin [30] yetki kodu yoludur (Bölüm 9.1) ve SPEC-ID-0003 §9 ile SPEC-PROTO-0001 §11.2’de tanımlıdır. Cüzdan her adımda listedeki bir cüzdan sağlayıcısının verdiği cüzdan örneği kanıtını (WIA) taşır (Bölüm 13.3).

1	`Cüzdan → Kimlik servisi`	**Yetki isteği.** PAR ile istek bırakılır; istemci kimliği WIA'dır, PKCE kodu eklenir. Kimlik belgesi kapsamının yanında ZK kopyası kapsamı da istenebilir.	$\text{code_challenge} = \text{SHA-256}(\text{code_verifier})$
2	`Kimlik servisi → Kişi`	**Aydınlatma ve rıza.** Tarayıcıda aydınlatma metni gösterilir, açık rıza alınır; rıza yoksa akış `access_denied` ile biter.	
3	`Kimlik servisi → Sağlayıcı`	**Oturum.** Opak bir kişi referansıyla oturum açılır; kişi belgesini tarar, canlılık ve yüz eşleştirmesi yapılır.	$\text{vendor_data} = \text{subject_ref}$
4	`Kimlik servisi`	**Karar.** Bildirim gelse de karar sağlayıcının karar ucundan çekilir; üç denetim geçmişse seviye T2 olur.	$\text{T2} \Longleftarrow \text{belge} \wedge \text{canlılık} \wedge \text{yüz}$
5	`Kimlik servisi → Cüzdan`	**Yetki kodu ve belirteç.** Tek kullanımlık kod, PKCE doğrulaması ve WIA ile erişim belirtecine çevrilir; belirteç DPoP anahtarına bağlıdır.	$\text{jkt} = \text{SHA-256}\big(\text{JWK}_{\text{dpop}}\big)$
6	`Cüzdan → Kimlik servisi`	**Belge isteği.** Her kopya için ayrı cihaz anahtarıyla anahtar sahipliği ispatı ve anahtar kanıtı (KA) gönderilir.	$\text{cnf}_i \neq \text{cnf}_j \quad (i \neq j)$
7	`Kimlik servisi → Cüzdan`	**Verme.** SD-JWT VC ve mdoc biçiminde 10 kopya; istenmişse kısa ömürlü ZK kopyaları; ardından aynı belirteçle ayrı bir istekte takma ad tohumu.	
8	`Kimlik servisi`	**Temizlik.** Kişi alanları bellekten atılır; kalıcı kayıtta yalnız opak referans, belge numarasının anahtarlı özeti, süre ve iptal listesi konumları kalır.	

Temizlik adımında kalan anahtarlı özet şöyle hesaplanır:

$$\text{document_number_hash} = \text{HMAC-SHA256}(k_{\text{doc}}, \text{ülke} \parallel \text{tür} \parallel \text{no})$$

Tohumun ayrı bir istekte verilmesi bir standart uyumu kararıdır: OpenID4VCI 1.0 belge yanıtına ek alan koymaya izin vermez, bu yüzden tohum ayrı bir belge yapılandırması olarak ilan edilir ve kimlik belgesini veren belirteçle yalnız bir kez istenebilir (ADR-0061).

14.3 Seviyeler

Ağ güveni iki bağımsız eksende ölçer (ADR-0005). Birinci eksen kişinin kimliğinin ne kadar güçlü doğrulandığıdır: T0'dan T3'e. İkinci eksen belge verenin ne kadar denetlendiğidir: I1'den I3'e (Bölüm 18.6). Doğrulayıcının güveni ikisinin çarpımıdır, toplamı değildir; çok iyi doğrulanmış bir kişi denetlenmemiş bir kurumun belgesini taşıyorsa ya da akredite bir kurum kimliği hiç doğrulanmamış birine belge vermişse sonuç değersizdir. Kişi tarafındaki seviyeler eIDAS güvence düzeyleriyle [4] ve kimlik doğrulama için ETSI TS 119 461'in düzeyleriyle bire bir eşlenir; böylece ağ kendi ölçüsünü kullanırken AB ile aynı dili konuşur (Tablo 23).

Tablo 23. Kişi güvence seviyeleri ve eşlemeleri (ADR-0005; SPEC-ID-0003 §1; FW-ARF-0001 §6.5).

Seviye	eIDAS düzeyi	ETSI TS 119 461	Tipik yol	Kimlik servisinde
T0	yok	yok	cihaz anahtarı, e-posta ya da telefon kodu; kimlik iddiası yok	iletişim belgeleri
T1	Low	Baseline	ayrı kanaldan gelen kod, hat ya da hesap sahipliği	kullanılmaz
T2	Substantial	Substantial	uzaktan belge + canlılık + yüz eşleştirmesi ya da yüz yüze kayıt masası	kimlik belgesi bugün bu düzeyde
T3	High	High	nitelikli elektronik imza ile nonce imzalama; devlet aşamasında PID	uzaktan yüz doğrulamasıyla verilmez

İki kural tabloyu tamamlar. Birincisi, seviye belgeye yazılmaz. Belge türü bir asgari seviyeyi ön koşul olarak taşır; kurum bu seviyeyi belge vermeden önce sağlar ve hangi yolla sağladığını kendi denetim kaydına yazar (SPEC-ID-0003, Kapsam). Belgeye bir "güvence" alanı konsaydı her doğrulayıcı kişinin hangi yoldan geçtiğini öğrenirdi. İkincisi, NFC ile çip okunmuş olsa bile sonuç hukuken T3 sayılmaz; belge bu olguyu `document_chip_verified` alanıyla yalnız bir olgu olarak taşır (FW-RB-0003 §4.3). Seviyeler zamanla da aşınabilir: cihaz değişimi ya da uzun süre kullanılmama gibi olaylar seviyeyi düşürür (ADR-0005, karar 4).

14.4 Sınıf: nitelikli değil

Kimlik servisi güven listesine ilk olarak en üst sınıfta kaydedilmişti. Ardından yapılan AB boşluk analizi bunun savunulamayacağını gösterdi (ADR-0022). eIDAS 2.0'da [2] "nitelikli" bir hukuki unvandır; bağımsız bir uygunluk değerlendirme kuruluşunun denetimini ve denetim kurumunun gözetimini ister. Oysa ağ bu hizmette hem liste işletmecisi, hem kayıt kurumu, hem de belge verendir; kendini en üst sınıfa kendisi yazmış olurdu. Değerlendirilen dört seçenekten "nitelikli olmayan EAA, I2" kabul edildi: gerçek durumu anlatır ve AB'de nitelikli olmayan EAA'yı herkes verebilir. I1 de reddedildi, çünkü kimlik doğrulama ve anahtar yönetimi I2 şartlarını karşılıyordu.

Belgede bunun görünür bir izi vardır, daha doğrusu bir izin yokluğu. ETSI TS 119 472-1 [49], nitelikli olmayan ve kamu kaynaklı olmayan bir EAA'da hukuki kategori alanının bulunmamasını ister; bu yüzden kimlik belgesi `category` alanı taşımaz ve belgenin sınıfı belge verenin listedeki kaydından okunur (FW-RB-0003 §2.1). İki değişmez bu kararı korur: ağın kendi işlettiği bir hizmet bağımsız değerlendirme olmadan nitelikli ya da I3 olarak kaydedilmez, ve sınıf yükseltilene kadar hiçbir politika kimlik belgesi için I3 istemez. Bağımsız değerlendirmeden sonra sınıf yeni bir ADR ile yükseltilebilir. *Durum: yükseltme planlanan.*

14.5 Alanlar

Kimlik belgesi AB PID'inin alan adlarını ve kodlamasını kullanır (ADR-0045; Uygulama Tüzüğü (AB) 2026/1731 [7]). Ad ve kodlama farkları AB'nin kendi farklarıdır: SD-JWT VC'de [16] doğum tarihi `birthdate`, mdoc'ta [34] `birth_date` olarak, ISO tarih etiketiyle yazılır. Türü ve ad alanı (`urn:tamga:id:IdentityAttestation:1`, `tamga.id.1`) ağındır; AB'nin PID türü ve ad alanı kullanılmaz, çünkü belge PID değildir. Bu seçimin alternatifi, ağa özgü adları koruyup her doğrulayıcıya bir eşleme tablosu vermekti; reddedildi, çünkü her AB doğrulayıcısını ağın adlarını öğrenmeye zorlardı (Tablo 24).

Tablo 24. Kimlik belgesinin alanları (FW-RB-0003 §2.2, §3.1, §3.2). Bütün kişi alanları ayrı ayrı açıklanabilir; portre, adres ve güvence seviyesi alanı yoktur.

SD-JWT VC adı	mdoc öğesi	Ne taşır	Not
`given_name`, `family_name`	aynı	ad, soyad	AB PID adı
`birthdate`	`birth_date`	doğum tarihi	AB PID kodlaması
`nationalities`	`nationality`	uyruklar dizisi	her öğe ayrı açıklanır
`personal_administrative_number`	aynı	ulusal kimlik numarası	yalnız bu türde bulunur
`issuing_country`	aynı	AB anlamıyla belgeyi veren sağlayıcının ülkesi	bugün taranan kimlik belgesini veren ülke
`document_type`	aynı	doğrulanan belgenin türü	kimlik kartı, pasaport, oturma izni, sürücü belgesi
`document_number_hash`	aynı	belge numarasının anahtarlı özeti	numaranın kendisi yok
`document_chip_verified`	aynı	NFC çip okundu mu	olgu, seviye değil
`verification_method`	aynı	doğrulama yolu	uzaktan, NFC'li uzaktan, yüz yüze
`age_over_18`, `age_over_15`	aynı	yaş eşiği geçildi mi	türetilmiş evet/hayır

Kimlik numarası bilerek yalnız bu belgede durur ve yalnız kayıtlı kapsamında bu alan bulunan bir doğrulayıcıya açılır (SPEC-ID-0003 §8). Numaranın yokluğu da denendi: yalnız ad ve doğum tarihiyle eşleştirme adaşlarda belirsizleşir ve kurumların reddi artar; bu seçenek reddedildi (ADR-0011).

Yaş alanlarında doğrulayıcının çoğu zaman doğum tarihine ihtiyacı yoktur; bir eşiğin geçilip geçilmediğini bilmesi yeter. Kimlik servisi bu cevabı belgeyi verdiği anda doğum tarihinden türetir ve imzalar; cüzdan eşiği kendisi hesaplamaz, çünkü o zaman belge verenin imzası sonucu kapsamazdı. Adlar ISO/IEC 18013-5'in `age_over_NN` desenini izler ve eşik kümesi kapalıdır: bugün 15 ve 18; yeni bir eşik yalnız ADR ile eklenir (ADR-0064). 15 yaş eşiğinin gerekçelerinden biri, Türkiye'de 7578 sayılı Kanunla [10] sosyal ağ sağlayıcıları için getirilen ve 1 Kasım 2026'da yürürlüğe giren 15 yaş kuralıdır. Bu bir hukuki görüş değildir; bir platformun yükümlülüğünü nasıl karşılayacağını belirlemez, yalnız ağın kimlik belgesinin bu soruya en az veriyle cevap verebilmesini sağlar.

TEKNİK AYRINTI

Yaş alanlarının türetilmesi

Türetme belgenin verildiği gün, servis saatinin UTC takvim gününe göre yapılır. Kişi N. doğum gününün başladığı gün eşiği geçer; 29 Şubat doğumlular artık olmayan yıllarda 1 Mart'ta (ADR-0064, K1):

$$\text{age_over_N} = (\text{doğum_tarihi} + N \text{ yıl} \le \text{veriliş_günü}) \qquad N \in \{15, 18\}$$

$$\text{örnek:} \quad \text{1998-05-17} + 18 \text{ yıl} = \text{2016-05-17} \le \text{2026-11-04} \quad \Rightarrow \quad \text{age_over_18} = \text{true}$$

Değerler örnektir. Doğrulayıcı yalnız evet ya da hayır görür. İki eşiği birlikte açmak yaş aralığını ele verebileceği için (ikisinden biri evet, öteki hayırsa kişi 15 ile 17 yaş arasındadır) ağın doğrulayıcı politikaları tek eşik ister; iki eşiği birden isteyen bir kapsam doğrulayıcı kaydında ayrıca gerekçelendirilmelidir (ADR-0064, K3).

14.6 Kimlikten doğan belgeler

Kimlik servisi aynı altyapıyla üç belge türü daha verir. Her biri ayrı bir karardan doğdu ve hepsinde aynı soru soruldu: bu bilgi kimlik belgesinin içine mi konmalı, ayrı bir belge mi olmalı? Her seferinde cevap "ayrı belge" oldu, çünkü ayrı belgeler ayrı gösterilir, ayrı yaşar ve ayrı iptal edilir (Tablo 25).

Tablo 25. Kimlik servisinin verdiği türler.

Tür	Ne kanıtlar	Ön koşul	Geçerlilik	Biçim	Karar	Durum
Kimlik belgesi	kim olduğunu	uzaktan kimlik doğrulama (T2)	en çok 2 yıl	SD-JWT VC + mdoc	ADR-0011, ADR-0013	çalışıyor
ZK kopyası	yalnız yaş eşikleri	kimlik belgesi	en çok 24 saat	mdoc	ADR-0044	kimlik servisinde çalışıyor; cüzdan tarafı planlanan
Takma ad tohumu	hiçbir şey; gösterilmez	kimlik belgesi	kimlik belgesiyle aynı	SD-JWT VC	ADR-0031, ADR-0061	çalışıyor
E-posta, telefon	adresin o cüzdanın elinde olduğu	tek kullanımlık kod (T0)	en çok 1 yıl	SD-JWT VC	ADR-0021	e-posta çalışıyor; gerçek SMS gönderimi planlanan
Sürücü belgesi bilgisi	kartta yazan sınıflar ve tarihler	kimlik belgesinin gösterilmesi	kartın bitişi ya da 1 yıl, hangisi önceyse	SD-JWT VC	ADR-0039	sandbox'ta; gerçek kişilere hukuki incelemeden sonra

İletişim belgeleri kişinin kim olduğunu söylemez; yalnız "bu adres, belgenin verildiği anda bu cüzdanın elindeydi" der. Bu yüzden kimlik doğrulaması istemez ve kimlik bilgisi taşımaz. Adres yalnız akış süresince bellekte durur, belge verildikten sonra silinir; veritabanına yalnız anahtarlı özeti yazılır, günlüğe ne adres ne kod yazılır (ADR-0021). Numaralar ve adresler zamanla başkasına geçebildiği için geçerlilik bir yılla sınırlıdır.

Sürücü belgesi bilgisi en çok sınırla çevrili türdür. Araç kiralama ya da kurye işe alımı gibi işlerde karşı tarafın sorduğu "hangi sınıfta geçerli belgen var?" sorusuna cevap verir, ama resmî sürücü belgesi değildir ve mobil sürücü belgesi (mDL) de değildir. Bunu dört yerde açıkça söyler: tanıtım bilgisinde, her doğrulayıcının gördüğü ve hiç gizlenemeyen `not_official_licence: true` alanında, cüzdandaki kartın ön yüzünde ve doğrulayıcı ekranlarında (ADR-0039). Kartın bugün askıda olup olmadığını göstermez; ağın resmî kayda erişimi yoktur. Ulusal kimlik numarası, kısıtlama ve sağlık kodları belgeye girmez. Kart ile kimlik belgesi arasındaki eşleşme, sağlayıcıya ad gönderilmeden, kimlik servisinde anahtarlı bir özetle kurulur. Bir ülkenin yetkili makamı dijital sürücü belgesi vermeye başladığında ağ o ülke için bu türü vermeyi bırakır.

Takma ad tohumu ise hiç gösterilmeyen tek türdür. Görevi Bölüm 15.3'te anlatılır.

14.7 Saklama ve silme

Kimlik servisi bu veri için veri sorumlusudur (FW-TF-0001 §3.6). Bu yüzden ağın eskiden kullandığı "Tamga hiçbir kişisel veri görmez" cümlesi daraltıldı: ağ kimlik doğrulama verisini görür, eğitim ve sektör belgelerinin içeriğini görmez (ADR-0011, K4). Belge verildikten sonra kişi alanları tutulmaz; kalıcı kayıtta yalnız opak bir kişi referansı, belge numarasının anahtarlı özeti, süreler ve iptal listesi konumları kalır (SPEC-ID-0003 §8). Kayıtlar ve olay günlükleri kısa ve tanımlı sürelerle tutulur; bu süreler hukuki incelemeyle kesinleşecektir. Sağlayıcı tarafındaki görüntü saklama süresi sözleşmeyle asgariye çekilir.

Silme isteği ilginç bir tasarım sorununu çözer: kişinin bir hesabı yoktur, o hâlde “bu kayıt benim” diyeni servis nasıl tanır? Cevap, servisin verdiği belgelerin kendisidir. Kişi silme ucuna bir ya da birkaç kimlik belgesinin sunumunu gönderir; hiçbir alan açılmaz, yalnız imza ve cihaz bağı denetlenir. Kayıt iptal listesindeki konumdan bulunur. Sonuçta kaydın bütün kopyaları geçersiz olur, kayıt ve ona bağlı günlük satırları silinir, sağlayıcıdan oturumun silinmesi istenir (SPEC-ID-0003 §9.1). İptal listesinde yalnız bitler kalır. Takma ad tohumu servis tarafında hiç saklanmadığı için silinecek bir şeyi yoktur.

14.8 Mağaza inceleme kodu

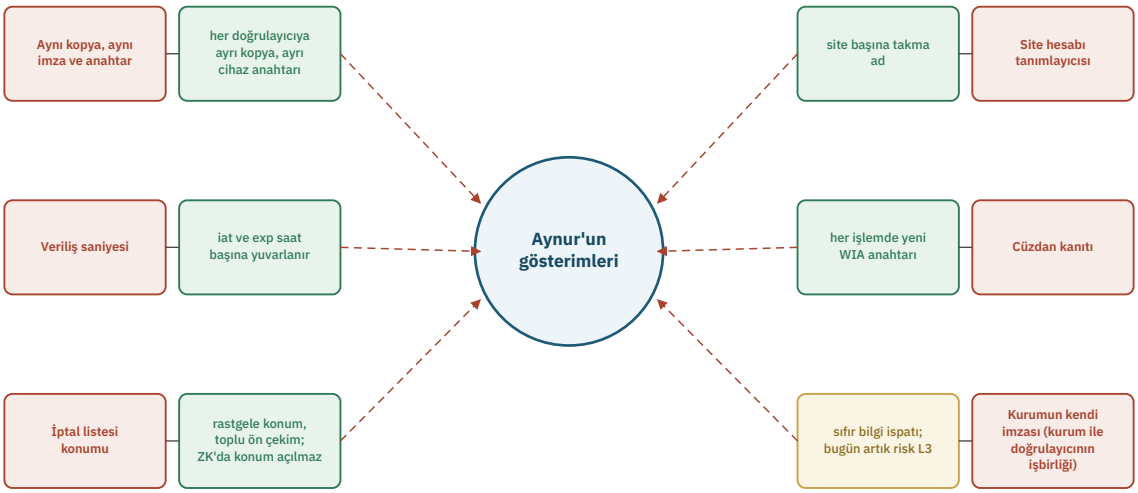
Bir cüzdan uygulaması uygulama mağazasına girmeden önce inceleyiciler onun bütün akışlarını denemek ister. Kimlik akışı gerçek bir kimlik belgesi ve yüz taraması istediği için inceleyici bunu yapamaz. Kalıcı bir “deneme kipi” reddedildi: gerçek kullanıcı da açabilir ve sahte belgeler gerçekmiş gibi görünebilir. Kabul edilen çözüm süreli ve tek kullanımlık bir inceleme kodudur (ADR-0033). Kod en az 128 bit rastgeledir, yalnız özetiyle saklanır, en çok 14 gün geçerlidir ve aydınlatma sayfasındaki küçük bir alana girilir. Geçerli kodla o oturum için sahte bir doğrulama kullanılır ve belge ayrı bir deneme imzacısıyla imzalanır. Bu imzacı listede en alt sınıfta (I1) durur; gerçek politikaların hepsi I2 istediği için deneme belgesi hiçbir gerçek doğrulamada geçmez. Kod ağın hizmetidir ve listedeki her cüzdana aynı koşullarla açıktır. *Durum: planlanan.* Kod hazırdır; deneme imzacısının liste kaydı bekleyen başvuru olarak durur ve kayıt yayımlanana kadar inceleme yolu “etkin değil” cevabı verir.

15 Gizlilik Mühendisliği

Timur bir şirkette işe alım yapıyor ve Aynur’un diplomasını doğruluyor. Aynı akşam Aynur, Dilnoza’nın geliştirdiği bir siteye “Tamga ile giriş yap” düğmesiyle üye oluyor. Ertesi hafta Timur’un şirketi ile Dilnoza’nın sitesi müşteri listelerini karşılaştırmaya karar verse ne olur? İki kayıtta ortak bir değer varsa, bir anahtar, bir numara ya da aynı saniyeye düşen bir zaman damgası, Aynur’un iki hayatı birbirine bağlanır. Mahremiyet yalnız “hangi alanı gösterdim” sorusu değildir; “gösterdiğim şeyler başkalarıyla birleştirilebilir mi” sorusudur. Bu bölüm ağın bu ikinci soruya verdiği mühendislik cevaplarını sıralar. Kavramın kendisi dizinin “Bağlanamazlık” yazısında ayrıntılı anlatılır.

15.1 Tehdit olarak bağlanabilirlik

Bağlanabilirlik birkaç ayrı kanaldan doğar ve her kanalın kendi önlemi vardır. Aynı belgenin aynı kopyası iki doğrulayıcıya gösterilirse imza ve cihaz anahtarı iki yerde de aynıdır. Belgenin veriliş saniyesi neredeyse bir parmak izi gibidir. İptal listesindeki konum belgeye özgüdür. Bir siteye giriş için kullanılan tanımlayıcı her sitede aynıysa siteler birleşir. Son olarak, belgeyi veren kurum kendi imzasını tanır; kurum bir doğrulayıcıyla işbirliği yaparsa kişiyi yine bulabilir. Ağ bu sonuncuyu bugün tam olarak kapatamaz ve bunu artık risk L3 olarak yazar (FW-ARF-0001 §7.4) (Şekil 23).



Şekil 23. Bağlanabilirliğin kanalları ve her birinin önlemi

15.2 Doğrulayıcı başına kopya ve yuvarlanmış zaman

Cüzdan bir belgeyi tek nüsha olarak değil on kopya olarak alır ve her kopya ayrı bir cihaz anahtarına bağlıdır (SPEC-PROTO-0001 §8). Kural belge veren tarafında da zorlanır: aynı anahtarla gelen kanıtlar reddedilir, çünkü aynı anahtar kopyaları yeniden birbirine bağlardı. Cüzdan her doğrulayıcıya ayrı bir kopya gösterir ve aynı doğrulayıcıya hep aynı kopyayı gösterir (yapışkan kopya kuralı, Bölüm 13.4). Böylece iki doğrulayıcı ellerindeki imzaları karşılaştırsa da ortak bir değer bulamaz. Kopyalar azaldıkça kurum belgeleri sessizce yenilenir (ADR-0023).

İkinci önlem zamandır. Bir belgenin veriliş ve bitiş anları saniyesiyle yazılsaydı, aynı kopya paketindeki belgeler ya da aynı gün verilen az sayıdaki belge zaman damgasından ayırt edilebilirdi. Belge verme paketi bu yüzden `iat` ve `exp` değerlerini saat başına aşağı yuvarlar; aynı paketteki bütün kopyalar aynı değerleri alır. Yuvarlama belgenin doğrulanabilirliğini bozacaksa (örneğin imza sertifikası o saatin içinde başladıysa) gerçek an kalır: doğrulanabilirlik bağlanamazlıktan önce gelir. *Durum: çalışıyor.*

15.3 Site başına takma ad

“Tamga ile giriş yap” ilk sürümünde her siteye kimlik belgesindeki belge numarası özetini gönderiyordu. Site değeri olduğu gibi saklamıyordu, ama iki site anlaşırsa aynı değeri görüp aynı kişiyi bulurdu. Üstelik kişi kimlik kartını yenileyince belge numarası değiştiği için sitedeki hesap da kaybolurdu. ADR-0031 bu iki sorunu birlikte çözmek için beş seçeneği karşılaştırdı.

Cüzdanın kendi rastgele sırrından anahtar türetmek tam bağlanamazlık verirdi, ama telefon değişince bütün hesaplar kaybolurdu. Belge verenin site başına tanımlayıcı üretmesi hesapları korurdu, ama kimlik servisi kişinin hangi siteye girdiğini öğrenirdi. Passkey tek başına kimlik taşımaz; günlük giriş için kaldı. Sıfır bilgi ispatıyla türetilen bir tanımlayıcı doğru uzun vadeli çözümdür, ama bugün mağaza derlemesi ve ZK kütüphanesi ister. Seçilen yol kimlikten türetilen bir tohumdur.

Kimlik servisi kimlik belgesini verirken kişinin değişmeyen kimliğinden (Türkiye için kimlik numarasından) bir tohum türetir. Tohum ayrı ve hiç gösterilmeyen bir belge türüyle cüzdana gelir ve sunucuda saklanmaz; her doğrulamada aynı girdiden yeniden hesaplanır. Cüzdan bu tohumdan her site için ayrı bir anahtar türetir. Site kişiyi o anahtarın parmak iziyle tanır. İki site farklı anahtarlar gördüğü için kişiyi eşleştiremez; kişi yeni bir telefonda kimliğini yeniden doğruladığında aynı tohum, dolayısıyla aynı takma adlar geri gelir. Varsayılan olarak bir sitede bir takma ad vardır, bu da sahte çoklu hesabı zorlaştırır; site isterse kaydında birden çok takma ada izin verebilir. Siteye kayıtta yalnız politikada izin verilen alanlar (örneğin ad, soyad), girişte ise hiçbir belge alanı gitmez. *Durum: çalışıyor.*

TEKNİK AYRINTI

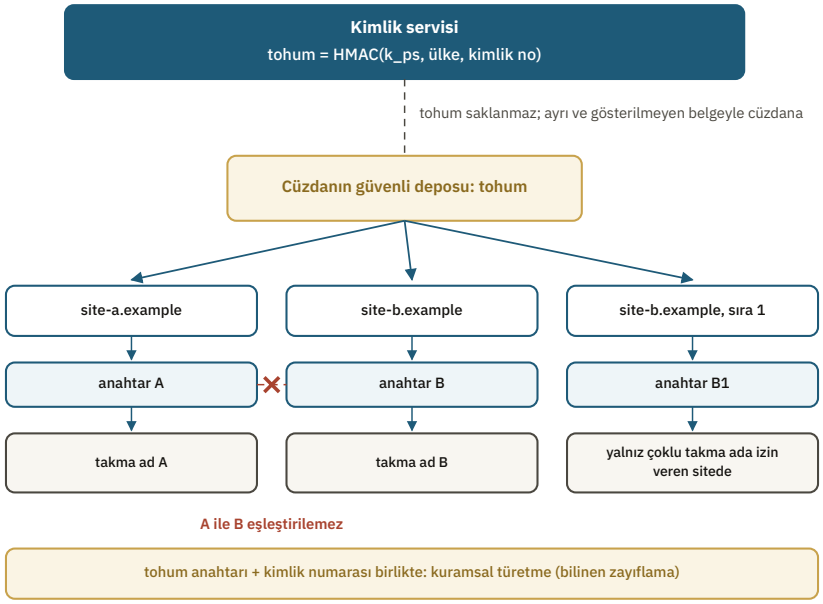
Takma ad türetme

Türetme iki aşamalıdır (ADR-0031, K1 ve K2; SPEC-WALLET-0001 §5.4). Etiket bir sürüm dizgesidir; sabitler kısaltılmıştır:

$$\begin{aligned} \text{seed} &= \text{HMAC-SHA256}\big(k_{\text{ps}},\quad \text{etiket} \parallel \text{ülke} \parallel \text{kimlik_no}\big) \\ d_{\text{site}} &= \text{HKDF-SHA256}(\text{seed},\quad \text{info} = \text{etiket} \parallel \text{dns_name} \parallel \text{sıra}) \bmod n \\ Q_{\text{site}} &= d_{\text{site}} \cdot G \quad \text{(P-256)} \\ \text{takma_ad} &= \text{RFC7638-parmak-izi}(Q_{\text{site}}) \end{aligned}$$

Birinci satır kimlik servisinde, öteki üçü cüzdanda, PIN ya da biyometri onayından sonra hesaplanır; türetilen özel anahtar saklanmaz. k_{ps} belge numarası özetinin anahtarından ayrı bir anahtardır ve yalnız kimlik servisinde durur. Site kimliği, doğrulayıcının güven listesindeki kalıcı kaydı olan alan adıdır (`dns_name`); sertifikadan türeyen istemci kimliği kullanılmaz, çünkü sertifika yenilenince değişir ve takma adı da değiştirirdi (ADR-0034). İki sitenin anahtarları neden bağımsızdır? HKDF'nin [27] farklı `info` değerleri için verdiği çıktılar, tohumu bilmeyen biri için birbiriyle ilgisiz rastgele değerler gibidir; bir takma addan ne tohum ne kimlik geri bulunabilir. Siteye giden şey, takma ad anahtarıyla imzalanmış kısa bir belirteçtir (`aud` = site, `nonce`) ve iptal edilmemiş bir cüzdan biriminden geldiğini gösteren yeni bir WIA'dır.

Bu tasarımın bilinen bir zayıflaması vardır ve ADR'de açıkça yazılıdır: tohum anahtarına ve bir kişinin kimlik numarasına birlikte sahip olan biri, örneğin kimlik servisini işleten taraf bir siteyle işbirliği yaparak, o kişinin o sitedeki takma adını hesaplayabilir. Önlemler anahtarın pilotta donanım güvenlik modülüne taşınması, erişim kaydı, şeffaflık raporunda anahtar kullanımının sayılması ve anahtarın ileride bir devlet sağlayıcısına devredilebilmesidir. Kalıcı çözüm sıfır bilgi ispatıyla türetmedir. *Durum: araştırma.* Bu zayıflamaya rağmen yeni durum eskisinden belirgin biçimde iyidir: önceden her site herkesi eşleştirebiliyordu, şimdi bunu ancak bu iki parçayı birlikte tutan biri yapabilir (Şekil 24).



Şekil 24. Takma ad türetme ağacı: bir tohum, siteler arasında bağı olmayan anahtarlar

15.4 Sıfır bilgi ispatı

Seçici açıklama kişinin yalnız gereken alanı göstermesini sağlar, ama gösterilen alanın imzası yine kurumun imzasıdır; kurum ile doğrulayıcının işbirliği (L3) bu imza üzerinden yürür. Sıfır bilgi ispatı bu

son kanalı kapatır: cüzdan "kurumun imzaladığı bir belgede `age_over_18` alanı doğru" önermesini belgeyi, imzayı ve doğum tarihini göstermeden kanıtlar. Ağ bunun için Longfellow [56, 57] ZK sistemini seçti (ADR-0032). BBS ailesi imzalar reddedildi, çünkü kurumların imza anahtarını ve biçimini değiştirmesini gerektirir ve AB'nin onaylı mekanizma listesinde yer almaz. Longfellow kurumun bugünkü ES256 imzalı mdoc [34] belgesine dokunmaz, güvenilir kurulum gerektirmez ve AB'nin yaş doğrulama profili ile ilgili teknik şartnamesi (TS13 [12]) aynı sistem üzerine kuruludur. Toplu kopya yöntemi kaldırılmadı; ispat yapılamadığında yedek yol olarak sürer.

İki ek kural bu yolu güvenli kılar. Doğrulayıcı yalnız listelerin listesinde yayımlanan ve etkin olan devre özetlerini kabul eder. ZK sunumunda iptal listesi konumu da açılmaz, çünkü açılsaydı iki gösterim yeniden birbirine bağlanırdı. İkinci kural bir sorun doğurur: iptal edilmiş bir kimlik belgesi ZK ile gösterilirse doğrulayıcı bunu göremez. ADR-0044 AB ARF'nin [11] kısa ömürlü belge yolunu seçti: ZK ile yalnız kimlik servisinin ayrıca verdiği, en çok 24 saat geçerli ve iptal listesi taşımayan ZK kopyaları gösterilir. Cüzdan bu kopyaları küçük paketler hâlinde alır ve kişiye sormadan yeniler; ana belge iptal edilmişse yeni kopya verilmez ve iptal ZK sunumunda en geç 24 saatte etkili olur. Yedi günlük kopyalar reddedildi, çünkü ARF'nin "iptal gerekmez" eşiği 24 saattir.

Durum: doğrulayıcı tarafı çalışıyor; cüzdan tarafı planlanan. İspatçı ağın açık paketidir (`@tamga-network/zk`) ve cüzdana bağlanmıştır; Android yerel kütüphanesi derlendi, iOS kütüphanesi bekliyor ve telefonda ölçüm henüz yapılmadı (FW-ARF-0001 §2.8).

TEKNİK AYRINTI

ZK ile yaş ispatı

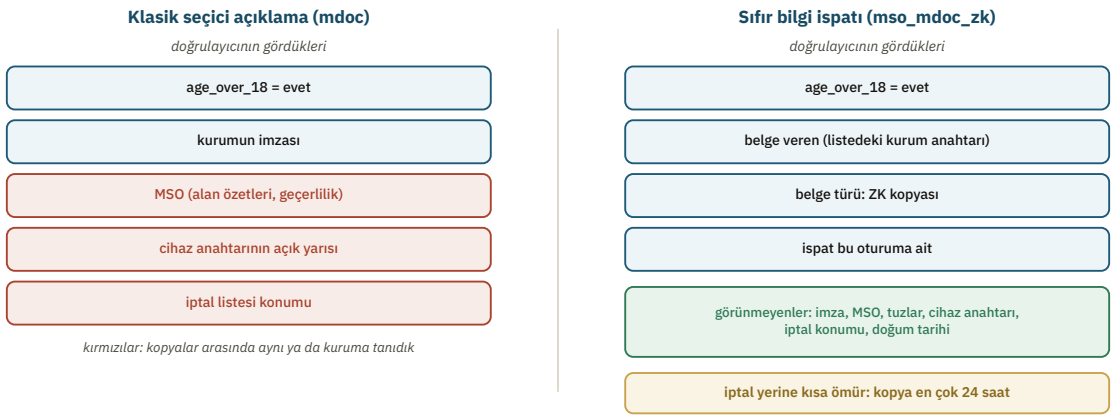
Doğrulayıcı DCQL [31] sorgusunda `mso_mdoc_zk` biçimini ister. Akışın ana hatları (ADR-0032, ADR-0044; SPEC-WALLET-0001 §4.5):

1	**Doğrulayıcı → Cüzdan**	**İstek.** İmzalı OpenID4VP isteği; DCQL'de `mso_mdoc_zk` biçimi ve tek bir öğe: `age_over_18 = true`.	nonce, aud
2	**Cüzdan**	**Kopya seçimi.** Geçerli bir ZK kopyası seçilir; kopya yoksa ZK sorgusu karşılanmaz, klasik seçenek önerilir.	$\text{validUntil} - \text{validFrom} \leq 24 \text{ sa}$
3	**Cüzdan (güvenli donanım)**	**Olağan cihaz imzası.** Oturum dökümü cihaz anahtarıyla olağan biçimde imzalanır; anahtar donanımdan çıkmaz.	$\sigma_{\text{cihaz}} = \text{Sign}(d_{\text{cihaz}}, \text{SessionTranscript})$
4	**Cüzdan (ispatçı)**	**İspat.** Devre listeden seçilir ve baytları yayımlanmış özetle karşılaştırılır; ispat üretilir.	$\text{SHA-256}(\text{devre}) = \text{combined_hash}$
5	**Cüzdan → Doğrulayıcı**	**Yanıt.** Yanıtta yalnız ispat bulunur; belge, imzalar ve tuzlar gitmez.	
6	**Doğrulayıcı**	**Denetim.** Devre özeti listede ve etkin mi; kurum anahtarı listeden; ispat doğrulanır; ispatın bağladığı tür ZK kopyasıysa iptal denetimi gerekmez.	$\text{status} = \text{NOT_APPLICABLE}$

Devrenin içinde kurumun imzası, alanın özeti, değerin `true` olduğu, geçerlilik süresi ve cihaz imzası denetlenir; ayrıntılar dizinin "Sıfır Bilgi İspatları ve Kimlik" [69] yazısındadır. ADR-0032'deki masaüstü ölçümünde ispat yaklaşık yarım saniyede üretildi, yaklaşık 343 KB tuttu ve beşte bir saniyede doğrulandı; bu boyut nedeniyle ispat QR ile taşınmaz. Bir ayrıntı şema kuralına dönüştü: kullanılan devre sürümü kurum anahtarını, belge türünü, alan adını ve değeri bağlar ama ad alanını bağlamaz. Bu yüzden bir belge türünde aynı alan adı yalnız bir ad alanında bulunabilir ve katalog bunu derlemede denetler

(ADR-0032, K8). Aynı devre bir eşitlik ispatıdır, eşik devrede sabit değildir; bu yüzden `age_over_15` için yeni devre gerekmedi (ADR-0064, K4).

Şekil 25 klasik seçici açıklamayla sıfır bilgi sunumunda doğrulayıcının gördüklerini karşılaştırır.



Şekil 25. ZK sunumu: ne gizlenir, ne görünür

15.5 Ortak kayıtlarda veri yok

Güven listeleri, çapa günlüğü, ileride gelecek ortak defter ve hizmet günlükleri ağın herkese açık ya da paylaşılan kayıtlarıdır. Bu kayıtların hiçbirinde kişisel veri bulunmaz; belge içeriği de belge özeti de yazılmaz (FW-ARF-0001 §1.6, ilke P2). Özet yazmamak bilinçli bir seçimdir: bir belgenin özeti kişisel veri değilmiş gibi görünür, ama elinde belgeyi tutan herkes onu kayıtta bulup “bu belge şu an şu işlemde kullanıldı” sonucuna varabilir. Hizmetler IP adresi kaydetmez; günlüklerde belge alanlarının değerleri ve iptal listesi konumu yer almaz (FW-ARF-0001 §4.5). İptal listeleri değişiklik olsun olmasın sabit aralıkla yayımlanır, böylece iptalin anı sızmaz (Bölüm 12.4). Kullanım istatistikleri yalnız toplu ve en az 50’lik gruplar hâlinde yayımlanır (FW-TF-0001 §1.7). Doğrulama sonucu nesnesi alanların değerlerini değil yalnız adlarını taşır ve iptal konumunu hiç taşımaz; uzun süre saklanan bu nesnenin bir izleme yüzeyine dönüşmesi böylece önlenir (SPEC-API-0001 §7) (Tablo 26).

Tablo 26. Gizlilik önlemleri, kapattıkları tehdit ve durumları.

Önlem	Kapattığı tehdit	Karar ya da kural	Durum
Seçici açıklama, yaş eşikleri	fazladan veri	ADR-0006, ADR-0064	çalışıyor
Doğrulayıcı başına ayrı anahtarlı kopya	doğrulayıcılar arası eşleştirme	SPEC-PROTO-0001 §8	çalışıyor
Saat başına yuvarlanan zaman	zaman damgasıyla eşleştirme	issuer paketi	çalışıyor
İşlem başına yeni WIA anahtarı	cüzdan kanıtıyla eşleştirme	ADR-0025	çalışıyor
Site başına takma ad	siteler arası hesap eşleştirmesi	ADR-0031, ADR-0061	çalışıyor
Rastgele iptal konumu, toplu ön çekim, sabit aralıklı yayın	iptal listesiyle izleme	SPEC-CRED-0003	çalışıyor
Sıfır bilgi ispatı ve kısa ömürlü kopya	kurum ile doğrulayıcının işbirliği (L3)	ADR-0032, ADR-0044	doğrulayıcı tarafı çalışıyor, cüzdan tarafı planlanan
Ortak kayıtlarda kişisel veri ve özet yok, IP kaydı yok	ortak kayıttan çıkarım	FW-ARF-0001 §1.6, §4.5	çalışıyor

Önlem	Kapattığı tehdit	Karar ya da kural	Durum
Sağlayıcının yalnız kimlik servisiyle konuşması	sağlayıcının kişiyi kurumlar arasında izlemesi	SPEC-ID-0003 §8	çalışıyor
ZK ile takma ad türetme	kimlik servisinin teorik türetmesi	ADR-0031, seçenek E	araştırma

15.6 Hukuki çerçeve

Ağın gizlilik kuralları teknik olduğu kadar hukukidir. Türkiye'de dayanak 6698 sayılı Kişisel Verilerin Korunması Kanunu'dur [9]; AB ile ilişkide Genel Veri Koruma Tüzüğü [8] (GDPR) belirleyicidir. Trust Framework rolleri şöyle dağıtır (FW-TF-0001 §3.6): belge veren kurum ve yetkili kaynak kendi verilerinin veri sorumlusudur; ağ, barındırdığı belge verme hizmetinde sözleşmeyle veri işleyen, kimlik servisinde ise veri sorumlusudur; cüzdan sağlayıcısı cihazdaki veriye erişmez; doğrulayıcı aldığı alanların sorumlusudur. Kişinin hakları cüzdanda somutlaşır: gösterme geçmişi cihazda tutulur, veri koruma kurumuna şikâyet yolu cüzdanda görünür ve rızanın geri alınması belgenin iptali demektir. Kimlik doğrulamadan önce aydınlatma yapılır ve açık rıza alınır.

Çerçeve, sözleşme ekleriyle birlikte pilottan önce Kişisel Verilerin Korunması Kanunu ve 5070 sayılı Elektronik İmza Kanunu açısından hukuki incelemeden geçer (FW-TF-0001 §1.4). Bu bölümdeki rol dağılımı ağın kendi kurallarının özetidir; bir hukuki görüş değildir. Küçük yaştakiler için veli onayı akışı açık bir konudur: ağ yaş sınırı koymaz (ADR-0043), GDPR'nin 8. maddesi rızaya dayalı hizmette küçükler için veli onayı ister ve bunun ağdaki karşılığı hukuki incelemeden sonra ayrı bir kararla ele alınacaktır.

15.7 Kalan gizlilik riskleri

Üç risk bugün açıkça kalır. Birincisi L3'tür: aynı kurumun belgeleri farklı doğrulayıcılarda birleştirilirse kişi eşleştirilebilir; sıfır bilgi ispatı cüzdanlara ulaştıkça bu risk kalkar. İkincisi takma ad türetmenin bilinen zayıflamasıdır; anahtar koruması ve şeffaflıkla sınırlanır, kalıcı çözümü araştırma aşamasındadır. Üçüncüsü kısa ömürlü ZK kopyalarının yenilenme sıklığıdır: kimlik servisi bir cüzdanın etkin olduğunu, yaklaşık günde bir yenilemeden öğrenebilir; hangi doğrulayıcıya ne gösterildiğini öğrenmez. Rastgele gecikme ve kişinin kapatabileceği otomatik yenileme ayarı bunu azaltır (ADR-0044, Sonuçlar). Bu riskler Bölüm 23'teki artık riskler tablosunda kalkma koşullarıyla birlikte toplanır.

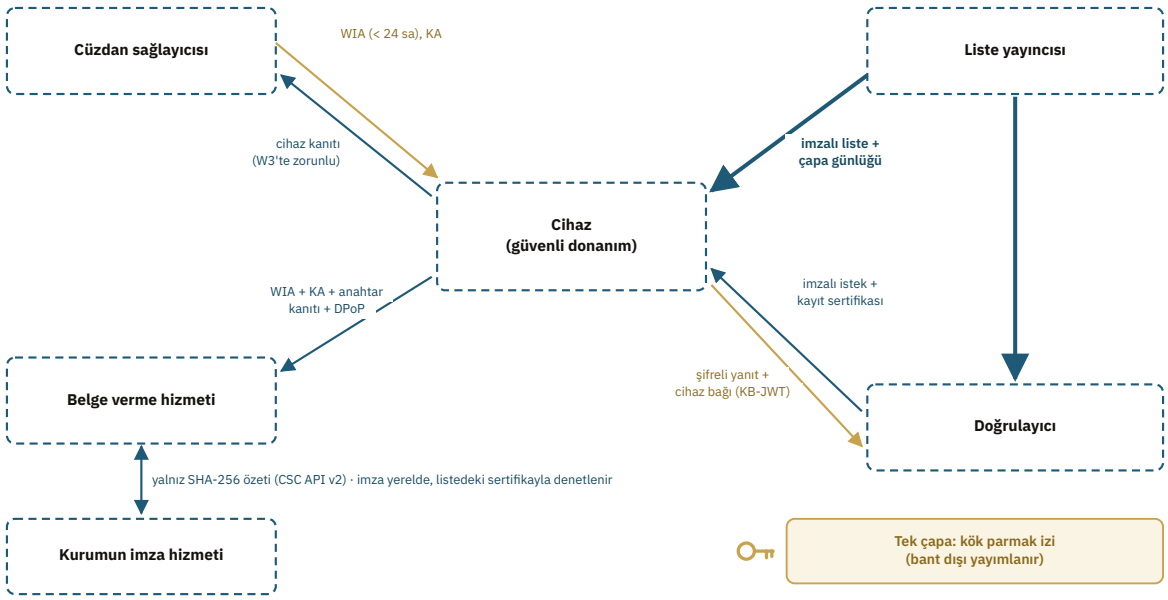
16 Güvenlik Modeli ve Tehditler

Nurlan bir konser kapısının önünde sıra bekliyor. Telefonundaki bilet bir geçiş kartına dönüşmüş, ekranda 60 saniyelik bir QR kodu duruyor. Arkasındaki biri ekranın fotoğrafını çekiyor. Bu fotoğrafla ne yapılabilir? Bir güvenlik modeli tam olarak bu tür soruları önceden sormak demektir: neyi koruyoruz, kime güveniyoruz, kim neyi deneyebilir ve denerse ne olur? Bu bölüm ağın bu sorulara verdiği cevabı tek yerde toplar.

16.1 Varlıklar ve güven varsayımları

Korunacak anahtarların her birinin ayrı bir yeri ve şartı vardır (FW-TF-0001 §2.3). Kök sertifika çevrimdışı bir törenle, iki kişi ve tutanakla üretilir. Liste imza anahtarı kural olarak en az iki kaydırmalı sertifikayla, donanım korumalı bir ortamda tutulur; SECURITY.md'ye [66] göre bugün liste tek imza anahtarıyla yayımlanır ve ikinci anahtar pilottan önce eklenecektir. Belge verenin imza anahtarı kurumun denetimindedir; gerçek ağ dosyadan okunan kurum anahtarını kabul etmez (ADR-0057). Belge sahibinin anahtarı cihazın güvenli bölgesinde üretilir, dışa aktarılamaz ve bir kurtarma tohumundan türetilmez. Kimlik servisinde belge imza anahtarı, belge numarası özetinin anahtarı ve takma ad tohumunun anahtarı birbirinden ayrıdır.

Cüzdanlar ve doğrulayıcılar tek bir şeye güvenir: listelerin listesini imzalayan köke. Liste sunucusuna, bağlantıya ya da bir alan adına güvenilmez; imza, sürüm zinciri ve tazelik denetlenmeden hiçbir kayıt kullanılmaz (FW-ARF-0001 §4.5). Belge verene yalnız kendi belgeleri için, kimlik doğrulama sağlayıcısına yalnız kimlik doğrulama kararı için güvenilir ve o karar her seferinde yeniden teyit edilir (Şekil 26).



Şekil 26. Güven sınırları ve sınırlardan geçen kanıtlar

ÖNEMLİ

Bugün güvenin tek çapası

Bugün güvenin çapası tek bir işletmecinin imzasıdır (artık risk L1; FW-ARF-0001 §6.6). İşletmeci ile bir belge veren birlikte hareket ederse listede tutarsız bir kayıt yayımlanabilir. Herkese açık çapa günlüğü bir geri sarmayı görünür kılar, şeffaflık raporu ve denetim bunu caydırır, ama hiçbiri imkânsız kılmaz. Bu sınır ancak birden çok bağımsız imzacı ve ortak defterle kalkar (Bölüm 19).

16.2 Saldırgan modelleri

Model sekiz saldırganı ayrı ayrı düşünür: sahte belge üreten, telefonu çalan, uygulamayı kopyalayan, gereğinden fazla isteyen ya da başkalarıyla veri birleştiren doğrulayıcı, QR kodunu gözetleyen, listeyi geri saran, işletmeciyle birlikte hareket eden kurum ve kimlik doğrulamada sahte yüz ya da belge kullanan. Her birinin elindeki imkân başkadır; Tablo 27 her biri için önlemi ve kalan riski verir.

16.3 Tehdit tablosu

Tablo 27. Tehdit modeli: tehdit, önlem, dayanak ve kalan risk.

Tehdit	Önlem	Dayanak	Kalan risk
Sahte kurum adına belge	kurum kimliği X.509 sertifikadan türetilir, `iss` alanından değil; tür yetkisi (C2) hiçbir ayarla atlanamaz	ADR-0004; SPEC-API-0001 §7	kurum anahtarının çalınması; olay süreci ve iptal
Belgenin başka cüzdana taşınması	cihaz bağı istisnasız zorunlu; her gösterim cihaz anahtarıyla imza ister	ADR-0006	yok denecek kadar az; anahtar dışa aktarılamaz
Telefonun çalınması	her gösterimde PIN ya da biyometri; hesapsız, iptal sırrıyla cüzdan birimi iptali; iptal cüzdan dışından öğrenilebilir	ADR-0047	telefon ve kilit bilgisi birlikteyken, ağa bağlanmayan telefonda süresi dolmamış kurum belgesi

Tehdit	Önlem	Dayanak	Kalan risk
Sahte ya da kopyalanmış cüzdan	listedeki sağlayıcının WIA ve KA'sı; yazılım anahtarlı cüzdana belge yok; cihaz kanıtı en üst seviyede zorunlu	ADR-0025, ADR-0047	donanım anahtarı ve cihaz kanıtı planlanan; cihazda henüz sınanmadı
Aşırı talep eden doğrulayıcı	imzalı istek, kayıt sertifikası, kapsam denetimi, kişiye uyarı; sertifikasız istek reddedilir	ADR-0026, ADR-0056	son karar kişide; uyarıyı geçebilir
İşbirliği yapan doğrulayıcılar	ayrı kopya, yuvarlanmış zaman, takma ad, ZK	ADR-0031, ADR-0032	L3, ZK cüzdanlara ulaşana kadar
Tekrar oynatma	`nonce`, `aud`, KB-JWT, DPoP, tek kullanımlık kod	SPEC-PROTO-0001; SPEC-PROTO-0002	yok denecek kadar az
QR'ı gören birinin sahte reddi	isteğin her çekimi taze `state`, `nonce` ve şifreleme anahtarıyla ayrı dal; ret yalnız kendi dalını kapatır	ADR-0067	yok denecek kadar az; saldırgan yalnız kendi dalını kapatır
QR'ı gören birinin bileti tüketmesi	kapı kendini terminal anahtarıyla tanıtır; anahtarsız istek jetona dokunmaz; kapı grupları listede	ADR-0065, ADR-0069	terminal anahtarının sızması; iptal edilir; sertifikalı kapı planlanan
Liste geri sarma	sürüm zinciri, önceki sürümün özeti, çapa günlüğü; geri sarma koruması varsayılan açık	SPEC-TRUST-0001; ADR-0056	tek imzacı (L1)
İşletmeci ile kurumun işbirliği	herkese açık değişiklik ve çapa günlüğü, şeffaflık raporu	FW-ARF-0001 §6.6	L1; ortak defterle kalkar
Barındırılan hizmette kurum anahtarı	uzaktan imza: hizmete yalnız özet gider, imza yerelde denetlenir; gerçek ağ dosyadaki kurum anahtarını reddeder	ADR-0057	planlanan; gerçek ağda kullanan kurum yok
İptal edilmiş kimlikle ZK sunumu	yalnız kısa ömürlü ZK kopyası; ana belge iptalse yeni kopya yok	ADR-0044	iptal en geç 24 saatte etkili
Sahte yüz ya da belgeyle kimlik doğrulama	canlılık ve yüz eşleştirmesi; belgede portre yok; T3 uzaktan yüzle verilmez	SPEC-ID-0003 §1, §8	sağlayıcının tespit gücüne bağlı
Entegratörün denetimi yanlışlıkla kapatması	güvenli varsayılanlar; atlamak için açık `"none"` değeri	ADR-0056	bilerek atlanan denetim

Kapı saldırısı bir saldırının nasıl fark edilip kapatıldığını iyi gösterir (Şekil 27). Kapı geçiş jetonunu doğrulama hizmetine gönderiyordu ve hizmet kapının kim olduğunu sormuyordu. Fotoğrafı çeken kişi jetonu önce kendisi gönderip tek kullanımlık bileti tüketebilir, Nurlan kapıya geldiğinde bilet "kullanılmış" görünürdü. Artık kapı, işletmecinin o kapı grubu için verdiği terminal anahtarıyla kendini tanıtır; anahtarsız istek jetona hiç dokunmaz (ADR-0065). Kapı grupları güven listesinde yayımlanır ve her grup kapıları işleten kurumu adlandırır; kurum yalnız kendi kapılarının anahtarlarını görür ve iptal eder (ADR-0069). Sahte ret saldırısı aynı ailedendir ve Bölüm 10.5'te anlatılır. *Durum: çalışıyor.*



Şekil 27. Sahte bilet tüketme saldırısı: terminal anahtarından önce ve sonra

16.4 Güvenli varsayılanlar

Bir kütüphanenin güvenliği, onu kullanan geliştiricinin en kolay yolu seçtiğinde ne olduğuna bağlıdır. Paketlerin 0.7.0 sürümünde bu ilke bir karara bağlandı (ADR-0056): güven çapası, dönüş adresi izin listesi, iptal sorgusu ve doğrulayıcı kaydı zorunlu girdiler oldu. Bir denetimi atlamak hâlâ mümkündür, ama yalnız açıkça `"none"` yazılarak; unutularak atlanamaz. Aynı karar kayıt sertifikası taşımayan istekleri, AB'nin daha uzun bir geçiş süresi tanımasına rağmen, bugünden reddetti; cihaz anahtarı olmayan mdoc'u [34] geçersiz saydı; güven listesi geri sarma korumasını varsayılan olarak açtı. Değerlendirilen alternatif, gevşek varsayılanları koruyup bir uyarı dönemiyle geçmekti; reddedildi. Paketlerin 0.8.0 sürümünde aynı ilke bir adım ilerledi: doğrulayıcı paketi artık isteğin her çekimine ayrı dal açmayı varsayılan yapar ve ortak bir istek nesnesi üretmez (CHANGELOG 0.8.0). *Durum: çalışıyor.*

16.5 Uyum ve sınama

Ağın bugünkü uyum rejimi "hafif uygunluk"tur (FW-TF-0001 §2.4, §4.3). Herkese açık uyum test vektörleri dondurulmuş girdileri ve beklenen çıktıları taşır; olumsuz durumların her biri (cihaz bağı kanıtı yok, yanlış `nonce`, süresi geçmiş belge…) reddedilmelidir. Taahhüt testleri en az üç şeyi ister: bayat liste "doğrulanamadı" sonucu verir, bilinmeyen biçimde işlem durur, imza hatasında işlem durur. `INDETERMINATE` beklenirken `REJECTED` dönen bir uygulama uyumsuz sayılır (GUIDE-0009).

Ekim 2026'da kimlik servisi ve Tamga Verify, OpenID Foundation'ın uyum test planlarıyla [33] sandbox üzerinde öz-test edildi; kapsamı ve sonuçları Bölüm 20.5'tedir. Bu bir öz-testti, sertifika ayrı bir süreçtir. Çalışmadan yirmiye yakın değişiklik çıktı ve dördü önceki kararları kayıtlı ADR'lerle değiştirdi (örneğin ADR-0061 ve ADR-0062).

Ağ bugüne kadar kendi güvenlik incelemelerini yaptı; kapı açığı Ekim 2026'daki güvenlik turunda bu yolla bulundu ve kapatıldı. SECURITY.md'nin belirttiği gibi ağ henüz bağımsız bir dış denetimden geçmedi; dış inceleme için kapsamı, tehdit modelini, veri akışlarını, değişmezler kataloğunu ve test sonuçlarını içeren bir paket depoda hazır tutulur. Paketlerde kurulum sonrası betik yoktur; on paketten sekizi yalnız sürekli entegrasyondan, kaynak kanıtıyla yayımlanır. İspatçı paketi telefon kütüphaneleri henüz orada derlenemediği için elle yayımlanır; katılım aracının ilk sürümü de elle yayımlandı, çünkü npm'in güvenilir yayımı yalnız var olan bir pakete kurulabilir; aracın sonraki sürümleri sürekli entegrasyondan, kaynak kanıtıyla çıkar.

16.6 Olay müdahalesi ve sorumlu bildirim

Trust Framework olayları önemlerine göre sınıflandırır (FW-TF-0001 §4.6). Güvenin kendisini tehlikeye atan olaylar (belge veren imza anahtarının sızması, liste anahtarından şüphe, bir cüzdan çözümünde açık) en geç 4 saatte, bir hizmeti ya da katılımcıyı etkileyenler en geç 24 saatte bildirilir. Anahtarı sızan belge veren askıya alınır, sertifikası ve etkilenen belgeler iptal edilir; liste anahtarından şüphede kaydırmalı ikinci sertifikaya geçilir. Kişisel veri ihlali KVKK'ya [9] 72 saat içinde bildirilir.

Kuralları çiğneyen katılımcı için uyarıdan çıkarmaya uzanan bir yaptırım merdiveni vardır ve çıkarma eski belgeleri geçersiz kılmaz (Bölüm 18.6).

Güvenlik açıkları `security@tamga.network` adresine bildirilir; ağ 72 saat içinde cevap verir ve 90 günlük koordineli açıklama penceresi uygular. Listede yer alan cüzdanlar kapsam dışıdır ve kendi işletmecilerine bildirilir (SECURITY.md). Aynı belge bilerek kabul edilmiş sınırları da listeler; bunların etkisini gösteren bir bulgu yine memnuniyetle karşılanır.

17 Sandbox, Açık Paketler ve Referans Hizmetler

Elif, Örnek Üniversitesi'nin öğrenci işlerinde çalışıyor ve diplomalarının cüzdanda nasıl görüneceğini, bir işverenin ne göreceğini merak ediyor. Dilnoza ise sitesine "Tamga ile giriş yap" düğmesini eklemek istiyor. İkisi de gerçek bir kişinin verisine dokunmadan, gerçek ağı kirletmeden ve kimseden izin beklemeden denemek ister. Bir ağın ne kadar açık olduğu, ona katılmak isteyenin ilk denemeyi ne kadar kolay yapabildiğiyle ölçülür. Bu bölüm o ilk adımın araçlarını anlatır.

17.1 Sandbox

Sandbox gerçek ağdan tamamen ayrı bir test ağıdır (ADR-0038). Hizmetleri gerçek ağdakiyle aynı koddur ve adres düzenini `sandbox` alt adıyla tekrarlar; bir cüzdan ya da doğrulayıcı yalnız adresleri ve güven çapasını değiştirerek geçer. Kendi test kökü, kendi anahtarları ve kendini açıkça test olarak işaretleyen listeleri vardır. Gerçek ağın kökü sandbox'ta hiçbir şey imzalamaz, sandbox kökü gerçek ağın hiçbir listesinde yer almaz ve gerçek ağ için yapılandırılmış bir yazılım sandbox listesini kabul etmez. Veriler her gece ilk hâline döner. Yalnız yerel geliştirme ortamı (telefon ve başka sunucular erişemez) ve gerçek ağda deneme kurumları (test belgeleri gerçek doğrulayıcılarda geçerli olurdu) seçenekleri reddedildi.

Sandbox'ta örnek kurumlar, farklı ülkelerden ve farklı durumlarda on üç sahte kişi ve her türden örnek belge vardır. Bazı kişiler olumsuz sonuçları denemek için hazırlanmıştır: diploması verilir verilmez iptal edilen, askıya alınan, 17 yaşında olan, hiçbir kurumda kaydı olmayan. Örnek kişilerin kimlik numaraları bilerek geçersiz biçimdedir (GUIDE-0013). Kimlik doğrulama varsayılan olarak sahte bir sağlayıcıyla yapılır. Gerçek kimlik doğrulama adımlarını görmek isteyenler için ayrı bir gerçek yol da vardır (ADR-0040); bu yol tavanlı ve sınırlıdır. Kişi taramadan önce açık bir test ortamı uyarısını onaylar, belgeye yalnız ad, soyad ve doğum tarihi geçer, kimlik ve belge numarasının yerine rastgele ve açıkça test olduğu belli bir değer yazılır; böylece sandbox belgesi gerçek ağdaki belgelerle ve takma adlarla bağlanamaz. Bu yol gerçek ağın sağlayıcı hesabını paylaşır; bunun getirdiği riskler ve azaltımları ADR-0040'ta yazılıdır.

Kurumlar sandbox'ta kendi test kurumlarını da açabilir (ADR-0041). Elif uydurma bir kurum adı ve türü yazar; e-posta, telefon ya da kişi adı istenmez. Kurum sandbox listesine "test kurumu" işaretiyle hemen eklenir; Elif sandbox'taki Kurum Konsolu'na passkey ile girer, uydurma kayıtlarını yükler ve masada belge verir. Kimlik numarası sağlama kuralını geçen bir sayı taşıyan kayıt reddedilir, çünkü gerçek bir kişiye ait olabilir. Test kurumlarının sertifikalarını doğrudan sandbox kökü vermez; kökün imzaladığı ve yalnız bir düzey alt sertifika verebilen ayrı bir ara sertifika makamı verir. Kökün özel anahtarı hiçbir sunucuda durmaz; ara makam ele geçirilirse yalnız o iptal edilip yenisi imzalanır. Cüzdan geliştiricileri kendi cüzdan sağlayıcılarını sandbox listesine bugün proje yönetimine başvurarak kaydettirir; ağ sandbox'ta da cüzdan sağlayıcısı işletmez (ADR-0042). *Durum: çalışıyor.* Tablo 28 sandbox'ı gerçek ağla karşılaştırır.

Tablo 28. Sandbox ile gerçek ağ.

Konu	Gerçek ağ	Sandbox
Güven kökü ve listeler	gerçek kök, `trust.tamga.network`	ayrı test kökü, `trust.sandbox.tamga.network`, listede test işareti
Kişiler	gerçek kişiler	sahte kişiler; isteğe bağlı, tavanlı gerçek kimlik yolu
Kimlik doğrulama	uzaktan kimlik doğrulama sağlayıcısı	varsayılan sahte sağlayıcı
Kurumlar	katılım kapılarından geçen kurumlar	örnek kurumlar ve kendi kendine açılan test kurumları
Kalıcılık	kayıt silinmez, değişiklik günlüğe eklenir	her gece sıfırlanır
Kapı anahtarları	işletmeci verir	deneme anahtarları herkese açık
Karşılıklı güven	sandbox'a güvenmez	gerçek ağa karışmaz

17.2 On paket

Ağın kuralları yalnız belgelerde durmaz; kod olarak da dağıtılır. `@tamga-network/*` adıyla on açık kaynak paket vardır. Kodun lisansı Apache-2.0, belgelerin lisansı CC BY 4.0'dır. Paketler npm'de 0.8.2 deneme sürümüyle yayımlanmıştır; kararlı 1.0.0 sürümüne kadar arayüzler değişebilir (README) (Tablo 29).

Tablo 29. Açık paketler.

Paket	Görev	Platform notu
`@tamga-network/core`	özetler, tanımlayıcılar, sertifika yardımcıları, AB PID ad tablosu	React Native için ayrı alt yollar
`@tamga-network/trust`	imzalı listeleri yükler ve doğrular; tek okuma arayüzü `TrustSource`	`/core` platformdan bağımsız, React Native dahil
`@tamga-network/schemas`	belge türü kataloğu: Type Metadata, JSON Schema, bütünlük özetleri	her yerde, React Native dahil
`@tamga-network/sd-jwt`	SD-JWT VC: seçici açıklama, cihaz bağı, iptal listesi	
`@tamga-network/mdoc`	ISO/IEC 18013-5 mdoc: CBOR, COSE, verme ve doğrulama	saf TypeScript, React Native uyumlu
`@tamga-network/issuer`	belge verme (OpenID4VCI) ve iptal listesi yayını; barındırılan hizmet istemcisi	sunucu
`@tamga-network/verifier`	doğrulama hattı ve OpenID4VP; sayfa kiti; ZK doğrulaması	sunucu; `/web` sayfa kiti
`@tamga-network/wallet-core`	cüzdan çekirdeği: anahtarlar, belge alma, yerel denetimler, gösterme	Node ve React Native
`@tamga-network/zk`	mdoc için cüzdan tarafı sıfır bilgi ispatçısı	çekirdek her yerde; telefonda yerel ispatçı
`@tamga-network/onboard`	kurumlar için katılım aracı: başvuru dosyası, anahtar ve CSR, kurulum ve güven listesi denetimi; düğüm adımları; yerel MCP sunucusu	komut satırı (`tamga-onboard`), Node.js 22+

Paketlerin en önemli tasarım kararı tek güven arayüzüdür (ADR-0015). Cüzdan dahil her istemci güven sorularını aynı arayüzden sorar; böylece aynı kural iki kez, iki farklı biçimde yazılmaz. Arayüzün arkasında bugün imzalı listeler durur; ortak defter geldiğinde arayüz değişmeden onun arkasına girer (Bölüm 6.6 ve 19.8). Cüzdan React Native üzerinde çalıştığı için doğrulama çekirdeği dosya sistemine ve platforma özgü kütüphanelere bağımlı olmayan bir alt yola ayrılmıştır.

TYPESCRIPT Örnek: bir sunumu kendi sunucunuzda doğrulamak (kısaltılmış, 0.8.2 deneme sürümü)

```typescript
import { fetchTrustSource } from "@tamga-network/wallet-core";
import { verifyPresentation } from "@tamga-network/verifier";

// Güven çapası: uygulamaya gömülü kök parmak izleri; liste sunucusuna güvenilmez
const { source: trust } = await fetchTrustSource("https://trust.sandbox.tamga.network", http, {
  pins: { lotlSigners: [SANDBOX_LOTL_SIGNER_FINGERPRINT], environment: "sandbox" },
});

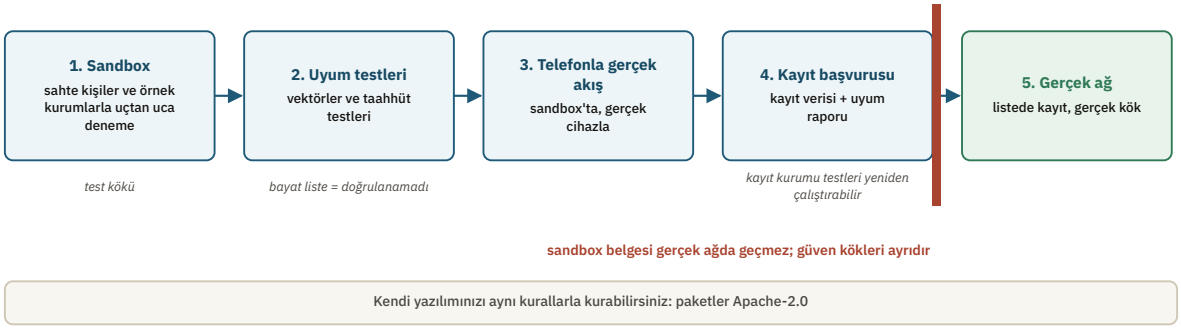
// Cüzdandan gelen şifreli yanıt çözüldükten sonra (istek dalı ve state denetimiyle)
const { result, claims } = await verifyPresentation({
  presentation, aud: clientId, nonce: branch.nonce, policy, policyCredentialId: "diploma",
  trust, statusCache, rootCertsDer,
  rp: trust.relyingParty(clientId),   // kayıt zorunlu; bilerek atlamak için "none"
  audit: (entry) => log(entry),       // denetim kaydı
});
// result.outcome: "ACCEPTED", "REJECTED" ya da "INDETERMINATE"
```

Örnek kısaltılmıştır ve değerler örnektir; isteğin her çekimine ayrı dal açan tam akış, sürekli entegrasyonda gerçek paketlere karşı çalışan örnek projelerdedir (`examples/02-verify-own-server`). Kendi doğrulayıcısını yazmak istemeyen biri barındırılan Tamga Verify'ı kullanabilir.

17.3 Referans hizmetler

Ağ dört referans hizmet işletir (ADR-0037): barındırılan belge verme hizmeti, Kurum Konsolu, Tamga Verify ve kimlik servisi. Bunlar ağın çalışabilmesi, denenebilmesi ve kurumların katılabilmesi içindir; satılmaz ve herkese aynı koşullarla açıktır. Dış bir kurum barındırılan belge verme hizmetine kendi sunucusundan, kiracıya bağlı ve yetki kapsamlı bir API ile erişir; tek bir paylaşılan yönetici anahtarı reddedildi (ADR-0016). Kurum Konsolu personelin davetle hesap açıp passkey ile girdiği, belgeleri, iptal ve askıyı, kayıt defterini yönettiği tek yerdir; eski öğrenci portalı kaldırıldı, çünkü kişi belgeyi artık cüzdandan ister (ADR-0019). Tamga Verify'da sonuca ve açıklanan alanlara yalnız sunumu açan doğrulayıcı, listedeki anahtarıyla imzalı kısa ömürlü bir beyanla ve yalnız bir kez erişir (ADR-0017).

Her hizmet için aynı cümle geçerlidir: kendi yazılımınızı aynı kurallarla kurabilirsiniz (FW-ARF-0001 §4.1). Bir kurum kendi belge verme servisini, bir doğrulayıcı kendi doğrulama yazılımını çalıştırabilir; ağın hizmetini kullanmak bir şart değildir (Şekil 28).



Şekil 28. Bir geliştiricinin yolu: sandbox'tan gerçek ağa

17.4 Belgelerin üç kapısı

Ağın dışa dönük belgeleri, AB'deki düzene benzer biçimde, üç ayrı kapıdan yayımlanır (ADR-0018). Genel anlatım tamga.network'tedir; geliştirici belgeleri, rehberler, şartnameler ve karar kayıtları docs.tamga.network'te; mimari ve referans çerçevesi (Tamga ARF) ile ekleri arf.tamga.network'tedir. Okur kendine göre kapıyı seçer: bir kurum yöneticisi kavramlarla, bir geliştirici rehberle, bir düzenleyici çerçeveyle başlar. Tamga ARF Türkçe ve İngilizce yayımlanır; Türkçe metin kaynaktır, İngilizce metin aynı sürümün resmî çevirisidir ve iki dil arasındaki sürüm kayması derlemede yakalanır. Bu belgede verilen ADR, SPEC ve FW numaralarının hepsi bu kapılardan herkese açık olarak bulunabilir.

18 Yönetişim ve Egemenlik

İki devletin bu ağa katıldığını düşünelim. Birincisi kendi ülkesindeki bir meslek kuruluşunu belge veren olarak listeye eklemek istiyor. İkinci devletin oyunu beklemesi gerekir mi? Gerekiyorsa hiçbir devlet böyle bir ağa girmez; kendi iç kararlarını başkasının onayına bağlamış olur. Gerekmiyorsa ağın ortak bir yanı kalır mı? Bu bölüm, Tamga Network'ün bu iki ucun arasında seçtiği yolu, bugün kimin neye karar verdiğini ve bu düzenin nasıl el değiştireceğini anlatıyor.

Önce bugünkü durum. Listelerde bugün yalnız Türkiye bölümü etkindir. Türk Devletleri Teşkilatı (TDT) üyesi Azerbaycan, Kazakistan, Kırgızistan ve Özbekistan ile gözlemci Macaristan ve Türkmenistan için yer ayrılmıştır (FW-TF-0001 §1.3). Bu yerler boş yuvalardır; hiçbir devletle anlaşma ya da görüşme bildirimi değildir. Aşağıda "devlet katılımında" diye anlatılan her şey, o gün gelirse işleyecek kurallardır.

18.1 Üç katmanlı egemenlik

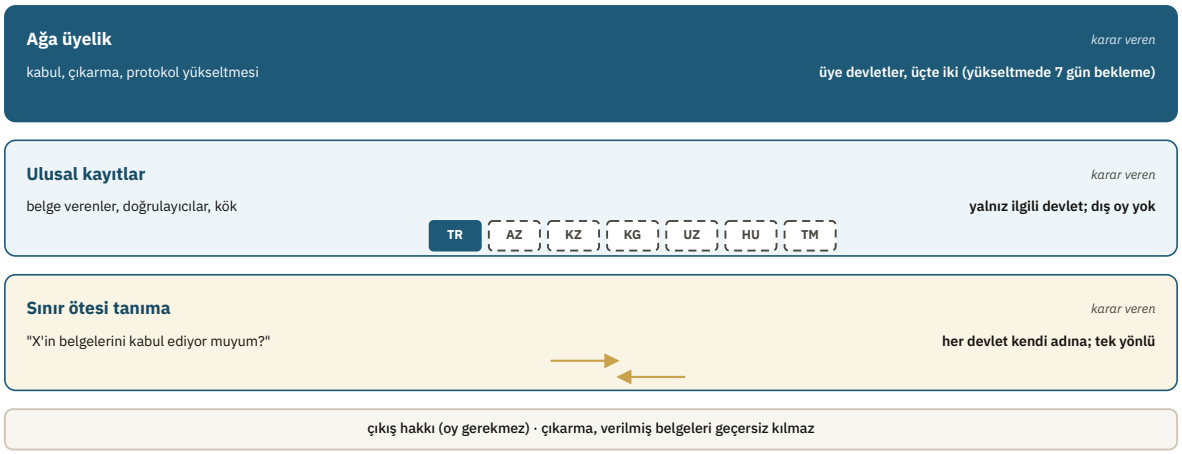
Avrupa Birliği bu soruyu kendi güven listeleriyle cevapladı: her üye devlet kendi listesini bağımsız yayımlar, Komisyon yalnız bu listeleri bir araya getiren listelerin listesini tutar ve hiçbir devlet bir başkasının hangi kurumu listeleyeceğine oy vermez. Tamga Network bu emsali izler ve yönetişimi, kararın her birinde farklı bir aktörde olduğu üç katmana ayırır (ADR-0002; Şekil 29).

Ağa üyelik. Masada hangi devletin oturduğu ortak bir karardır. Yeni devletin kabulü, bir devletin çıkarılması ve ortak protokolün yükseltilmesi üye devletlerin üçte iki oyuyla olur. Oybirliği bilerek seçilmedi; tek bir devletin ağın büyümesini kilitleyebilmesi demekti.

Ulusal kayıtlar. Bir devletin belge verenleri, doğrulayıcıları ve kök sertifikaları yalnız o devletin yetkisindedir; dış oy yoktur. İlke FW-ARF-0001 §1.6'da P1 olarak yazılıdır: her devlet kendi ulusal kayıtlarının tek yazarıdır. Liste aşamasında bu kural imzayla korunur: ulusal liste yalnız o kaydın imza anahtarıyla imzalanır. Defter aşamasında aynı kural defterin kendisinde zorlanır ve bir iyi niyet sözü olmaktan çıkar (ADR-0002 alt karar 2; ADR-0054 K2).

Sınır ötesi tanıma. "X ülkesinin belgelerini kabul ediyor muyum?" sorusunu her devlet kendi adına ve tek taraflı cevaplar. ADR-0002'nin başlangıç düzenine göre kurucu üyeler birbirini baştan tanır, sonradan katılan devlet tanımayı kendi mevzuatının hızında kendisi açar. Böylece "hepsi ya da hiçbiri" tuzağına düşülmez.

Bu katmanların üstünde iki güvence vardır. Bir devlet oy gerekmeden, tek taraflı olarak **ağdan çekilebilir**. Bir devletin **çıkarılması da vatandaşlarının belgelerini geçersiz kılmaz**: çıkarılan devlet yeni kayıt yazamaz, ama cüzdanlardaki belgeler kalır ve onlara ne olacağı diğer devletlerin tanıma kararına bağlıdır (ADR-0002 alt karar 4–5; FW-TF-0001 §3.3). Bir devletin ağa girerken soracağı ilk soru budur: "Bir gün ayrılırsam vatandaşlarım ne kaybeder?"



Bugün yalnız Türkiye listesi etkin. Yuvalar anlaşma ya da görüşme bildirimi değildir.

Şekil 29. Egemenliğin üç katmanı: kim karar verir?

TEKNİK AYRINTI

Oylama kuralları

n karar anındaki etkin üye sayısı, e evet oyu sayısı olsun. Eşiği tam sayılarla yazmak yuvarlama sorusunu kaldırır:

$$\text{kabul} \iff 3 \cdot e \geq 2 \cdot n$$

$$\text{çıkarma}: \quad n = n_{\text{etkin}} - 1 \quad (\text{çıkarılanın oyu sayılmaz})$$

$$\text{yükseltme}: \quad t_{\text{kuyruk}} + 7 \text{ gün} \leq t_{\text{uygulama}} \leq t_{\text{kuyruk}} + 37 \text{ gün}$$

Dört üyeli bir ağda kabul için en az üç evet gerekir ($3 \cdot 3 \geq 8$); beş üyede üç yetmez ($9 < 10$), dört gerekir. Yükseltmede eşik dolunca öneri kuyruğa girer, en erken yedi gün sonra uygulanır ve uygulama anında eşik o anki etkin üyelerden yeniden sayılır (ADR-0055; Bölüm 19.6). Bugün bu kuralların hiçbiri kodda çalışmıyor: liste aşamasında yönetişim belgede yaşar (ADR-0009 K5).

18.2 Bugünkü organlar

Bu düzen devletleri varsayar, ama bugün ağda katılmış bir devlet yok. Trust Framework (FW-TF-0001) bu boşluğu adlandırmayı seçer: kurulamayan organ tabloda “henüz yok” diye yazılır, geçici durum geçici diye anılır (Tablo 30).

Bugün **geçici işletmeci** günlük işletimi, altyapıyı, liste işletmeciliğini ve kayıt kurumu rolünü devlet adına yürütür. Ağın tüzel kişiliği olmadığı için bu iş kurulacak kâr amacı gütmeyen vakıf adına yapılır; listelerde işletmeci adı her zaman “Tamga Network” yazar ve durumu `provisional` (geçici) olarak işaretlenir (ADR-0070 OP1). **Teknik kurul** şartname değişikliklerini, karar kayıtlarının onayını ve ortak belge türlerini yürütür. **Konsey** yoktur; üye devlet yokken kurulmaz. Yönetişim kurumu (vakıf ya da konsey) bir ya da iki devlet katılmaya istekli olduğunda kurulur ve listeler ona devredilir (FW-ARF-0001 §8.3).

Tablo 30. Organlar ve yetkileri (FW-TF-0001 §1.6, §4.2).

Konu	Bugün	Devlet katılımında
Ülke listesi, kayıt kurumu, kök sertifika	Geçici işletmeci, devlet adına	Her devlet kendi listesi için
Üye kabulü, çıkarma, protokol yükseltmesi	Yok (üye devlet yok)	Konsey, üçte iki
Şartnameler, karar kayıtları, ortak türler	Teknik kurul	Konsey politikalarına bağlı

Konu	Bugün	Devlet katılımında
Şema sahibi ve akreditasyon (ISO/IEC 17000 [40])	Geçici işletmeci	Konsey; ulusal akreditasyon kurumu
Uygunluk değerlendirmesi	Öz beyan ve açık uyum testleri	Bağımsız değerlendirme kuruluşları

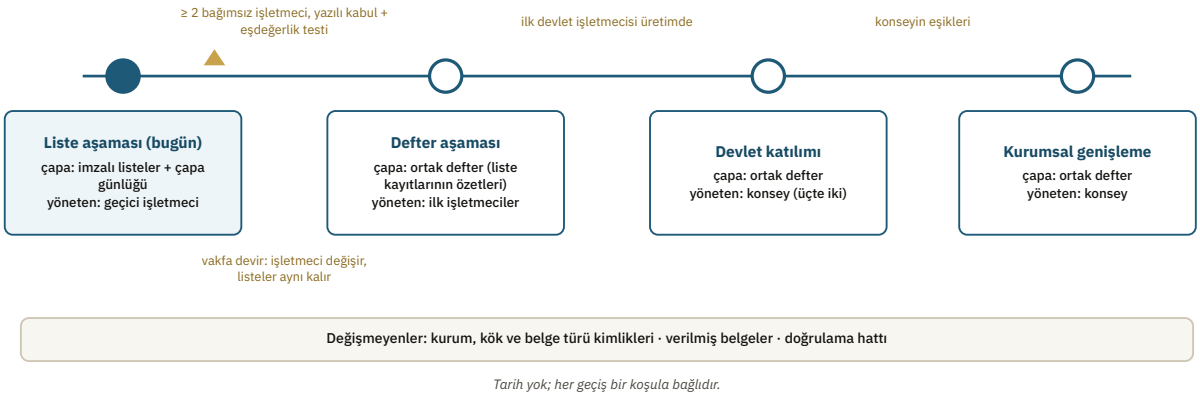
Tablonun en dürüst satırı ikincisidir: bugün bir devletin oy kullanacağı bir karar yoktur, çünkü oy kullanacak devlet yoktur. Geçici işletmecinin ve teknik kurulun geniş yetkileri tam da bu yüzden yazılı sınırlara, ölçülebilir eşiklere ve şeffaflık raporuna bağlanmıştır (Bölüm 18.5).

18.3 Aşamalar

Ağın evrimi dört aşamada tanımlıdır ve aşamalar takvimle değil koşulla tanımlanır (FW-ARF-0001 §8.1; Tablo 31, Şekil 30). Tarih verilmez, çünkü her geçiş ağın tek başına sağlayamayacağı bir şeye bağlıdır: bağımsız bir ikinci işletmeciye ya da bir devletin katılım kararına.

Tablo 31. Yönetişim aşamaları (FW-ARF-0001 §8.1; ADR-0009 K4).

Aşama	Güvenin çapası	Kim yönetir	Geçiş koşulu	Durum
Liste aşaması	İmzalı listeler ve çapa günlüğü	Geçici işletmeci	—	Çalışıyor
Defter aşaması	Ortak defter (listelerin projeksiyonu)	İlk işletmeciler	En az iki bağımsız işletmecinin yazılı kabulü; eşdeğerlik testleri	Planlanan (kod hazır, kapalı)
Devlet katılımı	Ortak defter	Konsey, üçte iki	İlk devlet işletmecisinin üretime geçmesi	Planlanan
Kurumsal genişleme	Ortak defter	Konsey	Konseyin eşikleri	Planlanan



Şekil 30. Yönetişim aşamaları: güvenin çapası ve yöneten

İki geçiş farklı soruları cevaplar. Defter aşaması güvenin **kaç imzacıya** dayandığını değiştirir; devlet katılımı ise güvenin **kime ait** olduğunu. İkisi farklı sırayla da gelebilir. Bölüm 19 birincisini, aşağıdaki devir planı ikincisini ele alıyor.

18.4 Devir planı

Tamga'nın bugün üstlendiği her devlet rolü devredilmek üzere tasarlanmıştır (FW-ARF-0001 §1.6 P4: hiçbir tanımlayıcı, rol ya da yapı tek işletmeci varsayımı taşımaz). Bunun izi listelerde görülür: kökün adı "TR National Root CA (geçici işletmeci)" biçimindedir, ad devlete aittir ve işletmeci ayrı bir alanda yazar (ADR-0009 K5). Devirde bu alan değişir; kurum, kök ve belge türü kimlikleri değişmez.

Devir iki ayrı olaydır. **Vakfa devir**, vakıf tüzel kişilik kazandığında ağın kendi hizmetlerinin işletmecisini değiştirir. Tek bir yapılandırma değeri ve ona bağlı kayıtlarla sertifikalar yenilenir; liste işletmecisi adı,

kök ve belge türü kimlikleri ile kurumların kalıcı kimlikleri değişmez (ADR-0070 K4, OP3). Devir hazır bir araçla ve yazılı bir kılavuzla yürütülür; araç kuru prova kipinde çalıştırılabilir. Bilinen tek yan etki kimlik servisindedir: belge imza sertifikasına kurum kimlik numarası vakfa devirde yeni bir anahtarla eklenecek ve kimlik belgeleri o gün bir kez yeniden alınacak; bu yeniden almayı iki kez yaşatmamak için böyle seçildi (ADR-0058; Bölüm 14).

Devlete devir, bir devlet kendi ülke listesini devraldığında olur ve altı adımda tanımlıdır (Tablo 32). Sıra esnektir; bir devlet önce liste işletmeciliğini alıp kayıt kurumunu sonra devralabilir.

Tablo 32. Devlete devir adımları (FW-TF-0001 §7).

Adım	Ne devredilir	Nasıl
1	Ülke listesinin işletmeciliği	İşletmeci alanı değişir; devletin imza sertifikası kaydırmalı eklenir; kimlikler sabit kalır
2	Kayıt kurumu	Kayıt yetkisi devlete geçer; geçici işletmeci artık kayıt yapamaz
3	Ulusal kök sertifika	Adı sabit kalır, işletmecisi değişir; ya da devletin kökü kaydırmalı eklenir, eski kök emekliye ayrılır
4	Kişi kimliği (PID) sağlayıcısı yeri	Devlet doldurur; yüksek kimlik doğrulama seviyeleri PID'e geçer
5	Ortak defter	Devlet işletmecileriyle defter; liste arşivi aynen aktarılır ve eşdeğerlik testinden geçer
6	Trust Framework	Konseyin mülkiyetine geçer; sürüm numaralandırması sürer

Trust Framework tablonun altına tek bir cümle koyar: "Devir hiçbir belgeyi, kaydı ya da kimliği geçersiz kılmaz." Cüzdan ve doğrulayıcı için devrin bütün etkisi, listenin adresinin ve imzacısının değişmesidir (ADR-0035 PO3). Kodla korunamayan varlıklar, yani alan adları, kök sertifikalar, liste arşivi ve anahtarlar, yazılı kurala bağlıdır: alan adı vakıf kurulunca vakıf adına kayıtlıdır, transfer kilidi ve DNSSEC uygulanır, en az on yıl önceden yenilenir; tasfiyede ya da devirde bunlar bir halefiyet sözleşmesiyle konseye ya da emanetçiye geçer (FW-TF-0001 §5.7; ADR-0070 K5).

18.5 Ölçülebilir eşikler ve şeffaflık

Kodla sınırlanabilen yetki kodla sınırlanır: imza anahtarı olmayan biri listeyi değiştiremez. Ama hizmetleri barındıran, alan adını tutan, kayıt tutan ve istatistik toplayan bir işletmeci, hiçbir kuralı çiğnemeden sessiz bir ağırlık kazanabilir. Trust Framework buna **yumuşak güç** der ve onu da sınırlar (G-B; FW-ARF-0001 §1.6 P7): her böyle yetki yazılı bir politikaya, ölçülebilir bir eşiğe ve şeffaflık raporuna bağlanır (Tablo 33).

Tablo 33. Yumuşak yetkiler ve sınırları (FW-TF-0001 §1.6–§1.7; FW-RB-0001 RB-OP-09…RB-OP-13).

Yetki	Sınır
Belge verme hizmetini barındırmak	Barındırılan kurumların listesi açıktır; oranları %30'u aşarsa konu konsey gündemine gelir
Defter düğümlerini işletmek	Devlet işletmecisi sayısı en az dört olunca ilk işletmecinin düğümleri devredilir
Listeleri dizinlemek	İşletmeci barındırılmış dizinleme hizmeti sunmaz; dizinleme yazılımı açık kaynaktır
İstatistik toplamak	Yalnız toplu sayaç; 50'den küçük grup yayımlanmaz; kurum ya da belge bazında sayaç yok; ham sayaç en çok 13 ay
Listeyi değiştirmek	Herkese açık değişiklik günlüğü (kim, ne zaman, ne, gerekçe); çapa günlüğü

Şeffaflık raporu üç ayda bir yayımlanır: liste sürümleri ve değişiklikler, barındırma oranı, en az 50'lik gruplarla tür kullanım sayaçları, olaylar ve denetim bulguları; kişisel veri içermez (FW-TF-0001 §1.7). Bu düzenin sınırı açıktır ve Bölüm 23'te artık risk olarak yeniden anılacak: bugün güvenin çapası tek işletmecinin imzasıdır. İşletmeci ile bir belge veren birlikte hareket ederse tutarsız bir kayıt yayım-

lanabilir; günlük, rapor ve denetim bunu caydırır ama imkânsız kılmaz (FW-ARF-0001 §6.6, L1). Bu sınırı kaldıracak olan Bölüm 19'daki çok imzacılı düzendir.

18.6 Katılım kapıları ve uyum rejimi

Trust Framework'ün ilk ilkesi bir sınır çizer: **kayıt yetkilendirme değildir** (G-A). Kayıt kurumu kaydeder, onaylamaz. Bir üniversitenin diploma vermeye yasal yetkisi ağın dışında, kendi ülkesinin mevzuatında verilir; ağ yalnız ağ içindeki kapsamı tutar: hangi türü, hangi alanlarla verebileceğini.

Belge verenler için dört kapı vardır (FW-TF-0001 §3.2). **I1 (kayıtlı)** alan adı sahipliği, iletişim bilgisi ve teknik uygunluk ister ve doğrulayıcıya "akredite değil" diye görünür. **I2 (sözleşmeli)** buna tüzel kişiliğin ve imza yetkilisinin teyidini, katılım sözleşmesini, X.509 [28] sertifikasını ve kişisel veri eklerini ekler. **I3 (akredite)** anahtarların donanım güvenlik modülünde ya da nitelikli e-mühürde tutulmasını, kayıt tutmayı, olay bildirimi sürelerini, yıllık gözden geçirmeyi ve sorumluluk sigortasını ister. **Kamu** sınıfı devlet kurumları ve yetkili kaynaklar içindir ve ilgili devletin kayıt kurumunca kaydedilir. Belge türü yetkisi kapıdan bağımsızdır: her tür için ayrı bir izin listesi vardır, varsayılan kapalıdır. Doğrulayıcı ve cüzdan sağlayıcı kapıları Bölüm 20.3'te anlatılıyor. Denetim, AB cüzdan ekosistemindeki gibi karma bir modeldir: nitelikli karşılığı belgeler önceden, diğerleri sonradan denetlenir (Tablo 34).

Tablo 34. Uyum rejimi (FW-TF-0001 §4.1).

Sınıf	Rejim	İçerik
I3 / nitelikli karşılığı	Önceden denetim	Kayıttan önce teknik ve kurumsal değerlendirme; yıllık denetim
I2	Sonradan denetim	Öz beyan, uyum testleri; şikâyet ya da olay üzerine denetim
I1	Öz beyan	Teknik uygunluk testi; "akredite değil" etiketi
Cüzdan sağlayıcısı	Bugün öz beyan ve uyum testleri	Devlet katılımında önceden denetim, sertifikalı çözüm
Doğrulayıcı	Sonradan denetim	Kapsam ihlali ya da aşırı talep şikâyeti üzerine

Kurumun bilgi işlem ekibi kapıya hazırlığını ağın açık katılım aracıyla (`@tamga-network/onboard`, komut `tamga-onboard`) yapar ve sınar. Araç başvuru dosyasını kayıt kurallarıyla (ADR-0024) denetler, kurumun iki imza anahtarını kurumun kendi bilgisayarında üretip kayıt kurumuna gidecek sertifika isteklerini (CSR) yazar (üretimde anahtarın donanım güvenlik modülünde ya da uzaktan imza hizmetinde üretilmesi yeğlenir; o zaman araç yalnız isteği denetler), alan adını, DNS teyidini, https adreslerini, meta veriyi ve sorgu ucunu sınar; kayıttan sonra kurumun imzalı güven listesindeki görünümünü araca gömülü kök parmak izlerine karşı doğrulayarak denetler. Aynı adımlar yerel bir MCP sunucusu olarak da sunulur; böylece kurumun kendi yapay zekâ asistanı adımları yürütebilir. Araç ağa ve listeye hiçbir zaman yazmaz, kişi bilgisi sormaz ve özel anahtar bilgisayardan çıkmaz; kayıt kararı ve listeye yazma kayıt kurumunda, bugün geçici işletmecide kalır (GUIDE-0014). Bu adımlar bugünkü liste düzeninde çalışır.

Kural çiğnenirse beş basamaklı bir yaptırım merdiveni işler: otuz gün giderme süreli uyarı, tür yetkisinin daraltılması, askı, halef atanarak çıkarma ve sözleşmenin feshi (FW-TF-0001 §4.5). Merdivenin en önemli kuralı yine belgeleri korur: çıkarma eski belgeleri geçersiz kılmaz, çünkü geçerlilik belgenin verildiği tarihe göre değerlendirilir (Bölüm 11.3). Para cezası yoktur; konsey kurulursa kendi kararıyla getirebilir. Uyuşmazlık önce şema sahibi nezdinde, sonra sözleşmedeki yargı yerinde çözülür; kurumun bulunduğu devletin hukuku esastır, devletler arasında konsey yetkilidir ve onun üstünde bir merci yoktur (FW-TF-0001 §4.7, §5.8). Çerçeve pilottan önce Türk kişisel veri ve elektronik imza mevzuatı açısından hukuki incelemeden geçirilecektir (FW-TF-0001 §1.4); bu belge hukuki görüş değildir.

18.7 Finansman ilkesi

Tamga Network kâr amacı gütmez ve ürün ya da hizmet satmaz (ADR-0037). Burada yalnız ağın tarafsızlığını etkileyen ilkeler yazılır (ADR-0071; FW-TF-0001 §5.5). Kişiler için ağ her zaman ücretsizdir. Geçici dönemde ağ hiçbir katılımcıdan liste kaydı, belge verme, doğrulama, kimlik servisi ya da liste hizmeti için ücret almaz. Mali katkı kayıt kararına, listedeki yere, katılım kapılarına ya da yönetişim oyuna etki etmez. Ücretli hizmetler ağın dışındaki şirketlerce kendi adlarıyla sunulur ve kayıt kararı bunlara bağlanamaz. Ücret konusu yeniden açılırsa bu, yönetişim kurumunun kararını ve yeni bir karar kaydını ister.

18.8 Rulebook düzeni

Tamga'nın mimari ve referans çerçevesi (FW-ARF-0001), AB'nin ARF'si [11] gibi bir ana belge ve eklerden oluşur. Ek A Trust Framework, Ek B **Tamga Rulebook**'tur (FW-RB-0001): her rolün uyacağı numaralı ve bağlayıcı kuralları toplar ve AB ARF'sinin üst düzey gereksinimler ekinin karşılığıdır. Kurallar `RB-<ROL>-<NN>` biçimindedir (ör. RB-OP-15: ortak defter en az iki bağımsız işletmecinin yazılı kabulü olmadan kurulmaz) ve RFC 2119'un MUST, SHOULD, MAY dilini kullanır. Her belge türünün rulebook'u (Education, Identity, Event Ticket, Contact) bu kitaptan dallanır, bütün kurallarını devralır ve AB'nin Attestation Rulebook [13] şablonunu izler.

Bu belgeler karar üretmez. Bağlayıcılık sırası karar kayıtları, şartnameler, Trust Framework, Tamga Rulebook ve sözleşme şablonlarıdır; çelişkide üstteki geçerlidir (FW-TF-0001 §0). Her değişiklik bir karar kaydına dayanır ve `arf.tamga.network`'te yayımlanır; katılımcı yükümlülüğünü değiştiren ana sürüm sözleşmelerin yeniden imzalanmasını gerektirir (FW-TF-0001 §8). Kurallardan her sapma gerekçesi ve kapanış tarihiyle kayda geçer; kayıtsız sapma ihlaldir (RB-ENF-04). Kararların nasıl alındığı Bölüm 21'de.

19 Ortak Defter: Neden Şimdi Değil, Nasıl Gelir

ÖNEMLİ

Bu bölümün durumu: planlanan

Bugün gerçek ağda da sandbox'ta da çalışan bir zincir yok. İzinli bir ortak defterin kodu yazıldı ve test edildi; yalnız geliştirici makinelerinde ve herkese açık depodaki dört onaylayıcılı test ağında çalışır, üretimde yok ve kapalı. İkinci bağımsız bir işletmeci olmadan açılmaz (ADR-0009, ADR-0051). Aşağıdakiler, defter açılırsa geçerli olacak kurallardır; kapsamı ve geçişi ADR-0073, ADR-0074 ve ADR-0075 belirler. Bugün güven Bölüm 6'daki imzalı listelere ve çapa günlüğüne dayanır ve doğrulamanın hiçbir adımı bir zincire bağlı değildir.

"Blokzincir nerede?" sorusu Tamga'ya en sık sorulan sorulardan biridir; çünkü ağın ilk tasarımı bir zincirle başlıyordu. Bugünkü cevap şudur: bir zincir şu anda hiçbir şey katmaz ve katmadığı bir dönemde kurulması güveni olduğundan büyük gösterir. Bu bölüm bunun gerekçesini, defterin hangi kurallarla geleceğini ve geçişin nasıl yapılacağını anlatıyor. Zincirin kimlikte ne zaman işe yaradığını genel olarak dizinin on ikinci yazısı [77] tartışıyor.

19.1 Bir defter ne zaman bir şey katar

Ortak defterin vaadi, birbirine tam güvenmeyen birkaç tarafın, hiçbirinin tek başına değiştiremeyeceği bir kayıt tutmasıdır. Bizans [58] hatalarına dayanıklı uzlaşma yöntemleri, tarafların bir kısmı hatalı ya da kötü niyetli olsa bile işler; ama geri kalanların birbirinden bağımsız olduğuna dayanır.

Eski planda ilk aşamada dört blok onaylayıcısı (validator) vardı ve dördü de aynı işletmecinin olacaktı. ADR-0009 basit bir soru sordu: aynı elin altındaki dört düğüm, o elin dürüst olduğu varsayımından fazla ne üretir? Kesinti dayanıklılığı üretir, güven üretmez. Tek işletmecinin zinciri, güven açısından

tek işletmecinin imzaladığı özet zincirli bir günlükle aynıdır; ikincisi ucuzdur, ETSI standardıdır ve AB cüzdan ekosisteminin kendi modelidir (ADR-0009 F1).

Bu gözlem bir ilkeye dönüştü (FW-ARF-0001 §1.6 P5): **ortak defter bir depolama tercihi değil, bir imzacı tercihidir.** Değer verinin nerede durduğundan değil, kaç bağımsız tarafın onu onayladığından gelir. Başlangıç eşiği bu yüzden yazılıdır: zincir ancak geçici işletmeciden hukuken ve operasyonel olarak bağımsız en az bir kurum (ikinci bir üniversite, bir oda ya da bir devlet kurumu gibi) onaylayıcı işletmeyi yazılı kabul edince kurulur (ADR-0009 K4; RB-OP-15). Bugün böyle bir işletmeci yoktur. Değerlendirilen alternatifler de kayıtlıdır: zinciri beklemek güvence kazancı olmadan pilotu altyapıya bağlıyordu; tek işletmecili bir "geliştirme zinciri" güven vermeden zincir görünümü verirdi; liste, sertifika ve iptal listesi olmayan bir demo ise aynı mimari olmadığı için geçişte her şeyin yeniden yazılmasını gerektirirdi.

19.2 Neden Besu ve QBFT

Defter bugün kurulmayacak olsa da teknolojisi seçilmiştir: Hyperledger Besu [59] ve QBFT uzlaşma yöntemi (ADR-0001). Ağ izinli ve bağımsız bir özel ağdır; kendi başlangıç bloğu ve zincir kimliği vardır, herkese açık hiçbir ağa bağlı değildir. QBFT'de blok, onaylayıcıların üçte ikisinden fazlasının onayıyla tek blokta kesinleşir ve oy gücü eşittir. Tasarımda onaylayıcılar devletlerdir, güvenilir kurumlar blok onaylamayan tam düğümler işletir; QBFT birkaç düzine onaylayıcının üstünde zorlandığı için bu ayrım ölçek sorununu da çözer (Tablo 35).

Tablo 35. Defter motoru için değerlendirilen seçenekler (ADR-0001; ADR-0051).

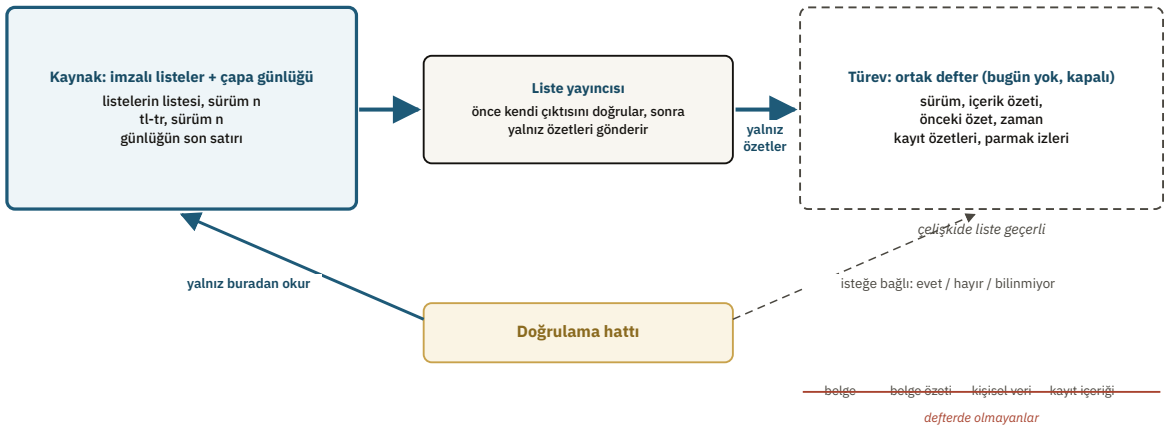
Seçenek	Sonuç	Neden
Hyperledger Besu + QBFT	Seçildi	İzinli ağ, eşit oy, anında kesinlik yerleşik; Apache 2.0, çatallanabilir; EBSI [60] de Besu tabanlıdır
Cosmos SDK (CometBFT)	Ret	Ölçek ve hız daha iyi; ama çok zincirli yapının avantajı tek ortak defterde atıl, EBSI'den farklı yığın
Sıfırdan uzlaşma yöntemi	Ret	Risk ve süre yüksek, egemenliğe katkısı yok
Herkese açık bir zincir ya da onun üstündeki katman	Ret	Egemenlik kaybı; kişisel veri sınırı dış zincirde denetlenemez

ADR-0001'in ilk gerekçeleri arasında defterin ileride değer aktarımı taşıyabilmesi de vardı; bu yön bugün askıdadır (Bölüm 19.9). Seçimi ayakta tutan gerekçeler izinli yapı, eşit oy, anında kesinlik, egemenlik ve AB'deki emsaldir.

19.3 Projeksiyon ilkesi

Defter gelirse listelerin yerine mi geçer? ADR-0051 en dar ve en güvenli cevabı verir: **zincir, imzalı listelerin projeksiyonudur.** Kaynak her zaman imzalı listeler ve çapa günlüğüdür; zincir, listelerin söylediğini özetlerle yineleyen ikinci bir kayıttır (Şekil 31).

Deftere ne yazılacağını iki karar belirler. ADR-0051 ilk adımı attı: her liste sürümünün özeti (hangi liste, kaçıncı sürüm, içeriğin SHA-256 özeti, önceki sürümün özeti, yayın zamanı) ve çapa günlüğünün son satırının özeti yazılır. Günlüğün satırları birbirine özet zinciriyle bağlı olduğundan son satır bütün günlüğü bağlar. ADR-0074 kapsamı genişletti: imzalı listelerde bir güven kararını etkileyen her kaydın defterde bir karşılığı olur. Kök sertifikalar, belge verenler, doğrulayıcılar ve kapı grupları, şemalar, cüzdan sağlayıcıları ile imza anahtarları, sıfır bilgi devreleri, dış listeler, liste imzacıları ve liste işletmecisi buna dahildir. Deftere kayıtların kendisi yazılmaz; özetleri ve parmak izleri yazılır. Bunlar tanımlayıcı özetleri, anahtar ve sertifika parmak izleri, kapalı küme değerleri, tarihler, devlet kodları ve hesap adresleridir. Ad, açıklama ve iletişim bilgisi gibi serbest metinler yalnız imzalı listede durur; defterde bunların kanonik biçiminden alınmış tek bir özet bulunur. Belgeler, belge özetleri, iptal bitleri ve kişisel veri deftere hiçbir zaman yazılmaz (ADR-0051 CH2; ADR-0074 PJ1, PJ2; Tablo 36). Sandbox listeleri de üretim defterine yazılmaz (ADR-0074 PJ4).



Şekil 31. Projeksiyon: kaynak liste, türev defter

Projeksiyonun en önemli kuralı yöndür. Doğrulama hattı ve istemcilerin güven sorularını sorduğu tek arayüz (`TrustSource`, Bölüm 6.6) yalnız listelerden okur; zincir hiçbir adımda gerekli değildir ve olmayacaktır. Bir doğrulayıcı isterse listesinin özetini zincirdeki onaylı özetle karşılaştırabilir ve üç cevaptan birini alır. **Evet**: onaylı özet aynıdır. **Hayır**: aynı sürüm için onaylı farklı bir özet vardır; bu, iki doğrulayıcıya iki farklı liste gösterildiğinin işaretidir, doğrulama sonucunu değiştirmez ama işletmeciye alarm üretir ve şeffaflık raporuna girer. **Bilinmiyor**: özellik kapalıdır ya da zincire erişilemez; sonuç kötüleşmez. Çelişkide liste geçerlidir; zincir kaydı düzeltilmez, yanına yeni sürüm eklenir (ADR-0051 K1, K5, CH1).

Tablo 36. Defterde ne var, ne yok (ADR-0051 CH2; ADR-0063 BL2; ADR-0074 PJ2; FW-ARF-0001 §1.6 P2).

Defterde var	Defterde yok
Liste sürümünün numarası, içerik özeti, önceki özet, yayın zamanı	Listenin metni; kayıtlardaki adlar, açıklamalar ve iletişim bilgileri
Çapa günlüğünün son satırının sırası, özeti, zamanı	Belgeler ve belge özetleri
Kurum, doğrulayıcı, şema, cüzdan sağlayıcısı ve liste imzacısı kayıtlarının tanımlayıcı özetleri, parmak izleri, durumları ve tarihleri	Kişisel veri, kimlik numarası, alan değerleri
Yazıcıların hangi adayı desteklediği, çelişki olayları	Cüzdan örneği, cihaz ya da takma ad kimliği
İptal listesinin adresi, özeti, sürümü, boyutu, bit sayısı	İptal bitleri, listedeki konumlar, belge türü adı

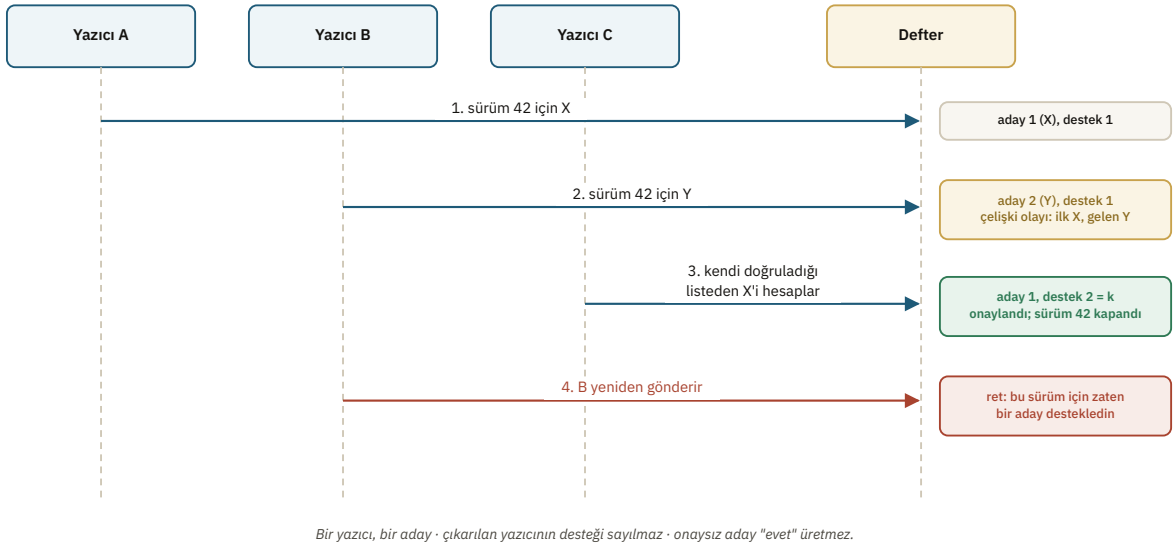
Son satır projeksiyon disiplinini iyi gösterir. Kimlik servisinin iptal listeleri girdi başına bir, kurum listeleri iki bit kullanır (Bölüm 12.3). Defterin eski taslağı yalnız iki biti kabul ediyordu ve kimlik listeleri hiç çapalanamazdı. ADR-0063 kuralı çevirdi: defter listenin kendini nasıl tanımladığını kaydeder ve IETF Token Status List'in [17] izin verdiği 1, 2, 4 ya da 8 değerlerinden birini kabul eder. Hangi türün kaç bit kullanacağı yayıncının ve doğrulayıcının kuralıdır; defter belge türünü bilmez.

19.4 Eşikli çapa ve rakip adaylar

Zincirde bir özetin onaylı sayılması için tek yazıcının (anchorer) göndermesi yetmez: eşik kadar farklı yetkili yazıcı birebir aynı veriyi göndermelidir ve üretimde eşik en az ikidir. Tek işletmeci onaylı çapa üretemez; bu, "ikinci bağımsız işletmeci" kuralının defterdeki karşılığıdır (ADR-0051 K3, CH3).

Yazıcılar anlaşamazsa ne olur? İlk tasarımda sürümü ilk açan yazıcı verinin ne olacağını belirliyor, farklı veri gönderen reddediliyordu. Bir güvenlik incelemesi bunun iki zayıflığını buldu: tek bir yazıcı sürümü yanlış veriyle açıp dürüst yazıcıları kalıcı olarak engelleyebiliyordu ve ret zincirde iz bırakmadığı için bu kilit görünmez kalıyordu. ADR-0053 kuralı değiştirdi: aynı sürüm için her farklı veri **ayrı bir aday** olarak kaydedilir, ikinci ve sonraki her farklı aday herkesin görebileceği bir çelişki olayı yayar,

eşiği ilk dolduran aday kazanır (Şekil 32). Onaydan sonra sürüm kapanır; onaylı kayıt değişmez ve silinmez. Kümeden çıkarılan yazıcının desteği sayılmaz, böylece anahtarını döndüren bir işletmeci aynı sürüme iki oy veremez; eşik de yazıcı sayısını aşacak biçimde ayarlanamaz (ADR-0053 K4).



Şekil 32. Rakip adaylar: aynı sürüm için iki farklı özet (eşik k = 2)

TEKNİK AYRINTI

Eşikli onayın kuralı ve bir çapanın yolu

W yetkili yazıcılar kümesi, k eşik, $D(v,a)$ de v sürümü için a adayını destekleyen yetkili yazıcılar olsun (ADR-0051 CH3; ADR-0053 AC1–AC4):

$$\text{onay}(v,a) \iff |D(v,a)| \geq k$$
$$2 \leq k \leq |W| \quad \text{(üretimde)}$$
$$D(v,a) \cap D(v,b) = \varnothing \quad \text{her } a \neq b \text{ için}$$

Üçüncü satır bir yazıcının aynı sürüm için iki aday destekleyemeyeceğini söyler; aksi hâlde tek işletmeci iki farklı özete destek verip çift konuşmayı kendi içinde gizleyebilirdi. Bir liste sürümünün zincire yolu:

1	`Liste yayıncısı`	**Yayın.** Listeyi imzalar; önceki sürümün özetini listeye yazar.	$\text{prev}_n = \text{SHA-256}(L_{n-1})$
2	`Liste yayıncısı`	**Öz denetim.** İmzayı, özet zincirini, tazeliği doğrular; sağlıksız set çapalanmaz.	$\text{Verify}(L_n) = \text{geçerli}$
3	`Yazıcı → Defter`	**Gönderim.** Yalnız özeti gönderir; bu bir oydur.	$h_n = \text{SHA-256}(L_n)$
4	`Defter`	**Aday.** Aynı özet desteği artırır; farklı özet yeni aday açar ve çelişki olayı yayar.	$\lvert D(n,h_n)\rvert + 1$
5	`Defter`	**Onay.** Destek eşiğe ulaşınca sürüm kapanır.	$\lvert D(n,h_n)\rvert \geq k$
6	`Doğrulayıcı`	**İsteğe bağlı denetim.** Listesinin özetini onaylı çapayla karşılaştırır.	$h \stackrel{?}{=} h_n$

Özellik bayrağı varsayılan kapalıdır; kapalıyken zincire bağlanılmaz. Üretimde bayrak ikinci bağımsız işletmeci ve en az iki eşik olmadan açılmaz (ADR-0051 CH5).

19.5 Ad alanı, devletler arası bağ, kotalar

"Ulusal kayıtlara yalnız o devlet yazar" ilkesi defterde kodun kuralı olur ve ADR-0054 bunun üç kenarını kapattı. **Adlar:** ortak türler `urn:tamga:<alan>:<Tür>:<ana sürüm>`, bir devlete özgü türler `urn:tamga:<cc>:<alan>:<Tür>:<ana sürüm>` biçimindedir (Bölüm 8.4). Ulusal tür yalnız kendi devletinin ad alanında olabilir, ortak tür hiçbir devletin ad alanında olamaz; böylece bir devlet konseyde oylanan bir ortak türün adını önceden kapamaz. **Bağlar:** bir kurum yalnız kendi devletinin köküne bağlanır ve yalnız kendi devletinden halef gösterir; bir devletin askı kararı başka devletin kurumlarını etkileyemez. **Kotalar:** istenmeyen yazımı sınırlayan günlük tavanlar devlet başına ve kayıt türü başına sayılır, iptal listesi yayını liste başına günde 48 ile sınırlıdır (saatlik yayın ve yeniden deneme payı) ve kurum başına günlük yeni liste kaydı sınırlıdır; tavan yeni liste açarak aşılamaz.

19.6 Yükseltme bekleme süresi

Ağın kurallarını değiştiren en güçlü işlem, defter üzerindeki kayıt programlarının (akıllı sözleşmelerin) yükseltilmesidir. Bölüm 18.1'deki çekilme hakkı, yükseltme oy geçtiği anda yürürlüğe girerse işlemez: itiraz eden devlet karar veremeden yeni kurallar uygulanmış olur. ADR-0055 bu yüzden yükseltmeye yedi günlük bir bekleme koyar.

TEKNİK AYRINTI

Bir protokol yükseltmesinin adımları

1	Üye devlet → Defter	**Öneri.** Yeni sürümü gösteren öneri açılır; serbest veri taşımaz.	$\text{öneri} = (\text{hedef}, \text{yeni sürüm})$
2	Üye devletler	**Oylama.** Etkin üyeler oy verir.	$3 \cdot e \geq 2 \cdot n$
3	Defter	**Kuyruk.** Eşik dolunca öneri uygulanmaz, kuyruğa girer.	$\text{eta} = t_{\text{kuyruk}} + 7\ \text{gün}$
4	Üye devletler	**Çekilme penceresi.** Herkes ne olacağını görür; katılmayan devlet çekilebilir.	$t_{\text{kuyruk}} \leq t < \text{eta}$
5	Defter	**Yeniden sayım.** Eşik o anki etkin üyelerden yeniden sayılır; çekilenin oyu düşer.	$3 \cdot e' \geq 2 \cdot n'$
6	Defter	**Uygulama.** Eşik sağlanıyorsa uygulanır; otuz günde uygulanmazsa öneri düşer.	$\text{eta} \leq t_{\text{uygulama}} \leq \text{eta} + 30\ \text{gün}$

İki gün devlet kurumlarına tepki süresi bırakmaz, on dört gün acil bir düzeltmeyi gereksiz uzatır; yedi gün yaygın uygulamadır. Ayrı bir zaman kilidi programı yeni bir yetki sahibi yaratacağı için reddedildi. Bekleme yalnız yükseltmeye uygulanır; üye kabulü, çıkarma ve ortak tür kaydı beklemesizdir.

Oylananın okunabilir kalması da kuraldır. Yükseltmeyle yalnız parametresiz bir başlangıç işlevi çağrılabilir; başlangıç değerleri yeni sürümün kodundadır ve oylanan o koddur. Yazıcı eklemek, eşiği değiştirmek ya da bir ortak türü kaldırmak gibi yönetim işlemleri türü belli ayrı önerilerle yapılır. Genel bir "şu çağrıyı yürüt" önerisi bilerek kurulmadı: defterde serbest veri alanı açar ve bir devletin neye oy verdiğini okumasını zorlaştırırdı (ADR-0055 GE2, GE3).

19.7 İzinlendirme ve işletim

Defter izinlidir: yalnız onaylı düğümler bağlanır, yalnız onaylı hesaplar işlem gönderir. İlk belgeler bunu Besu'nun zincir üstü izin mekanizmasıyla öngörüyordu; Besu bu mekanizmayı 24.12'de kullanımdan kaldırdı ve 25.6.0'da çıkardı. ADR-0052 kalan yolu, her düğümdeki yerel izin dosyasını seçti ve bir kural ekledi: dosya elle yazılmaz, defterin kendi yönetişim kaydından üretilir; her işletmeci onu

kendisi üretir, bütün onaylayıcılar aynı listeyi taşır ve fark bir işletme olayı olarak raporlanır. İzin listesi ikinci savunma hattıdır; yazma yetkisinin asıl denetimi defterin kurallarındadır ve listedeki bir hata o yetkiyi genişletmez. Düğümlerin uzaktan çağrı arayüzü internete açılmaz; dış erişim yalnız karşılıklı TLS doğrulayan bir ters vekil arkasından, tanımlı istemcilere verilir (ADR-0052 LP4, LP5).

Defter açıldığı gün için katılım aracında bir devletin ya da işletmecinin düğüm adımları da vardır (`tamga-onboard node`): araç düğüm anahtarını düğümün kendi makinesinde üretir, izinli kipte bir yapılandırma şablonu ile işletmecilere gidecek düğüm bildirimini yazar ve çalışan düğümü yalnız okuyarak denetler; deftere ve izin listesine yazmaz, oylar ve izin listesi değişiklikleri işletmecilerde kalır.

19.8 Geçiş

Listelerden deftere geçiş bir yeniden yazım olmayacak. Geçiş, liste sürüm arşivinin deftere **yeniden oynatılmasıdır**: her sürüm sırayla işlenir ve kayıtların durum geçmişindeki zamanlar korunur (ADR-0009 K7). Amaç şudur: kapanmış bir kurumun eski diploması, verildiği tarihte kurum etkin olduğu için geçerlidir (Bölüm 11.3) ve geçişten sonra da aynı cevabı almalıdır. Kabul ölçütü buna göre yazılıdır: pilot boyunca kaydedilen her güven sorusunda listeye dayanan güven kaynağı ile deftere dayanan güven kaynağı aynı cevabı vermelidir; tek bir sorguda kabul ile ret ayrışırsa geçiş tamamlanmamıştır. Verilmiş belgeler yeniden verilmez; cüzdan ve belge verme hizmeti değişmez; istemciler yalnız `TrustSource` arayüzünün arkasındaki uygulamayı değiştirir (ADR-0015; FW-ARF-0001 §8.2). Geçiş geri de dönülebilir ve listeler defter aşamasında da yayımlanmayı sürdürür (ADR-0009 Gerekçe 3).

Yeniden oynatmanın nasıl yapılacağını ADR-0073 belirler. Her kayıt sözleşmesinde yönetişim oyuyla yalnız bir kez açılan bir **göç penceresi** vardır. Pencere en çok 30 gün sürer, süresi dolunca kendiliğinden kapanır ve bir daha açılamaz. Açıkken geçmiş tarihli kayıt yazılabilir, ama hiçbir tarih o anki blok zamanını geçemez. Listeye ve deftere sorulan güven sorularının cevapları arasında kabul ile ret farkı kaldıkça geçiş tamamlanmış sayılmaz. Aynı karar **sert iptali** de tanımlar: bir kurumun anahtarı ele geçirilmişse iptal kaydı bir başlangıç tarihi taşır ve o tarihten sonra verilmiş belgeler kabul edilmez. Askıya alınan bir kurumun askıdan önce verdiği belgeler ise geçerli kalır. Doğrulayıcının defterdeki kimliği alan adının özetidir ve sertifikası yenilenince değişmez. Bu kimliğin başka bir devlete devri ya da iptalden sonra yeniden kaydı yalnız üçte iki oyla yapılır ve eski dönemin geçmişi silinmez (ADR-0075).

19.9 Değer katmanı: askıda

İlk tasarımda defterin ileride bir değer katmanı taşıyabilmesi için bazı kararlar alınmıştı (ADR-0003). Bunlar artık bağlayıcı değildir ve yalnız bir araştırma yönü olarak kayıtta durur (ADR-0072). Tamga Network token ya da coin ihraç etmez; ödeme, mutabakat ya da değer aktarımı işlemez ve bunlar ne ilk sürümün ne de pilotun parçasıdır. Defter kodu yalnız listelerin projeksiyonudur. Bu yönün yeniden açılması yönetişim kurumunun kararını, bir gizlilik araştırmasını, bağımsız bir güvenlik incelemesini ve yeni bir karar kaydını gerektirir.

20 AB Uyumu ve Üçüncü Ülke Tanıma

Aynur İstanbul'da bir işe başvuruyor; işverenin Avrupa'da bir ortağı var ve o da Aynur'un belgesini görmek istiyor. Ortağın sistemi AB cüzdanlarından gelen belgeleri okuyabiliyor; Aynur'un belgesi de AB'nin seçtiği biçimde ve imzalı. Belge orada kabul edilir mi?

Cevabın iki yarısı var. Birinci yarı tekniktir: belge okunabilir mi, imzası denetlenebilir mi, veren kurum güvenilen bir listeden öğrenilebilir mi? Tamga'nın tasarımı bu yarıya cevap vermeye çalışır. İkinci yarı hukukidir: okunan belgeye Avrupa'da hangi değer verilir? Bu yarı ağın elinde değildir. Bir not daha:

Aynur'un Bakü'de aldığı diploma bugün ağın listelerinde yer almaz; yalnız Türkiye listesi etkindir ve Azerbaycan için ayrılan yer, bir devlet katılınca dolacak boş bir yuvadır, anlaşma bildirimi değildir.

20.1 Üç seviye birlikte çalışabilirlik

Trust Framework üç seviye tanımlar (FW-TF-0001 §6). **Taşınabilirlik**: belgeler SD-JWT VC [16] ve mdoc [34] biçimindedir, OpenID4VCI [30] ve OpenID4VP [31] ile verilir ve gösterilir; bir AB cüzdanı Tamga belgesini teknik olarak işleyebilir. **Güven**: listeler ETSI modelindedir, ETSI TS 119 602 [42] JSON görünümüyle de yayımlanır, kök parmak izleri bant dışında duyurulur ve listelerin listesinde başkalarının listeleri için yer vardır. **Hukuki tanıma**: belgenin başka bir ülkede hukuken geçerli sayılması. İlk iki seviye ağın işidir ve bugün büyük ölçüde çalışır; üçüncüsü devletlerin işidir ve ağ bu anlaşmaların tarafı değildir.

20.2 Standart uyum haritası

Teknik katmanın AB'ninkiyle aynı olması FW-ARF-0001 §1.6'da P3 olarak yazılıdır: Tamga'ya özgü her ek standart bir uzantı noktasıyla yapılır ve standart istemcileri bozmaz (ADR-0035 PO1). Tablo 37 AB ekosisteminin dayandığı standartları, Tamga'daki karşılıklarını ve durumlarını gösteriyor; "çalışıyor" gerçek ağda ya da sandbox'ta canlı demektir.

Tablo 37. Standart uyum haritası (FW-ARF-0001 §2.8, §8.4; FW-REF-0001; ilgili karar kayıtları).

Alan	Standart ya da AB kuralı	Tamga'daki karşılığı	Durum
Güven listesi	ETSI TS 119 602 (LoTE, JSON)	Dış listeler bu biçimde okunur (ADR-0036); Tamga listelerinin LoTE görünümü (Bölüm 6.8)	Okuma çalışıyor; görünümlerin yayını planlanan
Güven listesi	ETSI TS 119 612 V2.4.1 (XML)	Aynı imzalı kaynaktan, aynı sürümle XAdES imzalı görünüm (ADR-0066)	Sandbox'ta çalışıyor; gerçek ağda planlanan
Kurum kimliği	X.509 (RFC 5280), ETSI EN 319 401; TS 119 412-6, EN 319 412-3	Ulusal kök ve kurum sertifikaları, kurum kimlik numarası (ADR-0004, ADR-0050)	Çalışıyor
Erişim sertifikası	ETSI TS 119 411-8	Ticari ad, destek adresi, hizmet kimliği (ADR-0058)	Çalışıyor; politika tanımlayıcısı planlanan
Belge veren politikası	ETSI TS 119 471	Tamga Rulebook belge veren kuralları	Kurallara işlendi
Belge biçimi	IETF SD-JWT VC, ETSI TS 119 472-1, ISO/IEC 18013-5 mdoc	SD-JWT VC birincil; kimlik ayrıca mdoc (ADR-0006, ADR-0013)	Çalışıyor
Kimlik alanları	AB Uygulama Tüzüğü 2026/1731	AB PID alan adları; belge PID değildir (ADR-0045)	Çalışıyor
Verme ve gösterme	OpenID4VCI 1.0, OpenID4VP 1.0, DCQL, HAIP 1.0, ETSI TS 119 472-2/–3	Tamga verme ve gösterme profilleri (Bölüm 9–10; ADR-0034)	Çalışıyor
Tarayıcıdan gösterme	W3C Digital Credentials API, ISO/IEC 18013-7	Doğrulayıcı tarafı	Doğrulayıcı hazır; cüzdan planlanan
Yakın alan	ISO/IEC 18013-5 (Bluetooth)	Hedef akış; bugün köprü yollar (ADR-0012)	Planlanan (cihaz testi bekliyor)
Cüzdan kanıtları	AB teknik şartnamesi TS3	24 saatten kısa WIA ve anahtar kanıtı (ADR-0025)	Çalışıyor; cihaz kanıtı planlanan
İptal	IETF Token Status List	İptal listeleri; mdoc için CWT (ADR-0008, ADR-0048)	Çalışıyor

Alan	Standart ya da AB kuralı	Tamga'daki karşılığı	Durum
Kayıt	AB Uygulama Tüzüğü 2025/848 (2026/1730 ile), ETSI TS 119 475	Ortak kayıt veri seti; kayıt sertifikası, politikası ve durum listesi (ADR-0024, ADR-0026, ADR-0068)	Çalışıyor
Paylaşım kuralı ve takma ad	AB ARF Konu 43 ve Konu 11	Gömülü açıklama politikası; site başına takma ad (ADR-0046, ADR-0031)	Çalışıyor
Kimlik doğrulama	ETSI TS 119 461	Seviye eşlemesi; sağlayıcı sözleşmesi buna atıf yapar	Kurallara işlendi
Olay bildirimi	AB Uygulama Tüzüğü 2025/847	Önem seviyeleri ve süreler (FW-TF-0001 §4.6)	Kurallara işlendi
Sertifikalı cüzdanlar listesi	AB Uygulama Tüzüğü 2025/849	Karşılığı devlet katılımında	Planlanan
Belge türü kuralları	AB Attestation Rulebook şablonu 1.5	Tamga Rulebook'un dalları	Çalışıyor
Sıfır bilgi ispatı	Longfellow ZK (mdoc)	Yaş ispatı; devreler listede (ADR-0032, ADR-0044)	Doğrulayıcı çalışıyor; cüzdan planlanan
Eğitim anlamı	ELM 3 / Europass, ISCED-F, EQF	Diploma alanlarının anlamı (Education Rulebook)	Çalışıyor
Güven işareti	AB cüzdan güven işareti	Kullanılmaz; "Tamga Network'te listeli" göstergesi (ADR-0049)	Çalışıyor

Tablo bir uyum iddiası taşır, sertifika iddiası taşımaz: "çalışıyor", standardın uygulandığını ve bunun kaynakla gösterilebildiğini söyler; bağımsız bir kuruluşun onayladığını söylemez (Bölüm 20.5).

20.3 AB kayıt verisi ve sertifikalar

AB'nin yaklaşımında cüzdandan veri isteyen her kurum önce kayıt olur ve kayıtta bildirdiğinden fazlasını isteyemez (eIDAS 2.0 [2] madde 5b). Tamga aynı mantığı kendi kayıt kurumuyla ve AB'nin kendi veri seti ve sertifika türleriyle kurar; bir devlet bu rolü devraldığında ya da bir AB doğrulayıcısı bu kayıtlara baktığında yabancı bir yapıyla karşılaşmaması için.

Kayıtlar AB'nin ortak kayıt veri setini taşır (Uygulama Tüzüğü 2025/848 [6] Ek I, 2026/1730 [7] değişikliğiyle): resmî ve ticari ad, kimlik numarası, adres, iletişim, her kullanım için amaç ve gizlilik politikası, kamu kurumu olup olmadığı, aracı ilişkileri ve veri koruma kurumu. Yalnız tüzel kişiler kaydolur; cüzdanın onay ekranı, silme talebi ve şikâyet yolu bu veriye dayanır (ADR-0024). Doğrulayıcı iki sertifika taşır. **Erişim sertifikası** kim olduğunu söyler (ETSI TS 119 411-8 [45]; ADR-0058). **Kayıt sertifikası** neye kayıtlı olduğunu söyler: ETSI TS 119 475 [46] biçiminde, içeriği yalnız imzalı listedeki kayıttan gelen, ayrı bir kayıt kurumu anahtarıyla imzalanan ve en çok 12 ay geçerli bir sertifika. Cüzdan istenen alanları onunla karşılaştırır; sertifikasız istek reddedilir, iptal edilmiş sertifikalı isteğe veri gönderilmez (ADR-0026, ADR-0056, ADR-0068). Cüzdan sağlayıcıları ise çözümlerini beyan eder, uyum testlerini geçer ve kanıt imza anahtarları listelerin listesine eklenir (FW-TF-0001 §3.2).

AB ARF'sinin [11] iki konusu da aynı yoldan alındı. Konu 43'e göre bir belge veren, belgesinin yalnız belirli doğrulayıcılara gösterilmesini isteyebilir; Tamga'da bu kural kurumun imzalı tanıtım bilgisinde yayımlanır, cüzdan onu doğrulayıcının sertifikalarıyla karşılaştırır, tutmazsa uyarır ve son kararı kişiye bırakır (ADR-0046). Konu 11'in takma ad kuralları, site başına takma ad düzeniyle madde madde eşlenmiştir (SPEC-WALLET-0001 §5.4.1; Bölüm 15.3).

20.4 Hukuki tanıma ağın elinde değil

Bu bölümün en önemli cümlesi şudur: AB standartlarıyla teknik uyum, AB'de hukuki tanıma anlamına gelmez. Dizinin on birinci yazısı [76] bunu tüzüğün metninden ayrıntılı gösterdi; burada Tamga açısından sonuçlarını özetliyoruz (ADR-0035 hukuki notu; FW-ARF-0001 §6.2).

Sık yapılan bir yanlış, madde 5f'yi üçüncü ülkelerin tanınma yolu sanmaktır. Madde 5f, AB içindeki kurumların **AB cüzdanlarını** kabul etme yükümlülüğüdür; konusu tüzüğe göre sağlanan cüzdanlara AB içinde güvenilmesidir. Tüzükte AB dışındaki bir ülkenin cüzdanını Avrupa Dijital Kimlik Cüzdanı sayan ya da onunla eşdeğer tutan bir hüküm yoktur.

"Üçüncü ülke" ifadesinin geçtiği asıl madde, "Uluslararası boyut" başlıklı 14. maddedir ve **güven hizmetleriyle** sınırlıdır. Madde 14(1)'e göre üçüncü ülkede kurulu güven hizmeti sağlayıcılarının hizmetleri, bir uygulama tüzüğüyle ya da AB ile o ülke arasında Avrupa Birliği'nin İşleyişi Hakkında Antlaşma'nın 218. maddesine göre yapılmış bir anlaşmayla tanınırsa AB'deki nitelikli güven hizmetleriyle hukuken eşdeğer sayılır. Madde 14(2), üçüncü ülkedeki sağlayıcıların AB'deki nitelikli sağlayıcılara uygulanan şartları karşılamasını ve o ülkenin tanınan sağlayıcılarının bir güven listesini kurup yayımlamasını ister; madde 14(3) karşılıklılık şartıdır. Bu yolun tarafları devletlerdir: Türkiye ya da başka bir Türk devleti bu yola girebilir, Tamga Network bir anlaşmanın tarafı olamaz.

Ağın rolü **teknik hazırlıktır**: ETSI biçiminde listeler, ETSI profilli sertifikalar ve devredilebilir devlet rolleri. Bir devlet bu yola girmek isterse ağ ona denenmiş bir araç ve şablon sunabilir; liste sahibi o devlet olur. ETSI TS 119 612 [41] XML görünümünün gerekçelerinden biri budur (ADR-0066). Komisyon, üçüncü ülkelerin imza ve mühür hizmetleri için ayrıca bir ara yol [14] açmıştır: üçüncü ülke güven listelerinin listesi ve ona bağlı uluslararası uyumluluk pilotu. Bu yol devletin denetlediği imza ve mühür sağlayıcılarını kapsar ve hukuki eşdeğerlik vermez; Tamga'nın listesindeki kurumlar bu yolun konusu değildir ve Tamga devlet olmadığı için kendi listesi oraya girmez (ADR-0066) (Şekil 33).



Şekil 33. Tanıma yolları: teknik güven ve hukuki tanıma

Kısa vadede tablo şöyledir. Tamga'nın listeler listesi AB'nin listelerini aynı federasyon mekanizmasıyla, kapsamı belge türüne göre sınırlayarak gösterebilir (Bölüm 6.9); bu teknik bir güvendir ve bugün listede dış liste yoktur. Ters yönde, AB'deki bir doğrulayıcı Tamga belgelerini ancak kendi isteğiyle, Tamga'nın listesini kendi güven kaynağına ekleyerek kabul edebilir; bu da hukuki tanıma değildir ve öyle anlatılmaz. Aynur'un Avrupalı ortağı için bugünkü cevap, belgenin teknik olarak okunabileceği, ama ona verilecek değerin o kurumun kendi kurallarına ve ilgili hukuka bağlı olduğudur.

20.5 Uyumu nasıl gösteriyoruz

"AB uyumlu" bir iddiadır ve kanıt ister. Bugün uyum dört yoldan gösterilir; hiçbiri sertifika değildir.

Açık uyum testleri. Belge verenin, doğrulayıcının ve cüzdan sağlayıcısının neyle sınandığı depoda herkese açık ve sürümlüdür; vektörler kişisel veri ve özel anahtar içermez. Taahhüt testleri en az şunları sınar: bayat liste "doğrulanamadı" sonucunu verir, bilinmeyen biçimde ve imza hatasında işlem durur. Testler her yayından önce zorunludur (FW-TF-0001 §4.3; RB-ENF-01).

OpenID öz-testi. Ekim 2026'da kimlik servisi ve Tamga Verify, sandbox'ta OpenID Foundation'ın uyum test planlarını [33] çalıştırdı: HAIP [32] ve FAPI 2.0 ile OpenID4VCI (63 modül) ve HAIP ile OpenID4VP (14 modül). Belge verme tarafının son koşusu başarısız modül olmadan, doğrulayıcı tarafınınki başarısız modül ve uyarı olmadan bitti. Doğrulayıcı koşusu, istek işleyişinin 29 Ekim'de değişmesinden öncedir ve yeniden çalıştırılacak; cüzdan planları cihaz derlemesi gerektirdiği için koşulmadı. Bu, OpenID Foundation'ın kendi aracıyla yapılmış bir öz-testtir; sertifikasyon ayrı bir süreçtir. Öğrenilenler açık kaynak bir test kiti olarak yayımlandı.

ETSI listesinin AB aracıyla okunması. Sandbox'taki ETSI TS 119 612 XML listesi ETSI'nin resmî XML şemasına ve AB'nin imza doğrulama aracına (DSS) karşı denetlendi. Araç imzayı ve başvuruları sağlam buldu; imzacı AB'de güven çapası olmadığı için sonuç "belirsiz" çıktı ve bu beklenen sonuçtur (ADR-0066). Denetim yalnız biçimin doğru olduğunu kanıtlar; bir tanıma anlamı taşımaz.

Birlikte çalışabilirlik etkinlikleri. AB'nin birlikte çalışabilirlik etkinliklerine katılım çerçevede öngörülmüştür (FW-ARF-0001 §7.3) ve **planlanan** durumdadır. Devletler katıldığında bu hafif uygunluk düzeninin üstüne bağımsız değerlendirme kuruluşları ve ulusal sertifikasyon eklenecektir (FW-TF-0001 §2.4).

20.6 Ad ve işaret

Uyumun dili de uyumun parçasıdır. "EUDI Wallet", yani Avrupa Dijital Kimlik Cüzdanı, bir AB üye devletinin sunduğu ya da tanıdığı ve AB kurallarına göre sertifikalanan cüzdanın hukuki adıdır; AB dışındaki bir kuruluşun cüzdanı bu unvanı alamaz ve AB güven işaretini kullanamaz (FW-ARF-0001 §1.4; ADR-0035 PO4). Ağ, listesindeki cüzdanlar için kendi yazılı göstergesini kullanır: "Tamga Network'te listeli". Göstergenin logosu yoktur, AB yıldızları ve renkleri kullanılmaz; dokunulunca imzalı listedeki sağlayıcı kaydı açılır ve kayıt listeden çıkınca gösterge kaybolur (ADR-0049). Tablo 38 kamuya açık her metinde uyulan dili özetliyor.

Tablo 38. Ne diyebiliriz, ne diyemeyiz (ADR-0035 hukuki notu ve PO4; ADR-0049; ADR-0066 TX2).

İfade	Kullanılır mı	Neden
"AB uyumlu", "AB standartlarında"	Evet	Aynı biçimler, protokoller ve liste modeli; testlerle desteklenir
"OpenID öz-testi yapıldı"	Evet	Kapsamı ve tarihi yazılarak
"Tamga Network'te listeli"	Evet	Ağın kendi yazılı göstergesi
"EUDI Wallet", "Avrupa Dijital Kimlik Cüzdanı"	Hayır	Üye devlete ait hukuki unvan
"AB güven işareti", AB yıldızları	Hayır	AB dışında kullanılamaz
"Sertifikalı"	Hayır	Sertifikasyon ayrı bir süreçtir ve yapılmadı
"Nitelikli", "bildirilmiş liste"	Hayır	Belge verenler nitelikli değildir; liste 910/2014 kapsamında bildirilmemiştir
"AB'de geçerli", "AB ile karşılıklı tanınma"	Hayır	Hukuki tanıma devletler arası anlaşma ister
"Ulusal cüzdan"	Hayır	Ağ cüzdan işletmez ve hiçbir devlet adına konuşmaz

Bu kuralların amacı, okuru Tamga'nın olduğundan büyük bir şey olduğuna inandırmamaktır. Ağın söyleyebileceği şey, Avrupa'nın seçtiği dili konuştuğu ve bunu herkesin sınayabileceği biçimde gösterdiğidir. O dilin Avrupa'da hukuken neye karşılık geleceğine devletler karar verecektir.

21 Kararlar ve Gerekçeleri

Bu belge boyunca her önemli seçimi bir karar kaydına bağladık. Okur bir seçimin gerekçesini merak ettiğinde ADR numarasından karar kaydının tam metnine gidebilir; orada sorunun nasıl ortaya çıktığını, hangi seçeneklerin tartıldığını ve hangisinin neden seçildiğini bulur. Bu bölüm kararları bir arada sunar. Önce bir kararın nasıl alındığını, sonra on büyük kararı derinlemesine, ardından kabul edilmiş bütün kararları temalarına göre ve son olarak zaman içinde değişen kararları anlatır.

21.1 Karar nasıl alınır

Tamga'da bağlayıcı bir seçim yazılı bir karar kaydıyla başlar. Kural kısadır ve ağın her deposunda aynı sözle tekrarlanır: önce karar kaydı, sonra kod. Bir karar kaydı dört soruya cevap verir. Hangi durum bir karar gerektirdi, hangi seçenekler değerlendirildi, hangisi seçildi ve bunun sonuçları ne oldu? Kayıtların çoğu ayrıca kararın doğurduğu bağlayıcı kuralları, yani değişmezleri, kısa kodlarla sayar; örneğin ADR-0017'nin kuralları `HV1`, `HV2` diye anılır ve uyum testleri bu kodlara atıf yapar.

Bir kayıt üç durumdan geçer. **Öneri** (*Proposed*) aşamasında karar yazılmıştır ama bağlayıcı değildir. Proje yönetimi kararı kabul edince kayıt **etkin** (*Active*) olur ve kabul tarihi kaydedilir; etkilenen şartnameler ve çerçeve belgeleri aynı çalışmada güncellenir. Kapatılmış bir karar ancak yeni bir karar kaydıyla değişir. Değişen kayıt silinmez; **yerini aldı** (*Superseded*) olarak işaretlenir ya da yeni kayıt eski kaydın hangi maddesini değiştirdiğini açıkça yazar. Böylece bir kararın bugünkü hâli kadar nasıl bu hâle geldiği de okunabilir.

Bu baskının hazırlandığı tarihte 75 karar kaydı vardır: 73'ü etkin, biri öneri durumunda (ADR-0028) ve biri yerini başka bir karara bırakmış (ADR-0003). Bütün kayıtların numarası, başlığı, durumu ve kabul tarihi Ek B'dedir.

21.2 On büyük karar

Kayıtların hepsi aynı ağırlıkta değildir. Aşağıdaki on karar ağın biçimini belirler; geri kalanların çoğu bunların ayrıntısıdır. Her biri için soruyu, seçenekleri, seçimi, gerekçeyi ve seçimin bedelini kısaca veriyoruz. Ayrıntılar ilgili bölümlerdedir.

1. Belge biçimi: SD-JWT VC [16] ve kimlik için ayrıca mdoc [34] (ADR-0006, ADR-0013). Soru, belgenin hangi biçimde kodlanacağıydı. SD-JWT VC seçici açıklamayı yerleşik olarak sunar, AB'nin ana biçimidir ve JSON-LD tabanlı biçimlerden daha yalındır; bu yüzden birincil biçim oldu. Kimlik belgesi için tek biçim yetmedi. iOS tarayıcısı üzerinden gösterme ve yakın alan mdoc ister, AB de kişi kimlik verisini iki biçimde tanımlar. Değerlendirilen öteki iki yol, yalnız SD-JWT VC'de kalmak ve tamamen mdoc'a geçmekti; ilki tarayıcı yolunu kapatır, ikincisi web akışları için daha yalın olan hattı bozardı. Bedeli, kimlik belgesi için ikinci bir verme ve doğrulama kodu ile onun testleridir (Bölüm 8).

2. Kurum kimliği X.509 [28], kişiye küresel kimlik yok (ADR-0004). Kurumların kimliği için ağa özgü bir merkeziyetsiz tanımlayıcı profili ile X.509 sertifikaları arasında seçim yapıldı. Kurumlar elektronik imza ve mühür için zaten X.509 kullanır, mevzuatta karşılığı vardır ve AB'nin nitelikli sertifika düzeni bu zemindedir; ağa özgü profil geçersiz kılındı. Aynı karar kişiler için ters bir ilke koyar: kişiye ağ genelinde sabit bir tanımlayıcı verilmez. Bedeli, sertifika yenilenince kurum kimliğinin de değişmesi ve sürekliliğin halef bağıyla kurulmasıdır (Bölüm 6.7, 7.1).

3. Zincirsiz başlangıç ve iki bağımsız işletmeci eşiği (ADR-0009, ADR-0051). Soru, ortak bir defterin ne zaman kurulacağıydı. Seçenekler, pilotu defterin kurulmasına bağlamak, tek işletmecili bir geliştirme zinciriyle başlamak ve defteri bir eşiğe bağlayıp imzalı listelerle başlamaktı. Tek işletmecinin dört düğümü, aynı işletmecinin imzaladığı listeden fazla güven üretmediği için üçüncü yol seçildi. Defter, en az iki bağımsız işletmecinin yazılı kabulüyle kurulur ve kurulduğunda da imzalı listelerin projeksiyonu olur. Bedeli, bugün güvenin tek bir imzacıya dayanmasıdır; bu artık risk Bölüm 23'te L1 olarak yazılıdır (Bölüm 19).

4. İptal listesi zincir dışında (ADR-0008). İptal bilgisinin bit dizisini ortak defterde tutmak kalıcı ve denetlenebilir görünür. Ama hangi bitin ne zaman değiştiği herkese açık bir defterde izlenebilir; düğüm işletenler bir belgenin iptal anını öğrenir. Karar, bit dizisini belge verenin imzaladığı ve sabit aralıkla yayımladığı listede tutar; defter kurulursa yalnızca listenin özetini taşır. Kriptografik akümülatör ya da sıfır bilgiyle iptal ertelendi, kısa ömürlü belge yolu ise kısmen benimsendi. Bedeli, iptalin bir yayın aralığı kadar gecikmeyle etkili olmasıdır (Bölüm 12).

5. Ağ yalnızca ağdır ve cüzdan işletmez (ADR-0037, ADR-0042). İlk konumlanma kararı ağın üstünde ürün ve hizmetler de düşünüyordu ve listeyi yöneten tarafın hizmet satmasının bir gerilim taşıdığını kendisi not etmişti. ADR-0037 bu gerilimi kaldırdı: ticari hizmetler ağın dışındaki şirketlerce kendi adlarıyla sunulur. ADR-0042 aynı ilkeyi cüzdanlara uyguladı; ağın bir cüzdanın sağlayıcı hizmetini işletmeyi sürdürmesi ve cüzdanlar için ayrı bir test ortamı kurmak reddedildi. Bedeli, ağın ilk cüzdanının da kendi sağlayıcısını ağın dışında kurmak zorunda kalmasıdır (Bölüm 4.3, 5.4).

6. Geçici kimlik belgesi sağlayıcısı, nitelikli değil (ADR-0011, ADR-0022). Devletin kişi kimlik verisi sağlayıcısı yokken kurumların kişiyi güvenilir biçimde tanıyabilmesi gerekiyordu. Seçenekler, her kurumun kendi kimlik doğrulamasını yapması, devleti beklemek ve kimlik numarası taşımayan bir belgeydi; ilki kişiyi her kurumda yeniden doğrulatır, ikincisinin tarihi yoktur, üçüncüsü adaşlarda eşleşmeyi belirsizleştirir. Seçilen yol, ağın geçici bir kimlik servisi işletmesi ve PID olmayan bir belge vermesidir. Servisin sınıfı da ayrı bir kararla nitelikli olmayan öznitelik belgesi ve I2 olarak sabitlendi; "nitelikli" bağımsız değerlendirme ister. Bedeli, ağın bu servis için veri sorumlusu olmasıdır (Bölüm 14).

7. Yetkili kaynak kurumda, imza anahtarı da kurumda (ADR-0020, ADR-0057). Barındırılan belge verme hizmeti kurumlar için kolaydır, ama iki risk taşır: kişi kayıtlarının ağda toplanması ve kurum anahtarının işletmecide durması. ADR-0020 kişi kayıtlarını ağda tutmayı reddetti; bilgi imza anında kurumun sorgu ucundan okunur ve saklanmaz. ADR-0057 anahtarı sunucuda dosyada tutmayı, tek bir bulut sağlayıcısına bağlanmayı ve ağa özgü bir imza ucu tanımlamayı reddetti; hizmet imzayı CSC API v2 [54] ile ister ve karşı tarafa yalnız özet gönderir. Bedeli, kurumun bir sorgu ucu ve bir imza hizmeti işletmesidir (Bölüm 5.2, 7.6, 9.2).

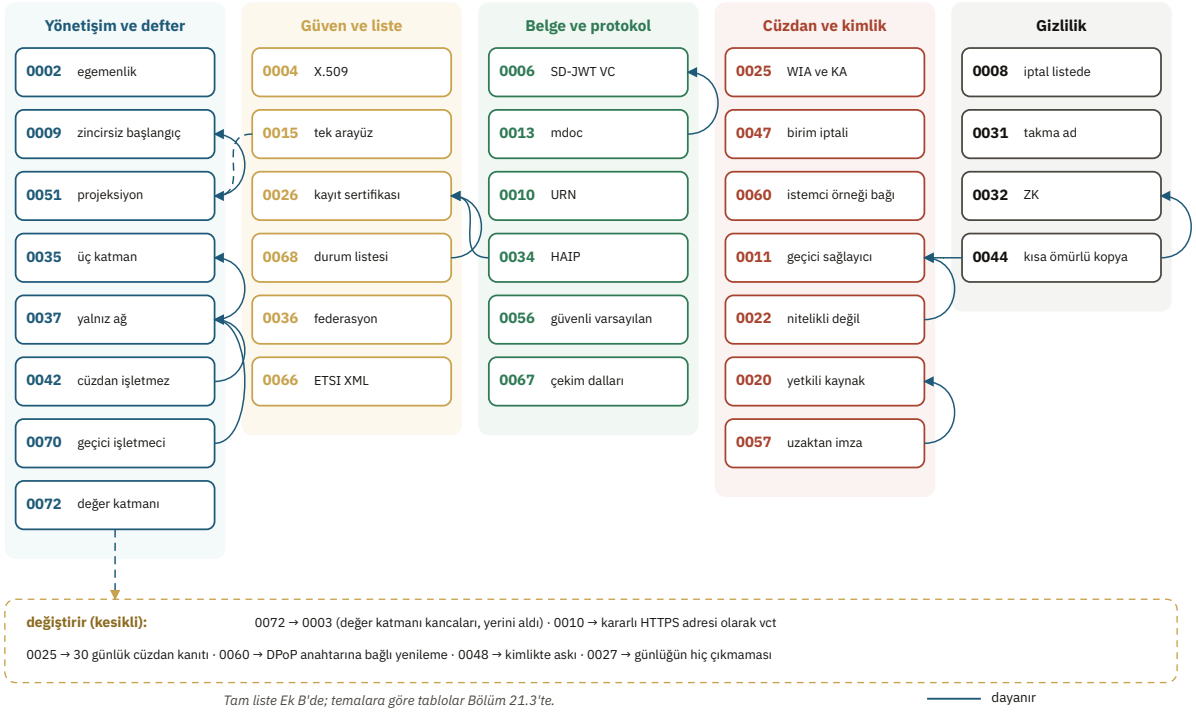
8. Site başına takma ad (ADR-0031). "Tamga ile giriş yap" bir siteye kişinin kim olduğunu her seferinde aynı biçimde söylemeliydi, ama iki site aynı kişiyi eşleştirememeliydi. Beş yöntem tartıldı: cüzdanın rastgele bir sırrı (telefon değişince hesaplar kaybolur), geçiş anahtarı (kimlik taşımaz), belge verenin site başına tanımlayıcı üretmesi (hangi siteye girildiğini öğrenir), kimlikten türetilen bir tohum ve sıfır bilgi ispatlı türetme. Bugün dördüncüsü uygulanır; beşincisi hedeftir. Bedeli, kimlik servisinin tohum anahtarı ile kişinin kimlik numarasını birlikte kullanarak takma adı kuramsal olarak türetebilmesidir (Bölüm 15.3).

9. Sıfır bilgi ispatı ve kısa ömürlü kopyalar (ADR-0032, ADR-0044). Kurum ile doğrulayıcı aynı belgenin imzasını karşılaştırarak kişiyi eşleştirebilir. Belgeyi değiştirmeden, onun hakkında bir ispat üretmek bu bağı koparır; ilk yüklem yaş eşiğidir. Ama ispat iptal listesindeki konumu da gizlediği için iptal sunumda denetlenemez. İptal listeli bir ispat ve uzun ömürlü kopya reddedildi; ZK sunumu en çok 24 saat geçerli, sessizce yenilenen kopyalarla yapılır. Bedeli, iptalin ZK sunumunda en geç 24 saatte etkili olması ve kopya yenilemesinin kimlik servisine bir etkinlik izi bırakmasıdır (Bölüm 15.4).

10. AB'nin yolu: WIA ve KA, HAIP [32], kayıt sertifikası, güvenli varsayılanlar (ADR-0025, ADR-0034, ADR-0026, ADR-0056). Bu dört karar aynı ilkenin uygulamasıdır: AB'nin seçtiği çözüm varken ağa özgü bir çözüm yazılmaz. Tek ve 30 gün geçerli bir cüzdan kanıtı yerine AB'nin 24 saatten kısa ömürlü ve her işlemde yeni anahtarlı WIA'sı ile anahtar kanıtı benimsendi. Doğrulayıcının istemci kimliği, HAIP'in istediği gibi erişim sertifikasının özeti oldu. Kayıt sertifikası üretmemek AB'de isteğe bağlıydı, ama AB cüzdanlarının Tamga doğrulayıcılarının kapsamını bilebilmesi için seçildi. Paketlerde denetimi atlatan gevşek varsayılanlar da kaldırıldı; atlamak artık koda açıkça yazılması gereken bir

değerdir. Bedeli, entegratörlerin her sürümde daha sıkı kurallara uyum sağlamasıdır (Bölüm 7.5, 10.1, 13.3, 16.4).

Şekil 34 bu kararları ve aralarındaki “dayanır” ve “değiştirir” bağlarını temalara göre gösterir.



Şekil 34. Karar haritası: büyük kararlar ve aralarındaki bağlar

21.3 Bütün kararlar

Aşağıdaki yedi tablo etkin bütün kararları temalarına göre sıralar: güven ve listeler (Tablo 39), belge ve şema (Tablo 40), protokol (Tablo 41), cüzdan (Tablo 42), kimlik (Tablo 43), gizlilik (Tablo 44) ile yönetişim, konumlanma ve defter (Tablo 45). Her satır kararı tek cümleyle, gerekçesini ve karar kaydında bırakılan başlıca seçeneği verir. Gerekçe ve seçenek sütunları karar kayıtlarının “Bağlam” ve “Değerlendirilen seçenekler” bölümlerinden özetlenmiştir; bir karar kaydı bir seçeneği açıkça tartışmıyorsa sütunda yalnızca kaydın kendi karşılaştırması yazılıdır.

Tablo 39. Güven ve liste kararları.

Karar	Gerekçe	Bırakılan seçenek
ADR-0004. Kurum kimliği X.509; kişiye küresel kimlik yok	Kurumlar zaten sertifikalı; mevzuatta karşılığı var	Ağa özgü DID kurum profili
ADR-0015. Tek güven arayüzü (`TrustSource`), cüzdan dahil	Aynı kural iki kez yazılmaz; deftere geçişte arayüz sabit kalır	Cüzdanda ayrı doğrulama; her soruyu ağın sunucusuna sormak
ADR-0024. Kayıtlarda AB ortak kayıt veri seti	Onay ekranı, silme ve şikâyet bu veriye dayanır	Eski dar kayıt
ADR-0026. Kayıt sertifikası (ETSI TS 119 475)	Cüzdan doğrulayıcının kapsamını denetleyebilsin	Kayıt sertifikası üretmemek; doğrulayıcı başına tek sertifika
ADR-0036. Dış listelerle federasyon: adres, sabit imzacı, kapsam, onay	Devlet listelerini ve AB türlerini tanıyabilmek	Dış kayıtları kendi listesine kopyalamak
ADR-0046. Gömülü açıklama politikası (AB ARF Konu 43)	Kurumun paylaşım kuralı; son karar kişide	Kuralı belgenin içine gömmek; bağlantıyla indirmek
ADR-0050. Kurum sertifika profili ETSI TS 119 412-6	Kayıtla eşleşen kurum numarası sertifikada	Numarayı yalnız listede tutmak

Karar	Gerekçe	Bırakılan seçenek
ADR-0058. Erişim sertifikası ETSI TS 119 411-8; kimlik servisi sertifikası vakıf devrinde yenilenir	ETSI profili; tek seferlik yeniden alma	Kimlik servisi sertifikasını hemen değiştirmek
ADR-0066. ETSI TS 119 612 XML görünümü, aynı kaynaktan ve aynı sürümle	AB ve üçüncü ülke araçları XML ister	Ayrı kayıt defterinden XML; "nitelikli" ETSI adresleri
ADR-0068. Kayıt sertifikası politikası ve 1 bitlik durum listesi	Sertifikanın geri alınabilmesi	Durumsuz sertifika

Tablo 40. Belge ve şema kararları.

Karar	Gerekçe	Bırakılan seçenek
ADR-0006. SD-JWT VC birincil; OpenID4VCI ve OpenID4VP; ES256; cihaz bağı istisnasız	AB'nin ana yığını; bağ olmadan belge başkasına geçer	JSON-LD tabanlı biçim (gerekçede karşılaştırılır)
ADR-0007. Şema kataloğu zincir dışında, bütünlük özeti zorunlu, sürümlü	Doğrulayıcı tanımın değiştiğini anlamalı	Şemanın tamamını zincirde tutmak; serbest `vct`
ADR-0010. `vct` bir URN, katalogdan çözülür; kategori sinyali	Tür kimliği bir alan adına bağlanmamalı	Kararlı HTTPS adresi olarak `vct`
ADR-0013. Kimlik belgesi ayrıca mdoc	Tarayıcı ve yakın alan mdoc ister; AB PID emsali	Yalnız SD-JWT VC; tamamen mdoc
ADR-0014. Kurum sınıflarına yalnız etkinlik sınıfı eklenir	Gerçek kullanım gelmeden sınıf açılmaz	Ulaşım ve iletişim sınıflarını da eklemek
ADR-0021. E-posta ve telefon belgeleri; adres tutulmaz	Doğrulanmış iletişim ihtiyacı	Adresi kimlik belgesine eklemek; tek belgede ikisi
ADR-0029. Geliştirme evresinde şemalar yerinde düzeltilir	Bu evrede geriye uyum yükü taşınmaz	Her düzeltmede yeni sürüm
ADR-0039. Sürücü belgesi bilgisi (resmî belge değil, mDL değil)	Doğrulanmış bilgi ihtiyacı; resmî belgeyle karışmasın	Resmî mDL belge türüyle vermek; bilgiyi kimlik belgesine eklemek
ADR-0045. Kimlik alanları AB PID kodlamasıyla	Uygulama Tüzüğü 2026/1731 ile hizalama	Eski alan adları
ADR-0064. `age_over_15` eklenir; yaş eşikleri kapalı küme	15 yaş eşiği ihtiyacı (hukuki görüş değildir)	Yalnız 18; açık küme

Tablo 41. Protokol kararları.

Karar	Gerekçe	Bırakılan seçenek
ADR-0012. Yakın alan için köprü yollar; hedef ISO/IEC 18013-5	Bluetooth cihazda hazır olana kadar	ISO/IEC 18013-5'i hemen yapmak; tam belgeyi QR'a koymak
ADR-0016. Barındırılan belge vermeye kiracıya bağlı kapsamlı erişim	Kurum kendi sunucusundan çağırabilsin	Tek paylaşılan yönetici anahtarı
ADR-0017. Doğrulama sonucuna yalnız imzalı beyanla ve tek okumayla erişim	Sonuç adresi herkese açıktı	Kimliği bilen herkese cevap
ADR-0034. HAIP 1.0: `x509_hash` istemci kimliği; WIA `sub` ortak	HAIP zorunluluğu; kalıcı kayıt `dns_name`	`x509_san_dns`'te kalmak; iki öneki birden kabul etmek
ADR-0048. Kimlik türlerinde askı yok; mdoc için CWT listesi	AB PID kuralı	Kimlikte askı
ADR-0056. Paket API'lerinde güvenli varsayılanlar	Denetimi atlatan varsayılan olmasın	Gevşek varsayılan ve uyarı
ADR-0059. Bir erişim belirteciyle birden çok belge isteği (en çok 10 kopya)	OpenID4VCI 1.0 ve AB referansı	Tek kullanımlık belirteç

Karar	Gerekçe	Bırakılan seçenek
ADR-0060. Yenileme belirteci istemci örneği anahtarına bağlı	Attestation profili; DPoP anahtarı değişebilir	DPoP anahtarına bağ
ADR-0062. ZK kopyası yenileme belirteci yalnız kapsamı istenince	Kapsam ilkesi (RFC 6749 [19] §6)	Her kimlik yetkisinde vermek
ADR-0065. Kapı terminali terminal anahtarıyla kimlik gösterir	QR'ı gören bileti tüketemesin	Kimliksiz uç
ADR-0067. İstek nesnesinin her çekimi ayrı dal	Sahte ret saldırısı	Tek istek nesnesi
ADR-0069. Kapı grupları listede; terminal anahtarı kurum adına	Kurum yalnız kendi kapılarını yönetsin	İşletmeci geneli anahtar

Tablo 42. Cüzdan kararları.

Karar	Gerekçe	Bırakılan seçenek
ADR-0023. Kopyalar sessizce yenilenir	Kopyalar tükenir; AB kuralları	Her yenilemede kişiye sormak
ADR-0025. WIA (24 saatten kısa) ve anahtar kanıtı, AB TS3 modeli	Bağlanamazlık; AB modeli	Tek, 30 günlük cüzdan kanıtı
ADR-0047. Birim iptali, cüzdan dışı iptal yolu; cihaz kanıtı yalnız en üst seviyede zorunlu	AB şablonundaki açık konular	Kurum belgelerinde zincirleme iptal; her seviyede cihaz kanıtı
ADR-0049. "Tamga Network'te listeli" yazılı göstergesi	AB güven işareti AB dışında kullanılamaz	AB işareti ya da logo

Tablo 43. Kimlik kararları.

Karar	Gerekçe	Bırakılan seçenek
ADR-0005. İki eksenli güvence (kişi T0–T3, kurum I1–I3); devletsiz başlangıç	eIDAS güvence düzeyleriyle eşleme; devlet yokken mevcut güveni devralmak	Güveni tek bir sayıyla ölçmek
ADR-0011. PID yokken geçici kimlik belgesi sağlayıcısı (PID değil)	Kimliğin tek yerde doğrulanması; kurumların eşleştirebilmesi	Her kurumda ayrı doğrulama; kimlik numarasız belge
ADR-0020. Yetkili kaynak kurumda; ağ kişi kaydı tutmaz	Veri kaynağında kalır	Kişi kaydını ağda tutmak
ADR-0022. Kimlik servisi nitelikli değil, I2	"Nitelikli" bağımsız değerlendirme ister	Nitelikli sınıf ya da I3
ADR-0033. Mağaza incelemesi için tek kullanımlık kod	Gerçek kimliksiz inceleme; her cüzdana eşit	Uygulamada kalıcı bir deneme kipi
ADR-0043. Yaş sınırı yok	eIDAS 2.0 asgari yaş öngörmez	Yaş sınırı koymak
ADR-0057. Barındırılan vermede kurum anahtarı kurumda (CSC API v2)	Anahtar işletmecide kalamaz	Anahtarı hizmette dosyada tutmak

Tablo 44. Gizlilik kararları.

Karar	Gerekçe	Bırakılan seçenek
ADR-0008. İptal bit dizisi zincir dışında, imzalı listede	İptal anı düğümlere sızmasın	Bit dizisini zincirde tutmak
ADR-0027. Günlük yalnız kişinin başlattığı şifreli dışa aktarımla çıkar	AB TS10 zorunluluğu ve cihazda kalma ilkesi	Günlüğün hiç çıkmaması
ADR-0031. Site başına takma ad; kimlikten türetilen tohum	Siteler eşleştiremez; yeni telefonda aynı hesap	Cüzdanın rastgele sırrı; belge verenin ürettiği tanımlayıcı
ADR-0032. Longfellow ZK ile mdoc sunumu; ilk yüklem yaş	Belge değişmeden bağlanamaz ispat	Yalnız toplu kopya (yedek olarak kaldı)
ADR-0044. ZK sunumu en çok 24 saatlik kopyalarla	ZK'da iptal denetlenemez	İptal listeli ZK; uzun ömürlü kopya

Karar	Gerekçe	Bırakılan seçenek
ADR-0061. Takma ad tohumu ayrı belge yapılandırması	Standart uyumu	Standart dışı yanıt alanı

Tablo 45. Yönetişim, konumlanma ve defter kararları.

Karar	Gerekçe	Bırakılan seçenek
ADR-0001. Defter gelirse Hyperledger Besu ve QBFT	İzinli, eşit oy, anında kesinlik; AB emsali	Cosmos SDK; sıfırdan uzlaşma; herkese açık zincir
ADR-0002. Egemenlik öncelikli üç katmanlı yönetişim	Her devlet kendi kaydının tek yazarı; çıkış hakkı	Kurucu konsorsiyum ve ortak oylama
ADR-0009. Zincirsiz başlangıç; zincir en az iki bağımsız işletmeciyle	Tek işletmecinin zinciri güven üretmez	Zinciri beklemek; tek işletmecili geliştirme zinciri
ADR-0018. Belgelerin üç kapısı; Türkçe kaynak, İngilizce resmî çeviri	Okura göre ayrım; AB düzeni	Bütün belgeleri tek sitede toplamak
ADR-0019. Kurum Konsolu ve veritabanı	Kurum işleri tek yerde; kişi cüzdandan ister	Öğrenci portalı ve dosya tabanlı kayıt
ADR-0030. Ürün adları	Tutarlı ad	Eski ürün adı
ADR-0035. Üç katmanlı konumlanma	Her katman tek başına değer taşır	Yalnız AB uyumlu cüzdan; önce ağır kurum
ADR-0037. Ağ yalnızca ağdır; ticari hizmetler dışarıda	Tarafsızlık; devredilebilirlik	Hizmetlerin ağın içinde kalması
ADR-0038. Ayrı sandbox test ağı	Gerçek ağdan tam ayrım	Gerçek ağda test kurumları
ADR-0040. Sandbox'ta tavanlı gerçek kimlik doğrulama yolu	Gerçek akışın denenebilmesi	Yalnız sahte kişi
ADR-0041. Sandbox'ta kurum test hesapları	Kurumların kendi kendine denemesi	Konsolsuz sandbox
ADR-0042. Ağ cüzdan işletmez, listeler	AB rol ayrımı; tarafsızlık	Ağın bir cüzdanın sağlayıcısını işletmesi; ayrı cüzdan sandbox'ı
ADR-0051. Zincir imzalı listelerin projeksiyonudur	Kaynak tek; doğrulama zincire muhtaç değil	Zincirin kaynak olması
ADR-0052. Besu yerel izinlendirme	Besu 25.6.0 zincir üstü izni kaldırdı	Zincir üstü izin sözleşmesi
ADR-0053. Liste çapasında rakip adaylar	İlk yazan kilitleyemesin	İlk yazanın değeri kilitler
ADR-0054. Şema ad alanı, devletler arası bağ, kota kapsamı	Ad kapma ve kota kaçağı olmasın	Ad ayırma; şema kimliğine devlet kodu katmak
ADR-0055. Yükseltmede 7 gün bekleme; tür belli kayıt önerileri	Katılmayan devletin çekilme hakkı	Anında uygulama; genel çağrı önerisi
ADR-0063. Zincirdeki iptal kaydı listenin bit sayısını kabul eder	Projeksiyon ilkesi	Sabit 2 bit
ADR-0070. Vakıf kurulana kadar geçici işletmeci; listede ad "Tamga Network"	Ağın tüzel kişiliği yok; devir tek noktadan	Listede işletmeci şirketin adı; tüzel kişi gerektiren işleri beklemek
ADR-0071. Geçici dönemde katılımcıdan ücret alınmaz	Tarafsızlık; mali katkı kayda etki etmez	Kurumdan yıllık ücret
ADR-0072. Değer katmanı askıda, araştırma yönü	Ağ token ve ödeme işlemez; zincir yalnız projeksiyon	ADR-0003 kancalarını bağlayıcı tutmak
ADR-0073. Deftere geçişte tek seferlik göç penceresi (en çok 30 gün), sert iptal, şema sürüm özetleri yalnız eklenir	Liste geçmişi deftere birebir aktarılabilsin; iki kaynak aynı cevabı versin	Geçmişi aktarmamak; her zaman açık göç yetkisi
ADR-0074. Listelerdeki bütün güven kayıtları defterde, yalnız özet ve parmak izi olarak	Kayıt düzeyinde sorgu ve eşdeğerlik; kişisel veri ve serbest metin defterden silinemez	Yalnız liste özetleri; ayrıntı metinlerini açık yazmak

Karar	Gerekçe	Bırakılan seçenek
ADR-0075. Doğrulayıcı kimliğinin devri ve iptal sonrası yeniden kaydı yalnız üçte iki oyla	İlk kaydeden devlet kimliği kapamasın; iptal kalıcı kilit olmasın	Alan adı kanıtını tek başına yeterli saymak; hiçbir şey yapmamak

21.4 Değişen kararlar

Bir karar dizisinin dürüstlüğü, değişen kararlarını saklamamasından anlaşılır. Tamga'nın karar kayıtlarında altı değişiklik özellikle öğreticidir; her biri yeni bir bilginin, bir standardın ya da bir incelemenin sonucudur.

İlki değer katmanıdır. Ağın erken tasarımında olası bir defterin ileride değer aktarımı taşıyabilmesi için beş bağlayıcı kural konmuştu (ADR-0003). ADR-0072 bu kuralları bağlayıcı olmaktan çıkardı ve araştırma yönü olarak askıya aldı; ADR-0003 bugün "yerini aldı" durumundadır. İkincisi belge türü kimliğidir. İlk tasarım türü kararlı bir HTTPS adresiyle tanımlıyordu; çok devletli bir ağda tür kimliğinin tek bir alan adına bağlı kalamayacağı görülünce kimlik URN oldu ve tanım katalogdan çözülür hâle geldi (ADR-0010). Üçüncüsü cüzdan kanıtıdır: tek ve 30 gün geçerli bir kanıt, AB teknik şartnamesi yayımlanınca kısa ömürlü WIA ve anahtar kanıtıyla değiştirildi (ADR-0025).

Dördüncüsü işlem günlüğüdür. Cüzdan kuralları günlüğün cihazdan hiç çıkmamasını istiyordu; AB ise kişinin günlüğünü dışa aktarabilmesini zorunlu tutar. Kural, günlüğün yalnız kişinin kendi başlattığı ve kendi parolasıyla şifrelediği dışa aktarımda çıkabileceği biçimde daraltıldı (ADR-0027). Beşincisi askıdır: kimlik servisinin belgelerinde askı vardı, AB'nin kişi kimlik verisi kuralına hizalanırken kaldırıldı (ADR-0048). Altıncısı yenileme belirtecinin bağıdır. Belirteç önce DPoP [20] anahtarına bağlıydı; uyum çalışmasında DPoP anahtarının değişebileceği ve standardın bağı istemci örneği anahtarına kurduğu görülünce kural değişti (ADR-0060).

Bu değişikliklerin ortak bir yanı var: hiçbiri sessiz değildir. Her biri eski kaydı yerinde bırakır, neyi değiştirdiğini yazar ve etkilenen şartnameyi aynı çalışmada günceller.

22 Durum, Yol Haritası ve Açık Kararlar

Bir güven ağının hangi işlevi bugün sunduğunu, hangisini yalnızca kararlaştırdığını açıkça söylemesi, onu kullanacakların ilk ihtiyacıdır. Bu bölüm belge boyunca dağınık verilen durum etiketlerini tek bir tabloda toplar, yol haritasını aşamalar ve koşullar olarak verir, öneri durumundaki kararı ve açık kararları sayar. Tarih verilmez; çünkü aşamaların her biri ağın kendi elinde olmayan koşullara, bağımsız işletmecilerin, kurumların ve devletlerin kararlarına bağlıdır.

22.1 Bugün ne çalışıyor

Tablo 46 işlevleri üç durum etiketine göre sıralar. Etiketlerin anlamı okuma kılavuzundaki gibidir: **çalışıyor** gerçek ağda ya da sandbox'ta canlı demektir, **planlanan** karara bağlı ama canlı olmayan, **araştırma** kararı olmayan ya da askıdaki işlevdir. Tablo bu baskının hazırlandığı tarihe göredir ve ana çerçeve belgesinin işlev durumu tablosuyla birlikte güncellenir (FW-ARF-0001 §2.8).

Tablo 46. İşlevlerin durumu.

İşlev	Durum	Not	Bölüm
İmzalı güven listeleri, listelerin listesi, çapa günlüğü, arşiv	Çalışıyor	gerçek ağ ve sandbox	6
Belge türü kataloğu	Çalışıyor	değişmez dosyalar, bütünlük özeti	8.4
Kurum ve cüzdan başlatmalı belge verme	Çalışıyor	barındırılan hizmette iki yol	9

İşlev	Durum	Not	Bölüm
Uzaktan gösterme, Tamga Verify, doğrulama hattı	Çalışıyor	üç değerli sonuç	10, 11
İptal listeleri (JWT; mdoc için CWT)	Çalışıyor	sabit aralıklı yayın	12
Web sitelerine giriş ve site başına takma ad	Çalışıyor		10.7, 15.3
Bilet ve tek kullanımlık kapı geçişi	Çalışıyor (sandbox)	gerçek ağda tanımlı kapı politikası yok	10.9
Veri silme, geçmiş, dışa aktarım	Çalışıyor		13.5
Geçici kimlik servisi ve kimlik belgesi	Çalışıyor	gerçek ağda etkin tek belge veren	14
E-posta belgesi	Çalışıyor		14.6
Kayıt sertifikaları, politika alanları ve durum listesi	Çalışıyor		7.5
Dış listelerle federasyon mekanizması	Çalışıyor	bugün listede dış liste yok	6.9
Cüzdan sağlayıcısı kaydı	Çalışıyor	ilk listeli cüzdan, gerçek ağ ve sandbox	5.4
Sıfır bilgi ispatı, doğrulayıcı tarafı	Çalışıyor		15.4
Sandbox	Çalışıyor	herkese açık; kimlik doğrulaması tavanlı	17.1
Açık paketler	Çalışıyor	npm'de 0.8.2 deneme sürümü, Apache-2.0	17.2
ETSI TS 119 612 XML görünümü	Sandbox'ta çalışıyor	gerçek ağda planlanan	6.8
ETSI TS 119 602 görünümlerinin yayını	Planlanan	üretici hazır	6.8
İkinci liste imza sertifikası ve donanım anahtar deposu	Planlanan	şartnamede açık iş	6.3
Bluetooth ile yakın alan (ISO/IEC 18013-5)	Planlanan	kodlandı, cihaz testi bekliyor	10.8
Tarayıcıdan gösterme, cüzdan tarafı	Planlanan	doğrulayıcı hazır	10.6
Sıfır bilgi ispatı, cüzdan tarafı	Planlanan	cihaz testi yok	15.4
Donanım anahtarları ve cihaz kanıtı	Planlanan	kodlandı, cihaz testi bekliyor	13.2
Uzaktan imzanın gerçek ağda ilk kullanımı	Planlanan	kod ve testler hazır	7.6
Telefon belgesi için gerçek SMS gönderimi	Planlanan		14.6
Sürücü belgesi bilgisinin gerçek kişilere açılması	Planlanan	hukuki incelemeden sonra; bugün sandbox'ta	14.6
Mağaza inceleme kodu	Planlanan	kod hazır; deneme imzacısının liste kaydı bekliyor	14.8
Kimlik servisinin I3'e yükseltilmesi	Planlanan	bağımsız değerlendirmeden sonra, yeni kararla	14.4
Erişim sertifikasında politika tanımlayıcısı	Planlanan	sertifika uygulama beyanı yayımlanınca	7.4
Sertifikalı ve çevrim dışı kapı kimliği	Planlanan	alan ve okuyucu hazır	10.9
OpenID doğrulayıcı planının yeniden çalıştırılması; cüzdan planları	Planlanan		20.5
Ortak defter	Planlanan	kod hazır; yerel ağda ve açık test ağında çalışıyor, gerçek ağda ve sandbox'ta kapalı	19

İşlev	Durum	Not	Bölüm
Vakıf, konsey ve listelerin devri	Planlanan		18.4
AB birlikte çalışabilirlik etkinliklerine katılım	Planlanan		20.5
Sıfır bilgi ispatıyla takma ad türetme	Araştırma		15.3
Kriptografik akümülatör ya da sıfır bilgiyle iptal	Araştırma	ertelendi	12.2
Kuantum sonrası algoritmalara geçiş	Araştırma	karar yok	23.3
Değer katmanı	Araştırma	askıda; token, coin ve ödeme yok	19.9

Tablonun okunuşu konusunda bir not ekleyelim. “Çalışıyor” etiketi bir işlevin kaynakla gösterilebildiğini söyler; bir kurumun gerçek ağda bu işlevi kullandığını söylemez. Gerçek ağın Türkiye listesinde bugün etkin tek belge veren ağın geçici kimlik servisidir; kurum belgeleri ilk kurumlar katıldıkça aynı yoldan verilecektir.

22.2 Yol haritası

Yol haritası altı adımdan oluşur. Her adım bir koşula bağlıdır ve hiçbir adım bir önceki adımda kurulan kimlikleri değiştirmez (Tablo 47). İlk dört adımın yönetişim tarafı Bölüm 18.3’te, defter tarafı Bölüm 19.8’de anlatıldı; Şekil 30 aynı yolu yönetişim aşamaları olarak gösterir.

Tablo 47. Yol haritasının adımları: koşul, ne değişir, ne değişmez.

Adım	Koşul	Ne değişir	Ne değişmez
1. Liste aşaması (bugün)		imzalı listeler ve çapa günlüğü; sandbox; paketler deneme sürümünde; OpenID öz-testi	
2. Hazırlık	listeli cüzdanların mağaza sürümleri ve cihaz testleri	cihaz kanıtı, Bluetooth ve tarayıcı yolları canlıya geçer; ilk kurumlar gerçek ağa katılır	belge türleri, kök ve kurum kimlikleri
3. Vakıf	vakfın tüzel kişilik kazanması	işletmecilik vakfa geçer; gerçek ağda XML liste; kimlik servisi sertifikası yenilenir	liste işletmecisinin adı, kök kimliği, belge türleri, verilmiş belgeler
4. Defter	en az iki bağımsız işletmecinin yazılı kabulü ve eşdeğerlik testleri	listelerdeki güven kayıtları özet ve parmak izi olarak deftere de yazılır; geçmiş tek seferlik göç penceresinde aktarılır	imzalı listeler kaynak kalır; doğrulama hattı; deftere kişisel veri yazılmaz
5. Devlet katılımı	bir devletin kendi listesini yayınlaması	konsey kurulur; PID yeri dolar; geçici roller devredilir	kurum kimlikleri, belge türleri, verilmiş belgeler
6. Kurumsal genişleme	konseyin belirlediği eşikler	yeni sektör şemaları kendi kararlarıyla eklenir	ağın ilkeleri

Tablonun ilk satırında koşul ve “ne değişmez” sütunları boştur, çünkü bu adım bugündür. İkinci adımın kurum tarafı bilinçli olarak adsız bırakılmıştır: bu belge hiçbir kurumla bir anlaşmayı ya da görüşmeyi bildirmez. Beşinci adımın koşulu da ağın elinde değildir; bir devletin katılması o devletin kendi kararıdır.

22.3 Öneri durumundaki karar

Etkin olmayan tek kayıt sağlık alanındaki belgelerle ilgilidir (ADR-0028). Öneri, sağlık meslek mensupları için birbirini tamamlayan üç belge tarif eder: meslek icra belgesi, meslek kuruluşu üyelik belgesi ve kurumun kendi personeline verdiği görev belgesi. Bir hastane işe alımda bu belgeleri doğrulayıcı olarak isteyebilir. Belgelerde sağlık verisi ve kimlik numarası yoktur; hasta tarafı kapsam dışıdır. Öneri, proje yönetiminin kararıyla askıdadır: ilk sektör eğitim olduğu için üzerinde çalışılmaz,

ama kayıt silinmez. Sağlık alanı açılırsa bu öneri yeni bilgilerle yeniden değerlendirilir ve kabul edilirse kendi kurallarıyla gelir.

22.4 Açık kararlar ve sonraki işler

Karar kayıtlarının ve şartnamelerin "açık konular" bölümleri, henüz kararı verilmemiş soruları açıkça sayar. Tablo 48 bunların kamuya açık olanlarını, ilgili kaynakla birlikte verir. Bazıları teknik bir ölçüm bekler, bazıları hukuki bir incelemeyi, bazıları da ağın bir sonraki aşamasını.

Tablo 48. Açık kararlar.

Soru	Neden açık	Kaynak
Cihaz değişiminde belgelerin onaylı devri	Yeni cihazda belgeler yeniden alınır; kurumun kişiyi yıllar sonra tanıması gerekir	FW-ARF-0001 §7.4 L4; SPEC-WALLET-0001
Çoklu cihaz (telefon ve tablet)	Her cihaz ayrı cihaz anahtarı ve ayrı belge verme demektir	SPEC-WALLET-0001
En üst cüzdan seviyesinin devlet aşamasında nasıl tespit edileceği	Cihaz kanıtı mı, ayrı donanım mı	SPEC-WALLET-0001
Küçükler için veli onayı akışı	Hukuki inceleme ve sağlayıcının küçükler için koşulu bekleniyor	ADR-0043; SPEC-ID-0003
İkinci kimlik doğrulama sağlayıcısı	Tek sağlayıcıya bağımlılığın önlenmesi	SPEC-ID-0003
İptal listesi toplama zorunlu mu; çoklu durum sağlayıcısı	Bugün "önerilir"; açık yazılması gerekebilir	SPEC-CRED-0003
Doğrulayıcı kapsamının belge türü kimliklerine bağlanması	Her yeni türde her doğrulayıcının güncellenmesi sorunu	SPEC-PROTO-0002
ZK için AB başka bir iptal yöntemi seçerse	Kısa ömürlü kopya kararı yeniden değerlendirilir	ADR-0044
Kök sertifika kaydırmasında örtüşme süresi; ara sertifika makamı	Öneri 12 ay; devletlerin tercihine bağlı	SPEC-ID-0002
Kapsam dışı işlevler: PID ihracı, ödeme, kurum cüzdanı, W3C VCDM temsili, nitelikli elektronik imza	Her biri ancak ayrı bir kararla açılır	FW-ARF-0001 §1.7

23 Sınırlar ve Açık Sorular

Her mimari bazı riskleri ortadan kaldırır, bazılarını azaltır ve bazılarını bilerek taşır. Bu bölüm üçüncü gruba bakar: Tamga'nın bugün bildiği ve kabul ettiği riskleri, henüz cevabı olmayan soruları ve araştırma yönlerini. Bunları açıkça yazmak bir zayıflık itirafından çok bir sözleşmedir. Okur, ağın neyi garanti etmediğini bildiğinde neyi garanti ettiğine de daha çok güvenebilir.

23.1 Beyan edilen artık riskler

Ana çerçeve belgesi beş sınırı numarayla sayar (FW-ARF-0001 §7.4). Bunlara gizlilik, kimlik ve işletim bölümlerinde anlatılan birkaç risk eklenir. Tablo 49 her birini, neden bugün var olduğunu, neyle azaltıldığını ve hangi koşulda kalkacağını verir.

Tablo 49. Artık riskler.

Risk	Neden bugün var	Azaltım	Kalkma koşulu
L1. Güven çapası tek işletmecinin imzasına dayanır; işletmeci ile bir belge veren birlikte hareket ederse tutarsız kayıt yayımlanabilir	Liste aşamasında tek imzacı vardır	herkese açık değişiklik ve çapa günlüğü, şeffaflık raporu, denetim	ortak defter ve birden çok bağımsız imzacı (Bölüm 19)

Risk	Neden bugün var	Azaltım	Kalkma koşulu
L2. İptal birkaç dakikada etkili olur	iptal listesi sabit aralıkla yayımlanır ve önceden çekilir	kısa yayın aralığı (2 dakika), doğrulayıcının sık ön çekimi	kalkmaz; bilinçli bir gizlilik dengesidir (Bölüm 12.5)
L3. Aynı kurumun belgeleri farklı doğrulayıcılarda birleştirilirse kişi eşleştirilebilir	kurumun imzası kopyalarda tanınır	doğrulayıcı başına kopya, yuvarlanmış zaman	sıfır bilgi ispatının cüzdanlara ulaşması (Bölüm 15.4)
L4. Cihaz değişiminde belgeler yeniden alınır	onaylı devir tasarımı açıktır	kurumdan yeniden verme; sessiz yenileme	onaylı devir kararı (Tablo 48)
L5. ZK sunumunda iptal denetlenemez	ispat iptal listesindeki konumu gizler	en çok 24 saatlik kopyalar; iptal edilen belgenin kopyası yenilenmez	AB'nin ZK için başka bir iptal yöntemi seçmesi (ADR-0044)
Takma ad türetmenin bilinen zayıflaması	tohum kimlik servisinde kimlikten türetilir	anahtar koruması ve şeffaflık; tohum saklanmaz	sıfır bilgi ispatıyla türetme (araştırma)
ZK kopyası yenilemesinin etkinlik izi	kopyalar yaklaşık günde bir yenilenir	rastgele gecikme; kişinin kapatabileceği otomatik yenileme	kalıcı çözüm yok; hangi doğrulayıcıya ne gösterildiği öğrenilmez
Uzaktan kimlik doğrulamada sahte yüz ve araya girme saldırıları; tek sağlayıcıya bağımlılık	doğrulama bir uzaktan kimlik doğrulama sağlayıcısına dayanır	canlılık ve yüz eşleştirmesi; belgede portre yok; en üst seviye uzaktan yüzle verilmez	devletin PID'i; ikinci sağlayıcı (Tablo 48)
Tek liste imza sertifikası	ikinci kaydırmalı sertifika henüz devrede değil	30 gün önceden duyurulan anahtar değişimi kuralı	ikinci sertifika ve donanım anahtar deposu (Bölüm 6.3)
Küçüklerin kimlik doğrulaması	yaş sınırı yok; veli onayı akışı tanımlanmadı	sağlayıcının koşulu teyit bekliyor	veli onayı kararı (Tablo 48)
Çevrim dışı telefonda süresi dolmamış belge	iptal ağa bağlanmayan cihaza ulaşmaz	birim iptali, kısa geçerlilik, doğrulayıcının iptal denetimi	kalkmaz; kısa ömürle sınırlanır

İlk satır ayrıca vurgulanmayı hak eder, çünkü ağın bugünkü güven modelinin sınırını en açık biçimde o çizer. Yayımlanan listeler herkesin indirebildiği, sürümleri birbirine bağlı ve her değişikliği günlüğe yazılan dosyalardır; tutarsız bir kayıt saklanamaz, ama yayımlanabilir. Bu sınırı kaldıracak olan çok imzacılı düzendir ve o düzen ancak bağımsız taraflar katıldığında kurulur.

23.2 Henüz cevabı olmayan sorular

Bazı sorular bir karar kaydının açık konusu olmanın ötesinde, ağın uzun vadeli biçimini etkiler. Bunlardan dördünü ayrıca anıyoruz.

Birincisi belgenin cihazla bağıdır. Cihaz bağı belgenin kopyalanmasını engeller, ama aynı kişinin telefon değiştirmesini de zorlaştırır. Bir mezun on yıl sonra telefon değiştirdiğinde üniversitesinin onu hâlâ tanıması gerekir. Onaylı devir ve çoklu cihaz, güvenlik ile kullanılabilirlik arasındaki bu dengenin henüz kurulmamış iki parçasıdır.

İkincisi doğrulayıcının kapsamıdır. Bugün bir doğrulayıcının hangi alanları isteyebileceği kayıt sertifikasında yazılıdır. Bu kapsamın belge türü kimliklerine sıkıca bağlanması denetimi kolaylaştırır, ama her yeni belge türünde her doğrulayıcının kaydının güncellenmesini gerektirir.

Üçüncüsü kimlik doğrulamanın kaynağıdır. Geçici kimlik servisi bugün tek bir uzaktan kimlik doğrulama sağlayıcısıyla çalışır. İkinci bir sağlayıcı, özellikle yerli bir kaynak, bağımlılığı azaltır; devletin kişi kimlik verisi geldiğinde ise bu sorunun büyük kısmı ortadan kalkar.

Dördüncüsü küçüklerdir. eIDAS 2.0 [2] bir asgari yaş öngörmez ve Tamga da yaş sınırı koymaz (ADR-0043). Ama küçük yaştaki bir kişinin kimlik doğrulaması için veli onayının nasıl alınacağı ve sağlayıcının bu yaştaki kişiler için koşulu, hukuki inceleme bekleyen sorulardır.

23.3 Araştırma yönleri

Üç yön bugün kararsızdır ve öyle anılır. Birincisi **sıfır bilgi ispatıyla takma ad türetmedir**. Bugünkü takma ad yöntemi kimlik servisinin kuramsal olarak takma adı kurabilmesine izin verir. Türetmenin bir ispatla doğrulanması bu zayıflamayı kaldırır; karar kaydı bunu hedef olarak yazar, ama cüzdanlarda sıfır bilgi kütüphanesi olgunlaşmadan uygulanmaz (ADR-0031).

İkincisi **kuantum sonrası algoritmalara geçiştir**. Bugünkü imzalar eliptik eğri kriptografisine dayanır. Büyük ölçekli bir kuantum bilgisayarı bu imzaları kırabilir; uzun ömürlü belgeler ve kök sertifikalar bu yüzden geçişin en çok önem taşıdığı yerlerdir. Tamga'nın bu konuda bir kararı yoktur; konu, AB'nin ve standart kuruluşlarının seçimleri izlenerek ele alınacak bir soru olarak durur. Dizinin kuantum sonrası dönemi anlatan yazısı [79] sorunun teknik arka planını verir.

Üçüncüsü **değer katmanıdır**. İlk tasarımda defterin ileride bir değer katmanı taşıyabilmesi için alınan kararlar artık bağlayıcı değildir ve yalnız bir araştırma yönü olarak kayıtta durur (ADR-0072). Tamga Network token ya da coin ihraç etmez; ödeme, mutabakat ya da değer aktarımı işlemez. Bu yönün yeniden açılması yönetişim kurumunun kararını, bir gizlilik araştırmasını, bağımsız bir güvenlik incelemesini ve yeni bir karar kaydını gerektirir (Bölüm 19.9).

24 Sonuç

Aynur'un başvurusuyla başlamıştık. Bakü'de aldığı diplomayı İstanbul'daki bir işverene göstermek için taranmış kopyalar, noter onaylı tercümeler ve cevabı haftalar süren e-postalar gerekiyordu; sonunda bile Timur diplomanın gerçek olduğunu kanıtlayamıyordu. Bu belgenin anlattığı yapı aynı sahneyi başka bir yoldan kurar. Üniversite diplomayı imzalı bir belge olarak verir, Aynur onu telefonunda taşır ve yalnızca istenen alanları gösterir, Timur'un yazılımı da imzayı, yetkiyi, iptal durumunu ve cihaz bağını üniversiteyi aramadan denetler. Üniversite diplomanın nerede gösterildiğini öğrenmez; ortak kayıtların hiçbiri Aynur'u tanımaz.

Bu yolun Aynur için bugün ne kadar açık olduğunu da dürüstçe söylemek gerekir. Türkiye listesi etkindir ve akışın bütünü çalışır; ama Azerbaycan için listelerde yalnızca yer ayrılmıştır. Bu bir anlaşma ya da görüşme bildirimi değildir; bir devlet katıldığında kendi listesini yayınlayabileceği boş bir yuvadır. Aynur'un Bakü'deki üniversitesinin bu yoldan belge verebilmesi o yuvanın dolmasına bağlıdır. Yapı bunu bekleyecek biçimde kurulmuştur: yuva dolduğunda yeni bir alan eklenmez, var olan bir yer dolar.

Belge boyunca üç seçim tekrar tekrar karşımıza çıktı. Teknik katman AB'ninkiyle aynıdır, çünkü birlikte çalışmanın değeri kimsenin özel bir uyarlama yazmak zorunda kalmamasından gelir. Güven bugün imzalı listelerden gelir, çünkü tek bir işletmecinin zinciri imzalı bir listeden fazla güven üretmez; ortak defter ancak bağımsız taraflar onu birlikte işletince gelir ve o zaman da listelerdeki kayıtların yalnız özetlerini ve parmak izlerini taşır. Her devlet kendi kaydının tek yazarıdır ve bugün devlet adına yürütülen her rol, hiçbir belgeyi ve kimliği değiştirmeden devredilebilecek biçimde tasarlanmıştır.

Yol uzundur ve koşulları ağın elinde olmayan adımlar içerir: bağımsız işletmeciler, kurumlar, devletler. Bu yüzden yol haritası tarih vermez, koşul verir. İşletmeciler değişebilir, alan adları devredilebilir, defter gelebilir ya da gecikebilir. Kalıcı olan güven modelidir: herkesin denetleyebildiği imzalı kayıtlar, kaynağa sormadan doğrulama ve kişiyi tanımayan ortak kayıtlar.

Ek A — Sözlük

Terimler alfabetik sıradadır. Özgün terim parantezde verilir; teknik terimler çevrilmez. Tanımlar ağın sözlüğüyle (FW-DEF-0001) ve dizinin yazılarıyla tutarlıdır (Tablo 50).

Tablo 50. Sözlük.

Terim	Tanım
Anahtar kanıtı (*key attestation*, KA)	Cüzdan sağlayıcısının, belgenin bağlanacağı anahtarların cihazın güvenli donanımında üretildiğini ve korunduğunu beyan eden imzalı belge.
Anahtar sahipliği ispatı (*proof of possession*, `proof`)	Cüzdanın belge isteğine eklediği, belgenin bağlanacağı anahtarla imzalanmış kısa kanıt (OpenID4VCI JWT proof); anahtarın cüzdanda olduğunu ve isteğin taze olduğunu (`aud`, `iat`, `nonce`) gösterir. Anahtar kanıtıyla (KA) karıştırılmamalıdır: KA'yı cüzdan sağlayıcısı imzalar, ispatı cüzdan.
Aracı doğrulayıcı (*intermediary*)	Bir doğrulayıcı adına cüzdandan belge isteyen ve doğrulayan hizmet; cüzdan asıl doğrulayıcının adını gösterir. Tamga'da Tamga Verify.
Askı (*suspension*)	Bir belgenin geçici olarak geçersiz sayılması; yalnız şeması izin veren kurum belgelerinde vardır, kimlik türlerinde yoktur.
Bağlanamazlık (*unlinkability*)	Farklı doğrulayıcıların aynı kişinin gösterimlerini birbiriyle eşleştirememesi.
Bant dışı güven çapası	Listelerin listesini imzalayan sertifikanın, listelerden ayrı kanallarda yayımlanan parmak izi.
Barındırılan belge verme hizmeti (*hosted issuer*)	Ağın kurumlar adına işlettiği belge verme hizmeti; imza anahtarı kurumda kalır.
Belge (*credential, attestation*)	Bir belge verenin kişi hakkında imzaladığı ve kişinin cüzdanında taşınan elektronik belge.
Belge sahibi (*holder*)	Belgeyi cüzdanında taşıyan ve kime göstereceğine karar veren kişi.
Belge türü kataloğu	Belge türü tanımlarının ve şemalarının değişmez dosyalar olarak yayımlandığı yer.
Belge veren (*issuer, attestation provider*)	Belgeyi veren kurum: üniversite, meslek kuruluşu, bilet satıcısı gibi.
Cihaz bağı (*key binding, holder binding*)	Belgenin cihazın güvenli donanımında üretilmiş bir anahtara bağlanması; gösterimde o anahtarla imza istenir.
Cihaz kanıtı	İşletim sisteminin, anahtarın güvenli bölgede üretildiğini ve uygulamanın değiştirilmediğini doğrulayan imzalı beyanı.
Cüzdan birimi (*wallet unit*)	Bir cüzdanın belirli bir cihazdaki kurulumu.
Cüzdan örneği kanıtı (*Wallet Instance Attestation*, WIA)	Cüzdan sağlayıcısının bir cüzdan birimi için imzaladığı, 24 saatten kısa geçerli beyan; her belge işleminde yeni anahtarla alınır.
Cüzdan sağlayıcısı (*wallet provider*)	Cüzdanı sunan, birimleri kaydeden ve WIA ile anahtar kanıtını imzalayan kuruluş.
Çapa günlüğü (*anchor log*)	İptal listesi yayınlarını ve belge türü özetlerini saatlik imzalı satırlarla tutan herkese açık günlük.
Çekim dalı	İmzalı istek nesnesinin her çekiminde açılan, kendi `state`, `nonce` ve şifreleme anahtarı olan ayrı oturum; ret yalnız kendi dalını kapatır.
DCQL	Doğrulayıcının cüzdandan hangi belgeyi ve hangi alanları istediğini yazdığı sorgu dili (*Digital Credentials Query Language*).
Defter aşaması	Listelerdeki güven kayıtlarının özet ve parmak izi olarak birden çok bağımsız işletmecinin tuttuğu ortak deftere de yazıldığı aşama.
Deneme imzacısı	Mağaza inceleme kodu ile verilen, gerçek ekosistemde geçmeyen belgelerin imzacısı.
Doğrulama hattı	Doğrulayıcının bir gösterimi denetlediği sabit katmanlar: ön koşul, biçim, tür, güven, durum, politika.
Doğrulanamadı (*INDETERMINATE*)	Doğrulamanın hüküm veremediği sonuç; "geçersiz" anlamına gelmez.
Doğrulayıcı (*relying party, verifier*)	Cüzdandan belge isteyen ve doğrulayan kayıtlı kuruluş.

Terim	Tanım
DPoP	Erişim belirtecini istemcinin bir anahtarına bağlayan ve her istekte bu anahtarla imzalı bir kanıt isteyen OAuth eklentisi.
Erişim sertifikası (*access certificate*)	Doğrulayıcının isteklerini imzaladığı X.509 sertifikası; istemci kimliği bu sertifikanın özetidir.
Federasyon	Ülke listelerinin kendi sahiplerince işletildiği ve listelerin listesinde bir araya getirildiği model.
Geçici işletmeci (*provisional operator*)	Vakıf kurulana kadar ağın hizmetlerini “Tamga Network adına” işleten tüzel kişi.
Geçici kimlik belgesi	PID sağlayıcısı yokken kimlik servisinin uzaktan kimlik doğrulamasıyla verdiği belge; PID değildir.
Geçiş kartı	Yakın alanda kalıcı çözüm gelene kadar kullanılan, kısa ömürlü ve kişisel veri taşımayan imzalı jeton.
Gömülü açıklama politikası	Belge verenin, belgesinin hangi doğrulayıcılara gösterilebileceğini imzalı tanıtım belgesinde yazdığı kural; son karar kişidedir.
Güven çapası (*trust anchor*)	Bir doğrulayıcının baştan güvendiği tek değer: listelerin listesini imzalayan sertifikanın parmak izi.
Güven listesi (*trust list*)	Bir ülkenin kök sertifikalarını, belge verenlerini ve doğrulayıcılarını taşıyan imzalı liste.
HAIP	OpenID4VCI ve OpenID4VP’nin yüksek güvence gerektiren kullanımlar için seçeneklerini daraltan profil.
HKDF	Bir anahtardan başka anahtarlar türeten, HMAC tabanlı anahtar türetme işlevi.
HMAC	Gizli bir anahtarla hesaplanan, anahtarı bilmeyenin üretemeyeceği özet.
İptal listesi (*status list*)	Belge verenin, her belgenin durumunu birkaç bitle tuttuğu ve imzalayıp yayımladığı liste; durum listesi diye de anılır.
İptal (*revocation*)	Bir belgenin kalıcı olarak geçersiz sayılması.
Kayıt kurumu (*registrar*)	Belge verenleri, doğrulayıcıları ve cüzdan sağlayıcılarını kaydeden kuruluş; yasal yetki vermez.
Kayıt sertifikası (*registration certificate*)	Kayıt kurumunun, bir doğrulayıcı kullanımının amacını ve isteyebileceği alanları taşıyan imzalı belgesi.
Kopya	Aynı belgenin ayrı anahtarlara bağlı örneklerinden biri; cüzdan her doğrulayıcıya ayrı kopya gösterir.
Listelerin listesi (*List of Trusted Lists*, LoTL)	Ülke listelerinin adreslerini, imzacılarını ve tanınma durumlarını gösteren imzalı liste.
mdoc	ISO/IEC 18013-5’in tanımladığı, CBOR ile kodlanan ikili belge biçimi.
Nitelikli olmayan öznitelik belgesi (EAA)	Nitelikli güven hizmeti sağlayıcısı olmayan herhangi bir kurumun verdiği belge.
Ortak defter (*ledger*)	Güven kayıtlarının özetlerinin birden çok bağımsız işletmecice tutulduğu defter (zincir); bugün yoktur.
Ön yetkili kod (*pre-authorized code*)	Kurumun başlattığı belge vermede, kişinin önceden kimliği bilindiği için kullanılan tek kullanımlık kod.
PAR	Yetkilendirme isteğinin önce sunucuya doğrudan gönderildiği ve tarayıcıda yalnız bir başvuru adresinin taşındığı OAuth eklentisi.
PID	Kişi kimlik verisi; devletin ya da devletin yetkilendirdiği kuruluşun verdiği kimlik belgesi. Tamga PID vermez.
PKCE	Yetkilendirme kodunun ele geçirilmesine karşı istemcinin tek kullanımlık bir doğrulayıcı değer kullandığı OAuth eklentisi.
Projeksiyon	Ortak defterin imzalı listelerdeki kayıtların yalnız özetlerini ve parmak izlerini taşıması; kaynak listelerdir, çelişkide liste geçerlidir.
Sandbox	Gerçek ağdan ayrı kökle çalışan, herkese açık test ağı.
SD-JWT VC	Alanları tek tek gizlenebilen, imzalı JSON belge biçimi.

Terim	Tanım
Seçici açıklama (*selective disclosure*)	Kişinin bir belgeden yalnız istenen alanları göstermesi.
Sıfır bilgi ispatı (ZK)	Bir önermenin doğru olduğunu, önermeye dayanan bilgiyi göstermeden kanıtlayan ispat.
Takma ad (*pseudonym*)	Cüzdanın her site için ayrı ürettiği, kararlı ama siteler arasında eşleştirilemeyen hesap kimliği.
Takma ad tohumu	Kimlik servisinin kişinin kimliğinden saklamadan türettiği ve yalnız cüzdanda kalan gizli değer.
Tek güven arayüzü (`TrustSource`)	Belge verenin, doğrulayıcının ve cüzdanın bütün güven sorularını sorduğu tek arayüz.
Terminal anahtarı	Bir kapı terminalinin doğrulama servisine kendini tanıttığı, kurum adına verilen anahtar.
Uzaktan imza	Kurumun anahtarının kendi imza hizmetinde kaldığı, barındırılan hizmetin yalnız özet gönderip imza aldığı düzen (CSC API).
Ülke listesi (`tl-<cc>`)	Bir ülkenin kök sertifikalarını, belge verenlerini, doğrulayıcılarını ve ulusal belge türlerini taşıyan imzalı liste.
Yetkili kaynak (*authentic source*)	Belgedeki bilginin asıl kaydını tutan sistem; örneğin üniversitenin öğrenci bilgi sistemi.
ZK kopyası	Sıfır bilgi sunumu için verilen, en çok 24 saat geçerli ve iptal listesi taşımayan kısa ömürlü mdoc kopyası.

Ek B — Karar kayıtları dizini

Tablo 51 bütün karar kayıtlarını numara sırasıyla verir. Tarih, kaydın oluşturulduğu tarihtir; etkin kayıtlarda kabul tarihi çoğunlukla aynıdır, değilse kayıt kabul tarihini ayrıca yazar. “Bölüm” sütunu kaydın bu belgede anıldığı başlıca bölümleri gösterir. Kayıtların tam metni `docs.tamga.network/tr/adr/` altındadır.

Tablo 51. Karar kayıtları.

ADR	Başlık	Durum	Tarih	Bölüm
0001	Besu QBFT defteri	Etkin	2026-07-29	19
0002	Egemenlik öncelikli yönetişim	Etkin	2026-08-05	2, 4, 18
0003	Değer katmanı kancaları	Yerini aldı	2026-08-06	19
0004	Kurum kimliği: X.509	Etkin	2026-08-06	7, 16, 20
0005	Güvence modeli ve devletsiz başlangıç	Etkin	2026-09-03	14
0006	Belge biçimi: SD-JWT VC	Etkin	2026-09-03	4, 8, 15
0007	Şema kayıt defteri	Etkin	2026-09-09	8
0008	İptal listesinin yeri	Etkin	2026-09-09	12, 20
0009	Zincirsiz beta ve zincir eşiği	Etkin	2026-09-24	4, 18, 19
0010	Belge türü kimliği (URN)	Etkin	2026-09-24	8
0011	Geçici kimlik belgesi sağlayıcısı	Etkin	2026-09-25	3, 5, 14
0012	Yakın alanda belge gösterme	Etkin	2026-09-25	10, 20

ADR	Başlık	Durum	Tarih	Bölüm
0013	Kimlik belgesi için mdoc	Etkin	2026-09-26	8, 14, 20
0014	Etkinlik kategorisi	Etkin	2026-09-27	21
0015	Tek güven arayüzü	Etkin	2026-09-27	5, 6, 17
0016	Barındırılan belge vermeye erişim	Etkin	2026-09-27	7, 17
0017	Doğrulama sonucuna erişim	Etkin	2026-09-27	11, 17
0018	Belgelerin üç kapısı	Etkin	2026-09-27	17
0019	Kurum Konsolu	Etkin	2026-09-28	17
0020	Yetkili kaynak kurumdadır	Etkin	2026-09-29	5, 9
0021	E-posta ve telefon belgeleri	Etkin	2026-09-29	14
0022	Kimlik servisinin sınıfı	Etkin	2026-09-29	3, 7, 8
0023	Otomatik kopya yenileme	Etkin	2026-09-29	9, 13, 15
0024	Katılımcı kayıt verisi	Etkin	2026-09-29	6, 18, 20
0025	Cüzdan ve anahtar kanıtı	Etkin	2026-09-29	9, 13, 15
0026	Kayıt sertifikaları	Etkin	2026-09-29	7, 10, 20
0027	İşlem günlüğünü dışa aktarma	Etkin	2026-09-29	13
0028	Sağlık belgeleri	Öneri	2026-09-29	22
0029	Geliştirme evresinde şemalar	Etkin	2026-09-30	8
0030	Ürün adları	Etkin	2026-09-30	10, 11
0031	Site başına takma ad	Etkin	2026-10-01	8, 10, 15
0032	Sıfır bilgi ispatı (ZK)	Etkin	2026-10-01	15, 16, 20
0033	Mağaza inceleme kodu	Etkin	2026-10-01	14
0034	HAIP 1.0 uyumu	Etkin	2026-10-01	3, 10, 13
0035	Konumlanma	Etkin	2026-10-01	3, 4, 20
0036	Güven federasyonu	Etkin	2026-10-01	6, 20
0037	Tamga Network yalnızca bir ağdır	Etkin	2026-10-02	4, 17, 18
0038	Sandbox: test ağı	Etkin	2026-10-03	6, 17
0039	Doğrulanmış sürücü belgesi bilgisi	Etkin	2026-10-03	8, 14
0040	Sandbox’ta gerçek kimlik doğrulama	Etkin	2026-10-04	17
0041	Sandbox’ta kurum test hesapları	Etkin	2026-10-04	17
0042	Ağ ve cüzdanlar: ağ cüzdan işletmez	Etkin	2026-10-06	4, 5, 13
0043	Yaş sınırı yok: AB yaklaşımı	Etkin	2026-10-08	13, 15, 22

ADR	Başlık	Durum	Tarih	Bölüm
0044	ZK sunumu için kısa ömürlü kopyalar	Etkin	2026-10-09	8, 9, 15
0045	Kimlik belgesinin alan adları: AB PID kodlaması	Etkin	2026-10-09	8, 14, 20
0046	Gömülü açıklama politikası	Etkin	2026-10-09	10, 20
0047	Cüzdan birimi iptali, cüzdan dışı iptal yolu ve cihaz kanıtı	Etkin	2026-10-12	12, 13, 16
0048	Kimlik servisinin belgelerinde askı yok; mdoc iptal listesi CWT	Etkin	2026-10-13	8, 12, 20
0049	“Tamga Network’te listeli” göstergesi	Etkin	2026-10-13	5, 13, 20
0050	Kurum belge veren sertifika profili	Etkin	2026-10-13	7, 20
0051	Zincir, imzalı listelerin projeksiyonudur	Etkin	2026-10-17	4, 19
0052	Besu yerel izinlendirme	Etkin	2026-10-19	19
0053	Liste çapasında rakip adaylar	Etkin	2026-10-19	19
0054	Zincirde şema ad alanı, devletler arası bağ ve kota kapsamı	Etkin	2026-10-19	8, 18, 19
0055	Yönetişim: yükseltme bekleme süresi ve kayıt yönetimi önerileri	Etkin	2026-10-19	18, 19
0056	Paket API’lerinde güvenli varsayılanlar	Etkin	2026-10-19	7, 10, 16
0057	Barındırılan belge vermede kurumun imza anahtarı: uzaktan imza (CSC API)	Etkin	2026-10-20	5, 7, 16
0058	Erişim sertifikası profili (ETSI TS 119 411-8) ve kimlik servisi sertifikasının geçiş zamanı	Etkin	2026-10-21	7, 18, 20
0059	Erişim belirteci ömrü içinde birden çok belge isteği	Etkin	2026-10-21	9
0060	Yenileme belirteci istemci örneği anahtarına bağlı	Etkin	2026-10-22	9
0061	Takma ad tohumu ayrı belge yapılandırması olarak, standart belge isteğiyle	Etkin	2026-10-22	8, 14, 15
0062	ZK kopyası yenileme belirteci yalnız ZK kopyası kapsamı istendiğinde	Etkin	2026-10-23	9, 16
0063	Zincirdeki iptal listesi kaydı listenin kendi bit sayısını kabul eder	Etkin	2026-10-23	19
0064	Kimlik belgesinde yaş eşikleri: age_over_15 ve age_over_NN deseni	Etkin	2026-10-23	14, 15
0065	Kapı terminalleri doğrulama servisine kimlik gösterir: terminal anahtarı	Etkin	2026-10-26	10, 16
0066	ETSI TS 119 612 XML liste görünümü	Etkin	2026-10-29	6, 20
0067	İstek nesnesinin her çekimi ayrı dal, ret yalnız kendi dalını kapatır	Etkin	2026-10-29	10, 16
0068	Kayıt sertifikası politikası ve durum listesi	Etkin	2026-10-29	7, 10, 20
0069	Kapı grupları güven listesinde: kurum, politika, sertifika; terminal anahtarı kurum adına	Etkin	2026-10-29	10, 16
0070	Geçici işletmeci zinciri	Etkin	2026-10-30	4, 18
0071	Geçici dönemde ağın finansmanı: hizmet ücreti yok; vakıf hibe ve devlet/üye katkısıyla	Etkin	2026-10-30	4, 18

ADR	Başlık	Durum	Tarih	Bölüm
0072	Değer katmanı askıda: ADR-0003 kancaları araştırma yönü	Etkin	2026-10-30	4, 19, 23
0073	Zincir–liste eşdeğerliğinin uygulanabilirliği: göç kipi, sert iptal, şema sürümleri, doğrulayıcı kimliği, durum eşlemesi	Etkin	2026-11-04	19
0074	Projeksiyon kapsamı 0.8: imzalı listelerdeki bütün güven kayıtları zincirde	Etkin	2026-11-04	4, 19
0075	Doğrulayıcı alan adı kimliğinin sahipliği ve iptal sonrası yeniden kayıt	Etkin	2026-11-04	19

Ek C — Standart dizini

Tablo 52 belgede anılan dış standartları ve düzenlemeleri, sürümleri ve Tamga'da kullanıldıkları bölümlerle verir. Sürümler bu baskının hazırlandığı tarihe göredir; standartların içeriği alıntılanmaz, yalnız kullanıldıkları yer gösterilir.

Tablo 52. Standartlar ve düzenlemeler.

Kurum	Belge	Sürüm	Tamga'da	Bölüm
AB	Tüzük 910/2014 [1] ve 2024/1183 [2] (eIDAS 2.0)	2024/1183, 30 Nisan 2024	çerçeve, roller, belge sınıfları	3, 20
AB	Uygulama Tüzükleri 2024/2977–2982 [5]	Aralık 2024; 2026/1731 ile değişik	PID ve EAA kodlaması, cüzdan işlevleri	3, 13, 14
AB	Uygulama Tüzükleri 2025/847 [6], 2025/848, 2025/849	Mayıs 2025; 2025/848, 2026/1730 ile değişik	olay bildirimi, doğrulayıcı kaydı, sertifikalı cüzdanlar listesi	7, 18, 20
AB	Uygulama Tüzükleri 2026/1730 [7], 2026/1731, 2026/1735	Temmuz 2026	güncel standart atıfları; kimlik alanları	3, 14, 20
AB	Architecture and Reference Framework (ARF [11])	3.0.0, Temmuz 2026	rol seti, kurallar, konu başlıkları	3, 13, 20
AB	EUDI teknik şartnameleri (TS3 [12], TS10, TS13 …)	yaşayan belgeler	WIA ve KA, dışa aktarım, ZK	13, 15
AB	Attestation Rulebook [13] şablonu	1.5	Tamga Rulebook'un dalları	18.8
IETF	RFC 9901 [15] SD-JWT	Kasım 2025	belge biçimi	8
IETF	SD-JWT VC [16]	İnternet taslağı, çalışma sürüyor; uygulama draft-19'a göre (son taslak: −26)	belge biçimi	8
IETF	Token Status List [17]	draft-20 (AB'nin başvurduğu), draft-21	iptal listeleri	12
IETF	OAuth 2.0 Attestation-Based Client Authentication [18]	taslak	WIA ile istemci doğrulaması	9, 13

Kurum	Belge	Sürüm	Tamga'da	Bölüm
IETF	RFC 9449 DPoP [20] · RFC 9126 PAR [21] · RFC 7636 PKCE [22] · RFC 9700 [23]	yayımlanmış	belge verme profili	9
IETF	RFC 5280 [28] X.509 · RFC 8949 CBOR [29] · RFC 7638 [24] · RFC 9180 HPKE [25]	yayımlanmış	sertifikalar, mdoc, anahtar parmak izi, yanıt şifrelemesi	7, 8, 10
OpenID Foundation	OpenID4VCI 1.0 [30]	Final, Eylül 2025	belge verme	9
OpenID Foundation	OpenID4VP 1.0 [31] ve DCQL	Final, Temmuz 2025	gösterme	10
OpenID Foundation	HAIP 1.0 [32]	Final, Aralık 2025	yüksek güvence profili	9, 10
ISO/IEC	18013-5 [34]	2021	mdoc, yakın alan	8.3, 10.8
ISO/IEC	TS 18013-7 [35]	2025	tarayıcı üzerinden mdoc	10.6
W3C	Digital Credentials API [36]	çalışma taslağı	tarayıcıdan gösterme	10.6
ETSI	TS 119 612 [41]	V2.4.1	XML güven listesi görünümü	6.8
ETSI	TS 119 602 [42]	V1.1.1	LoTE görünümleri, dış listeler	6.8, 6.9
ETSI	TS 119 412-6 [43] ve EN 319 412-3 [44]	V1.2.1	kurum sertifika profili	7.3
ETSI	TS 119 411-8 [45]	V1.1.1	doğrulayıcı erişim sertifikası	7.4
ETSI	TS 119 475 [46]	V1.2.1	kayıt sertifikası	7.5
ETSI	TS 119 461 [47]	V2.1.1	uzaktan kimlik doğrulama	14
ETSI	TS 119 471 [48]; TS 119 472-1 [49]; TS 119 472-2 [50]; TS 119 472-3 [51]	V1.1.1; V1.2.1; V1.2.1; V1.1.1	belge veren politikası, belge, verme ve gösterme profilleri	8, 9, 10, 20
ETSI	EN 319 401 [52]; EN 319 132-1 (XAdES [53])	yayımlanmış	genel politika; XML imzası	6.8, 20
Cloud Signature Consortium	CSC API [54]	v2	uzaktan imza	7.6
Longfellow ZK	ispat sistemi ve CFRG taslağı	draft-00	yaş ispatı	15.4
AB	European Learning Model / Europass [61]	3	diploma alanlarının anlamı	8.5

Ek D — Kısaltmalar

Tablo 53 belgede geçen kısaltmaları açar; kısaltmaların çoğu Ek A'da da tanımlanmıştır.

Tablo 53. Kısaltmalar.

Kısaltma	Açılım
ADR	Architecture Decision Record, karar kaydı
ARF	Architecture and Reference Framework, Mimari ve Referans Çerçevesi
CBOR	Concise Binary Object Representation

Kısaltma	Açılım
CIR	Commission Implementing Regulation, Komisyon uygulama tüzüğü
CSC	Cloud Signature Consortium
CWT	CBOR Web Token
DC API	Digital Credentials API
DCQL	Digital Credentials Query Language
DPoP	Demonstrating Proof of Possession
EAA	Electronic Attestation of Attributes, elektronik öznitelik belgesi
EBSI	European Blockchain Services Infrastructure
ELM	European Learning Model
ETSI	European Telecommunications Standards Institute
EUDI	European Digital Identity, Avrupa Dijital Kimliği
FW	Tamga çerçeve belgesi (framework) kimliği
HAIP	OpenID4VC High Assurance Interoperability Profile
HKDF	HMAC-based Key Derivation Function
HMAC	Hash-based Message Authentication Code
HPKE	Hybrid Public Key Encryption
JWE / JWS / JWT	JSON Web Encryption / Signature / Token
KA	Key Attestation, anahtar kanıtı
KB-JWT	Key Binding JWT, cihaz bağı imzası
KVKK	6698 sayılı Kişisel Verilerin Korunması Kanunu
LoTE	Lists of Trusted Entities (ETSI TS 119 602)
LoTL	List of Trusted Lists, listelerin listesi
mDL	mobile Driving Licence
OpenID4VCI	OpenID for Verifiable Credential Issuance
OpenID4VP	OpenID for Verifiable Presentations
PAR	Pushed Authorization Requests
PID	Person Identification Data, kişi kimlik verisi
PKCE	Proof Key for Code Exchange
PuB-EAA	kamu kurumu tarafından verilen öznitelik belgesi
QBFT	Quorum Byzantine Fault Tolerance
QEAA	Qualified EAA, nitelikli öznitelik belgesi
SD-JWT VC	Selective Disclosure JWT Verifiable Credential
SPEC	Tamga şartname kimliği
TDT	Türk Devletleri Teşkilatı
TS	Technical Specification
VCDM	W3C Verifiable Credentials Data Model
WIA	Wallet Instance Attestation, cüzdan örneği kanıtı
XAdES	XML Advanced Electronic Signatures
ZK	Zero-Knowledge, sıfır bilgi

Ek E — Belge seti dizini

Tamga'nın çerçeve belgeleri `arf.tamga.network/tr/`, şartnameleri ve rehberleri `docs.tamga.network/tr/` altındadır. Tablo 54 bu belgede anılan kimlikleri adreslerine eşler. Adres, kökten sonraki yoldur; çerçeve belgeleri Türkçe ve İngilizce yayımlanır.

Tablo 54. Çerçeve belgeleri, şartnameler ve rehberler.

Kimlik	Başlık	Adres
FW-ARF-0001	Mimari ve Referans Çerçevesi	`arf.tamga.network/tr/architecture`
FW-TF-0001	Ek A: Trust Framework	`arf.tamga.network/tr/trust-framework`
FW-RB-0001	Ek B: Tamga Rulebook	`arf.tamga.network/tr/rulebook`
FW-RB-0002	Education Rulebook	`arf.tamga.network/tr/rulebooks/education`
FW-RB-0003	Identity Rulebook	`arf.tamga.network/tr/rulebooks/identity`
FW-RB-0004	Event Ticket Rulebook	`arf.tamga.network/tr/rulebooks/event-ticket`
FW-RB-0005	Contact Rulebook	`arf.tamga.network/tr/rulebooks/contact`
FW-DEF-0001	Ek D: Tanımlar	`arf.tamga.network/tr/definitions`
FW-REF-0001	Ek E: Kaynaklar	`arf.tamga.network/tr/references`
FW-ROLE-0001	Roller	`arf.tamga.network/tr/roles`
FW-ONB-0001	Katılım süreci	`arf.tamga.network/tr/onboarding`
FW-POL-0001	İptal Politikası	`arf.tamga.network/tr/policies/revocation`
FW-POL-0002	Cüzdan Kanıtı Politikası	`arf.tamga.network/tr/policies/wallet-attestation`
FW-POL-0003	Kayıt Sertifikası Politikası	`arf.tamga.network/tr/policies/registration-certificate`
SPEC-TRUST-0001	Güven listeleri	`docs.tamga.network/tr/specifications/trust-lists`
SPEC-ID-0002	Kurum kimliği (X.509)	`docs.tamga.network/tr/specifications/x509-identity`
SPEC-ID-0003	Kimlik doğrulama	`docs.tamga.network/tr/specifications/identity-proofing`
SPEC-CRED-0001	Belge biçimi ve protokoller	`docs.tamga.network/tr/specifications/credential-format`
SPEC-CRED-0002	SD-JWT VC profili	`docs.tamga.network/tr/specifications/sd-jwt-vc`
SPEC-CRED-0003	İptal ve durum listesi	`docs.tamga.network/tr/specifications/status-list`
SPEC-SCHEMA-0001	Şema kataloğu	`docs.tamga.network/tr/specifications/schema-catalog`
SPEC-SCHEMA-0002	Eğitim şemaları	`docs.tamga.network/tr/specifications/education-schemas`
SPEC-SCHEMA-0003	Sektör şemaları	`docs.tamga.network/tr/specifications/sector-schemas`
SPEC-PROTO-0001	OpenID4VCI profili	`docs.tamga.network/tr/specifications/openid4vci`
SPEC-PROTO-0002	OpenID4VP profili	`docs.tamga.network/tr/specifications/openid4vp`

Kimlik	Başlık	Adres
SPEC-API-0001	Doğrulama hattı ve API	`docs.tamga.network/tr/specifications/verification-api`
SPEC-WALLET-0001	Cüzdan kuralları	`docs.tamga.network/tr/specifications/wallet`
GUIDE-0009	Uyum testleri	`docs.tamga.network/tr/guides/conformance`
GUIDE-0013	Sandbox: test ağı	`docs.tamga.network/tr/guides/sandbox`
GUIDE-0014	Katılım aracı: bilgi işlem ekibi için	`docs.tamga.network/tr/guides/onboarding-tool`
ADR-0001 … ADR-0075	Karar kayıtları (Ek B)	`docs.tamga.network/tr/adr/`

Kaynaklar

[1] Avrupa Parlamentosu ve Konseyi (2014). *İç pazarda elektronik işlemler için elektronik kimlik ve güven hizmetlerine ilişkin 910/2014 sayılı Tüzük (AB).* Avrupa Birliği Resmî Gazetesi, L 257, 28 Ağustos 2014; 2024/1183 ile değiştirilmiş konsolide metin, CELEX 02014R0910-20241018.

[2] Avrupa Parlamentosu ve Konseyi (2024). *Avrupa Dijital Kimlik Çerçevesinin oluşturulması bakımından 910/2014 sayılı Tüzüğü değiştiren 11 Nisan 2024 tarihli ve 2024/1183 sayılı Tüzük (AB).* Avrupa Birliği Resmî Gazetesi, 30 Nisan 2024. http://data.europa.eu/eli/reg/2024/1183/oj

[3] Avrupa Komisyonu (2021). *Avrupa Dijital Kimlik Çerçevesine yönelik eşgüdümlü bir yaklaşım için ortak bir Birlik Araç Kutusu hakkında 2021/946 sayılı Tavsiye Kararı (AB).* 3 Haziran 2021.

[4] Avrupa Komisyonu (2015). *Elektronik kimlik araçlarının güvence düzeylerine ilişkin asgari teknik şartları ve prosedürleri belirleyen 2015/1502 sayılı Uygulama Tüzüğü (AB).* Avrupa Birliği Resmî Gazetesi, L 235, 9 Eylül 2015.

[5] Avrupa Komisyonu (2024). *2024/2977, 2024/2979, 2024/2980, 2024/2981 ve 2024/2982 sayılı Uygulama Tüzükleri (AB)* (Avrupa Dijital Kimlik Cüzdanları). 28 Kasım 2024; Avrupa Birliği Resmî Gazetesi, 4 Aralık 2024.

[6] Avrupa Komisyonu (2025). *2025/846, 2025/847 (cüzdanlardaki güvenlik ihlallerine tepkiler), 2025/848 (cüzdana güvenen tarafların kaydı) ve 2025/849 (sertifikalı cüzdanlar listesi) sayılı Uygulama Tüzükleri (AB).* 6 Mayıs 2025; Avrupa Birliği Resmî Gazetesi, 7 Mayıs 2025.

[7] Avrupa Komisyonu (2026). *2026/1730, 2026/1731 ve 2026/1735 sayılı Uygulama Tüzükleri (AB)*, uygulanacak standartlar ve şartnameler bakımından. 15 Temmuz 2026; Avrupa Birliği Resmî Gazetesi, 22 Temmuz 2026.

[8] Avrupa Parlamentosu ve Konseyi (2016). *Kişisel verilerin işlenmesi bakımından gerçek kişilerin korunması ve bu verilerin serbest dolaşımına ilişkin 2016/679 sayılı Tüzük (AB) (Genel Veri Koruma Tüzüğü).* Avrupa Birliği Resmî Gazetesi, L 119, 4 Mayıs 2016.

[9] *6698 sayılı Kişisel Verilerin Korunması Kanunu.* Resmî Gazete, 7 Nisan 2016, sayı 29677.

[10] *7578 sayılı Sosyal Hizmetler Kanunu ve Bazı Kanunlarda Değişiklik Yapılmasına Dair Kanun.* Resmî Gazete, 1 Mayıs 2026, sayı 33240.

[11] Avrupa Komisyonu ve eIDAS Uzman Grubu (2026). *European Digital Identity Wallet: Architecture and Reference Framework (ARF)*, sürüm 3.0.0, 23 Temmuz 2026. https://eu-digital-identity-wallet.github.io/eudi-doc-architecture-and-reference-framework/

[12] Avrupa Komisyonu. *EUDI Wallet Standards and Technical Specifications* (TS3 cüzdan birimi kanıtları, TS5 ve TS6 güvenen taraf kaydı, TS9 cüzdandan cüzdana etkileşim, TS10 veri taşınabilirliği, TS13 aritmetik devrelerle sıfır bilgi ispatı). https://github.com/eu-digital-identity-wallet/eudi-doc-standards-and-technical-specifications

[13] Avrupa Komisyonu. *EUDI Wallet attestation rulebooks catalog*: Attestation Rulebook şablonu, sürüm 1.5; PID ve mDL Rulebook. https://github.com/eu-digital-identity-wallet/eudi-doc-attestation-rulebooks-catalog

[14] Avrupa Komisyonu. *Pilot for the International Compatibility of Trust Services* ve üçüncü ülke güven listeleri. https://ec.europa.eu (erişim Kasım 2026).

[15] Fett, D., Yasuda, K. ve Campbell, B. (2025). *Selective Disclosure for JSON Web Tokens (SD-JWT).* IETF RFC 9901, Kasım 2025.

[16] Terbu, O., Fett, D. ve Campbell, B. *SD-JWT-based Verifiable Digital Credentials (SD-JWT VC).* IETF OAuth Çalışma Grubu İnternet taslağı draft-ietf-oauth-sd-jwt-vc (çalışma sürüyor; erişim tarihindeki son taslak: –26). https://datatracker.ietf.org/doc/draft-ietf-oauth-sd-jwt-vc/ (erişim 11 Kasım 2026).

[17] Looker, T., Bastian, P. ve Bormann, C. *Token Status List.* IETF OAuth Çalışma Grubu İnternet taslağı draft-ietf-oauth-status-list-20 (20 Nisan 2026; AB'nin 2026/1731 ile başvurduğu sürüm) ve draft-21 (21 Haziran 2026). https://datatracker.ietf.org/doc/draft-ietf-oauth-status-list/

[18] Looker, T., Bastian, P. ve Bormann, C. *OAuth 2.0 Attestation-Based Client Authentication.* IETF OAuth Çalışma Grubu İnternet taslağı (draft-ietf-oauth-attestation-based-client-auth).

[19] Hardt, D. (Ed.) (2012). *The OAuth 2.0 Authorization Framework.* IETF RFC 6749, Ekim 2012.

[20] Fett, D., Campbell, B., Bradley, J., Lodderstedt, T., Jones, M. ve Waite, D. (2023). *OAuth 2.0 Demonstrating Proof of Possession (DPoP).* IETF RFC 9449, Eylül 2023.

[21] Lodderstedt, T., Campbell, B., Sakimura, N., Tonge, D. ve Skokan, F. (2021). *OAuth 2.0 Pushed Authorization Requests.* IETF RFC 9126, Eylül 2021.

[22] Sakimura, N., Bradley, J. ve Agarwal, N. (2015). *Proof Key for Code Exchange by OAuth Public Clients.* IETF RFC 7636, Eylül 2015.

[23] Lodderstedt, T., Bradley, J., Labunets, A. ve Fett, D. (2025). *Best Current Practice for OAuth 2.0 Security.* IETF RFC 9700, Ocak 2025.

[24] Jones, M. ve Sakimura, N. (2015). *JSON Web Key (JWK) Thumbprint.* IETF RFC 7638, Eylül 2015.

[25] Barnes, R., Bhargavan, K., Lipp, B. ve Wood, C. (2022). *Hybrid Public Key Encryption.* IETF RFC 9180, Şubat 2022.

[26] Krawczyk, H., Bellare, M. ve Canetti, R. (1997). *HMAC: Keyed-Hashing for Message Authentication.* IETF RFC 2104, Şubat 1997.

[27] Krawczyk, H. ve Eronen, P. (2010). *HMAC-based Extract-and-Expand Key Derivation Function (HKDF).* IETF RFC 5869, Mayıs 2010.

[28] Cooper, D., Santesson, S., Farrell, S., Boeyen, S., Housley, R. ve Polk, W. (2008). *Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile.* IETF RFC 5280, Mayıs 2008.

[29] Bormann, C. ve Hoffman, P. (2020). *Concise Binary Object Representation (CBOR).* IETF RFC 8949, Aralık 2020.

[30] Lodderstedt, T., Yasuda, K., Looker, T. ve Bastian, P. (2025). *OpenID for Verifiable Credential Issuance 1.0.* OpenID Foundation, son sürüm, 16 Eylül 2025. https://openid.net/specs/openid-4-verifiable-credential-issuance-1_0.html

[31] Terbu, O., Lodderstedt, T., Yasuda, K., Fett, D. ve Heenan, J. (2025). *OpenID for Verifiable Presentations 1.0.* OpenID Foundation, son sürüm, 9 Temmuz 2025. https://openid.net/specs/openid-4-verifiable-presentations-1_0.html

[32] Yasuda, K., Lodderstedt, T., Bormann, C. ve Heenan, J. (2025). *OpenID4VC High Assurance Interoperability Profile (HAIP) 1.0.* OpenID Foundation, son sürüm, 24 Aralık 2025. https://openid.net/specs/openid4vc-high-assurance-interoperability-profile-1_0.html

[33] OpenID Foundation. *OpenID Conformance Suite* ve öz-sertifikasyon. https://openid.net/certification/ · Tamga Network, *oidf-conformance-kit*. https://github.com/tamga-network/oidf-conformance-kit

[34] ISO/IEC (2021). *ISO/IEC 18013-5:2021 Personal identification: ISO-compliant driving licence, Part 5: Mobile driving licence (mDL) application.* ISO/IEC JTC 1/SC 17. https://www.iso.org/standard/69084.html

[35] ISO/IEC (2025). *ISO/IEC TS 18013-7:2025 Personal identification: ISO-compliant driving licence, Part 7: Mobile driving licence (mDL) add-on functions.* İkinci baskı, Mayıs 2025 (ilk baskı Ekim 2024).

[36] Caceres, M., Cappalli, T. ve Yosef, M. A. (Ed.) (2026). *Digital Credentials.* W3C Working Draft, Federated Identity Working Group, 29 Ekim 2026. https://www.w3.org/TR/digital-credentials/

[37] W3C (2025). *Verifiable Credentials Data Model v2.0.* W3C Recommendation, 15 Mayıs 2025. https://www.w3.org/TR/vc-data-model-2.0/

[38] W3C (2016). *Subresource Integrity.* W3C Recommendation, Haziran 2016. https://www.w3.org/TR/SRI/

[39] JSON Schema. *JSON Schema: A Media Type for Describing JSON Documents*, draft 2020-12. https://json-schema.org/draft/2020-12

[40] ISO/IEC (2020). *ISO/IEC 17000:2020 Conformity assessment: Vocabulary and general principles.*

[41] ETSI (2025). *ETSI TS 119 612 V2.4.1: Electronic Signatures and Trust Infrastructures (ESI); Trusted Lists.* Ağustos 2025.

[42] ETSI (2025). *ETSI TS 119 602 V1.1.1: Electronic Signatures and Trust Infrastructures (ESI); Lists of Trusted Entities; Data model.* Kasım 2025.

[43] ETSI (2026). *ETSI TS 119 412-6 V1.2.1: ESI; Certificate Profiles; Part 6: Certificate profile requirements for PID, Wallet, EAA, QEAA and PSBEAA providers.* Nisan 2026.

[44] ETSI. *ETSI EN 319 412-3: ESI; Certificate Profiles; Part 3: Certificate profile for certificates issued to legal persons.*

[45] ETSI (2025). *ETSI TS 119 411-8 V1.1.1: ESI; Policy and security requirements for Trust Service Providers issuing certificates; Part 8: Access Certificate Policy for EUDI Wallet Relying Parties.* Ekim 2025.

[46] ETSI (2026). *ETSI TS 119 475 V1.2.1: ESI; Relying party attributes supporting EUDI Wallet user's authorisation decisions.* Mart 2026.

[47] ETSI (2025). *ETSI TS 119 461 V2.1.1: ESI; Policy and security requirements for trust service components providing identity proofing of trust service subjects.* Şubat 2025.

[48] ETSI (2025). *ETSI TS 119 471 V1.1.1: ESI; Policy and security requirements for providers of electronic attestation of attributes services.* Mayıs 2025.

[49] ETSI (2026). *ETSI TS 119 472-1 V1.2.1: ESI; Profiles for Electronic Attestation of Attributes; Part 1: General requirements.* Şubat 2026.

[50] ETSI (2026). *ETSI TS 119 472-2 V1.2.1: ESI; Profiles for Electronic Attestation of Attributes; Part 2: Profiles for EAA/PID Presentations to Relying Party.* Mart 2026.

[51] ETSI (2026). *ETSI TS 119 472-3 V1.1.1: ESI; Profiles for Electronic Attestation of Attributes; Part 3: Profiles for issuance of EAA or PID.* Mart 2026.

[52] ETSI. *ETSI EN 319 401: ESI; General Policy Requirements for Trust Service Providers.*

[53] ETSI. *ETSI EN 319 132-1: ESI; XAdES digital signatures; Part 1: Building blocks and XAdES baseline signatures.*

[54] Cloud Signature Consortium. *Architectures and protocols for remote signature applications* (CSC API), sürüm 2. https://cloudsignatureconsortium.org/

[55] ENISA (2022). *Remote Identity Proofing: Attacks & Countermeasures.* Avrupa Birliği Siber Güvenlik Ajansı, Ocak 2022.

[56] Frigo, M. ve shelat, a. (2024). "Anonymous Credentials from ECDSA." *Cryptology ePrint Archive*, Rapor 2024/2010.

[57] Frigo, M. ve shelat, a. (2026). *Longfellow ZK.* IRTF CFRG İnternet taslağı draft-irtf-cfrg-longfellow-00, 19 Ekim 2026; açık kaynak gerçekleme https://github.com/longfellow-zk/longfellow-zk
[58] Lamport, L., Shostak, R. ve Pease, M. (1982). "The Byzantine Generals Problem." *ACM Transactions on Programming Languages and Systems*, 4(3), 382–401.
[59] Hyperledger Besu belgeleri: "QBFT", "Local permissioning" ve 25.6.0 sürüm notları. https://besu.hyperledger.org (erişim Kasım 2026).
[60] European Blockchain Services Infrastructure (EBSI). Belgeler. https://hub.ebsi.eu (erişim Kasım 2026).
[61] Avrupa Komisyonu. *Europass ve European Learning Model (ELM)*, sürüm 3. https://europa.eu/europass/
[62] Tamga Network (2026). *Kadim mührün çağdaş karşılığını inşa ediyoruz* (manifesto), sürüm 1.0, Kasım 2026. https://tamga.network/manifesto-tr.pdf
[63] Tamga Network (2026). *Mimari ve Referans Çerçevesi* (FW-ARF-0001) ve ekleri: Trust Framework, Tamga Rulebook ve belge türü rulebook'ları, Tanımlar, Kaynaklar, Roller, Katılım, İptal, Cüzdan Kanıtı ve Kayıt Sertifikası politikaları; sürüm 1.0.0. https://arf.tamga.network/tr/ (kimlikler Ek E'de).
[64] Tamga Network (2026). *Şartnameler* (SPEC-TRUST-0001, SPEC-ID-0002/0003, SPEC-CRED-0001/0002/0003, SPEC-SCHEMA-0001/0002/0003, SPEC-PROTO-0001/0002, SPEC-API-0001, SPEC-WALLET-0001), sürüm 1.0.0; rehberler ve kavram sayfaları. https://docs.tamga.network/tr/
[65] Tamga Network (2026). *Mimari karar kayıtları* ADR-0001…ADR-0075. https://docs.tamga.network/tr/adr/ (dizin Ek B'de).
[66] Tamga Network (2026). *tamga-network* deposu: README, SECURITY.md, CHANGELOG (0.8.2, 5 Kasım 2026) ve `@tamga-network/*` paketleri, Apache-2.0. https://github.com/tamga-network/tamga-network
[67] Tamga Network Akademik Çalışmalar A1 (2026). *Dijital Kimliğin Evrimi: Kullanıcı Adından Kimlik Cüzdanına.* https://tamga.network/files/publications/evolution-of-digital-identity-tr.pdf
[68] Tamga Network Akademik Çalışmalar A3. *Seçici Açıklama: Gerekeni Göster, Gerisi Sende Kalsın.* Yayımlanacak.
[69] Tamga Network Akademik Çalışmalar A4. *Sıfır Bilgi İspatları ve Kimlik.* Yayımlanacak.
[70] Tamga Network Akademik Çalışmalar A5. *Bağlanamazlık: Doğrulayıcılar Seni Birbirine Anlatmasın.* Yayımlanacak.
[71] Tamga Network Akademik Çalışmalar A6. *Kime Güveniyoruz? Güven Listeleri ve Dijital Güven Altyapısı.* Yayımlanacak.
[72] Tamga Network Akademik Çalışmalar A7. *İptal: Bir Belgeyi Geri Almak, Kimseyi İzlemeden.* Yayımlanacak.
[73] Tamga Network Akademik Çalışmalar A8. *Belge Nasıl Verilir, Nasıl Gösterilir.* Yayımlanacak.
[74] Tamga Network Akademik Çalışmalar A9. *Yüz Yüze Doğrulama: NFC, Bluetooth ve Mobil Ehliyet.* Yayımlanacak.
[75] Tamga Network Akademik Çalışmalar A10. *Cüzdan Güvenliği: Anahtar Nerede Saklanır, Telefon Gerçek mi?* Yayımlanacak.
[76] Tamga Network Akademik Çalışmalar A11. *eIDAS 2.0'a Hukuk Dışından Bakış.* Yayımlanacak.
[77] Tamga Network Akademik Çalışmalar A12. *Blokzincir ve Dijital Kimlik.* Yayımlanacak.
[78] Tamga Network Akademik Çalışmalar A14. *Deepfake Çağında Kimlik Doğrulama.* Yayımlanacak.
[79] Tamga Network Akademik Çalışmalar A15. *Kuantum Sonrası Dönemde Dijital Kimlik.* Yayımlanacak.